

Daily Vulnerability Report - 2026-09-11

Window (UTC): 2026-09-08T12:30 to 2026-09-11T12:30 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-11 12:32:41 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
6125	19	706	2821	2240	263	90	2300

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-20079	10.0	CRIT	Yes	0.747	cisco:secure_firewall_management_center	A vulnerability in the web interface of Cisco Secure Firewall Management Center (FMC) Software could allow an unauthenticated, remote attacker to bypass authentication and execute script files on an affected device to obtain root access to the underlying operating system. This vulnerability is due to an improper system process that is created at boot time. An attacker could exploit this vulnerability by s...
CVE-2026-75650	10.0	CRIT	Yes	0.021	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by an Improper Neutralization of Special Elements Used in a Template Engine vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-86218	10.0	CRIT	Yes	0.007	n-able:n-central	N-central is vulnerable to a pre-auth remote code execution This issue affects N-central: before 2026.3.1.14.
CVE-2016-4117	9.8	CRIT	Yes	0.944	adobe:flash_player, opensuse:evergreen, opensuse:opensuse, redhat:enterprise_linux_desktop, redhat:enterprise_linux_serv	Adobe Flash Player 21.0.0.226 and earlier allows remote attackers to execute arbitrary code via unspecified vectors, as exploited in the wild in May 2016.
CVE-2022-41352	9.8	CRIT	Yes	0.955	synacor:zimbra_collaboration_suite	An issue was discovered in Zimbra Collaboration (ZCS) 8.8.15 and 9.0. An attacker can upload arbitrary files through amavis via a cpio loophole (extraction to /opt/zimbra/jetty/webapps/zimbra/public) that can lead to incorrect access to any other user accounts. Zimbra recommends pax over cpio. Also, pax is in the prerequisites of Zimbra on Ubuntu; however, pax is no longer part of a default Red Hat installation af...
CVE-2025-25249	9.8	CRIT	Yes	0.017	fortinet:fortios, fortinet:fortisase, fortinet:fortiswitchmanager, siemens:ruggedcom_ape1808, siemens:ruggedcom_ape1808_	A heap-based buffer overflow vulnerability in Fortinet FortiOS 7.6.0 through 7.6.3, FortiOS 7.4.0 through 7.4.8, FortiOS 7.2.0 through 7.2.11, FortiOS 7.0.0 through 7.0.17, FortiOS 6.4 all versions, FortiSwitchManager 7.2.0 through 7.2.6, FortiSwitchManager 7.0.0 through 7.0.5 allows attacker to execute unauthorized code or commands via specially crafted packets
CVE-2025-14733	9.3	CRIT	Yes	0.265	watchguard:firebox_m270, watchguard:firebox_m290, watchguard:firebox_m295, watchguard:firebox_m370, watchguard:firebox_m	An Out-of-bounds Write vulnerability in the WatchGuard Fireware OS iked process may allow a remote unauthenticated attacker to execute arbitrary code. This vulnerability affects both the mobile user VPN with IKEv2 and the branch office VPN using IKEv2 when configured with a dynamic gateway peer. If the Firebox was previously configured with the mobile user VPN with IKEv2 or a branch office VPN using IKEv2 to a dy...
CVE-2025-67038	9.3	CRIT	Yes	0.193	lantronix:e213f102s, lantronix:e213f102s_firmware, lantronix:e214f002s, lantronix:e214f002s_firmware, lantronix:e214f00c	An issue was discovered in Lantronix EDS5000 2.1.0.0R3. The HTTP RPC module executes a shell command to write logs when user's authentication fails. The username is directly concatenated with the command without any sanitization. This allow attackers to inject arbitrary OS commands into the username parameter. Injected commands are executed with root privileges.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19490	9.3	CRIT	Yes	0.06	citrix:netscaler_application_delivery_controller, citrix:netscaler_gateway	Vulnerability in NetScaler ADC and NetScaler Gateway. This issue affects ADC: from 14.1 through 73.32 and from 13.1 through 63.21; Gateway: from 14.1 through 73.32 and from 13.1 through 63.21.
CVE-2026-86060	9.2	CRIT	Yes	0.004	mikrotik:routeros	RouterOS contains an argument-handling flaw in the SSH login path involving usernames that begin with a prohibited character, allowing for the trusted RouterOS policy mask to be changed, leading to privilege escalation. Exploitation requires an unauthenticated SSH session to reach the RouterOS login helper. This issue was fixed in versions: 6.49.21 (Long-term), 7.23.4 (Long-term) and 7.24.2 (Stable)
CVE-2026-67277	8.8	HIGH	Yes	0.004	mikrotik:routeros	RouterOS accepts a "related" btest connection before the corresponding primary session has completed authentication. An unauthenticated client can use this state to start an IPv4 UDP test. With "random-data=false", the sender transmits an uninitialized tail from a kernel packet buffer. A separate unchecked, inverted packet-size interval causes unsigned integer underflow, anomalously large fragmented output, and ca...
CVE-2026-85046	8.8	HIGH	Yes	0.013	google:chrome, google:v8	Type confusion in V8 in Google Chrome prior to 152.0.7977.82 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87491	8.8	HIGH	Yes	0.008	google:chrome	Out of bounds write in V8 in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2016-7255	7.8	HIGH	Yes	0.81	microsoft:windows_10_1507, microsoft:windows_10_1511, microsoft:windows_10_1607, microsoft:windows_7, microsoft:windows_	The kernel-mode drivers in Microsoft Windows Vista SP2, Windows Server 2008 SP2 and R2 SP1, Windows 7 SP1, Windows 8.1, Windows Server 2012 Gold and R2, Windows RT 8.1, Windows 10 Gold, 1511, and 1607, and Windows Server 2016 allow local users to gain privileges via a crafted application, aka "Win32k Elevation of Privilege Vulnerability."
CVE-2022-37969	7.8	HIGH	Yes	0.283	microsoft:windows_10_1507, microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_20h2, microsoft:wi	Windows Common Log File System Driver Elevation of Privilege Vulnerability
CVE-2025-38352	7.8	HIGH	Yes	0.013	debian:debian_linux, linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: posix-cpu-timers: fix race between handle_posix_cpu_timers() and posix_cpu_timer_del() If an exiting non-autoreaping task has already passed exit_notify() and calls handle_posix_cpu_timers() from IRQ, it can be reaped by its parent or debugger right after unlock_task_sighand(). If a concurrent posix_cpu_timer_del() runs at that moment, it won't...
CVE-2026-31431	7.8	HIGH	Yes	0.999	amazon:amazon_linux, arista:cloudvision_agni, arista:cloudvision_portal, arista:netvisor_os, arista:velocloud_edge, aris	In the Linux kernel, the following vulnerability has been resolved: crypto: algif_aead - Revert to operating out-of-place This mostly reverts commit 72548b093ee3 except for the copying of the associated data. There is no benefit in operating in-place in algif_aead since the source and destination come from different mappings. Get rid of all the complexity added for in-place operation and just copy the AD direc...
CVE-2026-81963	7.8	HIGH	Yes	0.006	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Improper link resolution before file access ("link following") in Windows Update Stack allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85880	7.8	HIGH	Yes	0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2026-42945	9.2	CRIT		0.68	f5:dos, f5:nginx_gateway_fabric, f5:nginx_ingress_controller, f5:nginx_instance_manager, f5:nginx_open_source, f5:nginx_	NGINX Plus and NGINX Open Source have a vulnerability in the ngx_http_rewrite_module module. This vulnerability exists when the rewrite directive is followed by a rewrite, if, or set directive and an unnamed Perl-Compatible Regular Expression (PCRE) capture (for example, \$1, \$2) with a replacement string that includes a question mark (?). An unauthenticated attacker along with conditions beyond its control can exp...
CVE-2023-52251	8.8	HIGH		0.868	provectus:ui	An issue discovered in provectus kafka-ui 0.4.0 through 0.7.2 allows remote attackers to execute arbitrary code via the q parameter of /api/clusters/local/topics/{topic}/messages. No fixed release is available; the project has had no commit since 2024-04-08.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2020-14498	10.0	CRIT		0.029	hms-networks:ecatcher	HMS Industrial Networks AB eCatcher all versions prior to 6.5.5 is vulnerable to a stack-based buffer overflow, which may allow an attacker to remotely execute arbitrary code.
CVE-2026-14560	10.0	CRIT				The teddy-bear-customize-addon WordPress plugin through 1.0.5 does not properly validate uploaded files, relying on a client-supplied content type and preserving the original filename, allowing unauthenticated attackers to upload arbitrary PHP files and execute code on the server.
CVE-2026-19188	10.0	CRIT		0.019		A critical OS command injection vulnerability has been identified in the Haiwell IoT Cloud HMI Gateway product. The vulnerability exists in the Net Check feature accessible via the /setting endpoint. The cmdPing Socket.io event fails to properly sanitize user-supplied input before passing it to the underlying operating system, allowing an attacker to inject and execute arbitrary OS commands with root privileges.
CVE-2026-28659	10.0	CRIT		0.002		In MicroXR Blobstore, there is a possible way to access other app's files due to a missing permission check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-42043	10.0	CRIT		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, an attacker who can influence the target URL of an Axios request can use any address in the 127.0.0.0/8 range (other than 127.0.0.1) to completely bypass the NO_PROXY protection. This vulnerability is due to an incomplete for CVE-2025-62718, This vulnerability is fixed in 1.15.1 and 0.31.1.
CVE-2026-44756	10.0	CRIT		0.003		A memory safety vulnerability exists in the Extended Passport Protocol (EPP) processing library. Under specific conditions, an unauthenticated attacker could exploit a crafted network request containing a malformed EPP header, potentially resulting in undefined behavior and abnormal program termination. Successful exploitation may have a high impact on the confidentiality, integrity, and availability of the applic...
CVE-2026-45674	10.0	CRIT		0.002	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, Netty's DnsResolveContext fails to validate the origin (bailiwick) of CNAME records in DNS responses. Versions 4.1.135.Final and 4.2.15.Final patch the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-47691	10.0	CRIT		0.003	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, Netty's `DnsResolveContext` insufficiently validates the bailiwick of NS records, enabling DNS Cache Poisoning. An attacker controlling an authoritative name server for a subdomain can poison the cache for parent domains (like `.co.uk`). In `io.netty.resolver.dns.DnsResolveCon...
CVE-2026-48056	10.0	CRIT		0.005		Streambert is a cross-platform Electron Desktop App to stream and download video content. Versions prior to 2.5.0 improperly validate executable paths supplied to the run-download IPC handler, allowing a compromised renderer process to execute arbitrary local binaries with the application's privileges. Version 2.5.0 contains a patch.
CVE-2026-48168	10.0	CRIT		0.009		PraisonAI is a multi-agent teams system. In versions prior to 4.6.40, the bundled Claude GitHub Actions workflow is vulnerable to command injection because it embeds an attacker-controlled pull request branch name into a Bash run: block without quoting or validation. Additionally, the workflow allows any @claude comment to trigger the job regardless of whether the commenter is a trusted collaborator. An outside co...
CVE-2026-49883	10.0	CRIT		0.002		In checkReadPermission of PermissionsManager.java, there is a possible way to monitor sensitive device state data due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-54745	10.0	CRIT		0.004		Kubeflow Pipelines enables users to build and deploy portable, scalable machine learning workflows. Prior to 2.17.0, the Kubeflow Pipelines frontend exposes an unauthenticated server-side request forgery vulnerability through the /_proxy/ route in frontend/server/proxy-middleware.ts. The _routePathWithReferer() function accepts an arbitrary attacker-controlled HTTP or HTTPS target and passes its origin to createPr...
CVE-2026-65956	10.0	CRIT		0.004		KubePi is a Kubernetes multi-cluster management panel. In versions up to and including 1.6.15, the SSO configuration API endpoints are exposed on the same public routing boundary as the SSO login and callback endpoints, so SSO, OIDC, and SAML management operations can be reached without administrator authorization. Because reading, creating, and updating the global SSO configuration is not restricted to administra...
CVE-2026-70352	10.0	CRIT		0.006		Missing authentication for critical function in Azure AI Language allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-73299	10.0	CRIT		0.012		Prompty is a markdown file format (.prompty) for LLM prompts. Prior to 0.1.5 and 2.0.0-beta.5, the TypeScript Nunjucks renderer evaluated untrusted .prompty template bodies with unrestricted JavaScript member access. An attacker-controlled template could traverse constructor and prototype properties to execute JavaScript in the host Node.js process. This issue is fixed in versions 0.1.5 and 2.0.0-beta.5.
CVE-2026-75754	10.0	CRIT		0.002		Missing Authentication for Critical Function, Server-Side Request Forgery (SSRF), and Use of Hard-coded Credentials in ASUS Control Center allow an unauthorized user to obtain the encryption key via an HTTP request, causing a local service to enable SSH on port 2222. The attacker can then log in with the hardcode credentials to obtain a root shell, enabling direct reading, writing, and deletion of data on ASUS Con...
CVE-2026-77770	10.0	CRIT		0.001		The miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress plugin before 19.3 does not require a validated transaction before deleting site options whose names come from unauthenticated request input, allowing any visitor to delete arbitrary options, which can lock every administrator out of the dashboard or deactivate every miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress...
CVE-2026-79696	10.0	CRIT		0.004		A Code Injection vulnerability in adk web in Google Cloud Agent Development Kit (ADK) for Python versions 2.0.0 through 2.6.0 on Python (OSS), Cloud Run, and GKE environments where pytest is installed allows an unauthenticated remote attacker to execute arbitrary code using a crafted test session replay.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80098	10.0	CRIT		0.003	microsoft:copilot_studio	Improper verification of cryptographic signature in Copilot Studio allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-82004	10.0	CRIT		0.014	adobe:campaign	Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-83711	10.0	CRIT		0.006		Authorization bypass through user-controlled key in Microsoft Azure Active Directory B2C allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-85061	10.0	CRIT		0.003		MapLibre GL JS is an interactive vector tile map library for web browsers. Prior to 6.4.1, DOM.sanitize() in src/util/dom.ts iterates elem.attributes as a live NamedNodeMap while removeAttributes() removes attributes from the same collection, shifting indexes and skipping an adjacent dangerous attribute. An attacker who controls untrusted third-party style attribution strings or user-supplied custom attributions c...
CVE-2026-85978	10.0	CRIT		0.009		An unauthenticated remote code execution vulnerability exists in the Policy Manager console of Akana API Platform. A path normalization discrepancy between the authentication filter and the servlet dispatcher allows a crafted request to bypass authentication and reach an endpoint that evaluates attacker-supplied script code without sandboxing, resulting in arbitrary code execution. Exploitation requires no authent...
CVE-2026-86152	10.0	CRIT		0.019		A flaw has been found in Tenda CP3 27.5.57.101. The impacted element is the function CAutoAddWifi::ThreadProc of the file Functions/AutoAddWifi.cpp of the component Kylin. Executing a manipulation can lead to os command injection. The attack may be launched remotely.
CVE-2026-87827	10.0	CRIT		0.011		Certain KGUARD DVR devices running vulnerable firmware expose a system command execution service on all network interfaces without requiring authentication. A remote unauthenticated attacker with network access to the affected service can execute arbitrary system commands on the device, potentially resulting in complete compromise of the DVR. The vulnerability is known to have been exploited in the wild by the Mi...
CVE-2026-12645	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12646	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12647	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12650	9.9	CRIT		0.015		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-19232	9.9	CRIT		0.006		Adobe Experience Manager is affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user, potentially gaining elevated access or control over the victim's account or session. A low-privileged attacker could exploit this vulnerability to gain elevated access or control over the victim's account or session. Exploitation of this issue does not r...
CVE-2026-19583	9.9	CRIT		0.006		Velociraptor allows some sensitive artifacts to be gated by additional permissions. For example, the Linux.Sys.BashShell artifact allows arbitrary command execution on endpoints, and so it requires the EXECVE permission to schedule. However, no such check was implemented for client monitoring artifacts. Additionally there was no requirement that client monitoring artifacts carry the CLIENT_EVENTS type. This allows...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-22797	9.9	CRIT		0.006		An issue was discovered in OpenStack keystonemiddleware 10.5 through 10.7 before 10.7.2, 10.8 and 10.9 before 10.9.1, and 10.10 through 10.12 before 10.12.1. The external_oauth2_token middleware fails to sanitize incoming authentication headers before processing OAuth 2.0 tokens. By sending forged identity headers such as X-Is-Admin-Project, X-Roles, or X-User-Id, an authenticated attacker may escalate privileges ...
CVE-2026-26084	9.9	CRIT		0.002		A improper access control vulnerability in Fortinet FortiSandbox 5.0.0 through 5.0.5, FortiSandbox 4.4.0 through 4.4.8, FortiSandbox Cloud 5.0.4 through 5.0.5, FortiSandbox PaaS 5.0.4 through 5.0.5 may allow attacker to access sensitive information via crafted HTTP requests.
CVE-2026-47686	9.9	CRIT		0.004		vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.6, handleException() in lib/setup-sandbox.js sanitizes SuppressedError.error, SuppressedError.suppressed, and AggregateError.errors but does not sanitize Error.cause, allowing sandbox code to obtain a powerful host object such as process from an embedder-exposed host function that throws an error with that object as its cause and then execute arbitrary ho...
CVE-2026-48086	9.9	CRIT		0.003		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, a TENANT_ADMIN promotes themselves to platform-wide GLOBAL_ADMIN through a single PUT request. The role-update handler accepts the `GLOBAL_ADMIN` enum value from any tenant admin updating their own tenant's staff. No policy check enforces that "only an existing GLOBAL_ADMIN may grant ...
CVE-2026-48273	9.9	CRIT		0.017		ColdFusion is affected by an Improper Neutralization of Directives in Dynamically Evaluated Code ('Eval Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-48765	9.9	CRIT		0.003		TypeBot is a chatbot builder tool. Versions prior to 3.17.0 allow a low-privilege read collaborator to extract a workspace OAuth `credentialsId` from a readable bot configuration and then overwrite that credential through `handleUpdateOAuthCredentials()` by supplying an attacker-controlled writable `workspaceId`. The update path validates only the attacker-supplied workspace and then updates the credential record ...
CVE-2026-51366	9.9	CRIT		0.005		SQL Injection vulnerability in Bottinelli Informatica Vedo Suite v.1.2.5 allows a remote attacker to execute arbitrary code via the api_vedo/chat endpoint and the utente_chat parameter
CVE-2026-52855	9.9	CRIT		0.003		Wings is the server control plane for Pterodactyl, a free, open-source game server management panel. Prior to 1.12.3, {{config.}} placeholders in egg configuration-file templates allow a low-privileged user to read {{config.token}}, {{config.token_id}}, and {{config.docker.registries}} from the full daemon configuration. This issue is fixed in version 1.12.3.
CVE-2026-54680	9.9	CRIT		0.004		Logging operator automates the deployment and configuration of Kubernetes logging pipelines. Prior to 6.6.0, the Fluentd configuration renderer FluentRender in pkg/sdk/logging/model/render/fluent.go writes CRD strings such as Flow record_transformer.records values directly into fluent.conf without escaping, allowing a user who can create Flow resources to inject a Fluentd <match *> block using @type exec and exec...
CVE-2026-55089	9.9	CRIT		0.004		Etherpad is a real-time collaborative editor. From 2.1.0 until 3.1.0, Etherpad's src/node/handler/APIHandler.ts authorizes requests to /api/2/* in the authorization_code OAuth path by using requiredClaims with the admin claim. This check requires only that the claim exists, while src/node/security/OAuth2Provider.ts issues admin: false for configured non-admin users. A non-admin user with a valid signed token can t...
CVE-2026-55166	9.9	CRIT		0.003		Lemur manages TLS certificate creation. Prior to 1.9.2, authenticated users could influence an ACME authority acme_url without an effective server-side destination restriction and trigger AcmeHandler.setup_acme_client to make backend requests. An attacker could target cloud instance metadata or internal services from Lemur network context, potentially obtaining credentials available to the host. The advisory also ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55565	9.9	CRIT		0.005		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs LikeExpression.fillCode_getValueReturn in yamcs-core/src/main/java/org/yamcs/yarch/streamsqli/LikeExpression.java inserts an unescaped LIKE pattern into Java source compiled by Expression.getCompiledExpression through SimpleCompiler.cook instead of applying ValueExpression.escapeJavaString. The pattern can originate from POST /api/archive/{inst...
CVE-2026-55634	9.9	CRIT		0.004		Pimcore is an Open Source Data & Experience Management Platform. Prior to 11.5.19, 12.3.10, and 2026.1.6, the class-definition import endpoint /pimcore-studio/api/class/definition/configuration-view/detail/{id}/import accepts a DataObject field name that is emitted without an identifier allowlist by lib/DataObject/ClassBuilder/FieldDefinitionPropertiesBuilder.php into generated PHP properties and by models/DataObj...
CVE-2026-62283	9.9	CRIT		0.004		Nezha Monitoring is a self-hostable, lightweight, servers and websites monitoring and O&M tool. Nezha versions 1.14.13 through 1.14.14 and 2.0.0 through 2.0.9 do not bind stream identifiers created by CreateStream in service/rpc/io_stream.go to their creating user, and `GET /ws/terminal/:id` and `GET /ws/file/:id` only check whether the supplied UUID exists. An authenticated RoleMember who obtains a live stream UU...
CVE-2026-65818	9.9	CRIT		0.003	microsoft:power_platform	Server-side request forgery (ssrf) in Power Automate allows an authorized attacker to elevate privileges over a network.
CVE-2026-65974	9.9	CRIT		0.006		ERPNext is a free and open source Enterprise Resource Planning tool. Prior to 15.111.0 and 16.22.0, limited authenticated users can cross a permission boundary in Frappe safe execution because frappe.render_template is exposed without forcing restrict_globals, allowing server-side template injection and remote code execution. This issue is fixed in versions 15.111.0 and 16.22.0.
CVE-2026-66795	9.9	CRIT		0.003		A flaw was found in the managedcluster-import-controller. The Certificate Signing Request (CSR) auto-approval logic improperly validates incoming CSRs, specifically by not inspecting the signer name or decoding the PEM-encoded x509 CSR. This vulnerability allows a privileged service account on a spoke cluster to submit a malicious CSR. Successful exploitation can lead to privilege escalation, enabling the attacker...
CVE-2026-67401	9.9	CRIT		0.01		A vulnerability in cPanel allows a mail-enabled account to achieve remote code execution as root through SQLi in EmailTrack component
CVE-2026-68487	9.9	CRIT				Path traversal in Plesk's Backup Manager causes arbitrary file write as root by an authenticated customer.
CVE-2026-68488	9.9	CRIT				A Time-of-check Time-of-use (TOCTOU) race condition leading to insecure symlink following in Plesk causes local privilege escalation to root via arbitrary file/directory ownership takeover.
CVE-2026-72733	9.9	CRIT		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the backup.restoreBackupWithLogs tRPC subscription builds database restore shell pipelines from the user-controlled databaseName and backupFile fields without safely separating them from shell syntax. packages/server/src/utlis/restore/utlis.ts interpolates databaseName into database-specific restore commands, while packages/server/src...
CVE-2026-72735	9.9	CRIT		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, writeTraefikConfigRemote in packages/server/src/utlis/traefik/application.ts serializes user-controlled Traefik configuration with yaml.stringify and interpolates the resulting yamlStr into an echo command executed through execAsyncRemote. Single quotes in redirect regex and replacement fields, basic authentication usernames, domain h...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72736	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy passes user-controlled values directly into shell commands via unquoted template literal interpolation in the registry credential testing and Docker Swarm cluster management endpoints. Both endpoints have a safe local code path (using <code>execFileAsync</code> or the Docker API) but a vulnerable remote path (using <code>execAsyncRemote</code> which r...
CVE-2026-72738	9.9	CRIT		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the <code>backup.listBackupFiles</code> tRPC endpoint in <code>apps/dokploy/server/api/routers/backup.ts</code> passes the search parameter through <code>normalizeS3Path</code> and interpolates it into an <code>rclone lsjson</code> command executed by <code>child_process.exec()</code> , allowing an authenticated user with <code>backup:read</code> permission to execute arbitrary commands on the Dokploy host. This...
CVE-2026-72740	9.9	CRIT		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, <code>packages/server/src/utls/providers/git.ts</code> parses the user-controlled <code>customGitUrl</code> with <code>sanitizeRepoPathSSH</code> and interpolates its domain into the <code>ssh-keyscan</code> command from <code>addHostToKnownHostsCommand</code> without shell quoting, allowing an authenticated member with service deployment permission and an attached SSH key to execute arbitrary com...
CVE-2026-72862	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the <code>mariadb.ts</code> , <code>mongo.ts</code> , <code>mysql.ts</code> , <code>postgres.ts</code> , <code>redis.ts</code> , and <code>libsql.ts</code> Dokploy database service deployment functions pass user-controlled <code>dockerImage</code> fields unquoted into <code>docker pull \${dockerImage}</code> shell commands on the remote-server code path. This vulnerability is fixed in 0.29.13.
CVE-2026-72863	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy's WebSocket handlers (in-app terminals and log streamers) authenticate the session but never authorize it. They establish who the user is via <code>validateRequest()</code> and then proceed without consulting the role/permission model that every tRPC procedure enforces. Any authenticated member, can therefore open an interactive shell into...
CVE-2026-72864	9.9	CRIT		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the local branch of <code>/docker-container-terminal</code> in <code>apps/dokploy/server/wss/docker-container-terminal.ts</code> authenticates with <code>validateRequest</code> but does not authorize the attacker-controlled <code>containerId</code> against the caller's role, organization, or service access before passing it to <code>`docker exec`</code> , allowing any authenticated member to obtain ...
CVE-2026-72865	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the <code>compose.update</code> operation stores an unvalidated <code>composePath</code> that <code>packages/server/src/utls/builders/compose.ts</code> and <code>packages/server/src/services/compose.ts</code> interpolate into <code>docker compose -f</code> , <code>docker stack deploy -c</code> , and <code>touch</code> shell commands executed through <code>/bin/sh -c</code> . An authenticated member with <code>compose write</code> and <code>deploy</code> permission...
CVE-2026-72867	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). From 0.29.3 until 0.29.13, the incomplete fix for CVE-2026-45628 leaves <code>packages/server/src/db/schema/compose.ts</code> branch fields without server-side validation, allowing a direct <code>compose.update</code> request to store a malicious <code>customGitBranch</code> , <code>branch</code> , <code>gitlabBranch</code> , <code>bitbucketBranch</code> , or <code>giteaBranch</code> . A low-privileged authenticated user can trigger <code>compose.deplo...</code>
CVE-2026-72868	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, <code>apps/dokploy/server/api/routers/destination.ts</code> interpolates the <code>accessKey</code> , <code>secretAccessKey</code> , <code>region</code> , <code>endpoint</code> , <code>provider</code> , and <code>bucket</code> fields from <code>destination.testConnection</code> into an <code>rclone ls</code> command executed through <code>child_process.exec</code> . The <code>`withPermission("destination", "create")`</code> path permits a low-privileged organization member to reac...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72869	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the backup.restoreBackupWithLogs tRPC subscription passes the databaseName parameter to restore builders in packages/server/src/utls/restore/utls.ts, where PostgreSQL, MariaDB, MySQL, and MongoDB commands embed the value in nested shell text executed by Node.js exec. An authenticated user with backup:restore permission can supply a ...
CVE-2026-72872	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, application.saveBitbucketProvider stores bitbucketOwner and bitbucketRepository without validation and cloneBitbucketRepository in packages/server/src/utls/providers/bitbucket.ts interpolates those values into git clone commands executed through execAsync or execAsyncRemote, allowing a member with service deployment permission to exe...
CVE-2026-72876	9.9	CRIT		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, swarm.getNodeInfo, swarm.getNodeInfo, swarm.getNodeApps, and swarm.getAppInfos in apps/dokploy/server/api/routers/swarm.ts accept another organization's serverId without an activeOrganizationId ownership check, and getNodeInfo in packages/server/src/services/docker.ts interpolates nodeId into execAsyncRemote, allowing a caller with serve...
CVE-2026-72880	9.9	CRIT		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the apiCreateCertificate schema in packages/server/src/db/schema/certificate.ts accepts a client-supplied certificatePath, and packages/server/src/services/certificate.ts joins that value to the certificate root without confinement. An authenticated user with certificate create or delete permission can use certificatePath to write att...
CVE-2026-72882	9.9	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). In 0.28.8 and earlier, an authenticated user who can create or update file mounts for a service can inject shell metacharacters into filePath, causing Dokploy to execute attacker-controlled commands on the configured remote managed server over SSH. In the default deployment model, this yields direct remote host RCE from the web interface.
CVE-2026-72886	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). From 0.29.2 until 0.29.13, schedule.create and schedule.update in apps/dokploy/server/api/routers/schedule.ts derive serviceId from applicationId or composId and execute the owner/admin host-schedule gate only in the alternative branch, allowing a member with access to one application to attach its applicationId to a dokploy-server schedule and run a ...
CVE-2026-72901	9.9	CRIT		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy allows an authenticated low-privilege member to execute arbitrary commands on the control-plane host because the volumeName field accepted by volumeBackup.create and volumeBackup.runManually is interpolated without quoting in packages/server/src/utls/volume-backups/backup.ts and executed through child_process.exec, with Docke...
CVE-2026-72902	9.9	CRIT		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy allows an authenticated user to execute arbitrary commands on a local or SSH-connected target server because registry.testRegistry and registry.testRegistryById in apps/dokploy/server/api/routers/registry.ts interpolate the password field into an execAsyncRemote shell command instead of using safeDockerLoginCommand. This issue...
CVE-2026-72911	9.9	CRIT		0.004		ERPNext is a free and open source Enterprise Resource Planning tool. Prior to 15.118.0 and 16.29.0, the validate_template and render_template calls in erpnext/accounts/doctype/process_statement_of_accounts/process_statement_of_accounts.py render subject, body, and pdf_name fields with unrestricted globals including frappe.utls, allowing an authenticated user with a common operational role to inject template expre...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73263	9.9	CRIT		0.004		Prowler is a cloud security platform. Prior to 5.36.0, the Kubernetes provider connection test accepted kubeconfig_content containing a legacy gcp auth-provider with config.cmd-path and config.cmd-args because kubeconfig_contains_exec_auth in api/src/backend/api/v1/serializers.py checked only exec blocks, and POST /api/v1/providers/{id}/connection loaded it through config.load_kube_config_from_dict in prowler/prov...
CVE-2026-73268	9.9	CRIT		0.005		A flaw was found in the cluster-curator-controller component of multicloud engine (MCE). A tenant with create or update permissions on ClusterCurator resources can inject an arbitrary Job specification. This is possible because the CreateJob() function does not validate user-controlled input when unmarshaling the spec.install.overrideJob raw extension. Successful exploitation allows the injected Job to run with ...
CVE-2026-73269	9.9	CRIT		0.003		A flaw was found in the cluster-curator-controller component. A local user, by creating a ClusterCurator resource with a specific naming convention, can trigger the creation of a cluster-scoped ClusterRoleBinding. This allows the user to escalate their privileges from namespace-local access to cluster-wide control. This privilege escalation grants broad permissions, including the ability to access and manipulate s...
CVE-2026-73294	9.9	CRIT		0.006		Semaphore UI is a web interface for managing DevOps tools. Prior to 2.18.17 and 2.19.5-beta2, repository git_url handling passes an attacker-controlled --upload-pack option to CmdGitClient.GetLastRemoteCommitHash through POST /api/project/{id}/repositories and scheduled commit-hash polling, allowing a project Manager or Owner to execute arbitrary OS commands in the Semaphore server process. This issue is fixed in ...
CVE-2026-7374	9.9	CRIT		0.007		A flaw was found in KubeVirt's virt-handler component. This vulnerability allows an authenticated OpenShift user with edit permissions in a single namespace to exploit improper symlink validation when connecting to virtual machine console sockets. By replacing the console socket with a symlink to the host's container runtime (CRI-O) socket, an attacker can hijack virt-handler's privileged connection. This enables ...
CVE-2026-78234	9.9	CRIT		0.002		A flaw was found in hawtio-operator. The operator reads the OpenShift Service CA private signing key from the openshift-service-ca namespace and uses it to mint client certificates with a Subject Common Name (CN) supplied by the author of a namespaced Hawtio custom resource. Because the operator ships a ClusterRole that aggregates Hawtio CR permissions into the edit and admin roles, any user with edit access in an...
CVE-2026-79748	9.9	CRIT		0.003		MCPHub is a unified hub for centrally managing and dynamically orchestrating multiple MCP servers/APIs into separate endpoints with flexible routing strategies. Prior to version 0.12.15, the POST /api/servers and PUT /api/servers/:name endpoints in MCPHub create/update MCP server configurations and then immediately spawn the configured stdio process via child_process.spawn. Authentication is required, but there is...
CVE-2026-83941	9.9	CRIT		0.007		Missing authorization in Entra ID allows an authorized attacker to elevate privileges over a network.
CVE-2026-84869	9.9	CRIT		0.004		A condition in the ScreenConnect client may allow files to be transferred and executed through an active remote session without authorization or Host confirmation in certain circumstances. ScreenConnect servers are not impacted.
CVE-2026-86464	9.9	CRIT		0.004		In the current development version of Eclipse aeriOS, for which no official release has yet been published, the Identity Manager (IdM) deployment included insecure default configurations and credentials for security-sensitive services. The Helm chart exposed the Keycloak service and its PostgreSQL backing database through Kubernetes NodePort services by default, while the Docker Compose deployment similarly ex...
CVE-2026-89094	9.9	CRIT				Forgejo before 16.0.4 allows remote code execution via a crafted template repository because template expansion on files in .forgejo/template is mishandled.
CVE-2021-43716	9.8	CRIT		0.003		Verification Bypass vulnerability exists in EPSON 150075647YWWV110 EasyMP Network Updater Ver.1.20. The Epson projector can be updated by encrypted firmware through USB.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2021-43717	9.8	CRIT		0.004		An issue exists in pson EH-TW5350 Epson iProjection.apk v3.2.6. If you identify a projector equipped with an iProjection function, you can access the projector using hard-coded authentication information and control the projector maliciously.
CVE-2023-42179	9.8	CRIT		0.003		Bird Home Automation GmbH D1101V-F 000140 is vulnerable to Incorrect Access Control via the Key derivation process, password validation process.
CVE-2024-11080	9.8	CRIT		0.004		The Post Grid and Gutenberg Blocks – ComboBlocks plugin for WordPress is vulnerable to Unauthenticated Hook Injection in versions 2.2.32 to 2.3.1 via several functions in the ~/includes/blocks/form-wrap/function.php file. This makes it possible for unauthenticated attackers to execute actions with hooks in WordPress, granted no other security controls are present in the function.
CVE-2024-22373	9.8	CRIT		0.016	fedoraproject:fedora, malaterre:grassroots_dicom	An out-of-bounds write vulnerability exists in the JPEG2000Codec::DecodeByStreamsCommon functionality of Mathieu Malaterre Grassroot DICOM 3.0.23. A specially crafted DICOM file can lead to a heap buffer overflow. An attacker can provide a malicious file to trigger this vulnerability.
CVE-2025-29296	9.8	CRIT		0.022		H3C Magic BE18000 V200R007, H3C NX400 V100R015, H3C Magic NX30 Pro V100R0011, H3C Magic R3010 V100R009, H3C Magic NX15 V100R017, H3C Magic R1510 V100R016, H3C NE36 Pro V100R002 and H3C MC102G HM1A0V200R010 contain multiple command injection vulnerabilities in the /api/esps request handler. The affected object interfaces and methods are esps.dhcpd.vlan (getlist, delete), esps.filter.url (add, modify), esps.apcm.ver...
CVE-2025-63823	9.8	CRIT		0.004		My Safetipin Android Application 5.2.1 contains Hardcoded credentials in the authentication module, which allows remote attackers to bypass authentication and gain unauthorized access to user accounts via predictable OTP values.
CVE-2025-67066	9.8	CRIT		0.004		SQL Injection vulnerability in oasys sysoa version 1.0 allows a remote attacker to execute arbitrary code via the outtype parameter in the /outaddresspaging path
CVE-2025-70149	9.8	CRIT		0.004	codeastro:membership_management_system	CodeAstro Membership Management System 1.0 is vulnerable to SQL Injection in print_membership_card.php via the ID parameter.
CVE-2025-70150	9.8	CRIT		0.006	codeastro:membership_management_system	CodeAstro Membership Management System 1.0 contains a missing authentication vulnerability in delete_members.php that allows unauthenticated attackers to delete arbitrary member records via the id parameter.
CVE-2025-70152	9.8	CRIT		0.004	fabian:scholars_tracking_system	code-projects Community Project Scholars Tracking System 1.0 is vulnerable to SQL Injection in the admin user management endpoints /admin/save_user.php and /admin/update_user.php. These endpoints lack authentication checks and directly concatenate user-supplied POST parameters (firstname, lastname, username, password, user_id) into SQL queries without validation or parameterization.
CVE-2025-70290	9.8	CRIT		0.005		An issue was discovered in Denx U-Boot before 2026.04. An integer overflow vulnerability in the ZFS filesystem support can be triggered by malformed on-disk metadata. The issue may result in incorrect memory allocation followed by out-of-bounds memory access, potentially leading to a crash or arbitrary code execution during the boot process.
CVE-2025-70293	9.8	CRIT		0.005		An issue was discovered in Denx U-Boot before 2026.04. An integer overflow vulnerability exists in function ext4fs_get_bgdtable, the size calculation can lead to under allocation and this underallocated buffer will be used in memcpy() which could lead to arbitrary code execution, a denial of service, or other unspecified impacts.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-10196	9.8	CRIT		0.006		The Mail Mint – Email Marketing, Newsletter, Email Automation & WooCommerce Emails plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 1.31.0 via deserialization of untrusted input in the 'handle_form_submission' function. This makes it possible for unauthenticated attackers to inject a PHP Object. The additional presence of a POP chain allows attackers to execute code ...
CVE-2026-12744	9.8	CRIT		0.022		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote unauthenticated attacker to execute arbitrary code on the server.
CVE-2026-12745	9.8	CRIT		0.021		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote unauthenticated attacker to execute arbitrary code on the server.
CVE-2026-13447	9.8	CRIT		0.004		The Mstore Api plugin for WordPress is vulnerable to Authentication Bypass via JWT Forgery in versions up to, and including, 4.20.0 This is due to missing cryptographic signature verification in the FirebasePhoneAuthHelper::verify_id_token() function, which decodes and validates Firebase ID token claims (alg, kid, aud, iss) but never calls openssl_verify() or any equivalent to validate the JWT signature against Go...
CVE-2026-14559	9.8	CRIT				The teddy-bear-customize-addon WordPress plugin through 1.0.5 does not verify a user's password before authenticating them, allowing unauthenticated attackers to log in as any registered user, including administrators, by supplying only that user's email address.
CVE-2026-14563	9.8	CRIT				The advanced-customized-prompts WordPress plugin through 1.0.1 does not verify the password before issuing an authenticated session for a supplied email address in an unauthenticated action, allowing unauthenticated attackers to log in as any registered user, including administrators, or to create arbitrary new accounts.
CVE-2026-16310	9.8	CRIT		0.003		The MemberDash plugin for WordPress is vulnerable to Insecure Direct Object Reference in all versions up to, and including, 1.8.5 via the 'id' parameter due to missing validation on a user controlled key. This makes it possible for unauthenticated attackers to change the password of any WordPress user, including administrators, by supplying an arbitrary user ID during registration, and take over their account with...
CVE-2026-16504	9.8	CRIT		0.004		Deployment of the VPS.org one-click Zulip template deploys a hardcoded application signing key, a default database password ("zulip"), and DISABLE_HTTPS=True.
CVE-2026-18221	9.8	CRIT		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to gain unauthorized access due to improper validation of client-supplied authentication parameters.
CVE-2026-18351	9.8	CRIT		0.008		The Drag and Drop File Upload for Elementor Forms plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.6.0 via the elementor_file_upload function. This is due to insufficient file type validation in the is_file_type_valid() function, which uses the attacker-controlled 'type' parameter as regex keys in the MIME allowlist, allowing blacklist bypass via a crafted extensi...
CVE-2026-18658	9.8	CRIT		0.004		IBM Operational Decision Manager 9.6.0.0, 9.5.0.0, 8.11.1.0, 8.11.0.1, 8.12.0.1, 9.5.0.1, and 9.0.0.1 is vulnerable to SQL injection. An unauthenticated attacker can execute arbitrary SQL statements and leverage database functionality to write a web shell to the application web root, resulting in remote code execution.
CVE-2026-18749	9.8	CRIT		0.004		The type=track branch authorises on _is_my_case(t_attach.case) only and never checks VinceTrackAttachment.shared. A coordinator-uploaded case artefact that has NOT been marked shared is still retrievable by any case member who has (or is sent) its uuid — leaks not-yet-released coordinator material to vendors on the case.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-18922	9.8	CRIT		0.006		A flaw was found in 389 Directory Server. During SASL PLAIN authentication, a stale identity carried in a Cyrus SASL auxiliary property from a prior failed bind attempt can be installed on a connection following a subsequent, unrelated successful bind, regardless of which SASL mechanism completes that second bind. An attacker can send a SASL PLAIN bind as cn=Directory Manager with an incorrect password, then compl...
CVE-2026-19931	9.8	CRIT		0.008		A flaw in libcurl makes it wrongly reuse an HTTP connection setup for a given hostname using Negotiate authentication, when the initial request is done using empty credentials. This can make user B's request get sent over user A's previously authenticated connection.
CVE-2026-26035	9.8	CRIT		0.006	fortinet:fortiweb	An Improper Authentication vulnerability [CWE-287] vulnerability in Fortinet FortiWeb 8.0.0 through 8.0.2, FortiWeb 7.6.0 through 7.6.6, FortiWeb 7.4.0 through 7.4.11, FortiWeb 7.2.0 through 7.2.12, FortiWeb 7.0.0 through 7.0.12 may allow a remote unauthenticated attacker to login into the Fortiweb GUI/CLI with a random username and password
CVE-2026-28606	9.8	CRIT		0.002		In handleBondStateChanged of AdapterService.java, there is a possible way to skip pairing due to a logic error in the code. This could lead to remote escalation of privilege without user consent with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28780	9.8	CRIT		0.014	apache:http_server	Heap-based Buffer Overflow vulnerability in mod_proxy_ajp of Apache HTTP Server. If mod_proxy_ajp connects to a malicious AJP server this AJP server can send a malicious AJP message back to mod_proxy_ajp and cause it to write 4 attacker controlled bytes after the end of a heap based buffer. This issue affects Apache HTTP Server: through 2.4.66. Users are recommended to upgrade to version 2.4.67, which fixes the ...
CVE-2026-31020	9.8	CRIT		0.006		In DocsGPT 0.15.0 and below, the application provides a custom prompt feature that allows users to define prompt content used during chatbot interactions. This functionality renders user-supplied prompt data using Jinja templates without input sanitization or sandboxing. An unauthenticated attacker can inject malicious template expressions, leading to a server-side template injection (SSTI) vulnerability that can ...
CVE-2026-33815	9.8	CRIT		0.006	jackc:pgx	Memory-safety vulnerability in github.com/jackc/pgx/v5.
CVE-2026-33816	9.8	CRIT		0.006	jackc:pgx	Memory-safety vulnerability in github.com/jackc/pgx/v5.
CVE-2026-35868	9.8	CRIT		0.014		A Command Injection vulnerability exists in the bs_SetLimitCli_info function within the libshare.so library of LB-link Router AC2100_AZ3 V1.0.4. This flaw occurs due to insufficient validation and sanitization of user-supplied input before it is passed to a system-level command execution context. An attacker can exploit this vulnerability by injecting specially crafted shell metacharacters or payloads into the vul...
CVE-2026-35869	9.8	CRIT		0.013		A Command Injection vulnerability exists in the bs_SetLimitCli_info function within the libshare.so library of LB-link Router AC450M V4.0.0. This flaw occurs due to insufficient validation and sanitization of user-supplied input before it is passed to a system-level command execution context. An attacker can exploit this vulnerability by injecting specially crafted shell metacharacters or payloads into the vulnera...
CVE-2026-36433	9.8	CRIT		0.002		An issue in Actions Semiconductor Co. Ltd Tool- Media Player Utilities v.4.46 allows a physically proximate attacker execute arbitrary code via the Production.dll and RdiskUpgrade.exe components
CVE-2026-37003	9.8	CRIT		0.016		Agno up to and including 2.5.8 is vulnerable to Remote Code Execution (RCE) via prompt injection. The PythonTools and ShellTools components pass unsanitized, LLM-generated arguments directly to execution sinks including exec(), runpy.run_path(), and subprocess.run(). An unauthenticated attacker can exploit this by embedding malicious instructions in content processed by the agent (such as web pages or documents), ...
CVE-2026-37006	9.8	CRIT		0.006		A vulnerability in the WebSocket endpoint of gpt-researcher v0.14.7 and before allows an unauthenticated remote attacker to achieve code execution via malicious Model Context Protocol configurations.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-37236	9.8	CRIT		0.004		grpc-gateway v2.28.0 is vulnerable to Incorrect Access Control. The application processes the X-HTTP-Method-Override header in ServeMux.ServeHTTP without restricting allowed methods. When a POST request with Content-Type application/x-www-form-urlencoded includes this header, the request method is rewritten to an arbitrary attacker-supplied value before routing. This allows bypassing method-based access controls e...
CVE-2026-37751	9.8	CRIT		0.016		An OS command injection vulnerability in the killSessionSync function (lib/agent-runtime.ts) of 23blocks-OS ai-maestro v0.24.17 allows attackers to execute arbitrary commands via a crafted input.
CVE-2026-38165	9.8	CRIT		0.006		A Server-Side Template Injection (SSTI) vulnerability in the Velocity template engine configuration of xdocreport v0.9.2 to v2.2.0 allows attackers to execute arbitrary code via a crafted expression.
CVE-2026-39254	9.8	CRIT		0.006		Buffer Overflow vulnerability in SteelSeries GG (macOS) v.107.0.0 allows a remote attacker to execute arbitrary code via the libSSEdevice.dylib, CxAudioHidDevice::DeviceGetDescriptionString components
CVE-2026-39255	9.8	CRIT		0.006		Buffer Overflow vulnerability in SteelSeries GG (macOS) v.107.0.0 allows a remote attacker to execute arbitrary code via the libSSEdevice.dylib, dup_wcs components
CVE-2026-40860	9.8	CRIT		0.012	apache:camel	JmsBinding.extractBodyFromJms() in camel-jms, and the equivalent JmsBinding class in camel-sjms, deserialized the payload of incoming JMS ObjectMessage values via javax.jms.ObjectMessage.getObject() without applying any ObjectInputFilter, class allowlist or class denylist. Because this code path is reached whenever the mapJmsMessage option is enabled (the default) and Camel acts as a JMS consumer, an attacker able...
CVE-2026-41871	9.8	CRIT		0.004	apache:nutch	Missing Authorization, Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted use...
CVE-2026-42027	9.8	CRIT		0.007	apache:opennlp	Arbitrary Class Instantiation via Model Manifest in Apache OpenNLP ExtensionLoader Versions Affected: before 1.9.5, before 2.5.9, before 3.0.0-M3 Description: The ExtensionLoader.instantiateExtension(Class, String) method loads a class by its fully-qualified name via Class.forName() and invokes its no-arg constructor, with the class name sourced from the manifest.properties entry of a model archive. Th...
CVE-2026-42581	9.8	CRIT		0.006	netty:netty	Netty is an asynchronous, event-driven network application framework. Prior to 4.2.13.Final and 4.1.133.Final, HttpObjectDecoder strips a conflicting Content-Length header when a request carries both Transfer-Encoding: chunked and Content-Length, but only for HTTP/1.1 messages. The guard is absent for HTTP/1.0. An attacker that sends an HTTP/1.0 request with both headers causes Netty to decode the body as chunked ...
CVE-2026-45018	9.8	CRIT		0.007		Chainlit is a Python framework for building production-ready conversational AI applications. From 2.4.0rc0 until 2.12.0, Chainlit deployments with features.mcp.enabled set to true in .chainlit/config.toml expose the POST /mcp endpoint without requiring authentication. For stdio transport, the endpoint accepts a user-controlled fullCommand string. The validate_mcp_command() function in backend/chainlit/mcp.py check...
CVE-2026-45117	9.8	CRIT		0.008		MyBB is free and open source forum software. From 1.8.13 until 1.8.40, the installer module does not properly escape user-supplied database configuration values written to the configuration file, resulting in PHP code injection and remote code execution when the installer is available. install/index.php processes the values with addslashes(), but the \$characters argument added in MyBB 1.8.13 does not include the ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45538	9.8	CRIT		0.006		OpenSIPS is a Session Initiation Protocol (SIP) server implementation. In versions 4.0.0 and prior, processing a SIP message with a header name longer than 255 bytes causes a stack buffer overflow when sip_to_json() is called in the routing script. Function sip_to_json() (modules/sipmsgops/sipmsgops.c) copies SIP header names into a fixed 255-byte stack buffer without bounds checking, performing a memcpy of the fu...
CVE-2026-46670	9.8	CRIT		0.019		YesWiki is a wiki system written in PHP. Prior to version 4.6.4, an unauthenticated SQL injection in the Bazar form-import path (FormManager::create()) allows any unauthenticated visitor of a default YesWiki install to inject arbitrary SQL into an `INSERT` statement and read the full database, including `yeswiki_users.password` hashes. Version 4.6.4 fixes the issue.
CVE-2026-47698	9.8	CRIT		0.007		vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.6, lib/bridge.js and lib/setup-sandbox.js fail to block stacked indirection through Function.prototype.call around dangerous host prototype getter and setter mutators, allowing sandbox code to sever a host intrinsic's prototype chain and reach e.constructor.constructor for arbitrary host command execution. This issue is fixed in version 3.11.6.
CVE-2026-47884	9.8	CRIT		0.004	vmware:spring_framework	Use of XsltView in a Spring MVC application can result in SSRF and RCE attack if the application has an "/"**" mapping that results in view rendering, and where the view name is not explicitly specified. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.25.RELEASE and earlier
CVE-2026-4800	9.8	CRIT		0.028	lodash:lodash, lodash:lodash-amd, lodash:lodash-es, lodash:lodash.template	Impact: The fix for CVE-2021-23337 (https://github.com/advisories/GHSA-35jh-r3h4-6jhm) added validation for the variable option in __template but did not apply the same validation to options.imports key names. Both paths flow into the same Function() constructor sink. When an application passes untrusted input as options.imports key names, an attacker can inject default-parameter expressions that execute arbitra...
CVE-2026-48085	9.8	CRIT		0.006		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.1, a fully provisioned OpenReception instance accepts unauthenticated POST requests to `/setup/create-admin-account` and creates additional GLOBAL_ADMIN accounts without verifying that an admin already exists. Any unauthenticated network attacker who can submit a same-origin form POST ga...
CVE-2026-48087	9.8	CRIT		0.005		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, the registration handler at `POST /api/auth/register/{userId}` validates the relationship between the WebAuthn challenge and the registration cookie's email but never validates that the `userId` in the URL belongs to that email. An unauthenticated attacker requests a challenge for the...
CVE-2026-49819	9.8	CRIT		0.008		UpSnap is a wake on lan web app. Versions 4.4.1 through 5.3.5 are vulnerable to a missing-authentication / privilege-escalation chain in `pb.HandlerInitSuperuser` (backend/pb/handlers.go:249), reachable as `POST /api/upsnap/init-superuser`. The vulnerable code lacks any authentication, setup token, IP allow-list, or rate limit and is gated only by a `totalSuperusers > 0` count check — a condition that is false o...
CVE-2026-49921	9.8	CRIT		0.003		In multiple locations, there is a possible memory safety issue due to a heap buffer overflow. This could lead to remote code execution with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-50769	9.8	CRIT		0.004		The CRM+ application before and including version 2025.6 from Brainformatik is vulnerable to SQL Injection (time-based) vulnerability. The check conflict endpoint index.php?module=Appointments&action=CheckConflictOfDates&ajaxSkipHeader=true which is used to check any conflicts for user calendar is vulnerable to SQL injection allowing an attacker to execute arbitrary code.
CVE-2026-50774	9.8	CRIT		0.004		An issue in GAPTEQ Designer v.3.5 allows a remote attacker to escalate privileges via the Company Manger role.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-50775	9.8	CRIT		0.006		A blind SSRF attack in DataHub v.1.5.0.1 allows a remote attacker to execute arbitrary code via the server retrieving an image from a crafted URL, and it fails to return the content or any errors directly.
CVE-2026-50894	9.8	CRIT		0.005		easyadmin v2.0.2.2 is vulnerable to Unrestricted Upload of File with Dangerous Type in the background management interface which allows authenticated remote attackers to execute arbitrary code and gain server privileges via a crafted file upload.
CVE-2026-51190	9.8	CRIT		0.013		The "s init" command in Serverless-Devs @serverless-devs/s <= 3.1.11 passes unsanitized user input to child_process.spawn() with shell: true. A URL ending in ".git" bypasses the only input check, allowing OS command injection when a user runs "s init" with an attacker-controlled argument.
CVE-2026-51775	9.8	CRIT		0.003		SQL injection vulnerability in Fastadmin v.1.6.1.20250430 allows an attacker to execute arbitrary code via the application/common/controller/Backend.php component
CVE-2026-52098	9.8	CRIT				An issue in Flowise 3.1.2 allows a remote attacker to execute arbitrary code via the /api/v1/prediction/<flowId> endpoint
CVE-2026-52102	9.8	CRIT		0.018		An OS command injection vulnerability in the openmediavault-md plugin of OpenMediaVault v8.0.4-1 allows attackers to execute arbitrary commands as root via injecting shell metacharacters.
CVE-2026-52103	9.8	CRIT		0.006		A zero-click remote code execution (RCE) vulnerability in the /Terminal/Notification.hs component of SimpleX Chat before v6.5 allows attackers to execute arbitrary commands in the context of the application without user interaction via sending a crafted payload in a text message.
CVE-2026-52111	9.8	CRIT		0.003		An issue in fast-note-sync-service <=2.13.7 allows a remote attacker to escalate privileges via the admin configuration endpoint exposes authTokenKey
CVE-2026-52466	9.8	CRIT		0.003		Open Library Foundation VuFind v11.0.3 and v4.1 is vulnerable to incorrect Access Control. The application fails to stop processing an incoming request in VuFind\Controller\AbstractBase::validateAccessPermission after it has found that controller level access permissions do not allow access to the requested function. The requester receives a response indicating that access was denied, but the actual function is e...
CVE-2026-52490	9.8	CRIT		0.004		An issue in libtiff 85f2ac8e0b01cb7db2bbecf4a3b891bdbef67938 allows an attacker to execute arbitrary code via the process_command_opts() function in tools/tiffcrop.c
CVE-2026-52889	9.8	CRIT		0.007		Formie is a Craft CMS plugin for creating forms. Prior to 3.1.27, Formie can pass request-derived Hidden field defaults such as HTTP User Agent, Referer URL, Current URL, Current URL without Query String, Query Parameter, and Cookie Value to Craft's Twig rendering layer during front-end form rendering. An unauthenticated attacker can place Twig syntax in one of these request-controlled inputs when a public form co...
CVE-2026-52924	9.8	CRIT		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: sctp: purge outqueue on stale COOKIE-ECHO handling sctp_stream_update() is only invoked when the association is moved into COOKIE_WAIT during association setup/reconfiguration. In this path, the outbound stream scheduler state (stream->out_curr) is expected to be clean, since no user data should have been transmitted yet unless the state machine...
CVE-2026-53002	9.8	CRIT		0.004	linux:linux_kernel, redhat:enterprise_linux	In the Linux kernel, the following vulnerability has been resolved: netfilter: conntrack: remove sprintf usage Replace it with scnprintf, the buffer sizes are expected to be large enough to hold the result, no need for snprintf+overflow check. Increase buffer size in mangle_content_len() while at it. BUG: KASAN: stack-out-of-bounds in vsnprintf+0xea5/0x1270 Write of size 1 at addr [...] vsnprintf+0xea5/0x1270 ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53006	9.8	CRIT		0.004	linux:linux_kernel, redhat:enterprise_linux	In the Linux kernel, the following vulnerability has been resolved: ipv6: fix possible UAF in icmpv6_rcv() Caching saddr and daddr before pskb_pull() is problematic since skb->head can change. Remove these temporary variables: - We only access &ipv6_hdr(skb)->saddr and &ipv6_hdr(skb)->daddr when net_dbg_ratelimited() is called in the slow path. - Avoid potential future misuse after pskb_pull() call.
CVE-2026-53545	9.8	CRIT		0.005		Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. Prior to 2.3.2, the DELETE /ssh/tunnel/disconnect/:tunnelName teardown path in src/backend/ssh/tunnel.ts interpolates endpointPort, sourcePort, endpointUsername, and endpointIP into single-quoted skill -f patterns. An authenticated user who can edit a tunnel host field can include a single quote to termina...
CVE-2026-53611	9.8	CRIT		0.01		Looking Glass is a modern, stateless network-diagnostic platform — a single self-contained Go binary that fronts a fleet of routers over SSH and exposes ping / traceroute / BGP lookups through a gRPC (ConnectRPC) API, an embedded SvelteKit web UI, and a lg-cli client. Prior to version 1.3.5, there is an OS Command Injection vulnerability resulting from an unanchored regular expression in the input validation layer...
CVE-2026-54569	9.8	CRIT		0.008		SENAITE.CORE is the core framework for the SENAITE laboratory information management system. From 2.0.0 to 2.6.0, the SENAITE.CORE JSON API permits unauthenticated remote code execution through a two-request chain involving missing authorization and unsafe evaluation. The state-changing routes in src/bika/lims/jsonapi/update.py, including update, update_many, remove, doActionFor, doActionFor_many, and getusers, do...
CVE-2026-55546	9.8	CRIT		0.004		QWED-MCP is a deterministic verification gateway for MCP. Prior to 0.2.1, verify_math_expression() in src/qwed_mcp/engines/math_engine.py passes attacker-controlled expression and claimed_result strings directly to SymPy's parse_expr() after only normalizing caret syntax to Python exponent syntax, without restricting global_dict, removing Python built-ins, or validating the expression AST. Because parse_expr() cal...
CVE-2026-55559	9.8	CRIT		0.006		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs inserts templateArgs from POST /api/instances and PATCH /api/instances/{instance} into YAML through VarStatement.append in yamcs-core/src/main/java/org/yamcs/templating/VarStatement.java without YAML-context escaping. The rendered configuration is parsed by YamcsServer.createInstance and loaded by YamcsServerInstance, allowing an attacker to i...
CVE-2026-56207	9.8	CRIT		0.002	apache:impala	Signature of Bearer token is not verified in last step of SAML2 authentication for Impala's hs2-http interface, allowing altering user name and acting as another user. This issue affects Apache Impala: >=4.0.0. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-57967	9.8	CRIT		0.003		An unauthenticated remote attacker can craft a CORE protocol SESSION_REATTACH packet to steal an existing session and assume ongoing execution of the previously authenticated session. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-58240	9.8	CRIT		0.003		SAP NetWeaver Message Server does not sufficiently validate the authenticity of internal application server components during registration. An unauthenticated attacker with network access to the affected service could exploit this weakness to register an unauthorized component and potentially perform unauthorized actions within the application environment, resulting in a high impact on the confidentiality, integri...
CVE-2026-58822	9.8	CRIT		0.003		In multiple functions of ftsmooth.c, there is a possible memory safety issue due to improper casting. This could lead to remote code execution with no additional execution privileges needed. User interaction is not needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-61808	9.8	CRIT		0.02		LightRAG provides simple and fast retrieval-augmented generation. Through version 1.5.4, the LightRAG API server binds to all network interfaces with authentication disabled by default, allowing an unauthenticated network attacker to read indexed document content, upload or delete documents, modify the knowledge graph, cancel pipelines, clear caches, and consume LLM resources. This issue is mitigated in version 1....
CVE-2026-62916	9.8	CRIT		0.006	microsoft:entra_id	Authentication bypass using an alternate path or channel in Microsoft Entra ID allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-63223	9.8	CRIT		0.008		CodeIgniter is a PHP full-stack web framework. Prior to 4.7.4, the is_image and mime_in upload validation rules do not independently enforce a safe client filename extension, allowing a remote attacker to upload executable content when an application preserves the client filename and stores uploads in a web-accessible script-enabled directory. Applications are impacted when they validate uploads using is_image or ...
CVE-2026-66302	9.8	CRIT		0.005		External control of file name or path in Skype for Business allows an unauthorized attacker to execute code over a network.
CVE-2026-67868	9.8	CRIT		0.008		A heap-based out-of-bounds write vulnerability exists in S2OPC 1.7.3 in server-side EventFilter handling during CreateMonitoredItems processing. This allows a remote attacker to execute arbitrary code.
CVE-2026-67917	9.8	CRIT		0.005		zuraCast versions up to and including 0.23.7 contain a SQL injection vulnerability in the backup restore functionality. The `azuracast:restore` command executes the `db.sql` file extracted from a backup archive without any content validation or sanitization. This allows a remote attacker to escalate privileges
CVE-2026-67919	9.8	CRIT		0.008		An issue in Halo 2.25.4 allows a remote attacker to execute arbitrary code via the PluginEndpoint.java, installFromUri method, and DefaultPluginApplicationContextFactory components
CVE-2026-67967	9.8	CRIT		0.005		Buffer Overflow vulnerability in Tenda W20E V16.01.0.6(2782) allows an attacker to execute arbitrary code. This is an incomplete fix for CVE-2025-44867 and CVE-2026-36819
CVE-2026-68004	9.8	CRIT		0.007		An issue in OSSRS SRS (Simple Realtime Server) <v5.0.213 allows a remote attacker to execute arbitrary code via RTMP publish authorization, vhost-level security configuration (security.enabled), SrsSecurity::check(), trunk/src/app/srs_app_security.cpp, and SRS RTMP listener components
CVE-2026-68502	9.8	CRIT		0.005		LazyOwn RedTeam/APT Framework is an AI-powered C2 and red-team operations framework. Prior to 0.2.154, LazyOwn's lazyc2.py registers an unauthenticated Socket.IO input event handler that dispatches data.get('value') to LazyOwnShell.one_cmd, reaching LazyOwnShell.do_cmd and subprocess.call(command, shell=True), allowing unauthenticated remote code execution in the C2 process. This issue is fixed in 0.2.154.
CVE-2026-68503	9.8	CRIT		0.004		LazyOwn RedTeam/APT Framework is an AI-powered C2 and red-team operations framework. Prior to 0.2.154, LazyOwn ships default C2 credentials LazyOwn and LazyOwn in payload.json and core/payload_schema.py and passes them unchanged to lazyc2.py HTTP Basic authentication, allowing any network-reachable attacker who knows the defaults to authenticate to the C2 dashboard with operator-level access. This issue is fixed i...
CVE-2026-68839	9.8	CRIT		0.008		Heap-based buffer overflow in Windows USB Mass Storage Class Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69240	9.8	CRIT		0.003		Sequelize is a Node.js ORM tool. Prior to 6.37.4, SQL injection is possible with strings only if dialect is set to oracle. The escape function defined in sql-string.js does not escape quotes if the value starts with TO_TIMESTAMP or TO_DATE. In the Oracle dialect, when val is a string and starts with TO_TIMESTAMP or TO_DATE, escape returns val directly instead of replacing single quotes. An attacker can inject arbi...
CVE-2026-69276	9.8	CRIT		0.009		Integer underflow (wrap or wraparound) in Microsoft UxTheme Library (uxtheme.dll) allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69408	9.8	CRIT		0.01		Integer overflow or wraparound in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69431	9.8	CRIT		0.009		Heap-based buffer overflow in Telnet Client allows an unauthorized attacker to execute code over a network.
CVE-2026-69463	9.8	CRIT		0.009		Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.
CVE-2026-69491	9.8	CRIT		0.009		Heap-based buffer overflow in Windows Microsoft DirectMusic allows an unauthorized attacker to execute code over a network.
CVE-2026-69493	9.8	CRIT		0.01		Out-of-bounds read in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69496	9.8	CRIT		0.01		Heap-based buffer overflow in Windows Compressed Folder allows an unauthorized attacker to execute code over a network.
CVE-2026-69525	9.8	CRIT		0.011		Use after free in Windows Remote Desktop Services allows an unauthorized attacker to execute code over a network.
CVE-2026-69579	9.8	CRIT		0.01		Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-69586	9.8	CRIT		0.01		Integer overflow or wraparound in Microsoft Windows PDF allows an unauthorized attacker to execute code over a network.
CVE-2026-69590	9.8	CRIT		0.01		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-69595	9.8	CRIT		0.011		Use after free in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69715	9.8	CRIT		0.01		Out-of-bounds read in Windows Direct Show allows an unauthorized attacker to execute code over a network.
CVE-2026-69730	9.8	CRIT		0.011		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69768	9.8	CRIT		0.009		Heap-based buffer overflow in Windows RNDIS allows an unauthorized attacker to execute code over a network.
CVE-2026-69769	9.8	CRIT		0.009		Heap-based buffer overflow in Windows HTTP Print Provider allows an unauthorized attacker to execute code over a network.
CVE-2026-69819	9.8	CRIT		0.009		Out-of-bounds write in RPC Runtime allows an unauthorized attacker to execute code over a network.
CVE-2026-69824	9.8	CRIT		0.01		Integer underflow (wrap or wraparound) in Microsoft Standard XPS allows an unauthorized attacker to execute code over a network.
CVE-2026-69829	9.8	CRIT		0.011		Heap-based buffer overflow in Windows Shell allows an unauthorized attacker to execute code over a network.
CVE-2026-69845	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-69910	9.8	CRIT		0.01		Stack-based buffer overflow in Windows Hyper-V allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70296	9.8	CRIT		0.01		Out-of-bounds write in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-71374	9.8	CRIT		0.003		Deserialization of untrusted data vulnerability in Cosminexus Component Container. This issue affects Cosminexus Component Container: from 11-70-01 before 11-70-03, from 11-60 before 11-60-03, from 11-50 through 11-50-03, from 11-40 through 11-40-03, from 11-30 through 11-30-08, from 11-20 before 11-20-10, from 11-10 through 11-10-11, from 11-00 before 11-00-13, from 09-87 before 09-87-10, from 09-80 before 09-80-...
CVE-2026-71376	9.8	CRIT		0.01		OS command injection vulnerability in Cosminexus Component Container. This issue affects Cosminexus Component Container: from 11-70-01 before 11-70-03, from 11-60 before 11-60-03, from 11-50 through 11-50-03, from 11-40 through 11-40-03, from 11-30 through 11-30-08, from 11-20 before 11-20-10, from 11-10 through 11-10-11, from 11-00 before 11-00-13, from 09-87 before 09-87-10, from 09-80 before 09-80-05, from 09-...
CVE-2026-71377	9.8	CRIT		0.003		Command Argument Injection Vulnerability in Cosminexus Component Container. This issue affects Cosminexus Component Container: from 11-70-01 before 11-70-03, from 11-60 before 11-60-03, from 11-50 through 11-50-03, from 11-40 through 11-40-03, from 11-30 through 11-30-08, from 11-20 before 11-20-10, from 11-10 through 11-10-11, from 11-00 through 11-00-12, from 09-87 before 09-87-10, from 09-80 through 09-80-04, ...
CVE-2026-71624	9.8	CRIT		0.005		An issue in esoTalk v.1.0.0g4 allows a remote attacker to execute arbitrary code via the core/models/ETMemberModel.class.php, core/controllers/ETMemberController.class.php, and core/lib/ET.class.php components
CVE-2026-71625	9.8	CRIT		0.004		An issue in slimkit plus ThinkSNS+ v.2.4 allows a remote attacker to escalate privileges via the ResetPasswordController.php component
CVE-2026-71805	9.8	CRIT		0.002		An arbitrary file upload and path traversal vulnerability exists in LZ-litchi 1.0.0. Unauthenticated remote attackers can upload arbitrary files and write them outside the intended storage directory via the directory parameter in POST /app-api/infra/file/upload.
CVE-2026-7188	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows SQL Injection. This issue affects Access Control System: before Versiyon 2.
CVE-2026-72920	9.8	CRIT		0.004		SeaweedFS is a distributed storage system. Prior to 4.24, the filer registers the SeaweedIdentityAccessManagement gRPC service without mandatory authentication when jwt.filer_signing.key is unset, allowing any client that can reach the filer gRPC port to invoke CreateUser, CreateAccessKey, PutPolicy, and related IAM RPCs to mint credentials and gain S3 administrative control. This issue is fixed in versions 4.24.
CVE-2026-72979	9.8	CRIT		0.01		Use after free in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-72982	9.8	CRIT		0.009		Stack-based buffer overflow in Windows Netlogon allows an unauthorized attacker to execute code over a network.
CVE-2026-72983	9.8	CRIT		0.009		Use after free in Windows Internet Connection Sharing (ICS) allows an unauthorized attacker to execute code over a network.
CVE-2026-73009	9.8	CRIT		0.009		Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73010	9.8	CRIT		0.009		Use after free in Windows Failover Cluster allows an unauthorized attacker to execute code over a network.
CVE-2026-73025	9.8	CRIT		0.009		Weak authentication in Windows iSCSI allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-73211	9.8	CRIT		0.004		PeerTube is an ActivityPub-federated video streaming platform. Prior to 8.1.6, ActorFollowModel.updateScore() interpolates the attacker-controlled ActivityPub actor inboxUrl into an SQL query, allowing an unauthenticated remote server to read and write PeerTube database tables, including OAuthToken.accessToken, and take over administrator accounts. This issue is fixed in version 8.1.6.
CVE-2026-73778	9.8	CRIT		0.003	hpe:aruba_cx_10000-48y6c_(r8p13a), hpe:aruba_cx_10000-48y6c_(r8p14a), hpe:aruba_cx_10000-48y6c_(s0f98a), hpe:aruba	A vulnerability exists in the Credential Manager component that may allow for unauthorized administrative access. An unauthenticated remote attacker could exploit this vulnerability on a device in its factory-default or post-ZTP state before any administrator has configured credentials by providing a predictable factory-default password. Successful exploitation could result in full administrative control of the af...
CVE-2026-75003	9.8	CRIT		0.003	roundcube:webmail	In Roundcube Webmail before 1.6.18 and 1.7.x before 1.7.3, an unclosed url() in a FuncIRI attribute of an SVG image could evade the remote image blocking, which may lead to information disclosure or privilege escalation.
CVE-2026-75325	9.8	CRIT		0.003		DWSurvey v6.14.0 is vulnerable to authentication bypass via the '/api/dwsurvey/none/' and '/api/dwsurvey/up/**' parameters.
CVE-2026-75337	9.8	CRIT		0.004		The static resource interface /api/static/{deployKey}/ of Yu AI Code Mother v4.3 is vulnerable to path traversal. The user-controlled path is concatenated to the preview root directory without any normalization, allowing anonymous attackers to read files outside the preview root.
CVE-2026-75338	9.8	CRIT		0.003		disconf (Distributed Configuration Management Platform) 2.6.36 is vulnerable to Incorrect Access Control. The config-fetching APIs /api/config/item, /api/config/file, /api/config/list and /api/config/simple/list are exposed without authentication. The LoginInterceptor explicitly whitelists these four paths, so any anonymous attacker can read every configuration item and configuration file managed by the config cen...
CVE-2026-75430	9.8	CRIT		0.009		PowerJob Worker version 5.1.2 (and likely earlier versions) exposes the /worker/deployContainer HTTP endpoint without authentication on the default transport port. This allows a remote attacker to execute arbitrary code.
CVE-2026-75816	9.8	CRIT		0.005		The Frontend Admin by DynamiApps plugin for WordPress is vulnerable to Authentication Bypass to Account Takeover in all versions up to, and including, 3.29.12. This is due to the pre_update_value function lacking any capability or ownership check, and ActionPost::conditions_logic() short-circuiting its current_user_can('edit_post') authorization gate whenever the post ID is non-numeric — such as the string user_1 ...
CVE-2026-76578	9.8	CRIT		0.005		A flaw was found in FreeIPA. The self-managed OTP token ACI does not require authentication and does not restrict which attributes may be added alongside the token entry. An unauthenticated LDAP client can exploit this, combined with a related flaw in the underlying directory server's ACI evaluation (tracked separately), to create an arbitrary attacker-controlled Kerberos principal and have it added to the adminis...
CVE-2026-76904	9.8	CRIT		0.018		GeoTools is an open source Java library that provides tools for geospatial data. Starting in version 30.5 and prior to versions 33.6, 34.5, and 33.6, an SQL Injection Vulnerability is present when executing OGC Filters with PostGIS DataStore implementation: 'jsonArrayContains' function; Requires PostGIS 12 or greater with a String or JSON field. For PostGIS 12 and greater 'jsonArrayContains(<column>, <pointer>, <v...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77493	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Double free in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-77647	9.8	CRIT		0.026		SPIP before 4.4.20 allows unauthenticated remote attackers to execute arbitrary code, as exploited in the wild in August 2026. This is related to incorrect identification of <?php blocks, and var_export's mishandling of certain cases such as presence of a '<' character.
CVE-2026-77649	9.8	CRIT		0.004		The internment crate 0.8.7 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.
CVE-2026-77650	9.8	CRIT		0.004		The append-only-vec crate 0.1.9 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.
CVE-2026-77651	9.8	CRIT		0.005		The arrayref crate 0.3.10 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.
CVE-2026-77806	9.8	CRIT		0.042		SPIP before 4.4.21 allows unauthenticated remote attackers to execute arbitrary code, as exploited in the wild in August 2026. This is related to code injection via an X-Spip-Filtre HTTP request header that is mishandled by analyse_resultat_skel.
CVE-2026-78362	9.8	CRIT		0.003		The SEO Flow by LupsOnline WordPress plugin before 3.0.3 does not correctly validate the credential supplied with its API requests, allowing unauthenticated users to be served as the administrator who configured the SEO Flow by LupsOnline WordPress plugin before 3.0.3 and take over the site. Exploitation requires the SEO Flow by LupsOnline WordPress plugin before 3.0.3 to have been configured, which is its normal ...
CVE-2026-78445	9.8	CRIT		0.009		Use after free in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-78509	9.8	CRIT		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78510	9.8	CRIT		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78573	9.8	CRIT				IBM ContextForge MCP Gateway 1.0.0 through 1.0.7 could allow a remote attacker to gain administrative access due to the use of default credentials.
CVE-2026-7861	9.8	CRIT		0.003		Deserialization of untrusted data vulnerability in Next4Biz Information Technologies Inc. CSM (Customer Service Management) allows Code Injection. This issue affects CSM (Customer Service Management): before 8.0.3.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78745	9.8	CRIT		0.007		An issue in HiDPT/ Weyon HiDPTAndroid Hi3751V350 Hi3751V352E_DMO allows a remote attacker to execute arbitrary code via the Android Debug Bridge (ADB) daemon (adbd)
CVE-2026-79391	9.8	CRIT		0.004		No authentication exists in the MQTT service of Trueview 6.0.23.4. The MQTT broker accepts client connections on TCP port 1883 without requiring authentication, allowing a remote attacker with network access to establish an MQTT session and perform unauthorized publish or subscribe operations.
CVE-2026-79569	9.8	CRIT		0.004		Movie_Recommend v1.0.0 was discovered to contain a SQL injection vulnerability in the sort parameter at /loadingmore. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.
CVE-2026-79570	9.8	CRIT		0.003		mfish-nocode-pro v1.0.0 was discovered to contain a SQL injection vulnerability in the tableName parameter at /sys/dbConnect/data. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.
CVE-2026-79574	9.8	CRIT		0.005		An issue in the gateway server of mpush v0.8.1 allows attackers to execute arbitrary code via sending a crafted broadcast message.
CVE-2026-79576	9.8	CRIT		0.003		An issue in the Single-Sign On (SSO) component of Digital-Infrastructure v9.6.7 allows attackers to authenticate as any user, including the Admin, without a password.
CVE-2026-79689	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-79724	9.8	CRIT				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary OS commands due to improper neutralization of special elements used in an OS command.
CVE-2026-79941	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-80129	9.8	CRIT		0.004	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.
CVE-2026-80131	9.8	CRIT		0.005	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.
CVE-2026-80172	9.8	CRIT		0.003	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Insufficient Verification of Data Authenticity vulnerability. An unauthenticated attacker with remote access could exploit this, leading to unauthorized access. This vulnerability is considered critical as an unauthenticated attacker can repeatedly reuse a captured request to generate ADMIN ac...
CVE-2026-80351	9.8	CRIT		0.002		Improper neutralization of directives in dynamically evaluated code ('eval injection') vulnerability in Apache Camel K. An improper neutralization of directives in dynamically evaluated Maven configuration allows tenant-controlled repository content to influence code execution within the operator pod, potentially enabling tenants to execute arbitrary code with the privileges of the operator. This issue affect...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80352	9.8	CRIT		0.002		Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Camel K. A YAML injection vulnerability in custom resource configuration allows an authorized CR author to inject arbitrary Kubernetes objects, potentially enabling unauthorized resource creation with the privileges of the operator. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users ...
CVE-2026-81204	9.8	CRIT				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary code due to code injection during graph construction.
CVE-2026-81467	9.8	CRIT				Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-82923	9.8	CRIT		0.006		The AI Website Builder WordPress plugin (GitHub build) 1.0.0 does not perform any authorisation or nonce check on its REST API routes, allowing unauthenticated attackers to install and activate plugins and themes, import content from a URL under their control, write a file of their choosing into the uploads directory, and delete site content and media. On a host that serves PHP from the uploads directory, that fil...
CVE-2026-83627	9.8	CRIT		0.008		The Hummingbird – Speed Optimization, Caching, Minify, Compress & CDN plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 3.21.0 via the log_msg() function in core/modules/class-page-cache.php. The page-cache debug log is written to wp-content/wphb-logs/page-caching-log.php, a directly web-accessible PHP file that is supposed to be protected by a leading '<?php die(); ...
CVE-2026-8376	9.8	CRIT		0.004	perl:perl	Perl versions before 5.40.5-RC1, from 5.41.0 before 5.42.3-RC1, from 5.43.0 before 5.43.11 have a heap buffer overflow when compiling regular expressions with a repeated fixed string on 32-bit builds. Perl_study_chunk in regcomp_study.c checked the size of the joined substring buffer in characters rather than bytes. For a quantified fixed substring with a large minimum count, the byte length mincount * I could ov...
CVE-2026-84372	9.8	CRIT		0.004		Predis is a flexible and feature-complete Redis and Valkey client for PHP. From version 3.0.0-RC1 until version 3.3.0, pipeline handling on aggregate cluster and replication connections reparses an already serialized RESP buffer in AbstractAggregateConnection::write() by splitting it with explode("\r\n") instead of honoring RESP length prefixes. Attacker-controlled keys or values containing CRLF sequences can ther...
CVE-2026-85025	9.8	CRIT				IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an unauthenticated attacker to execute arbitrary code and access or modify chat sessions through publicly shared MCP project endpoints due to improper enforcement of public-flow security restrictions and session isolation controls.
CVE-2026-85102	9.8	CRIT		0.003		Improper certificate trust validation during VPN negotiation in Check Point Quantum Security Gateway may allow an unauthenticated remote attacker to execute arbitrary code on the Gateway.
CVE-2026-85103	9.8	CRIT		0.004		A heap-based buffer overflow in VPN certificate ASN.1 decoding may allow an unauthenticated remote attacker to execute arbitrary code on Check Point Quantum Security Management and Quantum Security Gateway systems.
CVE-2026-85504	9.8	CRIT		0.004		FreeIPMI before 1.6.19 has a stack-based buffer overflow in _ipmi_sel_oem_fujitsu_get_sel_entry_long_text in libfreeipmi/sel/ipmi-sel-string-fujitsu-irmc-common.c via malformed Fujitsu SEL long-text responses.
CVE-2026-85506	9.8	CRIT		0.004		ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in _get_dell_system_info_idrac_info in ipmi-oem/ipmi-oem-dell.c (idrac-info subcommand to dell get-system-info).
CVE-2026-85507	9.8	CRIT		0.004		ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in _output_dell_system_info_cmc_info in ipmi-oem/ipmi-oem-dell.c (cmc-info subcommand to dell get-system-info).

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85508	9.8	CRIT		0.004		ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in <code>_output_dell_system_info_cmc_ipv6_info</code> in <code>ipmi-oem/ipmi-oem-dell.c</code> (<code>cmc-ipv6-info</code> subcommand to <code>dell get-system-info</code>).
CVE-2026-85509	9.8	CRIT		0.004		FreeIPMI before 1.6.19 has a stack-based buffer overflow in <code>_read_fru_data</code> in <code>libfreeipmi/fru/ipmi-fru.c</code> when a BMC returns more bytes than requested.
CVE-2026-86219	9.8	CRIT		0.005		Authen::SASL::Perl::DIGEST_MD5 versions before 2.2100 for Perl accept replayed authentication responses via unverified nonce in <code>server_step</code> . <code>server_start</code> generates a fresh nonce and sends it in the challenge, and nothing later compares that value against the nonce the client returns. <code>server_step</code> derives the expected digest from the client's own parameters, so a response verifies whenever its digest matches the no...
CVE-2026-86304	9.8	CRIT		0.002		MojoX::Authentication versions before 0.006 for Perl allow SAML authentication bypass because <code>parse_assertion</code> builds <code>Net::SAML2::Binding::POST</code> without a trust anchor. <code>parse_assertion</code> in <code>MojoX::Authentication::Model::SAML2</code> calls <code>Net::SAML2::Binding::POST->new</code> with no <code>cacert</code> , <code>cert_text</code> or <code>anchors</code> argument, then passes the returned XML to <code>Net::SAML2::Protocol::Assertion->new_from_xml</code> with the IdP signing certificate...
CVE-2026-86478	9.8	CRIT		0.004		In JetBrains YouTrack before 2025.3.161254, 2026.1.14042 improper authentication in YouTrack Helpdesk allowed unauthenticated account takeover via a self-asserted email address
CVE-2026-86480	9.8	CRIT		0.003		In JetBrains Hub before 2026.2.52442 an unauthenticated attacker could register a trusted service and gain superuser privileges
CVE-2026-87534	9.8	CRIT		0.002	google:android, google:chrome	Missing authorization in WebView in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87544	9.8	CRIT		0.002	google:chrome	Incorrect authorization in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to bypass system access restrictions into a privileged page via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-8778	9.8	CRIT				The MIPL Grouped Checkout Fields for WooCommerce – Customize & Organize Checkout Fields. plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the <code>`mipl_wc_upload_file`</code> function in all versions up to, and including, 1.2.1. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution po...
CVE-2026-88018	9.8	CRIT				<code>rclone</code> is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, <code>rclone serve s3</code> configured with <code>--auth-proxy</code> but without <code>--auth-key</code> allows <code>authPairMiddleware</code> to register any client-chosen <code>accessKeyID</code> with an empty <code>ws.s3Secret</code> . <code>gofakes3</code> then verifies the request's <code>SigV4</code> signature against that same empty secret, while <code>Server.auth</code> passes the access key id...
CVE-2026-88278	9.8	CRIT		0.003		GeoVision GV-LPC2211 V1.13 fails to enforce WS-Security UsernameToken freshness or nonce reuse protection, allowing a captured <code>PasswordDigest</code> token to be replayed for subsequent ONVIF operations.
CVE-2026-9163	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GIS Informatics GisLab Laboratory Management System allows SQL Injection. This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19274	9.6	CRIT		0.002		IBM Observability with Instana (Agent) Build 1.0.303 through 1.0.323 IBM Instana Agent Operator could allow an authenticated Kubernetes tenant to hijack or permanently destroy another tenant's cluster-level RBAC permissions, caused by cluster-scoped RBAC objects being keyed solely by the bare CR name with no namespace disambiguation, allowing a same-named `InstanaAgent` CR in an attacker-controlled namespace to si...
CVE-2026-39821	9.6	CRIT		0.007	golang.net	The ToASCII and ToUnicode functions incorrectly accept Punycode-encoded labels that decode to an ASCII-only label. For example, ToUnicode("xn--example-.com") incorrectly returns the name "example.com" rather than an error. This behavior can lead to privilege escalation in programs using the idna package. For example, a program which performs privilege checks on the ASCII hostname may reject "example.com" but permi...
CVE-2026-47705	9.6	CRIT		0.005		TypeBot is a chatbot builder tool. Version 3.16.1 has a CSV injection vulnerability in the result export functionality. The application does not sanitize or escape user-supplied input when generating CSV files. An attacker can inject spreadsheet formulas into input fields, which are later executed when an administrator opens the exported CSV in spreadsheet software such as Microsoft Excel or LibreOffice Calc. Vers...
CVE-2026-50540	9.6	CRIT		0.004		Kata Containers is an open source project focusing on a standard implementation of lightweight Virtual Machines (VMs) that perform like containers. Prior to version 4.0.0, kata-runtime is vulnerable to host code execution via an unvalidated configuration path annotation. The runtime accepts an arbitrary io.katacontainers.config_path pod annotation and loads the referenced host TOML file without restriction. As a r...
CVE-2026-53546	9.6	CRIT		0.004		Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. Prior to 2.3.2, the terminal WebSocket accepts a user-controlled hostConfig.id and src/backend/ssh/host-resolver.ts resolves that host without requiring ownership or explicit access. When no credential is shared with the requester, resolveHostById performs an owner credential fallback, and src/backend/ssh/...
CVE-2026-53548	9.6	CRIT		0.004		Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. Prior to 2.6.1, the GET /host/db/host/:id/password endpoint in src/backend/database/routes/host.ts accepts an authenticated user's numeric host ID and the field=password or field=sudoPassword query without enforcing host ownership during credential resolution. A failed requester-scoped lookup can resolve t...
CVE-2026-53552	9.6	CRIT		0.002		Goploy is an open-source automation deployment system. In versions 1.17.5 and prior, Project.AddFile, Project.EditFile, Project.RemoveFile, and Project.Edit in cmd/server/api/project/handler.go accept a project or project-file row id from the JSON body and act on it without checking that the project belongs to the caller's namespace. The corresponding model.ProjectFile.GetData and model.Project.GetData queries fil...
CVE-2026-53649	9.6	CRIT		0.002		Joro is a web exploitation framework. Prior to version 1.1.1, Joro's default proxy mode exposes a local API on 127.0.0.1:9090 that performs no authentication and applies a wildcard CORS policy. Because plugin uploads use the CORS-safelisted multipart/form-data content type, cross-origin JavaScript on any page the operator visits can reach privileged endpoints - including uploading a native plugin and triggering a ...
CVE-2026-54523	9.6	CRIT		0.004		Kyverno is a policy engine designed for cloud native platform engineering teams. From 1.18.0 until 1.18.2, the NamespacedMutatingPolicy CEL compiler exposes the generator library to matchConditions, allowing a namespace-scoped policy to invoke generator.apply(namespace, resources) with an arbitrary target namespace. The validation in pkg/cel/policies/mpol/validate.go checks that the policy compiles but does not en...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54694	9.6	CRIT		0.003		SkillTree is a micro-learning gamification platform. Prior to version 4.4.2, two independent code flaws combine into a single exploitable attack chain, with three distinct exploitation paths of escalating impact. `StringHighlighter.js` builds an HTML string by interpolating raw `value` substrings directly into a template literal with no HTML entity encoding. `HighlightedValue.vue` renders that string — and all unf...
CVE-2026-54725	9.6	CRIT		0.003		vault-secrets-webhook is a Kubernetes mutating webhook that makes direct secret injection into Pods possible. Prior to 1.23.1, parseVaultConfig() in pkg/webhook/config.go accepts the vault.security.banzaicloud.io/vault-addr annotation, MutateConfigMap and MutateSecret call newVaultClient in pkg/webhook/webhook.go, and vault.security.banzaicloud.io/vault-serviceaccount can cause a ServiceAccount JWT to be sent to a...
CVE-2026-54754	9.6	CRIT		0.003		Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.19, marketplace settlement in core/kapp/market/market.go reads MarketOrderData.ReferralPercentage from the listing while reading asset.Royalties.MarketPercentage live at purchase time. An asset owner can create a valid listing and then use AssetTrigger.UpdateRoyalties to make the combined referral and royalty percentages exceed the ...
CVE-2026-54755	9.6	CRIT		0.004		Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.19, split-royalty fields decoded in core/kapp/builtInFunctions/utills.go can contain values greater than core.HundredPercent, and core/kapp/kda/create.go and core/kapp/kda/trigger.go sum those values in uint32 accumulators. Crafted values such as two 0x80000000 entries wrap the validation sum to zero and pass CheckValid100Params. Roy...
CVE-2026-55085	9.6	CRIT		0.005		Etherpad is a real-time collaborative editor. Prior to 3.3.1, result.appendSpan in src/static/js/domline.ts interpolates the start attribute of a numbered list directly into an unquoted ol start attribute before assigning the generated markup to node.innerHTML. ImportEtherpad.setPadRaw in src/node/utills/ImportEtherpad.ts accepts attacker-controlled attribute-pool values from a crafted .etherpad import, including l...
CVE-2026-65669	9.6	CRIT		0.007		Improper neutralization of special elements in output used by a downstream component ('injection') in SQL Server allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-71193	9.6	CRIT		0.004		In OpenStack Designate before 22.0.1, zone creation checks (_is_subzone, _is_superzone, and the duplicate-zone DB constraint) are scoped to the target pool only. An authenticated user can bypass these checks by scheduling a zone to a different pool via the AttributeFilter scheduler, creating an overlapping zone that conflicts with another tenant's zone. This enables cross-tenant DNS hijack (redirecting traffic to ...
CVE-2026-71319	9.6	CRIT		0.004		Nuxt is an open-source web development framework for Vue.js. Prior to 3.3.1, Nuxt DevTools (development mode only) exposes a bidirectional RPC channel over the Vite HMR WebSocket via the nuxt:devtools:rpc plugin. On affected versions the channel has no authentication: any client that can reach the Vite HMR endpoint (ws://<host>:<port>/, subprotocol vite-hmr) can call RPC methods, with no token, handshake, or origi...
CVE-2026-72737	9.6	CRIT		0.002		Dokploy is a free, self-hostable Platform as a Service (PaaS). In 0.29.8 and earlier, backup.create, backup.update, and backup.restoreBackupWithLogs in apps/dokploy/server/api/routers/backup.ts accept a client-controlled destinationId and use the referenced destination without verifying that destination.organizationId equals ctx.session.activeOrganizationId. An authenticated member with backup permissions for a se...
CVE-2026-72877	9.6	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the dockerImage field is interpolated without quoting into shell commands in buildRemoteDocker() in packages/server/src/utills/providers/docker.ts and is validated only as an optional string. An authenticated user with application create or update permission can use shell command substitution in dockerImage to execute arbitrary command...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72878	9.6	CRIT		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, Dokploy's backup and restore pipeline constructs shell commands by directly interpolating user-controlled database fields into bash -c "... " and sh -c "... " strings, then executes them via child_process.exec(). An authenticated admin/owner can inject arbitrary OS commands that execute on the host machine running Dokploy (not just insi...
CVE-2026-73300	9.6	CRIT		0.005		Budibase is an open-source low-code platform. Prior to 3.40.0, the MySQL integration component in Budibase is configured with multipleStatements: true, enabling execution of multiple SQL statements in a single query. Attackers can inject malicious SQL commands through user input fields, leading to complete database compromise. This vulnerability is fixed in 3.40.0.
CVE-2026-73843	9.6	CRIT		0.003		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.2 and 1.1.2, internal/cluster-gateway/server.go served caller-facing management APIs on the externally reachable agent listener without authentication, allowing network-reachable attackers to invoke /api/proxy/ and /api/exec/ operations, proxy the data-plane Kubernetes API, and execute commands in workload pods in multi-cluster d...
CVE-2026-81048	9.6	CRIT				Dell ThinOS 10, versions prior to 2605_10.2616, contain an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with adjacent network access could potentially exploit this vulnerability, leading to Remote Code execution
CVE-2026-81376	9.6	CRIT		0.007		Incomplete comparison with missing factors in Visual Studio Code allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-82100	9.6	CRIT				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to a path traversal vulnerability.
CVE-2026-82107	9.6	CRIT				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to improper authentication.
CVE-2026-84333	9.6	CRIT		0.003	google:android, google:chrome	Use after free in Dawn in Google Chrome on on Android prior to 152.0.7977.75 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-84352	9.6	CRIT		0.003	google:android, google:chrome	Use after free in WebGL in Google Chrome on on Android prior to 152.0.7977.75 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-84353	9.6	CRIT		0.003	google:android, google:chrome	Use after free in Shared Tab Groups in Google Chrome on on Android prior to 152.0.7977.75 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-85042	9.6	CRIT		0.003	google:chrome	Use after free in DevTools in Google Chrome prior to 152.0.7977.82 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-85047	9.6	CRIT		0.003	apple:iphone_os, google:chrome	Improper input validation in Transactions Platform in Google Chrome on on iOS prior to 152.0.7977.82 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-85050	9.6	CRIT		0.003	google:android, google:chrome	Out of bounds write in WebGL in Google Chrome on on Android prior to 152.0.7977.82 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-85085	9.6	CRIT		0.002		The Canva Android App before 2.376.0 allowed an external origin to be loaded in a privileged WebView. A threat actor who controls the page loaded by the user is able to communicate with Canva using the user's session.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87438	9.6	CRIT		0.006	google:android, google:chrome	Out of bounds write in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87448	9.6	CRIT		0.005	google:chrome	Use after free in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87455	9.6	CRIT		0.004	google:chrome	Use after free in Aura in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87464	9.6	CRIT		0.005	google:chrome	Use after free in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87470	9.6	CRIT		0.004	apple:macos, google:chrome	Improper quantity validation in Tint in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87474	9.6	CRIT		0.005	google:chrome	Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87488	9.6	CRIT		0.005	google:android, google:chrome	Use after free in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87492	9.6	CRIT		0.003	google:chrome	Incorrect authorization in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87494	9.6	CRIT		0.003	google:chrome, microsoft:windows	Use after free in Browser in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87500	9.6	CRIT		0.003	google:chrome	Improper validation of array index in ANGLE in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87504	9.6	CRIT		0.004	google:chrome	Use after free in Core in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted Chrome extension. (Chromium security severity: Medium)
CVE-2026-87512	9.6	CRIT		0.005	google:chrome, microsoft:windows	Use after free in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87520	9.6	CRIT		0.004	google:android, google:chrome	Use after free in Dawn in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87526	9.6	CRIT		0.004	google:chrome	Use after free in Passwords in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via UI Interaction. (Chromium security severity: Medium)
CVE-2026-87527	9.6	CRIT		0.005	google:chrome	Buffer overflow in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87528	9.6	CRIT		0.003	google:chrome, microsoft:windows	Type confusion in Rust in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87529	9.6	CRIT		0.005	google:chrome	Numeric truncation error in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87547	9.6	CRIT		0.004	google:chrome	Incorrect reference resolution in FileSystem in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87558	9.6	CRIT		0.004	apple:macos, google:chrome	Use after free in Payments in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87581	9.6	CRIT		0.004	google:chrome	Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87607	9.6	CRIT		0.004	apple:macos, google:chrome	Use after free in Device in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87609	9.6	CRIT		0.004	apple:iphone_os, google:chrome	Use after free in Sharing in Google Chrome on on iOS prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87621	9.6	CRIT		0.003	google:chrome, microsoft:windows	Out of bounds write in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87634	9.6	CRIT		0.004	google:chrome	Use after free in WebPackaging in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87637	9.6	CRIT		0.003	apple:macos, google:chrome	Use after free in Extensions in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87638	9.6	CRIT		0.003	google:chrome	Out of bounds write in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87643	9.6	CRIT		0.004	google:android, google:chrome	Integer overflow in GPU in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87646	9.6	CRIT		0.004	google:chrome	Use after free in Web Authentication in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87650	9.6	CRIT		0.003	google:chrome	Out of bounds read in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87654	9.6	CRIT		0.004	google:chrome, microsoft:windows	Buffer overflow in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-44950	9.5	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) copies each glyph's bitmap into a single buffer. Existing checks validates only that the source slice (position, length) lies within the source bitmap buffer. It does not check whether the running destination cursor has exceeded the allocation. A malicious font server can send overlapping source offsets -- for example 1000 glyphs each referenc...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-65639	9.5	CRIT				OS command injection in the advanced-rule parser of ConfigServer Security & Firewall allows a remote attacker who controls a configured allow/deny feed to execute arbitrary commands as root, due to insufficient validation of feed-supplied rule data. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-maintained fork that contain the vulnera...
CVE-2026-66066	9.5	CRIT		0.279		Action Pack is a framework for handling and responding to web requests. In versions prior to 7.2.3.2, 8.0.5.1 and 8.1.3.1, Active Storage does not disable libvips operations marked unsafe for untrusted content, allowing a crafted upload to invoke such an operation. Consuming applications are affected when configured to use libvips and accept image uploads from untrusted users. An unauthenticated attacker may explo...
CVE-2026-70470	9.5	CRIT		0.008		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, Flowise validatePythonCodeForDataFrame in packages/components/src/pythonCodeValidator.ts can be bypassed with Unicode homoglyph identifiers, allowing arbitrary Python execution inside Pyodide and full OS command execution on the Flowise host via Pyodide js module interop. The validator gates pyodide.runPythonAs...
CVE-2026-70477	9.5	CRIT		0.004		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, a prompt injection sent to a chatflow using a CSV Agent node can cause the LLM to respond with a malicious Python script that bypasses the blocklist validator and executes in an unsandboxed Pyodide environment. The specific flaw exists within the run method of the CSV_Agents class, where untrusted data is used ...
CVE-2026-85216	9.5	CRIT		0.005	misp-project:misp	MISP contains an authentication bypass vulnerability in its LDAP and LinOTP authentication components due to insufficient validation of user-supplied credentials. The custom LdapAuthenticate and LinOTPAuthenticate components replace CakePHP's FormAuthenticate implementation but did not replicate its credential validation checks. As a result, empty or non-string values could reach the underlying authentication mec...
CVE-2026-88062	9.5	CRIT				OmniRoute is an open-source AI gateway providing a single endpoint for multiple model providers. In 3.8.49 and earlier, the OmniRoute POST /api/acp/agents custom ACP agent endpoint accepted attacker-controlled binary and versionCommand values and used only a self-consistency check before execFileSync executed the selected interpreter and arguments. The same request called refreshAgentCache, and resolveVersionProbe...
CVE-2025-70141	9.4	CRIT		0.007	oretnom23:customer_support_system	SourceCodester Customer Support System 1.0 contains an incorrect access control vulnerability in ajax.php. The AJAX dispatcher does not enforce authentication or authorization before invoking administrative methods in admin_class.php based on the action parameter. An unauthenticated remote attacker can perform sensitive operations such as creating customers and deleting users (including the admin account), as well...
CVE-2026-11841	9.4	CRIT		0.005		An attacker may perform unauthenticated read and write operations on sensitive filesystem areas via the AppEngine FileAccess over HTTP due to improper access restrictions. A critical filesystem directory was unintentionally exposed through the HTTP-based file access feature, allowing access without authentication. This includes device parameter files, enabling an attacker to read and modify application settings, i...
CVE-2026-16242	9.4	CRIT		0.008		A flaw was found in the Konnectivity proxy-server configuration for hosted control planes. The agent-facing listener was started without --cluster-ca-cert (and without token-based agent authentication), so client certificates were not validated. A remote attacker who can reach the Konnectivity cluster endpoint could connect as an unauthenticated agent, join the routing pool, and potentially proxy, inspect, modify,...
CVE-2026-39975	9.4	CRIT		0.003		Combodo iTop is a web-based IT service management tool. Prior to 3.2.3, unauthenticated users could delete the .readonly file on iTop instances, leading to code execution. This file, created during the setup process, prevents users from performing write actions. This issue has been fixed in version 3.2.3.
CVE-2026-41242	9.4	CRIT		0.008	protobufjs_project:protobufjs	protobufjs compiles protobuf definitions into JavaScript (JS) functions. In versions prior to 8.0.1 and 7.5.5, attackers can inject arbitrary code in the "type" fields of protobuf definitions, which will then execute during object decoding using that definition. Versions 8.0.1 and 7.5.5 patch the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-43114	9.4	CRIT		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: netfilter: nft_set_pipapo_avx2: don't return non-matching entry on expiry New test case fails unexpectedly when avx2 matching functions are used. The test first loads a ranomly generated pipapo set with 'ipv4 . port' key, i.e. nft -f foo. This works. Then, it reloads the set after a flush: (echo flush set t s; cat foo) nft -f - This is ex...
CVE-2026-45272	9.4	CRIT		0.004		MyBooks is an enhanced and easy-to-use personal ebook management web server also known as Talebook. In 3.41.2 and earlier, the AdminSettings.post handler in webserver/handlers/admin.py accepts SOCIAL_AUTH key names without validating quotes or newline characters, and SettingsLoader.dumpfile in webserver/loader.py concatenates those names into the generated Python source file auto.py without escaping them. An admin...
CVE-2026-48088	9.4	CRIT		0.003		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.4, the route `POST /api/tenants/{tenantId}/staff/{staffId}/crypto` accepts and stores attacker-controlled ML-KEM-768 public keys against any tenant on the platform without authentication. The handler logs an "Unauthorized crypto key storage attempt" warning when neither a session nor a r...
CVE-2026-50561	9.4	CRIT		0.004		Yuxi is a large-model-based intelligent knowledge base and knowledge graph agent development platform. Prior to version 0.6.2, the project's authentication mechanism contains a flaw. In affected versions, the system does not sufficiently validate the identity token in the Authorization header — only performing a validity check. This allows an administrator token generated in another deployment instance or local te...
CVE-2026-52777	9.4	CRIT		0.002		YesWiki is a wiki system written in PHP. Prior to version 4.6.6, there is an authenticated PHP object injection vulnerability in BazarImportAction via unserialize. This issue has been patched in version 4.6.6.
CVE-2026-57580	9.4	CRIT		0.004		authentik is an open-source identity provider. Prior to 2026.2.6 and 2026.5.5, an inbound SAML Source configured with the non-default USERNAME_LINK or EMAIL_LINK user-matching mode interprets an XML comment in a NameID differently from the identity provider's signed assertion. An attacker with an account on the source identity provider who can set the account's NameID can inject an XML comment that truncates the v...
CVE-2026-61410	9.4	CRIT		0.013		Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains a Missing Authorization vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution. This vulnerability is considered critical because it allows an attacker to execute commands remotely on a target system by sending a spe...
CVE-2026-6223	9.4	CRIT		0.004		Improper restriction of excessive authentication attempts vulnerability in Bahçelievler Municipality BiHayat App allows Authentication Bypass. This issue affects BiHayat App: from 2.1.7 through 07092026. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-62668	9.4	CRIT		0.004		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.6, the Grav API plugin WebhookController.php accepts webhook URLs after only FILTER_VALIDATE_URL syntax validation, and WebhookDispatcher.php initializes cURL without CURLOPT_PROTOCOLS or CURLOPT_REDIR_PROTOCOLS restrictions. An account with api.webhooks.write can submit file, dict, gopher, private...
CVE-2026-63221	9.4	CRIT		0.004		CodeIgniter is a PHP full-stack web framework. From 4.3.0 through 4.7.3, Query Builder deleteBatch() substitutes bound values from where() conditions into generated SQL while ignoring their escape flags, allowing user-controlled condition values to be interpreted as SQL. This affects only the deleteBatch() code path. Regular delete() operations escape where() binds correctly. This issue is fixed in version 4.7.4.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67305	9.4	CRIT		0.005	freerdp:freerdp	FreeRDP Windows client before 3.29.0 contains a heap buffer overflow vulnerability in the clipboard virtual channel when processing CLIPRDR_FILE_CONTENTS_RESPONSE PDUs without validating the server-provided size against the destination buffer. A malicious RDP server can send a response with a data payload significantly larger than requested, causing arbitrary heap memory corruption that may enable remote code exec...
CVE-2026-67330	9.4	CRIT		0.004		@better-auth/scim (a better-auth plugin) versions >= 1.4.0-beta.27 through <= 1.6.21 and >= 1.7.0-beta.0 through <= 1.7.0-beta.9 contain an authorization bypass. SCIM token issuance did not reject provider IDs already used by existing SSO, SAML, OIDC, generic OAuth, or social account providers, and the same logical provider ID was used for both SCIM provider configuration and account ownership. An authenticated us...
CVE-2026-67336	9.4	CRIT		0.002		better-auth versions before 1.6.11 contain insecure cryptographic defaults in the oidcProvider and mcp plugins that advertise the none algorithm and accept plain PKCE by default. Attackers can exploit algorithm negotiation to accept unsigned tokens or intercept authorization codes when PKCE plain is used instead of the required S256 method.
CVE-2026-6881	9.4	CRIT		0.002		A SQL Injection in the Giving Reports functionality in Ellucian Advance Web and Legacy Advance allows an authenticated attacker to extract sensitive information from databases via a crafted SQL query in the class credit field. This issue affects Advance Web: all versions; Legacy Advance: all versions. Ellucian CRM Advance is not impacted.
CVE-2026-69254	9.4	CRIT		0.004		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, executeJavaScriptCode() accepted caller-provided nodeVMOptions and merged them over the default NodeVM security settings in packages/components/src/utlis.ts. An authenticated attacker reaching packages/server/src/routes/node-custom-functions/index.ts could run a custom function that imported flowise-components/...
CVE-2026-69256	9.4	CRIT		0.004		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the CSVAgent node allowed users to provide Python code that is executed through pyodide; although a denylist blocked dangerous Python constructs, pandas.read_pickle() could deserialize a pickled payload and achieve code execution without matching the denied words. The affected file is flowise-components/nodes/a...
CVE-2026-69259	9.4	CRIT		0.004		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the SQLite Record Manager node in packages/components/nodes/recordmanager/SQLiteRecordManager/SQLiteRecordManager.ts accepted user-controlled additionalConfig and spread it after the intended database setting, allowing additionalConfig.database to overwrite the SQLite database path. An authenticated attacker us...
CVE-2026-69264	9.4	CRIT		0.006		Prior to 3.1.3, Flowise CSVAgent interpolates an attacker-controlled segment of the csvFile data URI directly into a Python source-code template that is then executed by Pyodide. Because Pyodide is loaded with the default js bridge to globalThis, which on Node.js exposes eval and dynamic import, the attacker can break out of the Python string literal, hand a JavaScript string to js.eval, dynamically import Node bu...
CVE-2026-72841	9.4	CRIT		0.005		luci-app-ovpn fails to properly validate the instance_name2 parameter during file upload, allowing authenticated users to perform path traversal and write arbitrary files outside the intended directory. Attackers can upload malicious payloads to gain persistent root code execution by placing SSH keys in system directories accessible on reboot.
CVE-2026-72842	9.4	CRIT		0.004		luci-app-lxc contains an ACL inconsistency vulnerability that allows low-privileged authenticated LuCI users to access backend container management routes without proper authorization checks. Attackers can exploit path traversal via `/.%2E` in the `lxc_name` parameter to escape container directories and control host-side scripts executed through `lxc.hook.start-host`, achieving root code execution on the OpenWrt h...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72879	9.4	CRIT		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.8, the getRegistryCommands() function in packages/server/src/utls/cluster/upload.ts interpolates registry.password and registry.registryUrl directly into a shell command without escaping. An authenticated user with project access can configure malicious registry credentials and trigger a swarm deployment to execute arbitrary OS commands ...
CVE-2026-73653	9.4	CRIT		0.006		Vitest is a testing framework powered by Vite. Prior to versions 3.2.7, 4.1.10, and 5.0.0-beta.6, Browser Mode provider commands including upload, takeScreenshot, screenshotMatcher, stopChunkTrace, deleteTracing, and annotateTraces accept browser-supplied file paths without enforcing the allowWrite permission gate or confining paths to the project root. A client that can reach the Browser Mode API can read arbitra...
CVE-2026-75925	9.4	CRIT		0.007		Improper neutralization of CRLF sequences in IXON VPN Client before version 1.4.7 allows an attacker to execute commands as root or SYSTEM. Configuration values accepted by the local service are written to a file later consumed by a privileged subprocess, without line-ending sequences being neutralized, which allows additional directives to be introduced into that file. The configuration interface accepts changes ...
CVE-2026-76969	9.4	CRIT		0.003		@sap/cds-mtxs NPM library does not perform sufficient checks on certain functionality used in multitenant CAP applications with extensibility enabled. An unauthenticated attacker could send specially crafted requests to obtain sensitive credentials and abuse them to replace or delete tenant data. Successful exploitation can result in a high impact on availability and integrity of the application. There may also be...
CVE-2026-81046	9.4	CRIT				Dell ThinOS 10, versions prior to 2605_10.2616, contain a Protection Mechanism Failure vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Arbitrary Code Execution within the application context.
CVE-2026-82533	9.4	CRIT		0.004		DeepSeek Harness before 0.1.2-alpha.1 contains an authentication bypass vulnerability that grants unauthenticated access to its local HTTP agent-control API by accepting a client-supplied loopback Host header in place of validating the actual TCP connection origin. On the default configuration, a confined tool-executed process can reach the loopback API without any port exposure and use it to escape its own OS san...
CVE-2026-84200	9.4	CRIT		0.002		Kyverno versions v1.9.0 through v1.12.7 contain a policy exception handling flaw. When a policy in enforce mode is combined with two PolicyExceptions, the less restrictive exception takes precedence, allowing an attacker to bypass the policy by crafting a resource name that matches the second exception's name pattern (e.g., "*ingress*"). This can be used to circumvent policies such as one blocking hostPath volumes...
CVE-2026-86123	9.4	CRIT		0.003		SQL Chat contains four unauthenticated API endpoints that accept client-supplied database connection parameters and execute arbitrary SQL queries against attacker-specified hosts. Attackers can connect to internal databases, execute SQL commands, enumerate schemas, and pivot into the server's network without authentication.
CVE-2026-86148	9.4	CRIT		0.025		A security flaw has been discovered in Tenda CP3 27.5.57.101. This vulnerability affects the function SystemAsh of the file Apis/system.c of the component Kylin. The manipulation of the argument AlarmVoiceURL results in os command injection. It is possible to launch the attack remotely.
CVE-2026-86149	9.4	CRIT		0.02		A weakness has been identified in Tenda CP3 27.5.57.101. This issue affects some unknown processing of the file Net/NetCheckPing.cpp. This manipulation of the argument interface_name/host causes os command injection. The attack can be initiated remotely.
CVE-2026-86151	9.4	CRIT		0.02		A vulnerability was detected in Tenda CP3 27.5.57.101. The affected element is the function sub_2F77E8 of the file Apis/system.c of the component Network Configuration Management. Performing a manipulation results in os command injection. The attack may be initiated remotely.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86153	9.4	CRIT		0.004		A vulnerability has been found in Tenda CP3 27.5.57.101. This affects the function CRedirServer::SetRedirectEnable of the file Functions/Redirect.cpp. The manipulation leads to improper privilege management. Remote exploitation of the attack is possible.
CVE-2026-88285	9.4	CRIT		0.003		GeoVision GV-LPC2211 V1.13 exposes a network-accessible PTZ control service without authentication, allowing remote clients to retrieve PTZ information and issue PTZ or raw serial commands.
CVE-2023-54356	9.3	CRIT		0.001		Kyverno versions 1.9.4 and earlier support insecure 3DES cipher suites (TLS_ECDHE_RSA_WITH_3DES_EDE_CBC_SHA and TLS_RSA_WITH_3DES_EDE_CBC_SHA) on their TLS endpoints. These 64-bit block ciphers are vulnerable to the Sweet32 attack (CVE-2016-2183), which, over very long-lived TLS connections carrying large volumes of traffic, could allow an attacker to recover small amounts of plaintext. The issue is fixed in Kyver...
CVE-2023-54391	9.3	CRIT		0.017		Proxmox Virtual Environment (VE) 7.0 through 8.0 contains an authentication bypass vulnerability in libpve-access-control before 8.0.4 that allows unauthenticated attackers to authenticate as any existing enabled user without a configured second factor by supplying an arbitrary tfa-challenge value in the API login endpoint. Attackers can send a POST request to the access ticket API endpoint with any value in the t...
CVE-2024-58376	9.3	CRIT		0.017		Renovate versions 37.158.0 before 37.199.0 contain a command injection vulnerability in the helmv3 manager's registryAliases handling that allows attackers with commit access to execute arbitrary commands. Attackers can manipulate registryAliases keys with unquoted shell metacharacters to inject commands executed during helm repo add operations, gaining full access to Renovate's execution environment.
CVE-2025-14813	9.3	CRIT		0.003		: Use of a Broken or Risky Cryptographic Algorithm vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcpv on all (core modules). This vulnerability is associated with program files G3413CTRBlockCipher. This issue affects BC-JAVA: from 1.59 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.
CVE-2025-31114	9.3	CRIT		0.007		Foofocus is an image generating software. In versions 2.5.5 and prior, the Foofocus web UI is vulnerable to remote code execution due to the unsafe use of eval when processing metadata JSON. An attacker with access to the Foofocus web UI may be able to execute arbitrary code on the instance. As of time of publication, no known patched versions are available, but a suggested fix pull request is available.
CVE-2025-71401	9.3	CRIT		0.003		better-auth (npm) before 1.4.2 allows an external request to configure baseURL when it is not otherwise defined (e.g., BETTER_AUTH_URL is unset). An attacker able to make the very first request to the server after startup can poison the router's base path, causing all routes to return 404 for all users (denial of service). The issue is not reachable when baseURL is explicitly configured or on typical managed hosti...
CVE-2026-15378	9.3	CRIT		0.005		A flaw was found in the `guardrails-detectors` component. This vulnerability allows a remote attacker to perform a blind Server-Side Request Forgery (SSRF) by submitting a specially crafted XML Schema Definition (XSD) string. This can lead to unauthorized access to sensitive information, including credentials from cloud metadata services, Kubernetes API, internal MinIO, and other internal network endpoints. Additi...
CVE-2026-16876	9.3	CRIT		0.003		An authentication bypass vulnerability exists in the WebGUI of Series UNIVERGE IX-R/IX-V. A user could bypass authentication and execute arbitrary CLI commands by tampering with WebGUI messages and sending them to the device via internet.
CVE-2026-19264	9.3	CRIT		0.008		Postiz is an open-source social media scheduling tool. The route that serves locally stored media joins URL-supplied path segments onto the upload directory and streams the file without normalising the path or confining it to that directory, and the route requires no authentication. Raw dot-segments are collapsed before routing, but URL-encoded separators survive route matching and are decoded only once they reach...
CVE-2026-21102	9.3	CRIT		0.001	samsung:android	Use after free in DualDAR prior to SMR Sep-2026 Release 1 allows local privileged attackers to execute arbitrary code with root privilege.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-25896	9.3	CRIT		0.005	naturalintelligence:fast-xml-parser	fast-xml-parser allows users to validate XML, parse XML to JS object, or build XML from JS object without C/C++ based libraries and no callback. From 4.1.3to before 5.3.5, a dot (.) in a DOCTYPE entity name is treated as a regex wildcard during entity replacement, allowing an attacker to shadow built-in XML entities (<, >, &, ", ') with arbitrary values. This bypasses entity encoding and leads ...
CVE-2026-41452	9.3	CRIT		0.025		Krayin CRM 2.2.4 contains a missing authentication vulnerability in the installer middleware that allows unauthenticated remote attackers to overwrite the primary administrator account by sending a crafted HTTP POST request with the X-Requested-With: XMLHttpRequest header to bypass the CanInstall middleware redirect check. Attackers can supply arbitrary name, email, and password values to the admin-config-setup en...
CVE-2026-44402	9.3	CRIT		0.009		Voltronic Power SNMP Web Pro 1.1 contains an unauthenticated remote code execution vulnerability in the upload.cgi firmware update endpoint that allows remote attackers to execute arbitrary commands as root by uploading a crafted tar archive without valid credentials. Attackers can supply a malicious tar archive containing arbitrary executable files that are extracted to a privileged directory and executed as root...
CVE-2026-44990	9.3	CRIT		0.006		ApostropheCMS is an open-source Node.js content management system, and sanitize-html provides a simple HTML sanitizer with a clear API. Under the default configuration, versions of `sanitize-html` prior to 2.17.4 can turn attacker-controlled content inside a disallowed `xmp` element into live HTML or JavaScript. This is a sanitizer bypass in the default `disallowedTagsMode: 'discard'` path and can lead to stored X...
CVE-2026-45118	9.3	CRIT		0.004		MyBB is free and open source forum software. Prior to 1.8.40, the Contact module does not validate a redirect URL or protocol correctly, resulting in an open redirect and reflected JavaScript code injection. contact.php accepts the redirect target from the from HTTP parameter in \$mybb->input['from'] or the Referer HTTP header in \$_SERVER['HTTP_REFERER'] and passes it to redirect() without sufficient verification. ...
CVE-2026-4599	9.3	CRIT		0.005	kjur:jsrsasign	Versions of the package jsrsasign from 7.0.0 and before 11.1.1 are vulnerable to Incomplete Comparison with Missing Factors via the getRandomBigIntegerZeroToMax and getRandomBigIntegerMinToMax functions in src/crypto-1.1.js; an attacker can recover the private key by exploiting the incorrect compareTo checks that accept out-of-range candidates and thus bias DSA nonces during signature generation.
CVE-2026-47156	9.3	CRIT		0.005		MantisBT is an open source bug tracker. Versions 2.28.3 and earlier contain a critical authentication bypass in the SOAP API's mci_check_login() function. Any user knowing any valid cookie_string can authenticate as any other user (knowing their username), including the administrator, without knowing the target's password. The vulnerability is exploitable with zero prior access on default MantisBT installations be...
CVE-2026-47187	9.3	CRIT		0.004		SSHFS is a network filesystem client for connecting to SSH servers. Prior to version 3.7.6, a rogue SFTP server can return absolute symlink targets or relative targets containing parent-directory components that SSHFS passes through FUSE for resolution by the client kernel against the local filesystem. The documented transform_symlinks mitigation does not contain relative targets because transform_symlink() return...
CVE-2026-47754	9.3	CRIT		0.003		Metacat is data repository software that helps researchers preserve, share, and discover data. Versions 2.x through 2.19.1 and all 1.x versions contain an unauthenticated path traversal in the `archiveEntryName` parameter of the `action=read` endpoint that is part of the original 1.x Metacat API. `ArchiveHandler.readArchiveEntry()` concatenates the user-supplied parameter into a filesystem path without validation,...
CVE-2026-48046	9.3	CRIT		0.003		Streambert is a cross-platform Electron Desktop App to stream and download video content. Versions prior to 2.5.0 contain an unvalidated auto-updater URL vulnerability that allows a compromised renderer process to make the main process download and execute an arbitrary binary, resulting in remote code execution. Version 2.5.0 contains a patch.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-48063	9.3	CRIT		0.002		Baileys is a cocket-based TS/JavaScript API for WhatsApp Web. In versions prior to both 6.7.22 and 7.0.0-rc12, any Baileys session can be sent a malicious payload via the placeholderResendMessage and trigger a fake messages.upsert event with a fake message key and payload. This allows anyone to spoof messages. The same exploit also allows an attacker to corrupt the app state sync system by sending fake key shares...
CVE-2026-48158	9.3	CRIT		0.004		use-context-selector is a React useContextSelector hook in userland Between 2026-05-18 15:57:18 and 2026-05-19 15:24:34, the default branch contained malicious commits 9d8481a513b7b0d1c0941b220c69b25de748641b through 6f2dae054ca014068bdbbb4db96006424d674124 that executed remote attacker-controlled code on developer machines during `npm install`. The commits were removed by force-push, but local clones, forks, and ...
CVE-2026-48159	9.3	CRIT		0.005		use-reducer-async is a React useReducer with async actions. Between 2026-05-18 16:29:52 and 2026-05-19 15:26:07, the default branch contained malicious commits da72edbde5705efce6c62e0a3dcb73687b78dc8 through df07d5711458d8b46e11dd7afaaa21e88cafabfb that executed remote attacker-controlled code on developer machines during `npm install`. The commits were removed by force-push, but local clones, forks, and direct-S...
CVE-2026-48160	9.3	CRIT		0.004		react-tracked provides state usage tracking with Proxies. Between 2026-05-18 19:26:36 and 2026-05-19 15:22:45, the default branch contained malicious commits 6978272a7d6ca02225cb747ea69f427512e33699 through 949f1a3d6bb1ff7d1a0dec892afd773e742627e8 that executed remote attacker-controlled code on developer machines during `npm install`. The commits were removed by force-push, but local clones, forks, and direct-SHA...
CVE-2026-48996	9.3	CRIT		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter does not sanitize note titles, and the GeoMap note view interpolates a marker note's title into raw HTML that is rendered as innerHTML, allowing an attacker-supplied import archive to inject script that runs when the map is displayed. Because Safe import neutralizes scripts b...
CVE-2026-51106	9.3	CRIT		0.002		An issue in TokTok qTox v1.18.4 allows a local attacker to cause a denial of service via the src/persistence/serialize.cpp component
CVE-2026-52735	9.3	CRIT		0.003		ZEBRA is a Zcash node written entirely in Rust. Prior to 4.5.0, Zebra can accept a block that zcashd rejects because the P2SH signature-operation counter undercounts redeem scripts containing a disabled opcode followed by signature opcodes. In zebra-script/src/lib.rs, p2sh_input_sigop_count used the pure-Rust script::Code::sig_op_count path, whose try_fold parser stops at disabled opcodes such as OP_CODESEPARATOR ...
CVE-2026-53578	9.3	CRIT		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter sanitizes HTML only for text notes and excludes the mindMap note type, whose JSON content is stored without sanitization, allowing an attacker-supplied import archive to embed a payload that renders as arbitrary HTML. A mind map node can carry a dangerouslySetInnerHTML proper...
CVE-2026-53579	9.3	CRIT		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter sanitizes HTML only for text notes and excludes the book note type, whose content is stored without sanitization and later rendered as HTML, allowing an attacker-supplied import archive to embed a payload that executes as script. A book note's content is routed through the sa...
CVE-2026-53670	9.3	CRIT		0.003		PREVAIL is a Polynomial-Runtime EBPF Verifier using an Abstract Interpretation Layer. Prior to version 0.2.4, in the Prevail eBPF verifier, EbpfTransformer::add() silently skips offset-variable updates when the destination register carries a non-singleton typeset (two or more simultaneously possible pointer types). Subsequent bounds checks use the stale offset and accept out-of-bounds memory accesses, so a crafted...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53671	9.3	CRIT		0.003		PREVAIL is a Polynomial-Runtime EBPF Verifier using an Abstract Interpretation Layer. Prior to version 0.2.4, the abstract transformer in prevail treats writes through a T_CTX-typed base register as a silent no-op: do_mem_store in src/crab/ebpf_transformer.cpp only models T_STACK stores, and the checker's T_CTX bounds arm never tests AccessType::write. An attacker can craft an eBPF program that overwrites a contex...
CVE-2026-55068	9.3	CRIT		0.004		free5GC is an open-source implementation of the 5G core network. In 4.2.2 and earlier, the NRF RegisterNFInstance handler at PUT /nnrf-nfm/v1/nf-instances/{nfInstanceId} accepts NF Profiles without enforcing UUID format, nfStatus enum values, heartBeatTimer ranges, mandatory profile fields, or nfServices.ipEndpoints address constraints. The invalid profiles are persisted in the MongoDB NfProfile collection and ret...
CVE-2026-55220	9.3	CRIT		0.005		Pimcore is an Open Source Data & Experience Management Platform. Prior to 11.5.19, 12.3.10, and 2026.1.6, Pimcore\Mode\DataObject\ClassDefinition\Data\Hotspotimage::getDataFromResource() in models\DataObject\ClassDefinition\Data\Hotspotimage.php passes the field __hotspots object-store column to Pimcore\Tool\Serialize::unserialize() without an allowed-classes restriction after JSON decoding fails. An attacker wit...
CVE-2026-55378	9.3	CRIT		0.006		JS Recon is a JavaScript enumeration and SAST tool. From 1.2.1-beta.1 until 1.3.1-beta.2, the PR Branch Checker workflow in .github/workflows/pr_checker.yml places github.head_ref and github.event.pull_request.head.repo.full_name into BRANCH_NAME and SOURCE_REPO and interpolates those untrusted values into a shell gh pr comment command. A remote user who opens a pull request can use shell metacharacters in a branc...
CVE-2026-56705	9.3	CRIT		0.005		Adminer before 5.4.3 fails to sanitize the server field before constructing a PDO DSN string, allowing unauthenticated attackers to inject ODBC parameters via semicolons. Attackers can inject TraceFile and TraceOn parameters to write PHP code to the web root, achieving remote code execution when the trace file is accessed.
CVE-2026-57910	9.3	CRIT		0.002		Improper authentication in the WatchGuard Agent allows an unauthenticated attacker with network access to cause the agent to execute arbitrary code with elevated privileges.
CVE-2026-61514	9.3	CRIT		0.005		Puwell IP Camera firmware versions 2.x through 4.x contains an authentication bypass vulnerability that allows unauthenticated attackers to access device functions by sending protocol-conforming packets over TCP port 23456 without credentials. Attackers can exploit the unvalidated Session field in the proprietary control protocol header to access live video streams, control pan and tilt motors, activate audio func...
CVE-2026-61515	9.3	CRIT		0.016		Puwell IP Camera firmware versions 2.x through 4.x contains an unauthenticated command injection vulnerability that allows remote attackers to execute arbitrary operating system commands by sending a crafted JSON payload to the DebugShell interface exposed on TCP port 34567. Attackers can exploit the lack of authentication and input sanitization in the binary protocol service to pass arbitrary commands directly to...
CVE-2026-61516	9.3	CRIT		0.004		Netis NX10 firmware V4.0.1.5808 and V3.0.0.4142 contain an information disclosure vulnerability that allows unauthenticated attackers to retrieve the administrator password by sending a request to the sysinfo action in the web management interface without a valid session. Attackers can replay the exposed credential against the login handler to establish a fully authenticated administrator session on the device.
CVE-2026-62645	9.3	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). Information is exposed through the web interface that can be used to calculate the current and past session ID numbers. This could allow an attacker to bypass the authentication and gain unauthorized access to the device.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-62647	9.3	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A random number generator is used to generate security-relevant values (such as session identifiers used for authentication purposes) that is not initialized with a True Random Number Generator (TRNG), resulting in a predictable sequence of generated values. This could allow an unauthenticated remote attacker to more easily predict the ge...
CVE-2026-62681	9.3	CRIT		0.007		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, an unescaped backtick in an OpenAPI path is emitted into request URL template literals generated for axios, fetch, react-query, and SWR clients without safe encoding. This permits attacker-controlled JavaScript to be evaluated when a generated request, URL-builder, or query-key function is cal...
CVE-2026-62682	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, an unescaped backtick in servers[0].url is emitted into request URL template literals generated when output.baseUrl.getBaseUrlFromSpecification is enabled without safe encoding. This permits attacker-controlled JavaScript to be evaluated when a generated request or URL-builder function is call...
CVE-2026-62928	9.3	CRIT		0.012		XING CPTTrans-ME-X contains an OS Command Injection (CWE-78). Unauthenticated OS command may be injected.
CVE-2026-63106	9.3	CRIT		0.003		ReadyEcommerce before 4.5.2 contains an unauthenticated SQL injection vulnerability in the product listing API where the rating parameter from the products endpoint is concatenated directly into a MySQL HAVING clause without parameterization in ProductController.php. Attackers can perform time-based blind SQL injection through the unsanitized rating parameter to extract the full database contents, including user c...
CVE-2026-64827	9.3	CRIT		0.005		Telenia Software TVox 26.5.3 and prior 26.x versions, and 24.9.21 and prior 24.x versions, contain an authentication bypass vulnerability in set_env.php where the redirectToLoginAdminIfRequestHaveAccessToken() function derives the current page name from PHP_SELF and skips authentication when the value matches 'login_admin.php'. Attackers can append '/login_admin.php' to the path of any target PHP script to cause th...
CVE-2026-65641	9.3	CRIT		0.005		A vulnerability allowing an unauthenticated network attacker to coerce SMB authentication from the service account.
CVE-2026-66747	9.3	CRIT		0.007		Zbtlink router firmware ships an embedded remote-control implant, ENDLESSDOORS, present in every published build across the product line. It is the open-source ycsunjane/rctl tool built in as an OpenWrt package (librctl.so), started at boot and run as root under the process name kworker to blend in with the kernel's [kworker/*] threads. It opens no listening port; it phones home over cleartext TCP to a hardcoded c...
CVE-2026-66794	9.3	CRIT		0.004		A flaw was found in the `cluster-proxy-addon` component of Multicluster Engine for Kubernetes. This vulnerability allows an unauthenticated attacker, who can access the user-facing route, to bypass authentication and authorization checks. By manipulating URL path segments, the attacker can proxy requests to arbitrary services across any managed cluster. This enables unauthorized access to internal services that wo...
CVE-2026-67308	9.3	CRIT		0.005		Wazuh workflows before 44bf114 contain a shell injection vulnerability in GitHub Actions that allows attackers to execute arbitrary commands by submitting pull requests with crafted VERSION.json files. Attackers can inject shell metacharacters into environment variables that are directly interpolated into run steps, enabling command execution and exfiltration of secrets including GITHUB_TOKEN and AWS credentials o...
CVE-2026-67531	9.3	CRIT		0.004		FrontMCP is a TypeScript-first framework for the Model Context Protocol (MCP). Prior to 1.5.7, the sandboxed codecall:execute tool exposes live host Zod schema instances to the script via getTool(), and because Zod v4 defines _zod as a non-configurable, non-writable own property, the ECMAScript Proxy invariants force the security membrane to hand back the raw host object, letting a script reach _zod.constr.constru...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67614	9.3	CRIT		0.006		CyberPanel before 3.0.0 contains a hard-coded JWT secret vulnerability in the WebTerminal FastAPI SSH service that allows unauthenticated remote attackers to forge valid authentication tokens and obtain an interactive root shell via WebSocket on port 8888. Attackers can craft a forged JWT signed with the hardcoded secret value, specifying ssh_user=root, to authenticate to the terminal service without any valid cre...
CVE-2026-68582	9.3	CRIT		0.003		Vikunja versions >= 0.24.0 and <= 2.3.0 contain a broken object level authorization (BOLA) vulnerability in the task-collection endpoint (GET /api/v1/projects/{project}/views/{view}/tasks). The endpoint loads the requested project view from the URL path without verifying the caller is authorized for it. For a link-share token holder, the task scope is pinned to the share's own project, but the view is taken from t...
CVE-2026-68770	9.3	CRIT		0.006		sentence-transformers contains a security control bypass vulnerability that allows attackers to achieve arbitrary code execution by exploiting a logic flaw in the import_module_class helper within sentence_transformers/util/misc.py, where the guard condition includes an 'or os.path.exists(model_name_or_path)' clause that satisfies the trust gate whenever the supplied path exists on the local filesystem, regardless...
CVE-2026-68771	9.3	CRIT		0.008		ComfyUI v0.23.0 contains an unsafe deserialization vulnerability in the LoadTrainingDataset node that allows unauthenticated remote attackers to execute arbitrary Python code by uploading a crafted pickle file and triggering its deserialization. Attackers can upload a malicious shard_*.pkl file via the unauthenticated POST /upload/image endpoint and then queue a workflow graph via POST /prompt referencing the uplo...
CVE-2026-68929	9.3	CRIT		0.003		FastGPT is an open-source LLM platform for building AI applications on a knowledge base. In versions prior to 4.15.2, the WeChat (iLink) share-channel endpoints authorize requests using only the public shareId, with no authenticated identity or team-ownership check. As a result, an unauthenticated attacker who knows a victim team's shareId can take that team's WeChat bot offline or hijack the channel to their own ...
CVE-2026-69356	9.3	CRIT		0.007		Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Exchange Server allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-69657	9.3	CRIT		0.003		XING CPTrans-ME-X contains a Use of Default Password (CWE-1393). Anyone with the knowledge of the credential may log in to the affected device.
CVE-2026-70403	9.3	CRIT		0.003		XING CPTrans-ME-X contains a Use of Hard-coded Password (CWE-259). Anyone with the knowledge of the credential may log in to the affected device.
CVE-2026-71864	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a double quote in a header parameter name is emitted into the generated request-validation zod.object({...}) schema without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution in the developer,...
CVE-2026-71865	9.3	CRIT		0.005		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a double quote in a query parameter name is emitted into the generated request-validation zod.object({...}) schema without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution in the developer, ...
CVE-2026-71866	9.3	CRIT		0.005		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. From version 8.19.0 until 8.21.0, a double quote in a schema property name is emitted into the generated zod.object({...}) schema without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution in the developer, Cl...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71867	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a single quote in a schema property name is emitted into single-quoted object keys in generated MSW mock factories without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated mock factory is called by tests or an MSW handler, resulting in code executio...
CVE-2026-71868	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in an enum default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution i...
CVE-2026-71869	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in an array item default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execu...
CVE-2026-71871	9.3	CRIT		0.005		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in a header parameter default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code ...
CVE-2026-71960	9.3	CRIT		0.005		Cudy WR3000 2.0 running firmware before 2.5.24 contains a hard-coded JWT HMAC signing secret vulnerability in the Mosquitto MQTT broker's authentication plugin that allows unauthenticated attackers to forge valid JWT tokens by extracting the secret from the firmware image. Attackers can use the extracted secret to craft arbitrary JWT tokens and authenticate to the MQTT broker without legitimate credentials, gainin...
CVE-2026-72716	9.3	CRIT		0.007		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in a query parameter default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code e...
CVE-2026-72717	9.3	CRIT		0.007		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in a schema default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution ...
CVE-2026-72839	9.3	CRIT		0.005		filebrowser through 2.63.16 fails to properly restrict scope and permissions when self-signup is enabled with default CreateUserDir setting. Unauthenticated attackers can register accounts that inherit the server root scope with full create, modify, delete, rename, share, and download permissions, allowing unrestricted access to all files.
CVE-2026-73080	9.3	CRIT		0.004		SeaweedFS is a distributed storage system. Prior to 4.24, VolumeServer.FetchAndWriteNeedle in weed/server/volume_grpc_remote.go fetches a caller-supplied remote endpoint through weed/remote_storage/s3/s3_storage_client.go and writes the response into a needle. The RPC performs no authentication and no target validation, allowing anyone who can reach a volume server's gRPC port to cause requests to arbitrary hosts,...
CVE-2026-73090	9.3	CRIT		0.002		PeerTube is an ActivityPub-federated video streaming platform. Prior to 8.2.2, processUpdateActivity and processUpdateVideo accept an ActivityPub Update containing a Video object without verifying that byActor.url is authorized for the host in videoObject.id, allowing a malicious federated server to rewrite another server's video metadata, visibility, media file, and HLS URLs. This issue is fixed in version 8.2.2.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73251	9.3	CRIT		0.002		Mongoose is an embedded web server and network library. Prior to 7.23, a network attacker can impersonate a TLS server to a Mongoose client configured with a multi-certificate CA bundle. In src/tls_builtin.c, the mg_tls_init() function stores the bundle in tls->ca_bundle_der while tls->ca_der.len remains zero, and mg_tls_recv_cert() uses tls_bundle_find() to accept a Common Name match without calling mg_tls_verify...
CVE-2026-73532	9.3	CRIT		0.005		Fluent Forms Pro 6.2.7 contains an embedded malicious code vulnerability introduced via a tampered plugin build served through a decommissioned update server. The tampered build introduced a rogue PHP file (libs/class-license-sync.php), loaded via a require_once directive added to fluentformpro.php, that established a backdoor REST API endpoint, dropped persistent PHP files in mu-plugins and uploads directories, i...
CVE-2026-73533	9.3	CRIT		0.004		Ninja Tables Pro 5.2.11 contains an embedded malicious code vulnerability introduced via a tampered plugin build served through a decommissioned update server. The tampered build introduced a rogue PHP file (app/Library/updater/NinjaTableDataSync.php) that established a backdoor REST API endpoint, dropped persistent PHP files in mu-plugins and uploads directories, installed a passwordless administrator account, an...
CVE-2026-73665	9.3	CRIT		0.003		FreePBX is an open source IP PBX. Prior to 17.0.9, the UCP Node server on ports 8001 and 8003 uses io.use(checkAuth) in node/lib/server.js, but Socket.IO version 4 applies that middleware only to the default namespace. An unauthenticated client can connect to custom namespaces that do not consistently invoke checkAuth in node/lib/auth.js and send crafted event values containing carriage-return or newline character...
CVE-2026-75827	9.3	CRIT		0.008		Grav before 2.0.15 contains an arbitrary file write vulnerability in the Blueprint dynamic-data bare-function validation that uses an incomplete denylist instead of a positive allowlist. Attackers with page-edit or blueprint-config access can invoke the error_log function through a data directive to append PHP payloads to web-accessible files, achieving remote code execution.
CVE-2026-75828	9.3	CRIT		0.003		Grav before 2.0.15 contains a stored cross-site scripting vulnerability in the detectXss() function where unpaired quotes in unquoted attribute values bypass event-handler detection. Authenticated editors can inject event handlers like onerror= that pass validation and execute in visitor browsers when page content is rendered.
CVE-2026-75832	9.3	CRIT		0.002		The Grav API plugin (getgrav/grav-plugin-api, bundled with Grav 2.0) before version 1.0.14 (fixed in 1.0.15) contains a missing authorization vulnerability in BlueprintPathResolver::resolveUserScope(). The method gates the users/<name> scope on the account's raw super-admin ACL flag (access.api.super) instead of validating the presented API key's actual scope. An attacker holding an API key scoped only to api.medi...
CVE-2026-75835	9.3	CRIT		0.002		Grav API plugin (getgrav/grav-plugin-api) before 1.0.14 contains a missing authorization vulnerability in userPassesAuthorize() (AbstractApiController.php). The function fails to consult the calling request's API key scopes, relying instead on the account's raw super-admin flag and ACL grants. As a result, an authenticated attacker holding a scoped API key minted on a privileged account can bypass their declared s...
CVE-2026-75837	9.3	CRIT		0.003		Grav before 2.0.14 fails to guard the access field in the core group blueprint with the required security@: admin.super restriction. A delegated admin.users operator can save a group with access[admin][super]=true to escalate to super-admin, gaining scheduler and Twig evaluation capabilities.
CVE-2026-75854	9.3	CRIT		0.011		ArcadeDB versions before 26.8.1 contain a missing authentication vulnerability in the Redis wire-protocol plugin that allows unauthenticated attackers to read, write, and delete data. Attackers can connect to the Redis port and execute arbitrary commands against any database on the server without providing credentials, bypassing all security gates.
CVE-2026-75940	9.3	CRIT				A vulnerability was reported in Lenovo Health Android Application, distributed exclusively in the Chinese market, that could allow an attacker to access sensitive health-related information.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-76200	9.3	CRIT		0.005	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session. Scope is changed.
CVE-2026-76201	9.3	CRIT		0.005	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session. Scope is changed.
CVE-2026-77089	9.3	CRIT		0.003		Command Center API contained an authentication bypass issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update Command Center.
CVE-2026-77413	9.3	CRIT		0.005		JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.0, the src/functions.js lookup function lacked an Object.prototype.hasOwnProperty check and allowed crafted expressions to access inherited prototype members. An attacker able to supply an expression could use inherited prototype setters and getters, constructor access, valueOf, and process.getBuiltinModule to reach the child_process modul...
CVE-2026-77414	9.3	CRIT		0.004		JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.1, the src/jsonata.js environment.lookup function used a bypassable hasOwnProperty check. Crafted expressions could use \$hasOwnProperty, \$spread, \$string, prototype access, and \$constructor to reach the object prototype and invoke process.getBuiltinModule with child_process, executing arbitrary code with the privileges of the host process....
CVE-2026-77415	9.3	CRIT		0.006		JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.1, crafted JSONata expressions could chain several object-integrity weaknesses to execute arbitrary code. The chain could overwrite \$clone to mutate objects through evaluateTransformExpression, expose and deconstruct JSONata functions or lambdas through \$merge.*, replace proc.arguments.forEach used by applyProcedure, and forge internal lam...
CVE-2026-77642	9.3	CRIT		0.002	torproject:tor	tor before 0.4.9.9 was prone to an out-of-bounds write when parsing a consensus or detached signature with unexpected signature digest type. Impact is minor for most Tor roles, but potentially major for directory authorities. This is TROVE-2026-019.
CVE-2026-77644	9.3	CRIT		0.003		A critical bypass access control vulnerability has been reported in PTC Windchill Risk and Reliability (WRR) Enterprise Edition.
CVE-2026-77776	9.3	CRIT		0.003		Headroom's LLM proxy derives the memory owner from the x-headroom-user-id request header. The header is read directly at several points in headroom/proxy/handlers/openai.py, including the chat completion and websocket paths, and nothing binds the value to the caller. A client can therefore name another user's identifier and read or write that user's stored LLM memory. The fix introduces a single resolve_memory_ide...
CVE-2026-78012	9.3	CRIT		0.005		An issue in the NetStaX EtherNet/IP Stack prior to v5.6.1 could allow a large Class 3 explicit-message request to exceed the application-side receive buffer without generating an error or warning. The result could be memory corruption, a device crash, or a potential remote attack vector without the originating device receiving a CIP error indicating that the request could not be processed.
CVE-2026-78082	9.3	CRIT		0.005		Joomla Extension - joomshaper.com - Unauthenticated SQL Injection in Property Search and Map Filtering in SP Property < 4.1.4 - The property search and listing query builders assembled several WHERE and ORDER BY clauses (zipcode, sorting, price_range_dropdown, and psize_range_dropdown) by directly concatenating raw request parameters into SQL strings without quoting or type casting. An unauthenticated remote attac...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78997	9.3	CRIT		0.003		UC Browser for Android (package com.UCMobile.intl, version 13.7.8.1314) contains a Universal Cross-Site Scripting vulnerability that allows an attacker to execute arbitrary JavaScript in the context of any origin. An attacker hosts a specially crafted URL on a UC-owned domain (via a reflected XSS) that leverages the browser's internal JavaScript bridge to register a deferred callback, navigate the tab to a victim ...
CVE-2026-79782	9.3	CRIT		0.001		rc1one before 1.74.4 fails to strip the X-Amz-Security-Token header when an S3 redirect changes scheme from HTTPS to HTTP on the same host. Attackers can intercept plaintext HTTP traffic to capture AWS STS session tokens sent in request headers.
CVE-2026-80238	9.3	CRIT		0.001		Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Execution with Unnecessary Privileges vulnerability. An unauthenticated attacker with local access could potentially exploit this vulnerability, leading to Protection mechanism bypass. This vulnerability is considered critical because a low-privileged operator with SSH access to the SCG host c...
CVE-2026-80428	9.3	CRIT		0.007		ILIAS before versions 9.22, 10.10, and 11.3 contains an unauthenticated PHP object injection vulnerability that allows unauthenticated attackers to execute arbitrary code by injecting serialized objects through the LTI authentication endpoint and triggering deserialization via the Shibboleth back-channel logout endpoint. Attackers can write arbitrary serialized objects into session storage, then exploit an availab...
CVE-2026-81800	9.3	CRIT				Unauthenticated SQL Injection in Verified Reviews (Avis Vérifiés) <= 2.4.6 versions.
CVE-2026-82526	9.3	CRIT		0.004		R2R through 3.6.6 contains a stacked SQL injection vulnerability that allows unauthenticated attackers to execute arbitrary SQL statements by manipulating the index name parameter in the vector index creation endpoint. The index name is interpolated directly into a CREATE INDEX statement via string formatting without identifier quoting or allowlist validation, enabling arbitrary DDL and DML execution through semic...
CVE-2026-82854	9.3	CRIT		0.011		Nodemailer before 8.0.4 is vulnerable to SMTP command injection through the unsanitized envelope.size parameter. When an application passes a custom envelope object with a size property containing CRLF characters to sendMail(), the value is concatenated into the SMTP MAIL FROM command (as SIZE=...) without sanitization, allowing injection of arbitrary SMTP commands such as RCPT TO to silently add attacker-controll...
CVE-2026-82859	9.3	CRIT		0.003		hulumi versions before v1.3.2 contain a deployment SCP template that allows tag-on-create bypasses for hulumi:iac-role protections. Attackers can bypass intended IAM boundary restrictions by exploiting the weakened SCP template in downstream deployments.
CVE-2026-82876	9.3	CRIT		0.001		Phison PS3111-S11 controller firmware verifies RSA signatures using a public modulus embedded within the firmware image itself rather than anchored in immutable storage. Attackers can generate arbitrary RSA key pairs, sign modified firmware with the private key, embed the matching modulus in the signature segment, and the controller accepts the tampered firmware as valid.
CVE-2026-8323	9.3	CRIT		0.003		URL redirection to untrusted site ('open redirect') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows Fake the Source of Data. This issue affects Access Control System: before Versiyon 2.
CVE-2026-84479	9.3	CRIT		0.003		WWBN AVideo (current e01e41ecc and earlier) makes three login-time security controls depend solely on the client-supplied User-Agent header. The isAVideoEncoder()/isAVideoMobileApp() checks match HTTP_USER_AGENT against a hardcoded literal ("AVideoEncoder"/"AVideoMobileApp") with no IP check or shared secret. An attacker who submits valid credentials and sets User-Agent: AVideoEncoder bypasses two-factor authentic...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84480	9.3	CRIT		0.003		WWBN AVideo fails to validate password recovery token expiration in userRecoverPassSave.json.php, allowing attackers to use expired tokens to reset account passwords indefinitely. Attackers who obtain a recovery token can use it at any time to change the target account's password and gain full account access.
CVE-2026-84695	9.3	CRIT		0.003		BookStack before 26.05.4 contains a stored cross-site scripting vulnerability in the drawing upload endpoint that accepts unvalidated base64 content and stores it without content inspection. Attackers with editor permissions can upload SVG files containing scripts that execute in administrator browsers when accessed through the image gallery API without content-type validation or CSP headers.
CVE-2026-84696	9.3	CRIT		0.001		Phison PS3111-S11 controller firmware versions through SBFQT1.3 expose privileged vendor unique commands over the ATA interface with absent or defeatable authentication mechanisms. Attackers can bypass the weak CRC-16 based unlock handshake or exploit builds with no VUC lock to read and write controller memory and raw flash, persisting implants across power cycles.
CVE-2026-85146	9.3	CRIT		0.004		SmartIT Desktop Manager developed by Lightstar has a Use of Hard-coded Credentials vulnerability. Unauthenticated remote attackers can obtain the SSH service account credentials and passwords for the SmartIT Agent directly from the application source code.
CVE-2026-85148	9.3	CRIT		0.004		SmartIT Desktop Manager developed by Lightstar has a Use of Hard-coded Credentials vulnerability. Unauthenticated remote attackers can exploit a fixed password to remotely access user hosts.
CVE-2026-85154	9.3	CRIT		0.003		WWBN AVideo contains an authentication failure vulnerability where the video_id_hash credential is a non-expiring, non-revocable bearer token that grants full administrator session access to the video owner's account. Attackers who obtain a video_id_hash can replay it indefinitely to authenticate as the video owner with full privileges, and the credential remains valid even after the owner changes their password.
CVE-2026-85183	9.3	CRIT		0.002		Taipy configures its socket.io server with wildcard CORS origin and credential flag enabled, allowing any web page to establish credentialed WebSocket connections to victim applications. Attackers can open socket.io sessions from arbitrary domains and invoke state variable modifications and action callbacks without CSRF protection.
CVE-2026-85391	9.3	CRIT		0.003		Peppermint through 0.5.5 contains a hardcoded JWT signing secret in docker-compose.yml that allows unauthenticated attackers to forge session tokens for any account. Attackers can use the published secret to mint valid tokens for arbitrary user IDs and access protected endpoints without credentials.
CVE-2026-85424	9.3	CRIT		0.005		MOOS core-moos through 10.4.0 lacks authentication in the wire protocol, allowing unauthenticated clients to connect with full publish, subscribe, and database clear privileges. Attackers can bypass the compile-time protocol string check and connect with arbitrary client names to execute privileged operations including DB_CLEAR which resets all variables and clears client mail queues.
CVE-2026-85425	9.3	CRIT		0.01		MOOS-lvP iSay through 24.8.1 contains a remote code execution vulnerability in the SAY_MOOS variable handler that passes unsanitized text to a shell command. Attackers can publish SAY_MOOS messages containing backticks or command substitution syntax to execute arbitrary commands as the iSay process user.
CVE-2026-85426	9.3	CRIT		0.006		MOOS-lvP uMemWatch through 24.8.1 constructs shell commands from attacker-chosen MOOS client names without sanitization. Attackers can inject shell metacharacters into client names to execute arbitrary commands as the uMemWatch process user through unquoted redirection targets in system calls.
CVE-2026-85428	9.3	CRIT		0.005		MOOS core-moos through 10.4.0 contains an authentication bypass vulnerability in the optional MOOSDB HTTP server that allows unauthenticated clients to write variables. Attackers can send HTTP requests with variable names and values to the MOOSDB HTTP server port to modify MOOS variables including actuator and override commands without authentication.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85433	9.3	CRIT		0.003		MOOS essential-moos pShare through 10.0.1 fails to properly authorize PSHARE_CMD messages, allowing any publisher to reconfigure network routes and listeners at runtime. Attackers can send crafted PSHARE_CMD messages with cmd=output or cmd=input parameters to open new listeners on arbitrary addresses and redirect or duplicate bus traffic to attacker-controlled destinations.
CVE-2026-85434	9.3	CRIT		0.002		MOOS-lvP uFldShoreBroker through 24.8.1 fails to verify node ping authenticity before creating outbound bridge routes. Attackers can publish NODE_BROKER_PING messages with crafted HostRecord data to redirect bridged variables to attacker-controlled addresses.
CVE-2026-85435	9.3	CRIT		0.002		MOOS-lvP uFldNodeBroker through 24.8.1 fails to validate the source of TRY_SHORE_HOST messages on the vehicle bus, allowing any publisher to enroll attacker-controlled shore routes. Attackers can publish malicious shore route messages to receive bridged vehicle traffic including sensor data and control information.
CVE-2026-85437	9.3	CRIT		0.007		MOOS-lvP through 24.8.1 contains multiple buffer overflow vulnerabilities in lvP function string decoders that trust attacker-controlled length fields without validation. Attackers can craft malicious encoded strings with mismatched declared and actual field lengths to overflow heap and stack buffers, potentially achieving remote code execution through MOOS variables or alog files.
CVE-2026-85438	9.3	CRIT		0.005		MOOS-lvP through 24.8.1 contains a buffer overflow vulnerability in StringToIvPFunction() where dimension, piece, and degree counts from encoded BHV_IPF payloads are used as allocation sizes and loop bounds without validation. Attackers can supply crafted payloads with mismatched dimension values to write attacker-controlled doubles past the end of the IvPBox weight array, causing memory corruption and potential C...
CVE-2026-85440	9.3	CRIT		0.006		MOOS core-moos through 10.4.0 contains a pre-authentication heap overflow vulnerability in MOOSCommPkt packet handling that allows remote attackers to write arbitrary data by declaring a negative packet length. Attackers can exploit the signed integer check in InflateTo() and negative size conversion in recv() to overflow a four-byte heap buffer during the HandShake phase before authentication.
CVE-2026-85595	9.3	CRIT		0.004		Traefik versions before v2.11.55 and versions v3.0.0 through v3.7.10 contain an authentication bypass vulnerability in the digestAuth middleware where unknown usernames receive an empty secret instead of rejection. Attackers can compute a valid digest response using the empty secret and arbitrary credentials to bypass authentication on any digestAuth-protected route without a valid username or password.
CVE-2026-85602	9.3	CRIT		0.003		The Grav Form plugin (getgrav/grav-plugin-form) versions 8.0.6 through 9.1.19 select the reCAPTCHA version to validate based solely on which response field key is present in the submitted payload. On a site configured for reCAPTCHA v3, an anonymous attacker can place their v3 token under the v2 field name (g-recaptcha-response instead of token), causing validation to use the v2 branch, which never applies the scor...
CVE-2026-85663	9.3	CRIT		0.005		Aim 3.29.1 remote tracking server fails to authenticate requests and dispatches arbitrary methods through getattr without allowlist validation. Unauthenticated attackers can register clients, instantiate Repo resources, and invoke arbitrary methods to read experiments or delete runs.
CVE-2026-85667	9.3	CRIT		0.004		xiaobei through 5.5.2 fails to implement authentication or signature validation on webhook endpoints, allowing unauthenticated attackers to inject arbitrary messages into the agent pipeline. Attackers can publish malicious messages via the /webhook_worktool handler and exploit unvalidated media URL fetching to perform server-side request forgery against internal services.
CVE-2026-85672	9.3	CRIT		0.015		zerox 1.1.20 contains an OS command injection vulnerability in the file download mechanism where the temporary file extension derived from document URLs is interpolated unsanitized into shell commands executed by poppler utilities. Attackers can craft document URLs with malicious file extensions containing command substitution syntax to execute arbitrary OS commands before document processing occurs.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85695	9.3	CRIT		0.004		FastChat contains an authentication bypass vulnerability in the /register_worker endpoint that allows unauthenticated attackers to register arbitrary worker addresses and perform server-side request forgery. Attackers can register malicious workers under victim model names to intercept user prompts, images, and responses, or probe internal network ports across the worker mesh.
CVE-2026-85696	9.3	CRIT		0.015		SadTalker contains an OS command injection vulnerability in the video muxing process where uploaded audio filenames are interpolated into ffmpeg commands without proper escaping. Attackers can upload audio files with shell metacharacters in the filename to break out of quoted arguments and execute arbitrary system commands when video generation occurs.
CVE-2026-86121	9.3	CRIT		0.006		Cua computer-server versions before 0.3.42 skip authentication when the CONTAINER_NAME environment variable is unset and bind to all interfaces by default, allowing unauthenticated attackers to execute arbitrary commands. Attackers can reach TCP port 8000 to run shell commands via the run_command endpoint, read and write arbitrary files through file operation endpoints, and access interactive PTY shells without au...
CVE-2026-86184	9.3	CRIT		0.006		Lara Dashboard before 1.3.0 contains an authentication bypass vulnerability in the screenshot-login route that allows unauthenticated attackers to authenticate as any user by email when APP_ENV is not production. Attackers can request the GET /screenshot-login/{email} endpoint with a registered email address to receive a fully authenticated session, enabling access to user administration, settings, database conten...
CVE-2026-86189	9.3	CRIT		0.004		WWBN AVideo contains a path traversal vulnerability in notify.ffmpeg.json.php that allows unauthenticated attackers to write files to arbitrary locations by supplying a caller-chosen path in the avideoRelativePath parameter. Attackers can replay any previously issued ciphertext as a notifyCode token, which is decrypted but never validated, to bypass authentication and write files to the application root and subdir...
CVE-2026-86190	9.3	CRIT		0.003		WWBN AVideo contains a broken access control vulnerability in videoViewsInfo endpoints that returns complete user records including password hashes, recovery tokens, and live session identifiers to unauthenticated callers when a hash parameter is provided. Attackers can use the disclosed session identifier to hijack viewer sessions, including administrator accounts, and obtain sensitive personal data for all video...
CVE-2026-86296	9.3	CRIT		0.013		A vulnerability was determined in D-Link DIR-822A A_101. This vulnerability affects the function strcpy of the file udhpcd/serverpacket.c of the component udhpcd. This manipulation causes stack-based buffer overflow. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-86543	9.3	CRIT		0.004		knowns versions before 0.30.0 serve the management API without authentication on all network interfaces by default, with no password required on fresh installations. Attackers can access the unauthenticated /api/tunnel/start endpoint to provision a public tunnel and republish the API at a publicly accessible address.
CVE-2026-86738	9.3	CRIT		0.003	snipeitapp:snipe-it	Snipe-IT versions before 8.7.0 contain a CSS injection vulnerability in the Custom CSS field due to incomplete sanitization that reverses HTML encoding on greater-than and double-quote characters. Superusers can plant malicious CSS payloads using @import and url() references to exfiltrate CSRF tokens from other superusers via attribute-selector rules, enabling account takeover.
CVE-2026-87929	9.3	CRIT		0.003		MaxSite CMS through 109.6 ships with a hardcoded session encryption key in application/config/config.php that is never changed during installation, allowing unauthenticated attackers to forge administrator session cookies. Attackers can mint a malicious ci_session cookie with administrator privileges by computing an HMAC-SHA1 using the publicly known encryption key, bypassing authentication checks in is_login() an...
CVE-2026-88069	9.3	CRIT		0.003		Pandora contains a path traversal vulnerability in its archive extraction worker. When processing a specially crafted archive or disk image, attacker-controlled file paths could be used without ensuring that the resulting destination remained within the intended extraction directory. An attacker able to submit a malicious file for analysis could use path traversal sequences or crafted paths to cause extracted con...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88860	9.3	CRIT				Capgo fails to clean up channel permission overrides when a user's last organization role binding is deleted, leaving stale overrides active. Attackers can retain channel-specific permissions after their base RBAC access has been revoked to perform unauthorized actions like changing production OTA versions.
CVE-2026-88864	9.3	CRIT				Capgo (capgo.app) fails to restrict direct write access to the public.sso_providers table exposed through Supabase PostgREST. A holder of an ordinary Capgo full API key can insert a row with status='active' and enforce_sso=true, bypassing the intended backend SSO provisioning route (supabase/functions/_backend/private/sso/providers.ts) and its controls: the Enterprise plan requirement, SSO provider creation via th...
CVE-2026-88866	9.3	CRIT				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to encode the User-Agent header before storing it in login history. Attackers with any valid login account can inject malicious scripts in the User-Agent header that execute in administrator browsers when viewing the Login History page, allowing script execu...
CVE-2026-88867	9.3	CRIT				WWBN AVideo, in versions up to and including commit c3edcc274c389816d434acadac07ee78eaf330c1, contains a stored cross-site scripting vulnerability. objects/categoryAddNew.json.php passes the POST parameters `name` and `iconClass` to Category::setName() and Category::setIconClass(), which store the values without sanitization (setName only truncates to 45 characters). The category name is later echoed as HTML text ...
CVE-2026-88868	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LiveLinks plugin where title and description fields are stored without sanitization. A user with canStream permission can inject malicious scripts that execute in the browser of every visitor viewing the live-link page, including administrators, within the site origin.
CVE-2026-88869	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the AD_Server plugin's log.php endpoint that fails to escape the label parameter before storage. An unauthenticated attacker can inject malicious HTML through the label parameter, which is later rendered unsanitized in the admin Ad Types report using jQuery .html(), allowing execution of arbitrary...
CVE-2026-88877	9.3	CRIT				Traefik is a HTTP reverse proxy and load balancer. In versions >= v3.7.0 and <= v3.7.11, the Kubernetes ingress-nginx provider mishandles Ingresses that carry both an authentication annotation and the nginx.ingress.kubernetes.io/from-to-www-redirect annotation. For such Ingresses the provider creates an additional 'sibling' router that matches on the host alone, carries only the RedirectRegex middleware, and still...
CVE-2026-88899	9.3	CRIT				known versions before 0.31.0 fail to properly validate the x-opencode-directory request header in the /api/opencode proxy endpoint. Remote attackers can supply arbitrary directory paths to execute file operations outside the project root on the host system.
CVE-2026-89042	9.3	CRIT				passport-saml-encrypted through 0.1.13 makes SAML signature verification conditional on an optional cert option, allowing attackers to bypass authentication by submitting unsigned SAML responses. Attackers can post forged SAML responses with arbitrary NameID and attributes to the assertion consumer service endpoint to receive authenticated profiles without valid signatures.
CVE-2026-89249	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the YPTWallet plugin where user-supplied CryptoWallet values are base64-encoded but not HTML-escaped before storage in wallet_log.information. Administrators viewing pending withdrawal requests in pendingRequests.php execute the stored markup in their session, allowing attackers to perform adminis...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89253	9.3	CRIT				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the user 'donationLink' profile field. User::setDonationLink() (objects/user.php) stores the value and save() validates it only with filter_var(..., FILTER_VALIDATE_URL), which accepts strings such as http://evil.example/"onmouseover=alert(document.domain)//, while getDonationLink() applies o...
CVE-2026-89254	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the CustomizeUser plugin where the field_name parameter is stored raw without sanitization. Administrators can inject malicious scripts via the add.json.php endpoint that execute when viewing extra info pages or profile forms that render the typeToHTML function.
CVE-2026-89255	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to HTML-encode PGP public keys echoed into a textarea element. An authenticated attacker can inject malicious JavaScript by submitting a crafted public key, which executes in an administrator's session when viewing the user's profile tab.
CVE-2026-89256	9.3	CRIT				AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the Bookmark plugin where chapter names are not encoded before being concatenated into public watch-page HTML. A video owner can inject malicious scripts via the bookmark name parameter, and every visitor of that video executes the payload in the AVideo origin.
CVE-2026-89258	9.3	CRIT				Hugo is a static site generator. In versions after v0.123.0 and before v0.165.0, symlinks in parent directories were not dropped during direct resource lookups, allowing path confinement to be bypassed. An attacker who can place — or who convinces a site author to place — a symlink inside a mounted directory (for example, in a locally vendored theme under themes/) can cause functions that perform direct lookups, s...
CVE-2026-89259	9.3	CRIT				Hugo is a static site generator. From v0.161.0, Hugo executes Node tools under Node's permission model, but TailwindCSS — included in the default security.exec.allow list — requires a highly permissive configuration (--allow-addons, --allow-child-process, --allow-worker). As a result, the restrictions intended by the fix for GHSA-x597-9fr4-5857 could still be bypassed, allowing a Node tool invoked during a build t...
CVE-2026-13737	9.2	CRIT		0.005	commvault:commvault	CommServe contained an allowlist bypass vulnerability affecting command execution authorization. Software customers upgrade to resolved maintenance release. Update all Commvault installations, including Commserve, Webserver, Command Center, Media Agents, Clients and HyperScale X.
CVE-2026-13745	9.2	CRIT		0.003		A vulnerability in the Gemini CLI and associated GitHub Action allowed an unprivileged attacker to achieve an arbitrary code execution in Gemini CLI via untrusted local .env files overriding GEMINI_CLI_HOME.
CVE-2026-21095	9.2	CRIT		0.004		Heap-based buffer overflow in DNG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-21096	9.2	CRIT		0.004		Heap-based buffer overflow in JPEG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-39923	9.2	CRIT		0.003		Flarum before 1.8.16 contains a password reset token expiry bypass vulnerability that allows unauthenticated attackers to reuse expired password reset tokens by submitting them directly to the reset processing endpoint. The SavePasswordController::handle() method calls PasswordToken::findOrFail() without performing any expiry validation, allowing attackers to bypass the 24-hour token lifetime enforced only during ...
CVE-2026-46713	9.2	CRIT		0.002		Misskey is an open source, federated social media platform. Versions 12.37.0 and later, but prior to 2026.5.4, contain a vulnerability in the JSON-LD signature validation and compaction process that allows spoofed activities to be accepted as valid. This issue has been fixed in version 2026.5.4.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-47243	9.2	CRIT		0.004		Kata Containers is an open source project focusing on a standard implementation of lightweight Virtual Machines (VMs) that perform like containers. Prior to 3.31.0, the runtime-rs standalone virtio-fs path is vulnerable to a guest-root to host-root escape. In this configuration, Kata runs the host virtiofsd as root with --sandbox none --seccomp none, so an attacker with root-equivalent access inside the guest can ...
CVE-2026-47839	9.2	CRIT				A vulnerability allows users authenticating through a federated OIDC provider to obtain the uaa.admin scope despite operators restricting that provider through externalGroupsWhitelist configuration. The issue occurs specifically when an OIDC identity provider uses groupMappingMode: AS_SCOPES with a wildcard externalGroupsWhitelist entry.
CVE-2026-53790	9.2	CRIT		0.005		rsync before 3.5.0 contains multiple command and argument injection vulnerabilities that allow attackers to execute arbitrary commands by supplying malicious input through several code paths, including the RSYNC_CONNECT_PROG environment variable, daemon hooks, the rsync-ssl wrapper, and remote-shell command newline injection. Attackers can inject shell metacharacters or newline characters into unsanitized user-sup...
CVE-2026-59679	9.2	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) indexes the per-character encoding[] array using num_chars from the FS_QueryXBitmaps16 reply, but that array was allocated with a size derived from num_extents in the separate FS_QueryXExtents16 reply. The two CARD32 fields are never cross-checked. A malicious or compromised font server can send a small num_extents (e.g. 1) in the extents reply...
CVE-2026-63382	9.2	CRIT		0.006		Libevent is an event notification library. Prior to 2.1.13 and 2.2.2-alpha, the libevent evhttp parser in http.c inconsistently handles duplicate Transfer-Encoding headers, comma-separated Transfer-Encoding values, and bare line feeds in chunked framing. evhttp_find_header can select only the first header, evhttp_check_transfer_encoding_ was absent so the previous whole-string comparison fails to recognize valid l...
CVE-2026-63385	9.2	CRIT		0.004		Libevent is an event notification library. Prior to 2.1.13 and 2.2.2-alpha, libevent has two HTTP parsing weaknesses in http.c. evhttp_decode_uri_internal decodes percent-encoded %00 bytes into literal NUL characters, which can cause downstream C string operations to truncate a path and bypass validation performed on a different representation. evhttp_header_is_valid_value also accepts obsolete line folding in hea...
CVE-2026-65638	9.2	CRIT				Improper escaping of a request URL in ConfigServer Security & Firewall allows an unauthenticated remote attacker to execute arbitrary commands as the CSF service account via shell command injection. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-maintained fork that contain the vulnerable code. WebPros has addressed the vulnerability ...
CVE-2026-66047	9.2	CRIT		0.005		ProfilePress (wp-user-avatar) WordPress plugin before 4.17.2 contains an unauthenticated remote code execution vulnerability that allows unauthenticated attackers to install and activate arbitrary plugins by brute-forcing a weak 32-bit connect token via the ppress_connect_process AJAX handler. Attackers can supply a caller-controlled URL through the file request parameter to trigger silent plugin installation and ...
CVE-2026-67276	9.2	CRIT		0.002		RouterOS does not compare the complete RSA public key when matching an SSH authentication request to an authorized user key, checking the key type and modulus but omitting the exponent. Because signature verification uses the client-supplied key, an attacker knowing an authorized RSA modulus can supply a key with exponent one, forge a valid signature, and open an SSH command channel as the target user without the ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67367	9.2	CRIT		0.008		A vulnerability has been identified in SIMOVE Fleetmanager V3.1 (All versions < V3.1.13), SIMOVE Fleetmanager V3.2 (All versions < V3.2.4), SIMOVE Fleetmanager V3.3 (All versions < V3.3.2), SIMOVE Fleetmanager V4.0 (All versions < V4.0.1), SIPLANT V1.7 (All versions), SIPLANT V2.2 (All versions), SIPLANT V3.0 (All versions), SIPLANT V3.1 (All versions < V3.1.4). Affected devices do not properly validate and neutra...
CVE-2026-67402	9.2	CRIT		0.003		An insecure Apache configuration in ConfigServer Security & Firewall maps /usr/bin as CGI programs through the Messenger v3 HTTPS virtual host. A remote unauthenticated attacker whose address is blocked can request a mapped executable and run arbitrary commands as the Apache user. The vulnerability affects installations where CSF Messenger v3 and its HTTPS mode are enabled. WebPros addressed the vulnerability in v...
CVE-2026-67443	9.2	CRIT		0.006		FUXA is a web-based Process Visualization (SCADA/HMI/Dashboard) software. In 1.3.2 and earlier, the allowDashboard authorization gate in server/integrations/node-red/index.js calls authJwt.verify for /nodered without inspecting the decoded identity. When nodeRedEnabled is true, secureEnabled is true, and nodeRedAuthMode is secure, a remote unauthenticated attacker can obtain a signed guest token from POST /api/hea...
CVE-2026-69255	9.2	CRIT		0.006		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the CSVAgent in packages/components/nodes/agents/CSVAgent/CSVAgent.ts extracted attacker-controlled CSV data with file.split(',').pop() and interpolated it directly into executable Python as base64_string = "\${base64String}" before calling Pyodide. The validatePythonCodeForDataFrame() denylist only checked late...
CVE-2026-70460	9.2	CRIT		0.004		rsync 2.3.3 before 3.5.0 contains a path traversal vulnerability that allows a malicious sender to escape the module root by exploiting symlinks within the module file tree when using --partial-dir or --backup-dir options. Attackers with write access to place a symlink under the module root, or who can exploit a pre-existing trusted symlink, can direct file writes to locations outside the intended module root, ach...
CVE-2026-70478	9.2	CRIT		0.004		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, the POST /api/v1/oauth2-credential/refresh/:credentialId endpoint is included in WHITELIST_URLS and requires no authentication. The endpoint decrypts the stored credential, sends a refresh request to the configured OAuth provider with the client secret and refresh token, and returns the refreshed access_token i...
CVE-2026-72836	9.2	CRIT		0.004		FileBrowser before 2.63.19 does not account for case-insensitive filesystems when checking home directory ownership during self-registration. When Signup and CreateUserDir are enabled and FileBrowser's root is on a case-insensitive filesystem (confirmed on Windows/NTFS), two self-registered usernames that differ only in letter case (e.g., CaseVictim and casevictim) are stored as distinct accounts but resolve to th...
CVE-2026-73414	9.2	CRIT		0.005		Shescape is a simple shell escape library for JavaScript. Prior to 2.1.14 and 3.0.1, getEscapeFunction in src/internal/win/cmd.js does not escape `(` and `)` when applications use the escape or escapeAll APIs on Windows with shell set to cmd.exe, or with shell set to true when CMD is the default. An attacker-controlled argument can break out of a parenthesized CMD construct and inject shell syntax depending on the...
CVE-2026-75856	9.2	CRIT		0.005		CodeWhale before 0.8.64 contains a server-side request forgery bypass vulnerability in DNS pinning logic that fails to prevent time-of-check-time-of-use attacks. Attackers can manipulate DNS responses to fail initial resolution checks and succeed on secondary requests, allowing requests to internal IP addresses and bypassing SSRF mitigations.
CVE-2026-77635	9.2	CRIT		0.003		CakePHP is a rapid development framework for PHP. Prior to versions 5.1.10, 5.2.15, and 5.3.7 on their respective release lines, FunctionsBuilder::jsonValue() with PostgresDriver is vulnerable to SQL injection when user-controlled data is supplied to the jsonPath parameter. This issue is fixed in versions 5.1.10, 5.2.15, and 5.3.7.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77645	9.2	CRIT		0.005		A critical remote code execution (RCE) vulnerability has been reported in PTC Windchill and PTC FlexPLM. The vulnerability may be exploited through the deserialization of untrusted data.
CVE-2026-82067	9.2	CRIT		0.003		Improper handling of case sensitivity in the configuration validation component of MongoDB Server may cause the authorization subsystem to remain in a default disabled state during server startup. An unauthenticated user with network access to a deployment where this condition occurs can perform arbitrary administrative operations, resulting in full impact of data confidentiality, integrity, and availability.
CVE-2026-82090	9.2	CRIT		0.003		Pocket through 8.33.0.0 allows XSS because "Save to Pocket" injects external HTML into the DOM. JavaScript code can alter the application state via native bridge methods.
CVE-2026-84189	9.2	CRIT		0.003		LibreNMS through 26.4.0 renders JSON fields (name, ip, model, author, commit message) returned by the admin-configurable Oxidized integration URL (oxidized.url) into the device showconfig page without applying htmlspecialchars(). An administrator who points the Oxidized URL at an attacker-controlled server (SSRF) can cause it to return malicious JSON, resulting in stored/persistent cross-site scripting affecting a...
CVE-2026-84197	9.2	CRIT		0.002		In Eclipse Ditto's Node.js JavaScript client, all released versions of @eclipse-ditto/ditto-javascript-client-node from 2.0.0 to 3.9.0 and of its predecessor package @eclipse-ditto/ditto-javascript-client-node_1.0 from 1.0.0 to 2.1.0, the WebSocket transport hard-codes rejectUnauthorized: false when creating the underlying ws WebSocket. Certificate chain and hostname validation are therefore disabled for every wss...
CVE-2026-85427	9.2	CRIT		0.004		MOOS essential-moos pAntler through 10.0.1 contains a remote code execution vulnerability that allows unauthenticated attackers to execute arbitrary programs by publishing a crafted MISSION_FILE message to the MOOSDB. Attackers can publish a mission file containing malicious Run entries that pAntler parses and executes via execvp() without authentication validation.
CVE-2026-85614	9.2	CRIT		0.002		OpenPanel before 2.3.0 contains an unauthenticated server-side request forgery vulnerability in the GET /tools/site-checker endpoint that accepts a fully client-controlled URL parameter with no private IP filtering or DNS-rebinding protection. Attackers can make the OpenPanel server issue requests to internal services, localhost, and cloud metadata endpoints, reading internal HTTP response titles, headers, status ...
CVE-2026-85625	9.2	CRIT		0.005		sift (sift.js) 17.1.3 enumerates query keys with for...in, which walks the object prototype chain, and dispatches any matched operator key including \$where. The \$where operation compiles a string value into a function using new Function unless CSP_ENABLED is set (not set by default). As a result, if a prototype-pollution primitive elsewhere in the process sets Object.prototype.\$where to a malicious string, even be...
CVE-2026-85694	9.2	CRIT		0.005		LaVague 0.2.35 contains a remote code execution vulnerability in PythonFromMarkdownExtractor.extract_as_object that evaluates untrusted language model output derived from web page content. Attackers can inject malicious Python code through web pages using indirect prompt injection to execute arbitrary code on the operator's host without review.
CVE-2026-86117	9.2	CRIT		0.004		Coolify through 4.3.17 contains an authentication bypass vulnerability in the OAuth callback handler that signs users into existing accounts based solely on email address without verifying provider assertions or binding OAuth identities. Attackers can register a victim's email address on any enabled OAuth provider to obtain authenticated sessions as that user, bypassing password requirements and two-factor authent...
CVE-2026-86426	9.2	CRIT		0.014		LibreNMS before 26.8.0 contains an authentication bypass vulnerability in the REST API that allows unauthenticated attackers to access protected endpoints by sending numeric values instead of string tokens. Attackers can exploit MySQL type coercion by sending small integers like 0 through 9 to match token hashes, gaining access to API functionality including device credentials and administrative features that enab...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87930	9.2	CRIT		0.003		MaxSite CMS through 109.6 passes the ci_session cookie to unserialize() without class restrictions, allowing unauthenticated attackers to inject PHP objects. Attackers can forge valid session cookies using the hardcoded encryption key to trigger magic methods and corrupt application state or achieve code execution if gadget classes exist.
CVE-2026-88880	9.2	CRIT				Renovate before 44.11.3 fails to validate Link header destinations when following GitLab server pagination, allowing malicious servers to redirect credential-bearing requests. Attackers controlling a compromised GitLab server can specify a Link header pointing to attacker-controlled infrastructure to exfiltrate authentication credentials.
CVE-2026-88881	9.2	CRIT				Renovate, a dependency update tool, follows pagination links supplied by the GitHub server in the HTTP `Link` header when interacting with GitHub.com, GitHub Enterprise Cloud, or GitHub Enterprise Server, and sends the credentials configured for that host to the URL given as the 'next' page. Because the pagination URL is not validated against the host originally contacted, a malicious or compromised GitHub server ...
CVE-2026-88882	9.2	CRIT				Renovate is a dependency update automation tool. In versions before 44.11.2 (and Mend Renovate CE/EE images and charts before 15.4.0, and mend-renovate-enterprise-edition helm chart before 10.4.0), when listing new package versions from a NuGet registry Renovate follows pagination URLs supplied by the registry in the HTTP `Link` header without verifying that the target has the same origin as the configured registr...
CVE-2026-88887	9.2	CRIT				Renovate is a dependency update automation tool. When listing tags/digests for a container image, Renovate follows pagination links supplied by the remote registry in the HTTP Link header and attaches the registry credentials to the follow-up request without verifying that the pagination URL has the same origin as the original registry. A malicious or compromised container registry can therefore specify a Link hea...
CVE-2026-89243	9.2	CRIT				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in UserGroups::setGroup_name() that fails to sanitize group_name input. Administrators with canAdminUserGroups permission can inject malicious HTML and JavaScript that executes in the browser when other administrators access the user manager interface.
CVE-2026-9277	9.2	CRIT		0.008		shell-quote's `quote()` function did not validate object-token inputs against the operator model used by `parse()`. The `.op` field was backslash-escaped character by character using `/(.)g`, which in JavaScript does not match line terminators (\n, \r, U+2028, U+2029). A line terminator in `.op` therefore passed through unescaped into the output; POSIX shells treat a literal newline as a command separator, so any...
CVE-2026-9317	9.2	CRIT		0.007		Nango before 0.71.6 contains a missing authentication vulnerability in the runner tRPC server that allows unauthenticated attackers to execute arbitrary JavaScript code by invoking the exposed start procedure without credentials. Attackers with network access to the runner port can send requests to the unauthenticated start procedure, bypassing the unenforced RUNNER_SECRET_KEY environment variable, to achieve remo...
CVE-2022-4993	9.1	CRIT		0.005		HTML::FormHandler versions before 0.410000 for Perl allow attacker selected method dispatch and resource exhaustion because _apply_actions and add_error use error message text built from request data as a Locale::Maketext bracket notation template. add_error hands its first argument to the language handle as the Locale::Maketext message key, and the default handle's lexicon sets `'_AUTO'`, so a string that is not a...
CVE-2025-49794	9.1	CRIT		0.008		A use-after-free vulnerability was found in libxml2. This issue occurs when parsing XPath elements under certain circumstances when the XML schematron has the <sch:name path="..."> schema elements. This flaw allows a malicious actor to craft a malicious XML document used as input for libxml, resulting in the program's crash using libxml or other possible undefined behaviors.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-49796	9.1	CRIT		0.015		A vulnerability was found in libxml2. Processing certain sch:name elements from the input XML file can trigger a memory corruption issue. This flaw allows an attacker to craft a malicious XML input file that can lead libxml to crash, resulting in a denial of service or other possible undefined behavior due to sensitive data being corrupted in memory.
CVE-2025-51679	9.1	CRIT		0.004		An issue was discovered in openRISC OR1200 commit 83ac6b. A mismatch between the RTL and netlist can lead to unexpected behavior.
CVE-2025-70146	9.1	CRIT		0.006	projectworlds:online_time_table_generator	Missing authentication in multiple administrative action scripts under /admin/ in ProjectWorlds Online Time Table Generator 1.0 allows remote attackers to perform unauthorized administrative operations (e.g., adding records, deleting records) via direct HTTP requests to affected endpoints without a valid session.
CVE-2026-10059	9.1	CRIT		0.003		A flaw was found in the Multicluster Engine for Kubernetes ClusterCurator controller. A tenant administrator with namespace-scoped privileges can exploit this vulnerability by creating a namespaced ClusterCurator. This action inadvertently grants the tenant administrator the ability to mint a token for a ServiceAccount with cluster-wide administrative authority. This leads to a privilege escalation, allowing the t...
CVE-2026-13221	9.1	CRIT		0.004	perl:perl	Perl versions before 5.40.5-RC1, from 5.41.0 before 5.42.3-RC1, from 5.43.0 before 5.43.10 produce silently incorrect regular expression matches when an alternation of more than 65535 fixed string branches is compiled into a trie in Perl_study_chunk. When such branches are combined into a trie, the delta between the first branch and the shared tail is stored in a 16-bit field. A branch count above 65535 overflows...
CVE-2026-16272	9.1	CRIT		0.001		Use of less trusted source vulnerability in PayTR Payment and Electronic Money Institution Inc. PayTR Virtual Pos iFrame API (v9x) WHMCS Module allows Exploitation of Trusted Identifiers. This issue affects PayTR Virtual Pos iFrame API (v9x) WHMCS Module: from v9.0.0 before v9.0.3.
CVE-2026-16503	9.1	CRIT		0.003		Deployment of the VPS.org one-click Supabase template deploys a PostgreSQL instance that is published on all interfaces (0.0.0.0:5432) with a default database password set to "postgres". Because Docker installs its own iptables rules, this exposure bypasses a standard host UFW configuration.
CVE-2026-17057	9.1	CRIT		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service and affect data integrity due to missing authentication for critical functions.
CVE-2026-17207	9.1	CRIT		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service and compromise integrity due to a buffer overflow.
CVE-2026-18412	9.1	CRIT		0.004		OpenCart extensions are uploaded as zip files with .ocmod.zip extensions. Upon installation, the OpenCart v4.2.0.0 extension installer extracts these zip files, but does not validate that the extracted paths stay inside the intended extraction directory. An attacker can craft a malicious extension containing file path traversal sequences, such as ../. With this vulnerability, an attacker can write files, such as a...
CVE-2026-18753	9.1	CRIT		0.003		The product firmware contains an embedded, static RSA private key utilized by the Lighttpd web server for TLS termination. Exposure of this private key allows malicious actors to breach the confidentiality and integrity of HTTPS communications, enabling traffic decryption and server spoofing.
CVE-2026-18754	9.1	CRIT		0.003		The product firmware contains an embedded, static RSA private key utilized by the Lighttpd web server for TLS termination. Exposure of this private key allows malicious actors to breach the confidentiality and integrity of HTTPS communications, enabling traffic decryption and server spoofing.
CVE-2026-18924	9.1	CRIT		0.006		A flaw in libcurl's handling of HTTP/2 Server Push streams, when the parent handle is set to share connections with other handles, can lead to use-after-free in the cleanup process.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19646	9.1	CRIT				IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 could allow a remote attacker to redirect users to an arbitrary domain due to improper validation of the HTTP Host header.
CVE-2026-19874	9.1	CRIT		0.007		A heap-based buffer overflow vulnerability exists in Konami's Metal Gear Online 3, originating from improper validation of lobby data fields related to kicked players. The affected function processes a list of kicked player identifiers using the lobby data key "kick_num" to determine the number of entries, and individual kicked player IDs supplied via keys in the format "kicked_id_%i". The function does not valida...
CVE-2026-22590	9.1	CRIT		0.004		eprosima Fast DDS is a C++ implementation of the DDS (Data Distribution Service) standard of the OMG (Object Management Group). Versions prior to 2.6.12, 2.14.6, 3.2.4, 3.3.1, and 3.4.2 have a remotely triggerable Out-of-Bounds Read while processing RTPS `DATA_FRAG` submessages. An attacker can craft a `DATA_FRAG` with a large `sampleSize` but a small actual payload, and set `fragmentsInSubmessage` such that the r...
CVE-2026-2332	9.1	CRIT		0.013	eclipse:jetty	In Eclipse Jetty, the HTTP/1.1 parser is vulnerable to request smuggling when chunk extensions are used, similar to the "funky chunks" techniques outlined here: * https://w4ke.info/2025/06/18/funky-chunks.html * https://w4ke.info/2025/10/29/funky-chunks-2.html Jetty terminates chunk extension parsing at \r\n inside quoted strings instead of treating this as an error. POST / HTTP/1.1 Host: localhost Tr...
CVE-2026-27690	9.1	CRIT		0.007	sap:approuter	Due to an HTTP Request Smuggling vulnerability in SAP Approuter, an unauthenticated attacker could send a specially crafted HTTP request that leads to request-response desynchronization. This could result in the exposure of user responses and cause the system to become unavailable. This leads to a high impact on confidentiality and availability.
CVE-2026-27962	9.1	CRIT		0.005	authlib:authlib	Authlib is a Python library which builds OAuth and OpenID Connect servers. Prior to version 1.6.9, a JWK Header Injection vulnerability in authlib's JWS implementation allows an unauthenticated attacker to forge arbitrary JWT tokens that pass signature verification. When key=None is passed to any JWS deserialization function, the library extracts and uses the cryptographic key embedded in the attacker-controlled J...
CVE-2026-33186	9.1	CRIT		0.016	grpc:grpc	gRPC-Go is the Go language implementation of gRPC. Versions prior to 1.79.3 have an authorization bypass resulting from improper input validation of the HTTP/2 `:path` pseudo-header. The gRPC-Go server was too lenient in its routing logic, accepting requests where the `:path` omitted the mandatory leading slash (e.g., `Service/Method` instead of `/Service/Method`). While the server successfully routed these reques...
CVE-2026-39830	9.1	CRIT		0.006	golang:crypto	A malicious SSH peer could send unsolicited global request responses to fill an internal buffer, blocking the connection's read loop. The blocked goroutine could not be released by calling Close(), resulting in a resource leak per connection. Unsolicited global responses are now discarded.
CVE-2026-39832	9.1	CRIT		0.006	golang:crypto	When adding a key to a remote agent constraint extensions such as restrict-destination-v00@openssh.com were not serialized in the request. Destination restrictions were silently stripped when forwarding keys, allowing unrestricted use of the key on the remote host. The client now serializes all constraint extensions. Additionally, the in-memory keyring returned by NewKeyring() now rejects keys with unsupported con...
CVE-2026-41869	9.1	CRIT		0.002	apache:nutch	Missing Authorization, Improper Resource Shutdown and Job Interruption vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted users only. Please, also visit the Ap...
CVE-2026-42044	9.1	CRIT		0.006	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. From 1.0.0 to before 1.15.2, he Axios library is vulnerable to a Prototype Pollution "Gadget" attack that allows any Object.prototype pollution in the application's dependency tree to be escalated into surgical, invisible modification of all JSON API responses — including privilege escalation, balance manipulation, and authorization bypass. The defa...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-42508	9.1	CRIT		0.073	golang:crypto	Previously, a revoked 'SignatureKey' belonging to a CA was not correctly checked for revocation. Now, both the 'key' and 'key.SignatureKey' are checked for @revoked.
CVE-2026-42579	9.1	CRIT		0.01	netty:netty	Netty is an asynchronous, event-driven network application framework. Prior to 4.2.13.Final and 4.1.133.Final, Netty's DNS codec does not enforce RFC 1035 domain name constraints during either encoding or decoding. This creates a bidirectional attack surface: malicious DNS responses can exploit the decoder, and user-influenced hostnames can exploit the encoder. This vulnerability is fixed in 4.2.13.Final and 4.1.1...
CVE-2026-42584	9.1	CRIT		0.008	netty:netty	Netty is an asynchronous, event-driven network application framework. Prior to 4.2.13.Final and 4.1.133.Final, HttpClientCodec pairs each inbound response with an outbound request by queue.poll() once per response, including for 1xx. If the client pipelines GET then HEAD and the server sends 103, then 200 with GET body, then 200 for HEAD, the queue pairs HEAD with the first 200. The HEAD rule then skips reading th...
CVE-2026-45100	9.1	CRIT		0.007		OpenSIPS is a Session Initiation Protocol (SIP) server implementation. Versions 3.4.0-beta through 3.6.5 and 4.0.0-beta contain a buffer overflow in the {s.b64encode} string transformation. The size check for {s.b64encode} only verifies that the input fits within the 64 KB transformation buffer, but base64 encoding expands the data by roughly a third, so an input between about 49,153 and 65,535 bytes produces more...
CVE-2026-45537	9.1	CRIT		0.004		OpenSIPS is a Session Initiation Protocol (SIP) server implementation. In versions prior to 3.6.6 and 4.0.0-rc1, the construct_uri() function concatenates multiple URI components (protocol, username, domain, port, params) into a fixed 1024-byte global BSS buffer without any bounds checking. When a routing script calls construct_uri() with an attacker-controlled username, a combined component length exceeding 1024 ...
CVE-2026-45764	9.1	CRIT				Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a protocol change while processing HTTP/2 traffic could lead to type confusion in Suricata. Crafted traffic may cause Suricata to crash, resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a workaround, disable HTTP/2 parsing if it is not ...
CVE-2026-47702	9.1	CRIT		0.002		TypeBot is a chatbot builder tool. In version 3.16.1, API tokens (bearer credentials used to authenticate against the builder API) are stored in the database as cleartext strings. An attacker who gains read access to the database (e.g., via SQL injection, backup exposure, or insider access) can extract all API tokens and impersonate any user without requiring a password or multi-factor authentication. Version 3.17...
CVE-2026-48024	9.1	CRIT		0.008		Wazuh is a free and open source platform used for threat prevention, detection, and response. From 4.0.0 until 4.14.6 and 5.0.0-beta3, cluster.unmerge_info() in framework/wazuh/core/cluster/cluster.py constructs paths from peer-controlled merge_type and name values in a merged synchronization archive. process_files_from_worker() in framework/wazuh/core/cluster/master.py does not adequately confine the resulting pa...
CVE-2026-48031	9.1	CRIT		0.003		go-base is a Go RESTful API Boilerplate template with JWT Authentication, backed by PostgreSQL. In versions prior to 2026-05-18, the JWT signing secret is hardcoded to the known string "random", letting any attacker who reads the public repository forge tokens for arbitrary users, including admin roles, and completely bypass authentication on all protected endpoints. This value is set in two places: the dev.env te...
CVE-2026-48039	9.1	CRIT		0.003		Meta Ads MCP is a Model Context Protocol (MCP) server that lets AI assistants run Meta Ads. Prior to version 1.0.109, `AuthInjectionMiddleware.dispatch()` at `http_auth_integration.py:272` unconditionally forwards unauthenticated Streamable HTTP requests to downstream MCP tool handlers without issuing a `401` response, allowing any network-reachable caller to invoke MCP tools without authentication. When no per-re...
CVE-2026-48162	9.1	CRIT		0.006		Wazuh is a free and open source platform used for threat prevention, detection, and response. From 4.0.0 until 4.14.6 and 5.0.0-beta3, DistributedAPI.send_tmp_file() in framework/wazuh/core/cluster/dapi/dapi.py joins an attacker-controlled tmp_file value to WAZUH_PATH without canonicalization or confinement. A cluster peer holding the shared Fernet key can use traversal or an absolute path to make the master retur...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-49364	9.1	CRIT		0.002		An unauthenticated network-adjacent attacker can leverage discovery to capture cluster administrative credentials during the initial cluster connection handshake. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-49441	9.1	CRIT		0.005		Wazuh is a free and open source platform used for threat prevention, detection, and response. From 4.3.0 until 4.14.6 and 5.0.0-beta3, the non-merged branch of process_files_from_worker() in framework/wazuh/core/cluster/master.py trusts a peer-controlled file_path key from files_metadata.json. The destination is joined to WAZUH_PATH without proving that it remains inside the directory selected by cluster_item_key....
CVE-2026-49849	9.1	CRIT		0.009		xShop is an open-source shop developed in Laravel. An Unrestricted File Upload vulnerability in xShop version 3.0.3 allows an authenticated administrator to upload executable files (e.g., .php). By uploading a specially crafted php file, an attacker can achieve Remote Code Execution (RCE) on the server, leading to a full system compromise. Version 3.0.4 fixes the issue.
CVE-2026-50152	9.1	CRIT		0.002		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the Monitor subscription handler fails to properly authorize access to the configuration-key store, allowing any CephX user with only `mon allow r` capabilities to read the entire store by sending a single crafted MMonSubscribe message. The config-key store holds sensitive secrets...
CVE-2026-51346	9.1	CRIT		0.005		SQL Injection vulnerability in StudIP 6.0.x before 6.0.3 and 5.4.x before 5.4.12 allows a remote attacker to execute arbitrary code and obtain sensitive information via the store() functions.
CVE-2026-52723	9.1	CRIT		0.002		ePA 3.x Integration implements the authorization workflow and writes Medical Information Objects to Germany's electronic patient record. Prior to 1.3.0, ePA 3.x Integration performs VAU server certificate validation in app/vau/VAUProtokoll.py without anchoring the signed_vau_server_pub_keys and AUT_VAU_CertData certificate path to independent trusted material. A network-positioned attacker between the DiGA backend...
CVE-2026-52766	9.1	CRIT		0.003		YesWiki is a wiki system written in PHP. Prior to version 4.6.6, the {{erasespamedcomments}} wiki action (actions/EraseSpamedCommentsAction.php) accepts a suppr[] array from POST and deletes every wiki page whose tag appears in that array, with no authorization check anywhere in the action body or in the page-deletion path it invokes. Combined with YesWiki's allow-by-default action ACL model, any user who has page...
CVE-2026-53793	9.1	CRIT		0.004		rsync before 3.5.0 contains a path confinement bypass vulnerability that allows remote clients to escape the intended inner-module root confinement by constructing paths that resolve outside the chroot boundary when the module root contains a ./ boundary marker. Attackers can exploit improper handling of the ./ notation or forge delta-basis transfers referencing xname paths that cross the ./ boundary to gain un...
CVE-2026-53939	9.1	CRIT		0.002		OpenIDC/cjose is a C library implementing the Javascript Object Signing and Encryption (JOSE). In versions 0.6.1 through 0.6.2.5, when cjose encrypts a JWE using an AES-CBC-HMAC content-encryption algorithm (`A128CBC-HS256`, `A192CBC-HS384`, or `A256CBC-HS512`) together with any key-management algorithm that generates a fresh content-encryption key (CEK), the CEK is all zero bytes instead of being randomly generat...
CVE-2026-55247	9.1	CRIT		0.003		plone.app.event provides the event content type for Plone. Prior to versions 5.2.4 and 6.0.1, the iCalendar import in src/plone/app/event/ical/importer.py accepts insufficiently restricted calendar and event URLs, does not adequately bound downloaded bytes or imported events, and commits work per event. A logged-in editor can make the server request internal network resources or local calendar files, exhaust resou...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55248	9.1	CRIT		0.003		plone.app.portlets provides portlets and a Plone-specific user interface for plone.portlets. Prior to 5.0.8, 6.0.4, and 7.0.2, a member who can add an RSS portlet can set its feed URL to a very large response, causing src/plone/app/portlets/portlets/rss.py to download and retain excessive data in memory and deny service. The same RSS URL handling accepts internal hosts, IP addresses, single-word domains, and expli...
CVE-2026-55511	9.1	CRIT		0.007		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs allows a user with SystemPrivilege.ControlArchiving to create a double-quoted StreamSQL column name that is interpolated into generated Java source by Expression.fillCode_InputDefVars and Expression.sanitizeName. A sum aggregate reaches yamcs-core/src/main/java/org/yamcs/yarch/streamsql/CompilableAggregateExpression.java and yamcs-core/src/mai...
CVE-2026-55536	9.1	CRIT		0.003		PraisonAI is a multi-agent teams system. Prior to praisonai 4.6.58, Browser Server _handle_connection() checks Chrome extension origins with re.match() and the unanchored expression chrome-extension://[a-z0-9]{32}. Extra trailing characters pass before websocket.accept(), allowing start_session commands and unauthorized browser automation. This issue is fixed in version 4.6.58.
CVE-2026-55640	9.1	CRIT		0.005		Nextcloud MCP Server is a production-ready MCP server that connects AI assistants to a Nextcloud instance. Prior to 0.117.2, the POST /webhooks/nextcloud endpoint in nextcloud_mcp_server/vector/webhook_receiver.py has no authentication by default because WEBHOOK_SECRET defaults to None and startup validation does not require it. When WEBHOOK_SECRET is unset, handle_nextcloud_webhook() accepts unauthenticated reque...
CVE-2026-57499	9.1	CRIT		0.01		Liman is open source server management software. Prior to 2.2.2 - 1103, an OS command injection vulnerability in the log rotation configuration endpoint allows an authenticated administrator to execute arbitrary operating system commands on the Liman server. The `ip_address` parameter is embedded directly into a shell command without sanitization, enabling shell escape via single-quote injection. This is fixed in ...
CVE-2026-58400	9.1	CRIT		0.012		GeoNetwork is a catalog application to manage spatially referenced resources. Prior to versions 4.4.12 and 4.2.17, the Saxon XSLT processor used to render formatters is configured without secure processing (`FEATURE_SECURE_PROCESSING`) and without disabling Java extension functions (`ALLOW_EXTERNAL_FUNCTIONS`). Any stylesheet loaded by GeoNetwork can therefore invoke `java.lang.Runtime.exec()` or `java.lang.Proces...
CVE-2026-61800	9.1	CRIT		0.006		Wazuh is an open-source security platform providing unified XDR and SIEM protection for endpoints and cloud workloads. In versions 4.4.0 through 4.14.6, a party holding the cluster key can write, overwrite, or delete arbitrary files under /var/ossec on worker nodes, leading to remote code execution as root. During cluster file synchronization, the non-merged branch of update_master_files_in_worker() moves each sta...
CVE-2026-62646	9.1	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A session identifier is generated using an algorithm with insufficient randomness, resulting in a token with low entropy that can be predicted or brute-forced within a feasible number of attempts. This could allow an unauthenticated remote attacker to derive valid session identifiers and bypass authentication.
CVE-2026-62862	9.1	CRIT		0.005		Typebot is an open-source chatbot builder. In self-hosted versions up to and including 3.17.1, the default passwordless email magic-link authentication is vulnerable to login-code brute forcing that leads to account takeover. The email provider overrides NextAuth's default cryptographically secure token with a 6-digit code generated using Math.random(), reducing the keyspace to 900,000 with a 10-minute expiry, and...
CVE-2026-67593	9.1	CRIT		0.003		A remote attacker can craft an Openwire RemoveSubscriptionInfo command to cause the deletion of a queue on the Artemis broker before the connection authentication and authorization stage or at any time thereafter. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67598	9.1	CRIT		0.002		Emlog Pro through 2.6.23 contains a disabled TLS certificate validation vulnerability in include/service/ai.php that allows network-adjacent attackers to intercept outbound HTTPS requests to configured LLM providers by presenting arbitrary TLS certificates, as CURLOPT_SSL_VERIFYPEER and CURLOPT_SSL_VERIFYHOST are unconditionally disabled across sendStream(), sendImageRequest(), send(), and fetchSearchHtml() with n...
CVE-2026-69641	9.1	CRIT		0.008		Missing authorization in Microsoft Exchange Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-70452	9.1	CRIT		0.005		rsync 3.1.0 before 3.5.0 contains an access control bypass vulnerability that allows remote attackers to circumvent hosts deny rules by inducing DNS resolution failures during hostname-based access control evaluation. When a DNS lookup for a hostname-based deny rule fails, the daemon skips the rule rather than defaulting to a deny decision, enabling attackers who can trigger DNS failures to bypass module-level IP ...
CVE-2026-73069	9.1	CRIT		0.004		Twenty is an open-source CRM (customer relationship management) platform. Prior to 2.15.0, Twenty allowed a workspace administrator with the DATA_MODEL permission to supply settings.asExpression for the system TS_VECTOR field searchVector through PATCH /rest/metadata/fields/:id or the updateOneField GraphQL mutation, causing buildSqlColumnDefinition in packages/twenty-server/src/engine/twenty-orm/workspace-schema-...
CVE-2026-73253	9.1	CRIT		0.002		Mongoose is an embedded web server and network library. Prior to version 7.22, an on-path network attacker with a wildcard certificate for a parent domain can impersonate deeper subdomains to a client using the built-in TLS stack. The mg_tls_verify_cert_san() and mg_tls_verify_cert_cn() functions in src/tls_builtin.c call mg_match(), whose wildcard can cross DNS label boundaries, so a pattern such as *.example.com...
CVE-2026-73256	9.1	CRIT		0.004		Mongoose is an embedded web server and network library. Prior to 7.22, a remote unauthenticated attacker can exploit an HTTP/1.0 reverse-proxy deployment by sending a request with Transfer-Encoding: chunked and conflicting framing. The http_cb() function in src/http.c tests hm.proto.len with an impossible greater-than-eight condition even though mg_http_parse() requires an eight-byte protocol string, so is_http_1_...
CVE-2026-73257	9.1	CRIT		0.005		Mongoose is an embedded web server and network library. Priro to version 7.22, a remote unauthenticated attacker can send an HTTP request containing both Content-Length and Transfer-Encoding: chunked. The cl_count and te_count checks in the mg_http_parse() and http_cb() paths in src/http.c accept both headers and prioritize chunked encoding, while a Content-Length-preferring reverse proxy can use a different reque...
CVE-2026-73309	9.1	CRIT		0.005		XenForo before 2.3.13 contains an authentication bypass vulnerability in the OAuth2 token endpoint that allows unauthenticated attackers to obtain valid token pairs by submitting empty values for client_secret and code_verifier parameters. Attackers can exploit PHP truthy evaluation logic, which treats empty strings as false and skips client secret validation and PKCE code verifier validation, to exchange a valid ...
CVE-2026-73311	9.1	CRIT		0.004		XenForo before 2.3.13 contains an OAuth2 authorization code reuse vulnerability that allows attackers to obtain unauthorized token pairs by submitting a previously used authorization code. Attackers can exploit the failure to invalidate or mark authorization codes as consumed after initial token issuance to receive an independent token pair for the same user and scopes, bypassing the single-use guarantee of the OA...
CVE-2026-73312	9.1	CRIT		0.004		XenForo before 2.3.13 contains a refresh token replay vulnerability that allows attackers to reuse a refresh token multiple times by exploiting the failure to mark tokens as consumed when the parent access token has expired. Attackers can repeatedly submit the same refresh token to generate additional independent token pairs, achieving persistent unauthorized access for the token's full lifetime.
CVE-2026-73475	9.1	CRIT		0.002	centarro:commerce_paypal	Incorrect Authorization vulnerability in Drupal Commerce PayPal allows Forceful Browsing. This issue affects Commerce PayPal versions: from 0.0.0 to 1.12.0, from 2.0.0 to 2.1.3.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75156	9.1	CRIT		0.002		Apache Airflow FAB provider versions 3.7.3 through 3.8.0 do not validate the issuer or audience of Azure AD `id_token`s during OAuth login. Deployments are affected only when the FAB auth manager is configured with Azure AD as an OAuth provider. Because the signing keys are fetched from Microsoft's **multi-tenant** JWKS endpoint, an `id_token` minted in *any* Azure tenant — including one the attacker creates — pas...
CVE-2026-75160	9.1	CRIT		0.004		An issue in X-Serie Gateway Firmware V6_00_05 allows a remote attacker to escalate privileges via the endpoints /cgi-bin/wwwugw.cgi and /cgi-bin/ugwdownload.cgi.
CVE-2026-75340	9.1	CRIT		0.002		The device metadata import interface /device/instance/{productId}/property-metadata/import of jetlinks community 2.11 is vulnerable to Server-side request forgery (SSRF).
CVE-2026-75431	9.1	CRIT		0.008		PowerJob Server version 5.1.2 (and likely earlier) uses a predictable JWT signing key for HS256-based authentication. This allows a remote attacker to execute arbitrary code.
CVE-2026-75595	9.1	CRIT		0.003		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Fina and 4.2.17.Final, io.netty.handler.ssl.SslClientHelloHandler#decode checks the wrong offset before reading the four-byte TLS handshake header, so a ClientHello whose handshake header spans records can cause an IndexOutOfBoundsException and invoke select(ctx, null). This selects the default SslContext instead of the SNI-spec...
CVE-2026-75746	9.1	CRIT		0.011		ColdFusion is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-77337	9.1	CRIT		0.004		CakePHP Authentication is an authentication plugin for CakePHP that can also be used in PSR-7 based applications. Versions before 2.11.2, from 3.0.0 through 3.3.6, and from 4.0.0 through 4.2.0 allow authentication bypass and potential CPU or memory exhaustion when CookieAuthenticator uses unencrypted, forgeable legacy tokens. This issue is fixed in versions 2.11.2, 3.3.7, and 4.2.1.
CVE-2026-78327	9.1	CRIT		0.016		An Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in the SonicWall Network Security Manager (NSM) On-Prem Management interface allows an authenticated attacker with SuperAdmin privileges to inject arbitrary commands that are executed on the underlying host, resulting in remote code execution.
CVE-2026-78328	9.1	CRIT		0.005		A missing authorization vulnerability in the SonicWall Network Security Manager (NSM) On-Prem Management interface allows a lower-privileged Admin user to escalate privileges to SuperAdmin.
CVE-2026-78361	9.1	CRIT		0.001		The zipMoney(Zip Co) Payments Plugin for WooCommerce WordPress plugin before 2.4.0 does not perform any authorisation checks on one of its front-end request handlers, and does not restrict which option name a caller may supply, allowing unauthenticated users to delete arbitrary WordPress options. This can be used to destroy site and access control configuration, deactivate every installed zipMoney(Zip Co) Payments...
CVE-2026-79571	9.1	CRIT		0.003		Incorrect access control in the SellerAuthorizeAspect component of springboot-project v1.0.0 allows unauthenticated attackers to access all seller management interfaces and list all products/orders, put products on/off sale, finish/cancel orders, and modify categories without authentication.
CVE-2026-80164	9.1	CRIT		0.002	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to unauthorized access.
CVE-2026-80181	9.1	CRIT		0.004		Apache Allura's webhooks are vulnerable to Server-Side Request Forgery (SSRF). This issue affects Apache Allura: through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80424	9.1	CRIT				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.
CVE-2026-81468	9.1	CRIT				Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-81939	9.1	CRIT		0.007		A Zip Slip vulnerability in the SonicWall Network Security Manager (NSM) On-Prem file upload and archive processing functionality allows an attacker to extract files outside the intended destination directory using a specially crafted archive.
CVE-2026-84939	9.1	CRIT		0.002		Path traversal vulnerability in Apache FreeMarker template loading mechanism, if the attacker can specify an arbitrary malformed locale identifier to FreeMarker, and the localized lookup configuration setting is enabled (it's by default enabled). This issue affects Apache FreeMarker from 2.2.0 through 2.3.34. Users are recommended to upgrade to version 2.3.35. Disabling localized lookup in previous versions also...
CVE-2026-85043	9.1	CRIT		0.003	google:chrome	Incomplete cleanup in Network in Google Chrome prior to 152.0.7977.82 allowed a remote attacker to bypass system access restrictions via crafted network traffic. (Chromium security severity: High)
CVE-2026-85184	9.1	CRIT		0.003		@fastify/middie versions >= 9.1.0 and before 9.3.4 decide whether to run path-scoped middleware by matching against the raw request target, while the Fastify router resolves an absolute-form request target to its path before dispatching. Because the two layers evaluate different strings, a request using an absolute-form target reaches the route handler while the path-scoped middleware, such as authentication or au...
CVE-2026-86729	9.1	CRIT		0.002		WWBN AVideo through commit e01e41ecc (no patched version available) exposes get_api_preauthorize in plugin/API/API.php as a second, undocumented login path. Unlike get_api_signIn, which enforces a rate limit of 10 attempts per 5 minutes via checkRateLimit(), get_api_preauthorize performs the same credential check with no throttling for any client, allowing unlimited remote password guessing against arbitrary accou...
CVE-2026-86840	9.1	CRIT		0.001		The `vtoken-minting` and `slpx` pallets in Bifrost contain an improper authorization vulnerability in channel commission attribution. A signed account can supply an arbitrary registered `channel_id` when minting tokens without verifying that the caller is authorized to mint on behalf of that channel. This allows an attacker to inflate a channel's recorded mint volume and cause protocol commission payments to be di...
CVE-2026-87806	9.1	CRIT		0.003		Parse Server versions <= 8.6.87 and >= 9.0.0 < 9.10.1-alpha.7 contain an authentication bypass in the built-in LDAP authentication adapter. The adapter forwarded the client-supplied password to the directory without verifying that a password had been supplied, and treated any non-error response from the directory as proof of authentication. A zero-length credential turns an LDAP simple bind into the unauthenticate...
CVE-2026-88007	9.1	CRIT				Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authentication, and backend keep-alive, an unr...
CVE-2026-88044	9.1	CRIT				rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.70.0 until 1.75.1, the serve/start RC interface accepts per-server proxyOpt.AuthProxy settings, and the FTP and S3 constructors in cmd/serve/ftp/ftp.go and cmd/serve/s3/server.go incorrectly check the process-global proxy.Opt.AuthProxy value instead. When the global value is empty, the request-local...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-89043	9.1	CRIT				passport-saml-encrypted through 0.1.13 contains an XML signature wrapping vulnerability where signature verification and assertion extraction use independent XPath lookups with no cross-validation. Attackers holding any validly signed SAML message can prepend a forged unsigned assertion that gets accepted as the verified identity while the genuine signature validates against the original assertion.
CVE-2026-89086	9.1	CRIT				In the jose package before 0.11.0 for OCaml, library calls to validate an RSA signature only confirm that PKCS #1 decoding succeeds, and proceed to declare the signature valid without the required steps that involve the public key.
CVE-2025-54603	9.0	CRIT		0.007		An incorrect OIDC authentication flow in Claroty Secure Access 3.3.0 through 4.0.2 can result in unauthorized user creation or impersonation of existing OIDC users.
CVE-2026-10090	9.0	CRIT		0.004		A flaw was found in the Application Subscription controller (multicluster-operators-subscription) of Red Hat Advanced Cluster Management for Kubernetes (ACM). A user with namespace-scoped "edit" privileges in an ACM hub namespace can create a Channel resource pointing to a Helm repository they control and a Subscription resource referencing it. The app-subscription controller fetches and applies the Helm chart con...
CVE-2026-53581	9.0	CRIT		0.003		OPNsense is a FreeBSD based firewall and routing platform. Prior to version 26.1.9 of opnsense/core and version 26.4_20 of BE/opnsense/core, a path traversal vulnerability in the NTP configuration module allows an attacker to overwrite arbitrary files on the system as the root user. By manipulating the GPS or PPS serial port parameter, an attacker with access to the NTP configuration can escape the intended direct...
CVE-2026-62988	9.0	CRIT		0.007		Froxlor is open source server administration software. From 2.3.7 until 2.3.8, the Customers.get, Customers.listing, Admins.get, Admins.listing, Ftps.get, and Ftps.listing API commands in lib/Froxlor/Api/Commands/Customers.php, lib/Froxlor/Api/Commands/Admins.php, and lib/Froxlor/Api/Commands/Ftps.php retrieve full database rows and return them without removing password and data_2fa fields. An authenticated API ca...
CVE-2026-66768	9.0	CRIT		0.003		SAP GUI for Java does not correctly enforce the trust level policy for certain functions invoked from a connected backend system. A low-privileged attacker could exploit this weakness by manipulating a connected backend system to trigger affected functionality. This could allow arbitrary command execution on the victim's machine, leading to a high impact on the confidentiality, integrity, and availability of the a...
CVE-2026-67403	9.0	CRIT		0.002		Cash Collect contains an improper authorization vulnerability in the Sage AR Automation API. Insufficient tenant-level authorization checks allow authenticated users to access administrative resources belonging to other tenants by specifying a valid non predictable tenant identifier.
CVE-2026-68484	9.0	CRIT		0.002		Cash Collect contains an improper authorization vulnerability in the Sage AR Automation API. Administrative functions do not properly verify user privileges, allowing authenticated low-privileged users to create administrator accounts and obtain elevated privileges.
CVE-2026-69251	9.0	CRIT		0.017		Flowise is a drag & drop user interface to build a customized large language model flow. Prior to 3.1.3, Flowise record manager and agent memory nodes allowed users to set arbitrary TypeORM DataSource options through the additionalConfig input in packages/components/nodes/recordmanager/MySQLRecordManager/MySQLRecordManager.ts, packages/components/nodes/recordmanager/PostgresRecordManager/PostgresRecordManager.ts, ...
CVE-2026-69253	9.0	CRIT		0.003		Flowise is a drag-and-drop user interface for building customized large language model (LLM) flows. Prior to version 3.1.3, several custom-tool components — AgentAsTool, ChatflowTool, and ExecuteFlow — ran code in the in-process vm2 sandbox. To build that code, they inserted a user-controlled baseUrl value straight into the JavaScript source, for example const url = "\${baseUrl}/..."; . The only check on base...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69854	9.0	CRIT		0.006		Improper authentication in Spring Cloud Azure allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-71851	9.0	CRIT		0.003		crypto-js is a JavaScript library of crypto standards. Versions of crypto-js prior to 4.0.0 generate randomness in CryptoJS.lib.WordArray.random() using a custom variation of the Multiply-With-Carry pseudorandom number generator, seeded from Math.random(), instead of a cryptographically secure source. This generator was introduced in version 3.1.2-4 and remained present in nearly every 3.x release. Nominal request...
CVE-2026-73302	9.0	CRIT		0.004		Budibase is an open-source low-code platform. Prior to 3.39.30, the OIDC flow in packages/backend-core/src/middleware/passport/sso/oidc.ts resolved an email without getEmailVerified or an email_verified requirement, and packages/backend-core/src/middleware/passport/sso/sso.ts then used users.getGlobalUserByEmail as a fallback account-linking key. An attacker who can authenticate through a configured identity provi...
CVE-2026-73407	9.0	CRIT		0.005		Budibase is an open-source low-code platform. Prior to 3.40.1, RestIntegration._req in packages/server/src/integrations/rest.ts attached credentials from getAuthHeaders and defaultHeaders without requiring the final request destination to match the datasource origin. An unauthenticated caller of a PUBLIC POST /api/v2/queries/:queryId query could supply an absolute or parameterized path to an attacker-controlled ho...
CVE-2026-73842	9.0	CRIT		0.002		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.3, 1.1.3, and 1.2.0-rc.2, internal/cluster-gateway/server.go exposed /api/proxy/, /api/exec/, and /api/wirelogs/ on an internal listener without requiring a client certificate or token, allowing any network-reachable caller to read tenant Kubernetes Secrets, mutate workloads, and execute commands across connected data planes. Thi...
CVE-2026-75604	9.0	CRIT		0.025		Next.js is a React framework for building full-stack web applications. From 13.4.0 until 15.5.24 and 16.3.3, Next.js applications using Pages Router or App Router without Cache Components on Windows-hosted servers do not consistently escape backslashes in route segments before constructing incremental-cache paths. In packages/next/src/shared/lib/router/utils/escape-path-delimiters.ts and packages/next/src/server/l...
CVE-2026-82021	9.0	CRIT		0.002		Hermes Agent 0.18.2 prior to 0.19.0 contains a supply chain vulnerability in its bundled MCP catalog that allows a remote attacker to execute arbitrary code by compromising a third-party upstream repository referenced via a mutable branch rather than a pinned commit SHA. An attacker who compromises the upstream repository can propagate malicious code to every host that installs the affected catalog entry, with no ...
CVE-2026-85982	9.0	CRIT		0.002		The Auth0 AD/LDAP Connector is vulnerable to stored Cross-Site Scripting (XSS) issues due to improper HTML encoding of data in search results and updater log content displayed in the admin panel. An authenticated user with privileges to modify directory attributes, or a low-privileged local user on the host where the connector is installed, could insert script content. This script content could then execute in an ...
CVE-2026-86259	9.0	CRIT		0.003		OpenMAIC before 1.0.1 skips server-side request forgery validation in non-production builds, allowing unauthenticated attackers to reach cloud instance metadata services. Attackers can supply arbitrary provider URLs via the x-base-url header or baseUrl parameter to access sensitive cloud credentials and metadata.
CVE-2026-87613	9.0	CRIT		0.004	google:chrome	Incorrect reference resolution in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87911	9.0	CRIT		0.01		An OS command injection weakness in the read-only enforcement of the SQL validation component in Amazon awslabs postgres-mcp-server before 1.1.7 might allow an unauthenticated actor to execute operating system commands on the host of a self-managed PostgreSQL server by placing a crafted COPY ... TO PROGRAM statement into content that is processed when an authenticated user interacts with the MCP server in its defa...

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-30156	8.9	HIGH		0.001		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the CephX authentication protocol encrypts tickets with AES-128-CBC in an unauthenticated mode that uses a hard-coded initialization vector and no message authentication, allowing an attacker to forge credentials and gain cluster-wide access. Because the ciphertext is malleable and...
CVE-2026-21441	8.9	HIGH		0.03	python:urllib3	urllib3 is an HTTP client library for Python. urllib3's streaming API is designed for the efficient handling of large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once. urllib3 can perform decoding or decompression based on the HTTP `Content-Encoding` header (e.g., `gzip`, `deflate`, `br`, or `zstd`). When using the streaming API, the library decompre...
CVE-2026-44432	8.9	HIGH		0.007	python:urllib3	urllib3 is an HTTP client library for Python. From 2.6.0 to before 2.7.0, urllib3 could decompress the whole response instead of the requested portion (1) during the second HTTPResponse.read(amt=N) call when the response was decompressed using the official Brotli library or (2) when HTTPResponse.drain_conn() was called after the response had been read and decompressed partially (compression algorithm did not matte...
CVE-2026-5598	8.9	HIGH		0.009		Covert timing channel vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA core on all (core modules). This vulnerability is associated with program files FrodoEngine.Java. This issue affects BC-JAVA: from 1.71 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.
CVE-2026-16745	8.8	HIGH		0.005		A flaw was found in odh-dashboard, the web console component of Red Hat OpenShift AI (RHOAI). Due to incorrect network binding, a malicious actor within the cluster can bypass authentication and impersonate any user by providing an arbitrary access token. This allows an attacker to gain unauthorized access to the Kubernetes API, potentially leading to arbitrary code execution, privilege escalation, or information ...
CVE-2026-18341	8.8	HIGH		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to corrupt memory due to an integer underflow.
CVE-2026-18486	8.8	HIGH		0.003		IBM ContextForge MCP Gateway <= v1.0.7 MCP Context Forge could allow a remote authenticated attacker to obtain sensitive credentials and escalate privileges due to improper validation of jq filters.
CVE-2026-18617	8.8	HIGH		0.005		A flaw was found in the Data Science Pipelines Operator (DSPO). A namespace editor can exploit a vulnerability in the spec.database.customExtraParams field, which allows for the injection of dangerous parameters into the MySQL Data Source Name (DSN) string. By manipulating these parameters, an attacker can enable LOCAL INFILE functionality and exfiltrate sensitive files, such as the service account token, from the...
CVE-2026-19298	8.8	HIGH		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to execute arbitrary code due to an authorization bypass in the flow build process.
CVE-2026-19633	8.8	HIGH		0.004		PostgreSQL Anonymizer contains a vulnerability that allows unprivileged masked users to execute arbitrary code by abusing operators, domain casts, or view subqueries that carry untrusted expressions. When these objects are evaluated in the context of the extension's masking mechanisms, the malicious code can run with elevated privileges. The issue is fixed in PostgreSQL Anonymizer 3.1.4 and later versions
CVE-2026-27606	8.8	HIGH		0.015	rollupjs:rollup	Rollup is a module bundler for JavaScript. Versions prior to 2.80.0, 3.30.0, and 4.59.0 of the Rollup module bundler (specifically v4.x and present in current source) is vulnerable to an Arbitrary File Write via Path Traversal. Insecure file name sanitization in the core engine allows an attacker to control output filenames (e.g., via CLI named inputs, manual chunk aliases, or malicious plugins) and use traversal ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-28666	8.8	HIGH		0.002		In multiple functions of LocalImageResolver.java, there is a possible Remote Persistent Denial of Service due to a DNG image rendering check bypass. This could lead to remote escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-32590	8.8	HIGH		0.004	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay's handling of resumable container image layer uploads. The upload process stores intermediate data in the database using a format that, if tampered with, could allow an attacker to execute arbitrary code on the Quay server.
CVE-2026-33001	8.8	HIGH		0.011	jenkins:jenkins	Jenkins 2.554 and earlier, LTS 2.541.2 and earlier does not safely handle symbolic links during the extraction of .tar and .tar.gz archives, allowing crafted archives to write files to arbitrary locations on the filesystem, restricted only by file system access permissions of the user running Jenkins. This can be exploited to deploy malicious scripts or plugins on the controller by attackers with Item/Configure pe...
CVE-2026-39944	8.8	HIGH		0.002		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the RADOS Gateway (RGW) protects STS session tokens with an AES-128-CBC handler that provides no message authentication, allowing an attacker who holds any valid STS token to tamper with it undetected and escalate to full RGW administrative access. Because the ciphertext is unauth...
CVE-2026-40858	8.8	HIGH		0.009	apache:camel	The camel-infinispan component's ProtoStream-based remote aggregation repository deserializes data read from a remote Infinispan cache using java.io.ObjectInputStream without applying any ObjectInputFilter. An attacker who can write to the Infinispan cache used by a Camel application can inject a crafted serialized Java object that, when read during normal aggregation repository operations such as get or recover, ...
CVE-2026-41870	8.8	HIGH		0.004		Missing Authorization, Improper Control of Generation of Code ('Code Injection'), Improper Control of Dynamically-Managed Code Resources, Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.11 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Ser...
CVE-2026-43112	8.8	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: fs/smb/client: fix out-of-bounds read in cifs_sanitize_prepath When cifs_sanitize_prepath is called with an empty string or a string containing only delimiters (e.g., "/"), the current logic attempts to check *(cursor2 - 1) before cursor2 has advanced. This results in an out-of-bounds read. This patch adds an early exit check after stripping pr...
CVE-2026-44829	8.8	HIGH		0.004		Gotenberg is a Docker-powered stateless API for PDF files. In 8.32.0 and earlier, filename handling in pkg/modules/api/context.go uses filepath.Base on Linux, which does not treat backslashes as path separators, so a multipart filename containing Windows-style parent directory components survives sanitization. The original filename flows through ctx.diskToOriginal and the multi-output PDF routes into archives.File...
CVE-2026-48054	8.8	HIGH		0.004		OpenZeppelin Contracts Wizard is a web application to interactively build a contract out of components from OpenZeppelin Contracts. Versions prior to 0.10.9 generate a Hardhat test file ('test/test.ts') by interpolating user-supplied `opts.name` (ERC20/ERC721) and `opts.uri` (ERC1155) directly into TypeScript string literals at `zip-hardhat.ts:48` and `:50` without any JavaScript string escaping. No authentication ...
CVE-2026-49050	8.8	HIGH		0.003	apache:dolphinscheduler	General user can mint admin access tokens via /access-tokens This issue affects Apache DolphinScheduler: before 3.4.2. Users are recommended to upgrade to version 3.4.2, which fixes the issue.
CVE-2026-49255	8.8	HIGH		0.005		electerm is an open-sourced terminal/ssh/sftp/telnet/serialport/RDP/VNC/Spice/ftp client. Prior to 3.11.11, electerm constructs operating system commands in src/app/lib/fs.js by interpolating untrusted file paths into the rmrf(), mv(), and cp() functions. A malicious SSH or SFTP server can provide a filename containing quote characters and shell metacharacters, and a victim can cause that filename to reach the aff...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-49467	8.8	HIGH		0.004		Pingvin Share X is a secure and easy self-hosted file sharing platform. A vulnerability in versions 1.5.0 through 1.18.0 allow an attacker to bypass password verification when managing Time-based One-Time Password (TOTP) settings. The root cause is a missing `await` keyword on calls to the asynchronous `verifyPassword` method in `authTotp.service.ts` and the `authenticateUser` method in `auth.service.ts`. In JavaS...
CVE-2026-50191	8.8	HIGH		0.003		4gaBoards is a boards system for realtime project management. Prior to 3.3.8, 4gaBoards is vulnerable to pre-account takeover when registrationEnabled, localRegistrationEnabled, and ssoRegistrationEnabled are enabled and Google, GitHub, Microsoft, or OIDC SSO is configured. The POST /api/register endpoint permits creation of an unverified local account with a victim's email address, and POST /api/access-tokens per...
CVE-2026-51974	8.8	HIGH		0.004		An eval() injection vulnerability in the get_list function in modules/meta_parser.py in Ilyasviel Fooocus 2.1.854 through 2.5.5 allows remote attackers to execute arbitrary Python code via a crafted styles payload in the EXIF metadata of an uploaded image file.
CVE-2026-52691	8.8	HIGH		0.003		** UNSUPPORTED WHEN ASSIGNED ** Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Griffin Hive Metastore Module. This issue affects Apache Griffin Hive Metastore Module: all versions. As this project is retired, we do not plan to release a version that fixes this issue. Users are recommended to find an alternative or restrict access to the instance ...
CVE-2026-53071	8.8	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: Bluetooth: l2cap: Add missing chan lock in l2cap_ecred_reconf_rsp l2cap_ecred_reconf_rsp() calls l2cap_chan_del() without holding l2cap_chan_lock(). Every other l2cap_chan_del() caller in the file acquires the lock first. A remote BLE device can send a crafted L2CAP ECREd reconfiguration response to corrupt the channel list while another thread ...
CVE-2026-53277	8.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Take the SRCU lock for page table walks in fault injection and AT emulation walk_s1() and kvm_walk_nested_s2() expect to be called while holding kvm->srcu to guard against memslot changes. While this is generally the case, __kvm_at_s12() and __kvm_find_s1_desc_level() call into the respective walkers without taking kvm->srcu. Fix by...
CVE-2026-53322	8.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: vfio/pci: Clean up DMABUFs before disabling function On device shutdown, make vfio_pci_core_close_device() call vfio_pci_dma_buf_cleanup() before the function is disabled via vfio_pci_core_disable(). This ensures that all access via DMABUFs is revoked before the function's BARs become inaccessible. This fixes an issue where, if the function is...
CVE-2026-54099	8.8	HIGH		0.001	redhat:openshift_container_platform , redhat:windows_machine_config_operator	A flaw was found in the Windows Machine Config Operator (WMCO) for Red Hat OpenShift Container Platform. The WICD CSR auto-approver validates that a Certificate Signing Request contains the organization system:wicd-nodes but does not reject additional organization values such as system:masters. A compromised Windows worker node that holds WICD credentials can submit a CSR that is auto-approved and signed by the cl...
CVE-2026-55485	8.8	HIGH		0.004		Piccolo Admin is an admin interface and content management system for Python, built on top of Piccolo. Prior to 1.14.0, piccolo_admin/endpoints.py uses superuser_validators to block PUT, PATCH, DELETE, and POST requests by non-superusers but permits GET requests to configured user and session tables, while piccolo_api/session_auth/tables.py exposes SessionsBase.token because the token column is not secret. In depl...
CVE-2026-55509	8.8	HIGH		0.004		WsgiDAV is a generic and extendable WebDAV server based on WSGI. Prior to 4.3.5, the sample MySQLBrowserProvider in wsgidav/samples/mysql_dav_provider.py concatenates the record key parsed from a request URL directly into SQL WHERE clauses. The affected _exists_record_by_primary_key, _get_field_by_primary_key, and _get_record_by_primary_key methods are part of a shipped example provider that is not enabled by defa...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55521	8.8	HIGH		0.004		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs omits authorization checks in IndexesApi.listPacketIndex, IndexesApi.listEventIndex, Cop1Api.disable, Cop1Api.resume, Cop1Api.initialize, Cop1Api.updateConfig, and TimeApi.setTime. An authenticated low-privilege user can read packet and event index metadata without ObjectPrivilegeType.ReadPacket, alter COP-1 link state without SystemPrivilege....
CVE-2026-55585	8.8	HIGH		0.004		QWED is open-source AI verification infrastructure for deterministic verification of LLM outputs, tool calls, code, schemas, and agent state before production execution. Prior to 5.1.2, the qwed package passes caller-controlled math expressions directly to SymPy parse_expr() without restricted global_dict and local_dict namespaces, allowing Python eval() to resolve builtins and execute arbitrary Python code in the...
CVE-2026-55676	8.8	HIGH		0.003		Malcolm is a network traffic analysis tool suite. The file-upload component (FilePond PHP backend) accepts uploads at `POST /server/php/submit.php` and stores them in a directory served by the same nginx and php-fpm instance. The allow-list that should restrict accepted file types is an empty array by default (`file-upload/php/config.php:16`), so the type check is a no-op and every extension is accepted. The filen...
CVE-2026-57163	8.8	HIGH		0.003		PJSIP is a free and open source multimedia communication library written in C. Prior to commit c4a151a, a stack buffer overflow exists in the GnuTLS TLS backend when parsing the Subject Alternative Name extension of a peer certificate (tls_cert_get_info() in ssl_sock_gtls.c). Only GnuTLS builds are affected (--with-gnutls); OpenSSL and Apple SecureTransport/Network.framework builds are not affected. While extracti...
CVE-2026-57866	8.8	HIGH		0.002	apache:impala	Server side request forgery in Apache Impala versions 4.4.x and 4.5.x. Authenticated Impala users with permissions to execute the ai_generate_text() function can exfiltrate secrets provided by the credential providers configured in the `hadoop.security.credential.provider.path` property of `core-site.xml`. The secret's key must be known to the user.
CVE-2026-62316	8.8	HIGH		0.004		Microsoft UFO open-source framework for intelligent automation across devices and platforms. Prior to 3.0.8, ufo/client/mcp/http_servers/linux_mcp_server.py binds a FastMCP streamable HTTP server to localhost:8010 but does not validate the Host, Origin, or Sec-Fetch-Site headers. An attacker-controlled web page can use DNS rebinding to reach the local /mcp endpoint, enumerate tool schemas through tools/list, and i...
CVE-2026-62706	8.8	HIGH		0.006		Out-of-bounds read in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-62744	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-62895	8.8	HIGH		0.007		Permissive cross-domain policy with untrusted domains in Azure Arc allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-64364	8.8	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: HID: multitouch: fix out-of-bounds bit access on mt_io_flags mt_io_flags is a single unsigned long, but mt_process_slot(), mt_release_pending_palms() and mt_release_contacts() use it as a per-slot bitmap indexed by the slot number. That slot number is only bounded by td->maxcontacts, which is taken from the device's ContactCountMaximum feature r...
CVE-2026-65772	8.8	HIGH		0.009		Deserialization of untrusted data in Microsoft Dynamics 365 allows an authorized attacker to execute code over a network.
CVE-2026-69266	8.8	HIGH		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Integer overflow or wraparound in Windows DHCP Server allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69268	8.8	HIGH		0.007	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69273	8.8	HIGH		0.005	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69282	8.8	HIGH		0.005	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69285	8.8	HIGH		0.006	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69291	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69334	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69355	8.8	HIGH		0.008		External control of file name or path in Microsoft Exchange Server allows an authorized attacker to execute code over a network.
CVE-2026-69360	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69386	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69434	8.8	HIGH		0.008		Heap-based buffer overflow in Windows URL Moniker allows an unauthorized attacker to execute code over a network.
CVE-2026-69439	8.8	HIGH		0.007		Heap-based buffer overflow in .NET and Visual Studio allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-69442	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69461	8.8	HIGH		0.008		Stack-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code over a network.
CVE-2026-69464	8.8	HIGH		0.009	microsoft:sharepoint_server	Execution with unnecessary privileges in Microsoft Office SharePoint allows an authorized attacker to elevate privileges over a network.
CVE-2026-69465	8.8	HIGH		0.008	microsoft:sharepoint_server	Missing authorization in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69494	8.8	HIGH		0.008		Out-of-bounds read in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69495	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69499	8.8	HIGH		0.008		Integer overflow or wraparound in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-69511	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69518	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Remote Desktop allows an unauthorized attacker to execute code over a network.
CVE-2026-69529	8.8	HIGH		0.006	microsoft:365_apps, microsoft:access, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:off	Heap-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69547	8.8	HIGH		0.009		Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over a network.
CVE-2026-69551	8.8	HIGH		0.009		Use after free in Windows DNS allows an authorized attacker to execute code over a network.
CVE-2026-69556	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69598	8.8	HIGH		0.008		Incorrect calculation of buffer size in Windows iSCSI allows an unauthorized attacker to execute code over a network.
CVE-2026-69601	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69603	8.8	HIGH		0.003		Heap-based buffer overflow in Windows Hyper-V allows an authorized attacker to execute code locally.
CVE-2026-69614	8.8	HIGH		0.009	microsoft:365_apps, microsoft:access, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Stack-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69628	8.8	HIGH		0.009		Heap-based buffer overflow in Windows iSCSI allows an authorized attacker to execute code over a network.
CVE-2026-69629	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Heap-based buffer overflow in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69632	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Use after free in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69649	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Raw Image Extension allows an unauthorized attacker to execute code over a network.
CVE-2026-69669	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Kernel allows an unauthorized attacker to execute code over a network.
CVE-2026-69671	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69676	8.8	HIGH		0.012		Authentication bypass by capture-replay in Windows Kerberos allows an authorized attacker to execute code over a network.
CVE-2026-69678	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69686	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69712	8.8	HIGH		0.009		Use after free in Windows Key Distribution Center allows an authorized attacker to execute code over a network.
CVE-2026-69716	8.8	HIGH		0.009	microsoft:sharepoint_server	Improper neutralization of special elements used in an sql command ('sql injection') in Microsoft Office SharePoint allows an authorized attacker to elevate privileges over a network.
CVE-2026-69722	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69724	8.8	HIGH		0.008	microsoft:sharepoint_server	Missing authorization in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69729	8.8	HIGH		0.009		Heap-based buffer overflow in Windows Credential Providers allows an authorized attacker to execute code over a network.
CVE-2026-69740	8.8	HIGH		0.003		Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69742	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:publisher	Integer overflow or wraparound in Microsoft Office Publisher allows an unauthorized attacker to execute code over a network.
CVE-2026-69759	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69764	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsof	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69767	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69772	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Network File System allows an unauthorized attacker to execute code over a network.
CVE-2026-69778	8.8	HIGH		0.008	microsoft:365_apps, microsoft:access, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:off	Heap-based buffer overflow in Microsoft Office Access allows an unauthorized attacker to execute code over a network.
CVE-2026-69784	8.8	HIGH		0.003		Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69797	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69857	8.8	HIGH		0.004	microsoft:azure_cosmos_db	Authorization bypass through user-controlled key in Azure Cosmos DB allows an authorized attacker to perform spoofing over a network.
CVE-2026-69860	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-70178	8.8	HIGH		0.004	microsoft:fabric	Missing authorization in Microsoft Fabric allows an authorized attacker to elevate privileges over a network.
CVE-2026-70203	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Media Player allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70351	8.8	HIGH		0.008		Integer overflow or wraparound in Microsoft WebP Image Extension allows an unauthorized attacker to execute code over a network.
CVE-2026-70586	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Paint allows an unauthorized attacker to execute code over a network.
CVE-2026-71336	8.8	HIGH		0.009		Integer overflow or wraparound in Windows Work Folder Service allows an authorized attacker to execute code over a network.
CVE-2026-71352	8.8	HIGH		0.007		Integer underflow (wrap or wraparound) in Windows Remote Access Connection Manager allows an authorized attacker to execute code over a network.
CVE-2026-71808	8.8	HIGH		0.002		A SQL Injection vulnerability in Siam Ordering (siam-server) 1.0.0 allows remote authenticated attackers to execute arbitrary SQL commands via the \${} string concatenation in AdminMapper.java and multiple other Mapper files (including MerchantWithdrawRecordMapper.java and MemberWithdrawRecordMapper.java).
CVE-2026-72883	8.8	HIGH		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the WebSocket handlers in apps/dokploy/server/wss/terminal.ts, apps/dokploy/server/wss/docker-container-terminal.ts, apps/dokploy/server/wss/docker-container-logs.ts, and apps/dokploy/server/wss/docker-stats.ts validate organization membership but do not enforce checkServiceAccess, accessedServerIds, or accessedServices, allowing an a...
CVE-2026-72933	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft WDAC OLE DB provider for SQL allows an unauthorized attacker to execute code over a network.
CVE-2026-72940	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Schannel allows an unauthorized attacker to execute code over a network.
CVE-2026-72950	8.8	HIGH		0.009		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-72959	8.8	HIGH		0.009		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-72960	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Media Player allows an unauthorized attacker to execute code over a network.
CVE-2026-72972	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-72973	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-73006	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73012	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Management Services allows an authorized attacker to elevate privileges over a network.
CVE-2026-73013	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73016	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73023	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73222	8.8	HIGH		0.002		Claude Code Templates is a CLI tool for configuring and monitoring Claude Code. Prior to 1.29.4, the Claude Code Studio server launched by the --studio option in cli-tool/src/sandbox-server.js binds to all interfaces on port 3444, permits cross-origin requests, and requires no authentication. The POST /api/execute endpoint passes the prompt request-body field to executeLocalTask(), and POST /api/install-agent pass...
CVE-2026-73667	8.8	HIGH		0.006		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.4, 1.1.4, and 1.2.0-rc.2, OpenChoreo Workflow Plane templates under samples/getting-started/workflow-templates/ interpolated developer-controlled workflow parameters into shell program text executed through sh -c instead of passing the values through container.env, allowing arbitrary commands to run in workflow pods while affecte...
CVE-2026-73841	8.8	HIGH		0.005		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.1.6 and 1.2.3, internal/openchoreo-api/api/handlers/exec.go and internal/openchoreo-api/api/handlers/wirelogs.go authorize component:exec and wirelogs:view using the caller-supplied project query parameter instead of comp.Spec.Owner.ProjectName, allowing a user with a project-scoped grant to execute commands in and read wirelogs fr...
CVE-2026-75624	8.8	HIGH				IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.27 could allow a remote authenticated attacker to bypass security restrictions due to incorrect authorization.
CVE-2026-75777	8.8	HIGH				IBM Aspera Enterprise WebApps 1.0.0 through 1.0.5 could allow a local attacker to escape container protections due to unrestricted system calls being permitted within the container.
CVE-2026-76059	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 An attacker who could submit custom component source code could bypass the static security scanner by crafting an annotated class-body assignment that resolved to a dangerous callable through alias tracking; the resolved value was never checked against the dangerous callable blacklist due to the logic error. If the crafted component reached the runtime execution path, the atta...
CVE-2026-77495	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-77504	8.8	HIGH		0.006		Double free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-77901	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Null pointer dereference in Microsoft Office Word allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77907	8.8	HIGH		0.006	microsoft:visual_studio_2026	Heap-based buffer overflow in Visual Studio allows an unauthorized attacker to execute code over a network.
CVE-2026-77908	8.8	HIGH		0.007		Improper control of generation of code ('code injection') in Microsoft Dynamics 365 allows an authorized attacker to execute code over a network.
CVE-2026-78439	8.8	HIGH		0.006		Stack-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-78442	8.8	HIGH		0.006		Heap-based buffer overflow in Windows OLE DB allows an unauthorized attacker to execute code over a network.
CVE-2026-78504	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78505	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78507	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Use after free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78511	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78512	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Numeric truncation error in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78514	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78517	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78518	8.8	HIGH		0.009	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code over a network.
CVE-2026-78519	8.8	HIGH		0.006	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Use of uninitialized resource in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78521	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78524	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds write in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78525	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78526	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78569	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow an authenticated attacker to execute arbitrary code due to an incomplete denylist in the security scanner.
CVE-2026-78571	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an unguarded eval() call on attacker-controlled input.
CVE-2026-78575	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary commands due to improper validation of command-line arguments in the MCP stdio server configuration.
CVE-2026-79742	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an incomplete environment variable blocklist.
CVE-2026-80080	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Double free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80081	8.8	HIGH		0.005	microsoft:365_apps	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-80083	8.8	HIGH		0.002	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Hyper-V allows an authorized attacker to execute code locally.
CVE-2026-80085	8.8	HIGH		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-80096	8.8	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Services allows an authorized attacker to elevate privileges over a network.
CVE-2026-80914	8.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: Bluetooth: ISO: fix use-after-free of listener socket in iso_conn_ready iso_conn_ready() looks up the BIS listener socket with iso_get_sock(), which takes a reference, and then, without re-checking its state, creates a child socket from it: parent = iso_get_sock(hdev, ...); if (!parent) return; lock_sock(parent); sk = i...
CVE-2026-80921	8.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: KVM: s390: vsie: zero stale crypto bits When shadowing crypto access bits from a format0 apcb (crycb 0 or 1), the bits 64..255 are unchanged from whatever is in the vsie page in the crycb and thus in the apcb. This gives a nested guest potential access to a device no longer available. Zero out the remaining bits.
CVE-2026-81211	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary Python code due to improper authorization of custom components in stored flows.
CVE-2026-81352	8.8	HIGH		0.005		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code over a network.
CVE-2026-81385	8.8	HIGH		0.01	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:publisher	Deserialization of untrusted data in Microsoft Office Publisher allows an unauthorized attacker to execute code over a network.
CVE-2026-81550	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-81551	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to arbitrarily write to or delete files on shared storage due to a path traversal vulnerability.
CVE-2026-81554	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-81940	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special characters in flow display names.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81941	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 allows an authenticated non-administrative user could execute arbitrary operating system commands on the server at the privilege level of the application process by constructing a flow with an MCP Tools component configured to use a local stdio subprocess transport. This bypasses both the LANGFLOW_CUSTOM_COMPONENT_ADMIN_ONLY and LANGFLOW_BLOCK_CODE_INTERPRETER_COMPONENTS serve...
CVE-2026-81952	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-81955	8.8	HIGH		0.006		Heap-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-81996	8.8	HIGH		0.001	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Incorrect Authorization vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82092	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-82095	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-82097	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to a Server-Side Request Forgery (SSRF) vulnerability.
CVE-2026-82098	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-82099	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-83992	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-83996	8.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-84889	8.8	HIGH				IBM Langflow OSS 1.0.0 through 1.10.3 could allow a remote authenticated attacker to execute arbitrary code due to improper limitation of a pathname to a restricted directory.
CVE-2026-85228	8.8	HIGH				An integer overflow in the tensor buffer validation component in Amazon Deep Java Library (DJL) from 0.13.0 through 0.36.0 on all platforms might allow a remote unauthenticated actor to obtain information from adjacent process memory or cause a denial of service via a crafted tensor payload. To remediate this issue, users should upgrade to version 0.37.0 or above.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85677	8.8	HIGH				The Gutenverse News WordPress plugin before 3.3.3 does not restrict the extra HTML it adds to WordPress's allowed elements to the context it is meant for, applying the same relaxed list to every sanitisation context including untrusted comments, allowing unauthenticated users to store JavaScript that will execute in the browser of any administrator who reviews the comment queue, and of any visitor to the post onc...
CVE-2026-85877	8.8	HIGH		0.004	microsoft:windows_11_24h2	Heap-based buffer overflow in Windows Print Spooler Components allows an unauthorized attacker to execute code over a network.
CVE-2026-87585	8.8	HIGH		0.003	google:chrome, microsoft:windows	Double free in PDFium in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code inside the sandbox via a crafted PDF file. (Chromium security severity: High)
CVE-2020-37267	8.7	HIGH		0.003		Renovate versions >=19.180.0 and <23.25.1, when used with Azure DevOps, may expose the bot's authorization token in server or pipeline logs because the git http.extraheader=AUTHORIZATION parameter is logged without redaction. Anyone with access to saved logs could obtain the bot credentials. Fixed in 23.25.1; Azure DevOps users should revoke and regenerate credentials if logs may have been exposed.
CVE-2022-50997	8.7	HIGH		0.005		Weaver (Fanwei) E-cology 8.0 and 9.0 contains a SQL injection vulnerability in the HrCareerApplyPerView.jsp endpoint that allows unauthenticated remote attackers to extract arbitrary data from the backend database by manipulating the id GET parameter. Attackers can send a single crafted GET request with UNION-based injection payloads through the unsanitized id parameter to retrieve arbitrary data from the Microso...
CVE-2024-58374	8.7	HIGH		0.005		Hongjing e-HR contains an unauthenticated SQL injection vulnerability in the getSdutyTree servlet endpoint that allows remote unauthenticated attackers to access protected resources by supplying a path traversal sequence in the request URI to bypass the oauthservlet authentication filter. Attackers can inject UNION-based SQL payloads through the unsanitized codeitemid parameter into the underlying Microsoft SQL Se...
CVE-2026-10143	8.7	HIGH		0.005	dcpk:kafka-python	kafka-python prior to 2.3.2 contains a denial-of-service vulnerability in SCRAM authentication handling that allows a malicious or machine-in-the-middle broker to freeze the client event loop by supplying an excessively large iteration count. In scram.py, ScramClient.process_server_first_message() passes the broker-controlled SCRAM iteration count directly to hashlib.pbkdf2_hmac() without validation, blocking prod...
CVE-2026-16174	8.7	HIGH				Netskope was notified about a potential gap in Netskope Endpoint DLP (EPDLP) running on Windows systems. Successful exploitation of the gap could potentially allow a privileged user to send a crafted message to the EPDLP process port to trigger an integer overflow, leading to memory corruption. Successful exploitation would require the EPDLP module to be enabled in the client configuration, and that Memory Integri...
CVE-2026-18608	8.7	HIGH		0.005		A flaw was found in the Data Science Pipelines Operator (DSPO). The operator's ClusterRole, which defines its permissions, includes extensive privileges beyond what is necessary for its operation. These excessive permissions, such as the ability to execute commands within pods and manage cluster-wide roles, could be exploited. If the DSPO pod were compromised, an attacker could leverage these privileges to gain fu...
CVE-2026-3505	8.7	HIGH		0.008		Allocation of resources without limits or throttling, Uncontrolled Resource Consumption vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcpg on all (pg modules). This vulnerability is associated with program files AEADEncDataPacket.Java, BcAEADUtil.Java, JceAEADUtil.Java, OperatorHelper.Java. This issue affects BC-JAVA: from 1.74 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.
CVE-2026-40192	8.7	HIGH		0.007	python:pillow	Pillow is a Python imaging library. Versions 10.3.0 through 12.1.1 did not limit the amount of GZIP-compressed data read when decoding a FITS image, making them vulnerable to decompression bomb attacks. A specially crafted FITS file could cause unbounded memory consumption, leading to denial of service (OOM crash or severe performance degradation). If users are unable to immediately upgrade, they should only open ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-41674	8.7	HIGH		0.005		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) `DOMParser` and `XMLSerializer` module. In @xmldom/xmldom prior to versions 0.9.10 and 0.8.13 and xmldom version 0.6.0 and prior, the package serializes DocumentType node fields (internalSubset, publicId, systemId) verbatim without any escaping or validation. When these fields are set programmatically to attacker-controlled strings, XMLSerialize...
CVE-2026-44494	8.7	HIGH		0.01	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. From 1.0.0 to before 1.16.0, the Axios library is vulnerable to a Prototype Pollution "Gadget" attack that allows any Object.prototype pollution in the application's dependency tree to be escalated into a full Man-in-the-Middle (MITM) attack — intercepting, reading, and modifying all HTTP traffic including authentication credentials. The HTTP adapte...
CVE-2026-45115	8.7	HIGH		0.003		MyBB is free and open source forum software. Prior to 1.8.40, the Buddy/Ignore component does not sanitize usernames correctly, allowing attackers to perform JavaScript code injection through a specially crafted username. The User CP Buddy/Ignore list and the Select Buddies list in Private Messages pass usernames through htmlspecialchars_uni(), which may leave single quotes unescaped. The payload is triggered when...
CVE-2026-45116	8.7	HIGH		0.003		MyBB is free and open source forum software. Prior to 1.8.40, the user datahandler does not properly validate checkbox and multiselect profile field types, resulting in stored JavaScript code injection. UserDataHandler::verify_profile_fields() only performs the specialized validation when is_array(\$profile_fields[\$field]) is true. A non-array profile_fields[fidX] value instead of the expected profile_fields[fidX][...
CVE-2026-47683	8.7	HIGH		0.004		vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.6, the bufferAllocLimit enforcement in lib/setup-sandbox.js does not cover Buffer.concat(list, totalLength) or Buffer.from(arrayLike) with an attacker-controlled length, allowing sandbox code to perform large synchronous host external-memory allocations that bypass the configured cap and can exhaust the host process. This issue is fixed in version 3.11.6.
CVE-2026-47879	8.7	HIGH		0.002	vmware:spring_cloud_gateway	Spring Cloud Gateway JsonToGrpcGatewayFilterFactory allows arbitrary Spring Resource locations for defining the proto descriptor. Spring Cloud Gateway 5.0.0 - 5.0.2 Spring Cloud Gateway 4.3.0 - 4.3.5 Spring Cloud Gateway 4.0.0 - 4.2.9 Spring Cloud Gateway 3.1.13 and earlier
CVE-2026-48006	8.7	HIGH		0.007	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, the RedisArrayAggregator handler permanently leaks pooled direct-memory buffers when a Redis pipeline connection closes before a RESP array aggregate completes. The handler retains child messages in per-handler state (`depths` field) but defines no `channelInactive`, `handlerR...
CVE-2026-48026	8.7	HIGH		0.002		lakeFS is an open-source tool that transforms object storage into a Git-like repositories. Prior to version 1.81.1 of the open source edition and 1.84.0 of the enterprise edition, lakeFS Web UI renders markdown files from repository objects without sanitizing the resulting HTML. A user with write access to any repository branch can commit a `.md` object containing arbitrary HTML/JavaScript. Any other user who open...
CVE-2026-49478	8.7	HIGH		0.002		Fulcio is a certificate authority for issuing code signing certificates for an OpenID Connect (OIDC) identity. Versions through 1.8.5 improperly follow cross-host redirects and attach Kubernetes ServiceAccount tokens during OIDC discovery, allowing a malicious or compromised issuer to perform blind SSRF, substitute and cache malicious JWKS keys, or disclose ServiceAccount tokens to external hosts. Version 1.8.6 bl...
CVE-2026-54347	8.7	HIGH		0.004		Froxlol is open source server administration software. Prior to 2.3.8, DNS TXT record content accepted by lib/Froxlol/Api/Commands/DomainZones.php can contain HTML special characters, lib/Froxlol/UI/Callbacks/Text.php returns the content from Text::wordwrap without HTML escaping, and templates/Froxlol/table/table.html.twig renders the callback result with the raw filter. An authenticated customer with DNS editor a...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54722	8.7	HIGH		0.003		DSSRF is a Node.js library that provides a wide range of utilities and advanced SSRF defense checks. Prior to 1.0.4, is_url_safe in src/helpers.ts strips the @ userinfo delimiter with remove_at_symbol_in_string before new URL parses the URL, allowing an attacker-controlled URL to bypass internal-IP validation and cause a client using the original URL to reach an internal service. This issue is fixed in version 1.0.4.
CVE-2026-54729	8.7	HIGH		0.003		DSSRF is a Node.js library that provides a wide range of utilities and advanced SSRF defense checks. Prior to 1.0.5, is_url_safe can treat localhost as safe when DNS resolver 1.1.1.1 returns NXDOMAIN because dns.resolve4 yields no address and no dns.lookup fallback occurs, allowing server-side request forgery. This issue is fixed in version 1.0.5.
CVE-2026-55100	8.7	HIGH		0.004		hashi-vault-js is a Node.js module for interacting with the HashiCorp Vault API. Prior to 0.5.2, src/Vault.js concatenates unencoded identifier values including name, username, group, role, and version into Vault request paths and query strings instead of using encodeURIComponent() and URLSearchParams, allowing path traversal and query parameter injection. This issue is fixed in version 0.5.2.
CVE-2026-55250	8.7	HIGH		0.006		Marvel, a PHP framework oriented towards dependency injection, prior to version 10.74.0 has a high-severity Token Replay Vulnerability arising from a structural lifecycle mismatch between stateless token validation engines and high-performance relational caching layers. Any application with low cache memory that causes premature eviction to free up memory and applications running macropay-solutions/maravel-framework...
CVE-2026-59643	8.7	HIGH		0.002	bouncycastle:bc-java, bouncycastle:bcpg-fips	In Bouncy Castle for Java before 1.85, OpenPGP inline-signature policy failures silently ignored. This issue also affects Bouncy Castle for Java FIPS (BC-FJA) before bcpg-fips 2.0.13.
CVE-2026-61556	8.7	HIGH		0.004		LiquidJS is a Shopify / GitHub Pages compatible template engine in pure JavaScript. From 10.26.0 until 10.27.1, the strip_html filter in src/filters/html.ts can enter an infinite loop when an input string contains <, includes at least one preceding character, and has no later >. In strip_html, the search for the next opener advances lt while the loop index remains unchanged when the closer search returns -1, and t...
CVE-2026-62243	8.7	HIGH		0.002		Netty (io.netty:netty-handler) versions from 4.2.0.Final through 4.2.16.Final and versions through 4.1.136.Final disable TLS hostname verification on the SslProvider.OPENSSL client path when a plain (non-extended) X509TrustManager is used and Unsafe-based trust-manager wrapping is unavailable (Java 25+). In this configuration the OpenSSL client does not perform hostname verification, allowing a man-in-the-middle a...
CVE-2026-67195	8.7	HIGH		0.012		Perspective 5.0.0 contains a remote code execution vulnerability that allows unauthenticated attackers to execute arbitrary operating system commands by submitting crafted expression strings to the PolarsVirtualServer backend, which passes client-supplied input directly to Python's eval() with only __builtins__={} cleared. Attackers can exploit Python object attribute traversal through the interpreter's loaded cla...
CVE-2026-68494	8.7	HIGH		0.004		The fix released in jackson-core 2.18.6 and 2.21.1 for CVE-2026-18401 (GHSA-72hv-8253-57qq, number length constraint bypass in the non-blocking parser) is incomplete. This record covers the remaining bypass. The earlier fix wired validateIntegerLength() into a new _setIntLength() helper and invoked it wherever the integer portion of a number is decided: a terminator byte arrives, a '.' or 'e'/'E' is seen, or inpu...
CVE-2026-68899	8.7	HIGH		0.004		Wekan is open source kanban built with Meteor. Prior to 9.90, isValid() in models/fileValidation.js used the Unix file command for content-based MIME detection, but detectMimeFromFile() silently returned undefined when that binary was unavailable and the validation fell back to the attacker-controlled fileObj.type supplied through server/routes/attachmentApi.js. On deployments with WITH_API=true and no file bi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69096	8.7	HIGH		0.017		OpenWrt luci-app-dockerman (LuCI master and openwrt-25.12 snapshots containing the ucode docker_rpc.uc RPC backend after the JS/ucode conversion) contains an OS command injection vulnerability. The package's read ACL grants broad ubus access to docker.* / docker.container.*, which exposes the docker.container.ttyd_start method even though it performs mutating operations. The run_ttyd handler builds a shell command...
CVE-2026-69220	8.7	HIGH		0.004		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.33.1, src/main/java/com/rabbitmq/client/impl/ValueReader.java permits ValueReader.readTable and ValueReader.readArray to call ValueReader.readFieldValue recursively for AMQP table type F and AMQP array type A values without a nesting-depth limit. A malicious AMQP server or network inte...
CVE-2026-69249	8.7	HIGH		0.003		python-cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. In versions 42.0.0 through 48.0.0, when resolving invalid certificate chains that include duplicate copies of self-signed certificates, the processing recursively invokes the same candidate, leading to an exponential blowup. Although the limitation that the chain depth cannot exceed a specified maximum de...
CVE-2026-71491	8.7	HIGH		0.003		sqlparse is a non-validating SQL parser module for Python. Prior to 0.6.0, group_comments in sqlparse/engine/grouping.py repeatedly rescans comment-only statements before the MAX_GROUPING_TOKENS guard, causing quadratic CPU consumption through sqlparse.parse() and sqlparse.format(sql, strip_comments=True). This issue is fixed in version 0.6.0.
CVE-2026-72870	8.7	HIGH		0.003		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the buildRemoteDocker() function in packages/server/src/utls/providers/docker.ts interpolates the application-controlled dockerImage value directly into a docker pull shell command. An authenticated user with project access can set a crafted dockerImage through application.update and trigger application.deploy, causing execAsync() to...
CVE-2026-72884	8.7	HIGH		0.004		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, sanitizeCommand in packages/server/src/utls/builders/compose.ts only trims whitespace and strips surrounding quotes from compose.command before exportEnvCommand and docker command interpolation, allowing an authenticated user who can update a Compose service to inject shell metacharacters and execute arbitrary commands on the Dokploy...
CVE-2026-73413	8.7	HIGH		0.003		Shescape is a simple shell escape library for JavaScript. From 2.1.11 until 2.1.14 and 3.0.1, the flag-protection loop in compose in src/internal/compose.js repeatedly joins and slices flag fragments when flagProtection is enabled, which is the default, making processing quadratic in input size across the escape, escapeAll, quote, and quoteAll APIs. An attacker who can supply a large untrusted input containing man...
CVE-2026-74787	8.7	HIGH		0.003		Scriban before 7.0.0 contains an uncontrolled recursion vulnerability in the object.to_json builtin function that lacks depth limits and circular reference detection. Attackers can craft templates with self-referencing objects to trigger unbounded recursion, causing a StackOverflowException that fatally terminates the hosting .NET process.
CVE-2026-75133	8.7	HIGH		0.003		Keep Backup Daily plugin for WordPress before 2.1.4 contains a sensitive information exposure vulnerability that allows unauthenticated attackers to trigger a full MySQL database dump by accessing the publicly exposed `kbd_cron_process` parameter without authentication. Attackers can predict the partially predictable dump filename based on the database name, a limited random range, and the current Unix timestamp t...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75596	8.7	HIGH		0.004		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Final and 4.2.17.Final, the default io.netty.handler.ssl.SniHandler constructors use the pre-handshake ClientHello aggregation path in handler/src/main/java/io/netty/handler/ssl/SslClientHelloHandler.java at io.netty.handler.ssl.SslClientHelloHandler#decode, where handshakeBuffer.clear() and writeBytes() recopy all previously re...
CVE-2026-75840	8.7	HIGH		0.004		ArcadeDB before 26.8.1 contains an arbitrary file read vulnerability in the GraalVM JavaScript sandbox allowlist enforcement, which uses unescaped regular expressions to validate package names. Attackers with trigger creation privileges can use Java.type() to access java.util.zip.ZipFile or java.util.jar.JarFile classes and read arbitrary files on the host system as the ArcadeDB server process.
CVE-2026-75915	8.7	HIGH		0.006		CodeWhale versions before 0.8.64 contain an environment variable exposure vulnerability in the js_execution tool that fails to scrub parent process environment variables before spawning Node.js. Attackers can craft malicious JavaScript code executed by the tool to read process.env and leak API keys, cloud credentials, and authentication tokens back to the model context.
CVE-2026-76224	8.7	HIGH		0.006		ArcadeDB before 26.8.1 (arcadedb-gremlin, affected <= 26.7.3) contains a remote code execution vulnerability in its Gremlin query engine. Although the engine defaults to the documented-secure java (gremlin-lang) engine, ArcadeGremlin.executeStatement() silently falls back to the insecure Groovy engine whenever a request carries any query parameter and the query does not parse as gremlin-lang. An authenticated user...
CVE-2026-77101	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a stack-based buffer overflow issue affecting service availability. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77102	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a heap-based buffer overflow issue affecting service availability. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77103	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained an authentication bypass issue affecting access authorization and information disclosure. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77105	8.7	HIGH		0.002	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a cryptographic signature verification issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update CommServe and Web Server.
CVE-2026-77357	8.7	HIGH		0.003		Mesop is a Python-based UI framework that allows users to build web applications. Prior to 1.3.3, applications running in debug mode expose a GET /hot-reload endpoint whose unbounded loop depends on the user-supplied counter parameter, allowing an unauthenticated attacker to hold worker threads with high counter values until the worker pool is exhausted and the server becomes unavailable. A single unauthenticated ...
CVE-2026-79707	8.7	HIGH		0.004		A Path Traversal vulnerability in the builder endpoint in Google Cloud Agent Development Kit (ADK) versions 1.9.0 through 1.21.0 on Python allows an unauthenticated remote attacker to read arbitrary files using a crafted file_path query parameter.
CVE-2026-79756	8.7	HIGH		0.051		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.17.4, the fix for unauthenticated OS command injection in the nuclio dashboard on the local/Docker platform is incomplete. The fix added validateFunctionName for function names and common.Quote() for the named-resource shell command path, but the list-all resource path (triggered when no specific resource name is provid...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82064	8.7	HIGH		0.003		A security issue in MongoDB Server allows an unauthenticated network user to cause a denial of service on a specific type of replica set member. The server contains an assertion in its read concern processing logic that can be reached without authentication, and the assertion's assumptions about internal state do not hold for all member configurations, causing the server process to terminate.
CVE-2026-82075	8.7	HIGH		0.003		An uncontrolled resource consumption weakness exists in the request-handling path of the MongoDB sharded-cluster router process. A client that has network access to a router port and has not authenticated can supply connection-monitoring parameters that cause the server to expend CPU resources without any rate limiting, degrading or denying service to legitimate clients. No authentication, elevated privileges, or ...
CVE-2026-83605	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.14 and 0.9.11, and in xmldom version 0.6.0 and earlier, Element.setAttribute() calls the private _createAttribute(name) path without validating the attribute name, while Document.createAttribute(name) validates against QName. XMLSerializer.serializeToString() emits attribut...
CVE-2026-83606	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.0-beta.9 until 0.9.11, the processing-instruction production in lib/grammar.js lets the greedy S+ separator and lazy Char*? data group repeatedly repartition a long whitespace tail when the required closing ?> is absent. Both parsePI and parseProcessingInstruction apply the expression to the entire re...
CVE-2026-83607	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.14 and 0.9.11, and in xmldom version 0.6.0 and earlier, Document.createElement(tagName) stores an unvalidated element name and XMLSerializer.serializeToString() emits that name verbatim. The requireWellFormed: true path did not validate the element qualified name or synthes...
CVE-2026-83608	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, the DOCUMENT_TYPE_NODE branch in lib/dom.js validates publicId, systemId, and internalSubset under requireWellFormed: true but emits DocumentType.name verbatim. A name containing > or whitespace can terminate the <!DOC...
CVE-2026-83609	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.0 until 0.9.12, the shared reg() builder in lib/grammar.js compiles the anchored QName_exact validator with the multiline flag, so ^ and \$ validate only one line instead of the complete name. createElementNS, createAttributeNS, createDocumentType, and createAttribute consequently accept a malformed XM...
CVE-2026-83612	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.0-beta.1 until 0.9.12, HTML-mode parsing through DOMParser.parseFromString() mishandles a mixed-case closing tag for the script, style, textarea, or title raw-text elements. parseHtmlSpecialContent, selected by isHTMLRawTextElement or isHTMLEscapableRawTextElement, uses a case-sensitive indexOf() and ...
CVE-2026-83613	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, DOMHandler.startElement in lib/dom-parser.js inserts every parsed attribute through setAttributeNode, while NamedNodeMap.setNamedItem in lib/dom.js calls the linear getNamedItem or getNamedItemNS lookup for each insert...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83614	8.7	HIGH		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom versions 0.3.0 through 0.6.0, two independent quadratic paths can cause denial of service. In lib/sax.js, parseElementStartPart repeatedly rescans a malformed tag name to the next > during single-character recovery; in lib/dom.js, normalize() re...
CVE-2026-83615	8.7	HIGH		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom versions 0.1.5 through 0.6.0, appendElement in lib/sax.js uses _copy to clone the complete currentNSMap for each nested element that declares a new namespace prefix. Keeping every ancestor map live on the parse stack creates quadratic peak names...
CVE-2026-83616	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, Document.createProcessingInstruction(target, data) in lib/dom.js accepts an unvalidated target, while the requireWellFormed: true serializer checks only for a colon and the reserved case-insensitive xml name on 0.9.x a...
CVE-2026-83617	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.11 until 0.9.12, the requireWellFormed: true element and attribute name checks use the anchored QName_exact expression produced by reg() in lib/grammar.js, which inherits the multiline flag. A name with a valid first line followed by U+000A, U+000D, U+2028, or U+2029 and breakout markup therefore pass...
CVE-2026-83618	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.9.10 until 0.9.12, the requireWellFormed: true serializer validates DocumentType.publicId and DocumentType.systemId with PubidLiteral_match and SystemLiteral_match expressions produced by reg() in lib/grammar.js, which inherit the multiline flag. A complete valid literal on the first line can therefore ...
CVE-2026-83619	8.7	HIGH		0.003		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. From 0.7.0 until 0.8.15, the release-0.8.x parser in lib/sax.js trims captured end-tag names with the unanchored global expression /[\t\n\r]+\$/g. For an end tag containing a long whitespace run followed by a non-whitespace character, the expression retries from each possible starting position and backtracks q...
CVE-2026-84202	8.7	HIGH		0.004		ModelScope uses PyYAML's unsafe yaml.Loader to parse model configuration files, allowing arbitrary code execution through Python object construction tags. Attackers can craft malicious model repositories with poisoned configuration files that execute code when loaded by users.
CVE-2026-84304	8.7	HIGH		0.004		gRPC-Go is the Go language implementation of gRPC. Prior to 1.83.1, internal/transport/transport.go stores each fragmented HTTP/2 DATA frame as a separate recvMsg in recvBuffer, so millions of one-byte frames can consume disproportionate heap memory even when payload bytes remain within connection and stream flow-control windows. An unauthenticated remote attacker can use concurrent multiplexed streams to exhaust ...
CVE-2026-84694	8.7	HIGH		0.005		Coolify before 4.2.0 fails to properly escape environment variable key names in Docker commands executed over SSH on managed servers. Authenticated attackers can inject shell metacharacters into environment variable keys to execute arbitrary commands on the server host outside containers.
CVE-2026-85155	8.7	HIGH		0.003		WWBN AVideo contains a SQL injection vulnerability in the sort column parameter of the get.json.php endpoint with APIName=channels that allows unauthenticated attackers to order results by arbitrary database columns including users.password and users.recoverPass. Attackers can exploit this ordering oracle to infer password hash values and recovery tokens, and trigger SQL errors that disclose the full query state...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85610	8.7	HIGH		0.004		OpenPanel before 2.3.0 fails to properly validate chart formula expressions, allowing authenticated project members with read access to execute arbitrary code by recovering the native JavaScript Function constructor through mathjs matrix objects. Attackers can use the recovered constructor to load Node.js built-ins and execute operating system commands with the privileges of the API process, bypassing organization...
CVE-2026-85687	8.7	HIGH		0.003		surya 0.22.1 screenshot server contains an unauthenticated arbitrary file read vulnerability in the /info, /page, and /process routes that accept raw file_path parameters. Attackers can read any image or PDF file on the host by supplying arbitrary file paths to Image.open or pypdfium2.PdfDocument, obtaining rendered contents as base64 and using /info as an existence oracle.
CVE-2026-85786	8.7	HIGH		0.003		Improper handling of highly compressed data in Amazon ion-java before 1.12.1 might allow remote attackers to cause a denial of service via a crafted compressed Ion document that expands to an arbitrarily large size upon decompression due to insufficient coverage of the GZIP auto-decompression opt-out introduced for CVE-2026-75936. To remediate this issue, users should upgrade to version 1.12.1.
CVE-2026-86076	8.7	HIGH		0.003		n8n is an open source workflow automation platform. Prior to 1.123.76, 2.37.7, and 2.38.2, the expression compiler sanitizer resolved through dynamically scoped this and did not reject reserved class member names. A class field named __sanitize could rebind the sanitizer and reach the Function constructor, enabling backend code execution and editor-preview JavaScript execution. The affected AST hook is PrototypeSa...
CVE-2026-86169	8.7	HIGH		0.005		Axolotl through 0.18.0 contains a remote code execution vulnerability in the multipack patch path where trust_remote_code defaults to None instead of False, causing the security guard to be bypassed. Attackers can execute arbitrary Python code by crafting a malicious Hugging Face model repository selected as base_model, which is loaded with hardcoded trust_remote_code=True during AutoModelForCausalLM.from_pretrained.
CVE-2026-87817	8.7	HIGH		0.003		GitPython before 3.1.60 fails to properly validate the git directory location, allowing attackers to impersonate the git directory using tracked files like gitdir, commondir, and HEAD. Attackers can execute arbitrary code by placing a malicious pre-commit hook in the tracked hooks directory that executes when a victim calls index.commit() on a cloned or opened repository.
CVE-2026-87819	8.7	HIGH		0.003		GitPython before 3.1.60 contains a regular expression denial of service vulnerability in Actor.name_email_regex that processes commit author and committer fields. Attackers can craft a commit object with a malformed author field containing an unterminated angle bracket to cause quadratic backtracking, exhausting CPU resources for over two minutes per commit access.
CVE-2026-88874	8.7	HIGH				AVideo through revision c3edcc274c389816d434acadac07ee78eaf330c1 (master, 2026-08-23) does not enforce the Live stream password check on the stats endpoint or on the HLS origin. Live::_getStats() (plugin/Live/Live.php) returns a password-protected transmission's RTMP stream key, its isPasswordProtected flag, and its HLS (m3u8) URL to unauthenticated callers, in both the public applications list and the hidden_appl...
CVE-2026-21087	8.6	HIGH		0.001	samsung:android	Out-of-bounds write in libmdnie.so prior to SMR Sep-2026 Release 1 allows local attackers to execute arbitrary code with system server privilege.
CVE-2026-25990	8.6	HIGH		0.004	python:pillow	Pillow is a Python imaging library. From 10.3.0 to before 12.1.1, an out-of-bounds write may be triggered when loading a specially crafted PSD image. This vulnerability is fixed in 12.1.1.
CVE-2026-44492	8.6	HIGH		0.009	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 0.32.0 and 1.16.0, Axios does not normalise IPv4-mapped IPv6 addresses. When NO_PROXY lists an IPv4 address such as 127.0.0.1 or 169.254.169.254, a request URL using the IPv4-mapped IPv6 form (::ffff:7f00:1, ::ffff:a9fe:a9fe) still routes through the configured proxy. Node.js resolves these addresses to the underlying IPv4 host, so the requ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-47727	8.6	HIGH		0.004		Trilium is an open-source hierarchical note-taking application. In versions prior to 0.104.0, the default-on "Safe import" filter fails to neutralize the shareTemplate relation because that relation is not marked as dangerous, allowing an attacker-supplied import archive to plant a server-side template that leads to remote code execution. The relation is omitted from the built-in list of dangerous attributes, so u...
CVE-2026-50553	8.6	HIGH		0.004		Note Mark is an open-source note-taking application. Prior to version 0.19.5, Note Mark validates book and note slug values with the OpenAPI/huma tag pattern:"[a-z0-9-]+". huma compiles this with regexp.MustCompile(s.Pattern) and tests it with patternRe.MatchString(str), an UNANCHORED match. Because the pattern is not anchored (^...\$), any string that merely CONTAINS one [a-z0-9-] substring passes validation. A sl...
CVE-2026-55848	8.6	HIGH		0.003		mapfish-print is a component of MapFish for printing templated cartographic maps. Prior to 3.28.30, 3.30.32, 3.31.24, 3.33.16, and 4.0.5, MapFish Print accepts an attacker-controlled GML layer url in requests to the /api/print3/print endpoint and fetches XML parsed by core/src/main/java/org/mapfish/print/map/geotools/GmlLayer.java without disabling external entities and external DTDs. A remote XML document and DTD...
CVE-2026-67340	8.6	HIGH		0.006		ArcadeDB before 26.7.2 (arcadedb-engine) allows trigger scripts to look up host classes in java.lang.* (via Java.type) because ScriptTriggerExecutor adds java.lang.* to the allowed packages. An authenticated user with UPDATE_SCHEMA permission can create a JavaScript trigger that invokes java.lang.Runtime.getRuntime().exec() (or ProcessBuilder), achieving OS command execution when the trigger fires.
CVE-2026-67608	8.6	HIGH		0.015		Telenia Software TVox 26.5.3 and prior 26.x versions, and 24.9.21 and prior 24.x versions, contain an OS command injection vulnerability in action_audio.php that allows authenticated attackers to execute arbitrary operating system commands by passing an unsanitized pid parameter into an exec() call when the action parameter is set to checkProcess. Attackers can inject malicious OS commands through the pid request ...
CVE-2026-73247	8.6	HIGH		0.004		Kestra is an open-source, event-driven orchestration platform. Prior to 2.0.0, Kestra's core/src/main/java/io/kestra/core/runners/pebble/functions/HttpFunction.java passes the user-controlled http() uri argument to URI.create() and the server-side HTTP client without restricting private, loopback, or link-local destinations, allowing an unauthenticated attacker to import and execute a flow that accesses internal s...
CVE-2026-74239	8.6	HIGH		0.007		XenForo before 2.3.13 contains a path traversal vulnerability in the style archive importer on Windows deployments that allows authenticated non-super administrators with style permissions to write arbitrary files outside the intended extraction directory by using backslash-based traversal sequences in ZIP member names. Attackers can craft a malicious ZIP archive with backslash path separators that bypass forward-...
CVE-2026-80097	8.6	HIGH		0.004		Improper authentication in Microsoft Authenticator allows an unauthorized attacker to elevate privileges locally.
CVE-2026-81213	8.6	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to obtain sensitive information from internal network resources due to improper validation of user-supplied URLs.
CVE-2026-81889	8.6	HIGH		0.003		eIFinder is an open-source file manager for web, written in JavaScript using jQuery UI. Prior to 2.1.70, eIFinder URL uploads in php/eIFinder.class.php can bypass server-side request forgery protections when PHP cURL is unavailable because validate_address() validates \$info['ip'], but get_remote_contents() selects fsock_get_contents(), which connects to \$arr['host'] and performs a second DNS resolution. An attacke...
CVE-2026-84452	8.6	HIGH		0.009		Windows ML CLI is a command line tool for building portable, performant, and high-quality AI models for Windows ML. Prior to 0.4.0, the src/winml/modelkit/serve/cli_api.py component exposes WinML CLI commands through a localhost HTTP API without authentication and configures the allow_origins setting as a wildcard in both src/winml/modelkit/serve/cli_api.py and src/winml/modelkit/serve/app.py. A malicious website ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85388	8.6	HIGH		0.003		Worklenz through 3.0.0 fails to properly validate the sort-field query parameter in pagination helper functions, allowing authenticated users to inject arbitrary PostgreSQL expressions into ORDER BY clauses. Attackers can use time-based and boolean-based blind SQL injection techniques to extract sensitive database content including password hashes from other tenants. This is an incomplete fix for CVE-2026-25947.
CVE-2026-86185	8.6	HIGH		0.001		Bilibili Desktop through 1.18.0 disables TLS certificate verification process-wide and executes unsigned remote JavaScript configuration without integrity checks. An attacker in an on-path network position can intercept configuration fetches, inject arbitrary JavaScript executed in the renderer with access to the privileged IPC bridge, and execute system commands or steal login credentials.
CVE-2026-86712	8.6	HIGH		0.004		SiYuan before 3.8.2 trusts the attacker-writable text/siyuan clipboard MIME type and skips sanitization in the paste handler, allowing code execution in the Node-enabled desktop renderer. Attackers can craft malicious web pages that write to the clipboard, and when pasted into SiYuan, injected scripts execute with full Node.js access through the Electron main process.
CVE-2026-86733	8.6	HIGH		0.003	snipeitapp:snipe-it	Snipe-IT before 8.7.0 streams the SQL entry from an uploaded backup archive directly into the MySQL/MariaDB command-line client ('mysql') without the --binary-mode flag, so the client interprets lines beginning with backslash commands such as '\!' as local shell commands. An authenticated superadministrator who uploads a crafted ZIP backup (POST /admin/backups/upload) and triggers a restore (POST /admin/backups/re...
CVE-2026-87794	8.6	HIGH		0.002		bestzip versions 2.2.6 and 3.0.2 contain an argument injection vulnerability in the nativeZip function that allows attackers to inject arbitrary arguments to the Info-ZIP backend. Attackers can supply a malicious destination path combined with crafted source entries to execute arbitrary commands with Node.js process privileges. Fixed in 2.2.7 and 3.0.3.
CVE-2026-88056	8.6	HIGH				Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular Server-Side Rendering in @angular/platform-server processes user-controlled resource or request URLs through HttpClient after application code validates them with WHATWG URL parsing. The resolveUrl and parseUrl utilities called String.pro...
CVE-2026-88058	8.6	HIGH				Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes ProcessingInstruction DOM nodes inside fallback raw-content elements without escaping matching ancestor closing tags. ProcessingInstruction data escaped greater-than chara...
CVE-2026-88060	8.6	HIGH				Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes untrusted input inside template content nested in fallback raw-content elements such as noscript, iframe, noembed, and noframes. The Domino serializer's fallbackRawContent...
CVE-2026-17107	8.5	HIGH		0.003		A flaw was found in the cluster-proxy service-proxy component used in Red Hat Advanced Cluster Management for Kubernetes (RHACM) and multicluster-engine (MCE). The service-proxy appends impersonation group headers to proxied requests without first removing caller-supplied values, and the spoke ServiceAccount holds unrestricted impersonation permissions. An authenticated hub principal can inject an Impersonate-Grou...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45221	8.5	HIGH		0.001		Konga before 2.1.0 contains a privilege escalation vulnerability that allows low-privileged local attackers to execute arbitrary code by planting attacker-controlled OpenSSL configuration or library files in a hardcoded filesystem path absent from default installations. On Windows, the missing directory resides in a location writable by any authenticated local user, enabling attackers to create the directory and p...
CVE-2026-54606	8.5	HIGH		0.004		SunEditor is a lightweight and powerful WYSIWYG editor in vanilla JavaScript with no dependencies. Prior to 3.1.4, the SunEditor Embed plugin in src/plugins/modal/embed.js parses attacker-controlled raw embed HTML with DOMParser and processes the resulting DOM nodes. When an external script element follows a valid iframe, the plugin recreates a script element from the attacker-controlled src attribute and appends ...
CVE-2026-57485	8.5	HIGH		0.003		Stirling-PDF is a locally hosted web application that facilitates various operations on PDF files. Prior to 2.9.0, the /api/v1/pipeline/handleData endpoint in app/core/src/main/java/stirling/software/SPDF/controller/api/pipeline/PipelineProcessor.java injects the STIRLING-PDF-BACKEND-API-USER API key into pipeline subrequests, allowing an authenticated ROLE_USER to retrieve the key through /api/v1/user/get-api-key...
CVE-2026-58113	8.5	HIGH		0.002		A vulnerability has been identified in Teamcenter V2412 (All versions < V2412.0013), Teamcenter V2506 (All versions < V2506.0010), Teamcenter V2512 (All versions < V2512.2607), Teamcenter V2606 (All versions < V2606.2607). Affected applications do not properly encode user-supplied input reflected into HTML attribute contexts within the authentication redirect flow (/auth/ endpoint). This could allow an unauthenti...
CVE-2026-62246	8.5	HIGH		0.003		Kamaji is the Hosted Control Plane Manager for Kubernetes. Prior to 26.7.4-edge, Kamaji derives a TenantControlPlane datastore schema, database user, and etcd key prefix from a lossy namespace-and-name normalization in GetDefaultDatastoreSchema() and GetDefaultDatastoreUsername(), allowing distinct tenants with colliding normalized identifiers to share control-plane state and read, modify, or destroy another tenan...
CVE-2026-65986	8.5	HIGH		0.002		CVAT is an open source interactive video and image annotation tool for computer vision. Versions 2.5.0 through 2.66.0 contain a XSS vulnerability that can be accessed through annotation guide assets. When CVAT serves the files attached to an annotation guide, it labels them with a media type (Content-Type) that the attacker can influence, so instead of treating an uploaded file as plain data, the victim's browse...
CVE-2026-67609	8.5	HIGH		0.001		Telenia Software TVox 26.5.3 and prior 26.x versions, and 24.9.21 and prior 24.x versions, contain a privilege escalation vulnerability that allows attackers with access to the apache account to execute arbitrary commands as root by exploiting an insecure sudoers configuration in /etc/sudoers.d/telenia. The configuration grants the apache user NOPASSWD execution of /bin/nice, which can be leveraged to invoke arbit...
CVE-2026-6958	8.5	HIGH		0.001		Acunetix 25.11.251107123 for Windows contains a local privilege escalation vulnerability in the Web Vulnerability Scanning Engine (wvsc.exe) that allows low-privileged local attackers to execute arbitrary code as SYSTEM by exploiting a missing hardcoded directory path for OpenSSL-related files. Attackers can create the missing directory, place a malicious file at the expected path, and cause the SYSTEM-level wvsc....
CVE-2026-73233	8.5	HIGH		0.002		FreeCAD is a free and open-source multiplatform 3D parametric modeler. Prior to 1.1.2, the FEM Displacement Constraint task dialog in src/Mod/Fem/Gui/TaskFemConstraintDisplacement.cpp passes the xDisplacementFormula, yDisplacementFormula, and zDisplacementFormula fields of a Fem::ConstraintDisplacement object through TaskDlgFemConstraintDisplacement::accept() into Gui::Command::doCommand. The escaping helper neutr...
CVE-2026-73248	8.5	HIGH		0.002		calibre is an e-book manager. Prior to 9.12.0, calibre processes attacker-controlled composite_template metadata from a malicious EPUB, OPF, PDF, or similar file through program: and a nested template() call whose formatter does not inherit allow_python_templates=False, allowing a nested python: template to reach compile_python_template and execute arbitrary Python code when the file is opened or imported. This is...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-74860	8.5	HIGH		0.004		A flaw was found in libxml2 with Python bindings enabled. A remote attacker could exploit this vulnerability by providing a specially crafted XML document containing a Document Type Definition (DTD) with enumerated attribute values. This triggers a double-free error in the SAX attributeDecl callback handler, where a string is freed twice. This flaw can lead to a denial of service (DoS) due to a reproducible crash ...
CVE-2026-75858	8.5	HIGH		0.003		CodeWhale (packages codewhale / codewhale-tui) versions >= 0.8.41 and < 0.8.64 contain a remote code execution vulnerability in the rlm_eval tool. The tool's approval_requirement() returns ApprovalRequirement::Auto, which the engine treats as 'never prompt,' causing arbitrary model-supplied Python code to run in a python3 interpreter without consulting the user's configured --approval-policy and without any approv...
CVE-2026-76958	8.5	HIGH		0.002		SAP Integration Suite does not sufficiently validate XML documents accepted from untrusted sources in certain internal components. An attacker with low privileges could submit specially crafted XML payloads containing malicious external entity declarations. Successful exploitation could allow the attacker to read sensitive file contents from the server and expose them through monitoring or logging output, resultin...
CVE-2026-80112	8.5	HIGH		0.001		PassMark PerformanceTest before 11.1 build 1012, BurnInTest before 11.1 build 1000, and OSForensics before 11.1 build 1016 contain an improper access control vulnerability in the DirectIo64.sys kernel driver that allows unprivileged local users to perform privileged hardware operations by opening a handle to the device object created without a security descriptor. Attackers can issue IOCTLs through the permissive ...
CVE-2026-80378	8.5	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to improper authorization.
CVE-2026-80436	8.5	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service by deleting arbitrary RabbitMQ queues or exchanges due to improper authorization.
CVE-2026-81207	8.5	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 allows any authenticated tenant — with no project membership or role — fully controls scheme/host/port/path of an outbound fetch originating from a shared-infrastructure pod, and the WSDL body is reflected verbatim to the caller. The ds-canvas pod sits on the OpenShift overlay with reach to co-tenant services, in-cluster CP4D APIs, and link-local addresses. Scope is Chan...
CVE-2026-81540	8.5	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to overwrite ruleset files belonging to other tenants due to a path traversal vulnerability.
CVE-2026-84226	8.5	HIGH		0.001		OpenVPN version 2.5.0 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows local authenticated users to perform a binary planting attack during network configuration steps
CVE-2026-85656	8.5	HIGH		0.011		An OS command injection issue in the log4j-cve-2021-44228-hotpatch package in Amazon Linux before 1.3-9 might allow a local user to execute arbitrary commands with root privileges via a Java process whose executable path contains embedded newline characters.
CVE-2026-86095	8.5	HIGH		0.001		Unidata netcdf-c through 4.10.1 contains an out-of-bounds write vulnerability in NC4_HDF5_inq_attname() that copies HDF5 attribute names into a fixed 256-byte buffer without length validation. Attackers can craft HDF5 files with oversized attribute names to overflow the destination buffer, causing memory corruption and crashes when applications enumerate attribute names.
CVE-2026-88886	8.5	HIGH				Renovate is a dependency update automation tool. In versions before 44.14.7 (and in Mend Renovate CE/EE distributions before 15.4.0, and the mend-renovate-enterprise-edition Helm chart before 10.4.0), the manager/gradle-wrapper module does not escape the distributionUrl value read from a repository's gradle/wrapper/gradle-wrapper.properties file before invoking the Gradle Wrapper CLI. In self-hosted deployments co...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88889	8.5	HIGH				Renovate before 44.14.7 contains a command injection vulnerability in the Maven Wrapper manager that allows attackers to execute arbitrary commands by specifying a malicious distributionType parameter in maven-wrapper.properties. Attackers can inject shell commands through unescaped distributionType values to achieve remote code execution when Renovate processes Maven Wrapper updates in binarySource=docker mode.
CVE-2026-89049	8.5	HIGH				A server-side request forgery issue due to improper validation of equivalent address representations in the port forwarding to remote hosts functionality in Amazon AWS Systems Manager Agent (SSM Agent) before 3.3.4851.0 on all platforms might allow an authenticated remote user to bypass the remote destination denylist and reach link-local endpoints, potentially obtaining the temporary IAM role credentials of a man...
CVE-2026-9854	8.5	HIGH		0.001	hitachienergy:microscada_x_sys600	A vulnerability exists in SYS600 RBAC mechanism where users having access to the engineering tools could elevate their privileges to administrator level on the underlying Windows host, granting themselves full control over the host machine.
CVE-2026-44901	8.4	HIGH		0.007		Wazuh is a free and open source platform used for threat prevention, detection, and response. From 4.0.0 until 4.14.6 and 5.0.0-beta2, AffectedItemsWazuhResult.merge() in framework/wazuh/core/results.py trusts the sort_casting field in a cluster worker's JSON response. During a distributed API merge, attacker-controlled type names are resolved through Python builtins without an allowlist. A compromised worker can ...
CVE-2026-47764	8.4	HIGH		0.001		pdm is a Python package and dependency manager supporting the latest PEP standards. Versions prior to 2.27.0 are vulnerable to path traversal through write_to_fs. InstallDestination.write_to_fs() in src/pdm/installers/installers.py overrides the base class to add symlink/hardlink support but replaces the safe_path_with_destdir() (which validates via Path.resolve() + is_relative_to()) with a bare os.path.join() th...
CVE-2026-47781	8.4	HIGH		0.001		PDM is a Python package and dependency manager. In versions up to and including 2.26.9, PDM automatically loads project-local plugins from a .pdm-plugins directory during initialization, allowing an attacker-controlled file in an untrusted repository checkout to execute arbitrary Python code before any command is parsed. This happens because load_plugins() runs during Core.init() and adds .pdm-plugins via site.add...
CVE-2026-52491	8.4	HIGH		0.001		An issue in libtiff 85f2ac8e0b01cb7db2bbe4a3b891bdbef67938 allows an attacker to execute arbitrary code via the libtiff/tools/thumbnail.c: main() component
CVE-2026-53091	8.4	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: pull headers in qdisc_pkt_len_segs_init() Most ndo_start_xmit() methods expects headers of gso packets to be already in skb->head. net/core/tso.c users are particularly at risk, because tso_build_hdr() does a memcpy(hdr, skb->data, hdr_len); qdisc_pkt_len_segs_init() already does a dissection of gso packets. Use pskb_may_pull() instead o...
CVE-2026-55581	8.4	HIGH		0.003		mcp-shell is an MCP server for running shell commands securely, auditably, and on demand. Prior to 0.6.0, the default Docker security.yaml includes /bin/bash in allowed_executables, while security.go validates only the first token and checkBlockedPatternsAndCommands does not reject the shell command-mode flag -c. A caller of the shell_exec MCP tool can provide the command argument `/bin/bash -c <arbitrary-command>...
CVE-2026-55582	8.4	HIGH		0.002		mcp-shell is an MCP server for running shell commands securely, auditably, and on demand. Prior to 0.6.0, the default security.yaml allows /usr/bin/git, while security.go omits ! from containsShellMetacharacters and containsDangerousShellConstructs and applies no per-executable argument policy. A caller of the shell_exec MCP tool can provide the command argument /usr/bin/git -c alias.pwn=!<arbitrary-command>, caus...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-64657	8.4	HIGH		0.003		Budibase is an open-source low-code platform. Prior to 3.39.19, the PostgreSQL datasource connector in packages/server/src/integrations/postgres.ts interpolates the user-controlled schema configuration field into a SET search_path statement without escaping embedded double quotes, allowing an authenticated administrator who saves or tests the datasource to execute arbitrary SQL through the simple query protocol. T...
CVE-2026-67986	8.4	HIGH		0.002		amazing-print/amazing_print at commit dc890dfafdf07088ea901df53c19c2710e5c5234 contains a Ruby code injection condition in AwesomeMethodArray#grep. A specially named method containing Ruby interpolation syntax can be interpolated into a dynamically constructed eval string when grep is called with a block, resulting in Ruby code execution in the host process. Exploitation requires an application path that allows an...
CVE-2026-69479	8.4	HIGH		0.003		Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code locally.
CVE-2026-69638	8.4	HIGH		0.003		Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code locally.
CVE-2026-77827	8.4	HIGH		0.002		Maono Link 3.8.13 MaonoAiServices Windows service allows local privilege escalation for a standard user account via improper write privileges in 'C:\ProgramData\Maono'. Fixed in 4.0.80.
CVE-2026-87811	8.4	HIGH		0.002		SiYuan before v3.8.2 inserts persisted notebook template paths into HTML input value attributes without proper attribute encoding. Attackers can craft malicious template paths that break out of the attribute context and execute JavaScript when a victim opens notebook configuration, enabling same-origin API requests and application state manipulation.
CVE-2026-87813	8.4	HIGH		0.003		SiYuan before v3.8.2 contains a stored cross-site scripting vulnerability in the Search Assets result list where asset filenames are interpolated into HTML without escaping. Authenticated attackers can craft asset filenames containing malicious markup that executes JavaScript in the victim's browser when searching assets, enabling same-origin API requests and application state manipulation.
CVE-2026-87814	8.4	HIGH		0.002		SiYuan before v3.8.2 contains a stored cross-site scripting vulnerability in the search asset preview feature that fails to escape indexed asset content before inserting it into the DOM using innerHTML. Attackers who can place crafted text assets in a workspace can execute JavaScript in the SiYuan origin when victims preview the assets, enabling authenticated API requests and workspace manipulation.
CVE-2026-88022	8.4	HIGH				Improper neutralization of special elements in data query logic in the MongoDB integration for Laravel can cause an array supplied to an explicit equality filter to be interpreted as a query condition rather than as a literal value. This affects the three-argument `where` method when the operator is `=` or `eq`, as well as the `find` and `delete` methods that use that code path. An attacker who can cause an affect...
CVE-2026-88890	8.4	HIGH				OpenPanel through commit cd24bb8 contains an SQL injection vulnerability in the analytics filter builder that fails to validate profile.* filter column identifiers before interpolating them into ClickHouse WHERE clauses. An authenticated attacker with project-scoped read or root export credentials can inject arbitrary ClickHouse SQL to bypass project isolation and read other organizations' analytics data and profi...
CVE-2026-52769	8.3	HIGH		0.003		YesWiki is a wiki system written in PHP. From version 4.6.2 to before version 4.6.6, the POST /api/forms/{formId}/actor/inbox route - exposed publicly with acl:"public" - accepts an HTTP Signature header whose keyId parameter is a URL. HttpSignatureService::verifySignature() parses the header and immediately makes a server-side HTTP GET to that URL, before any cryptographic verification or URL validation. An unaut...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54100	8.3	HIGH		0.003	redhat:openshift_container_platform , redhat:windows_machine_config_operator	A flaw was found in the Windows Machine Config Operator (WMCO) for Red Hat OpenShift Container Platform. WMCO establishes SSH connections to Windows worker nodes without verifying the remote server host key. An adjacent-network attacker who can intercept or redirect WMCO's SSH session can capture WICD and kubelet bootstrap credentials transferred during node configuration, enabling compromise of Windows node ident...
CVE-2026-77104	8.3	HIGH		0.004	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a path traversal issue affecting information disclosure. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-87524	8.3	HIGH		0.003	google:chrome, microsoft:windows	Use after free in Core in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87616	8.3	HIGH		0.004	google:chrome, microsoft:windows	Improper initialization in Views in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87618	8.3	HIGH		0.003	google:chrome, microsoft:windows	Incorrect reference resolution in Storage in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87644	8.3	HIGH		0.003	google:chrome, microsoft:windows	Incorrect authorization in Views in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87648	8.3	HIGH		0.003	google:chrome, microsoft:windows	Use after free in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-26007	8.2	HIGH		0.003	cryptography.io:cryptography	cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. Prior to 46.0.5, the public_key_from_numbers (or EllipticCurvePublicNumbers.public_key()), EllipticCurvePublicNumbers.public_key(), load_der_public_key() and load_pem_public_key() functions do not verify that the point belongs to the expected prime-order subgroup of the curve. This missing validation allows an a...
CVE-2026-28498	8.2	HIGH		0.002	authlib:authlib	Authlib is a Python library which builds OAuth and OpenID Connect servers. Prior to version 1.6.9, a library-level vulnerability was identified in the Authlib Python library concerning the validation of OpenID Connect (OIDC) ID Tokens. Specifically, the internal hash verification logic (_verify_hash) responsible for validating the at_hash (Access Token Hash) and c_hash (Authorization Code Hash) claims exhibits a f...
CVE-2026-41604	8.2	HIGH		0.009	apache:thrift	Out-of-bounds Read vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-44487	8.2	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 0.32.0 and 1.16.0, Axios's Node.js HTTP adapter may forward a Proxy-Authorization header to a redirected origin during specific proxy-to-direct redirect flows. This affects Node.js usage, where an initial HTTP request is sent through an authenticated HTTP proxy, redirects are followed, and the redirected URL is no longer proxied. Under affe...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-47719	8.2	HIGH		0.006		FUXA is a web-based Process Visualization (SCADA/HMI/Dashboard) software. Prior to 1.3.2, the DEVICE_WEBAPI_REQUEST and DEVICE_PROPERTY Socket.IO handlers in server/runtime/index.js omit isSocketWriteAuthorized and accept attacker-controlled property.address or endpoint connection data. A remote unauthenticated attacker can make server/runtime/devices/httprequest/index.js call axios.get against arbitrary HTTP or H...
CVE-2026-52767	8.2	HIGH		0.002		YesWiki is a wiki system written in PHP. From version 4.6.2 to before version 4.6.6, HttpSignatureService::verifySignature() checks the result of PHP's openssl_verify() with a loose boolean negation - if (!openssl_verify(...)) { throw ... }. PHP's openssl_verify has four possible return values: 1, 0, -1, and "false". The -1 row is the bypass: PHP's truthiness rules make -1 a truthy value, so !(-1) === false, the t...
CVE-2026-53501	8.2	HIGH		0.002		Thumbor is an open-source photo thumbnail service by globo.com. Prior to 7.8.0, Thumbor's HMAC validation can be bypassed due to the use of Python's .replace() when removing the signature from the URL before validation. Since .replace() removes all occurrences of the substring, an attacker can insert the same signature multiple times in the URL and manipulate the final URL used for validation. This allows crafting...
CVE-2026-53938	8.2	HIGH		0.002		OpenIDC/cjose is a C library implementing the Javascript Object Signing and Encryption (JOSE). Prior to version 0.6.2.5, cjose's JWE decryption path for the AES Key Wrap key-management algorithms (`alg` = `A128KW`, `A192KW`, `A256KW`) does not validate the length of the attacker-supplied `encrypted_key` (JWE Encrypted Key) before unwrapping it into a fixed-size, heap-allocated Content Encryption Key (CEK) buffer. ...
CVE-2026-62673	8.2	HIGH		0.005		Grav is a file-based Web platform. Prior to 2.0.4, the Grav .htaccess and webserver-configs/htaccess.txt security rules omit the Apache [NC] flag and therefore compare sensitive directory and file-extension patterns case-sensitively. On a case-insensitive filesystem, an unauthenticated requester can use uppercase directory or extension variants to bypass the rules and retrieve files under user/accounts or user/con...
CVE-2026-63135	8.2	HIGH		0.003		YOURLS is a self-hosted, customizable URL shortener written in PHP. From 1.5.1 until 1.10.4, YOURLS stores the HTTP Referer header through yourls_get_referrer(), yourls_sanitize_url_safe(), and yourls_log_redirect(), then aggregates the value in yourls-infos.php and passes the derived domain through yourls_get_domain(), yourls_stats_pie(), and yourls_google_array_to_data_table(). The chart builder concatenates lab...
CVE-2026-63376	8.2	HIGH		0.004		toml-node is a TOML parser for Node.js and the browser. Prior to 4.1.2, toml.parse() in lib/compiler.js can be tricked by a table path such as a.b.y.__proto__.__proto__, allowing traversal from a scalar value into Number.prototype and Object.prototype. The currentPath tracking value uses both arrays and strings, so valueAssignments records a comma-joined path such as a.b.y while deepRef checks the dot-joined path ...
CVE-2026-63407	8.2	HIGH		0.003		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.0-rc.16, the Grav API plugin CorsMiddleware returns Access-Control-Allow-Origin: * and permissive OPTIONS responses for authenticated /api/v1 endpoints. JavaScript from any origin can submit an attacker-obtained JWT through the Authorization or X-API-Token header, read the authenticated response, a...
CVE-2026-64380	8.2	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: smb: client: harden POSIX SID length parsing posix_info_sid_size() reads sid[1] to obtain the subauthority count, but its existing boundary check still accepts buffers with only one remaining byte. Require two bytes before reading sid[1] so all client paths that reuse the helper reject truncated POSIX SIDs safely.
CVE-2026-69247	8.2	HIGH		0.002		cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. From 44.0.0 until 50.0.0, pkcs7_decrypt_der, pkcs7_decrypt_pem, and pkcs7_decrypt_smime reported the outcome of decrypting a RecipientInfo's encryptedKey in several distinguishable ways, one of which disclosed the exact length recovered from the RSA operation. The same distinction was also observable by timing. ...
CVE-2026-69820	8.2	HIGH		0.003		Heap-based buffer overflow in Windows Hello allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69846	8.2	HIGH		0.003		Integer overflow or wraparound in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-69874	8.2	HIGH		0.003		Untrusted pointer dereference in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2026-69906	8.2	HIGH		0.003		Heap-based buffer overflow in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-72958	8.2	HIGH		0.003		Double free in Windows Credential Guard allows an authorized attacker to elevate privileges locally.
CVE-2026-72961	8.2	HIGH		0.003		Out-of-bounds read in Windows Hyper-V allows an authorized attacker to elevate privileges locally.
CVE-2026-72962	8.2	HIGH		0.003		Heap-based buffer overflow in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-73214	8.2	HIGH		0.004		Coturn is a free open source implementation of TURN and STUN Server. Prior to 4.16.0, dtls_server_input_handler() and create_new_connected_udp_socket() in src/apps/relay/dtls_listener.c retain OpenSSL dtls1_reassemble_fragment() state for a 35-byte fragmented ClientHello declaring a 650,000-byte handshake before cookie validation, allowing an unauthenticated remote sender using fresh UDP tuples to exhaust memory w...
CVE-2026-73658	8.2	HIGH		0.004		Trigger.dev is a platform for building and deploying fully managed AI agents and workflows. From 4.4.2 until 4.5.0-rc.5, Aws4FetchClient.buildUrl() and Aws4FetchClient.presign() in apps/webapp/app/v3/objectStoreClient.server.ts assign user-controlled packet keys to URL.pathname, while apps/webapp/app/routes/api.v1.packets.\$.ts accepts params["*"] without rejecting dot segments and uses findResource: async () => 1 ...
CVE-2026-73666	8.2	HIGH		0.005		OpenChoreo is a developer platform for Kubernetes. Prior to 1.0.4, 1.1.4, and 1.2.1, the OpenChoreo Backstage backend hardcoded backend.auth.dangerouslyDisableDefaultAuthPolicy and auth.providers.guest.dangerouslyAllowOutsideDevelopment to true, exposing /api/* without authentication and allowing unauthenticated catalog reads, scaffolder log reads, and catalog location creation or deletion. This issue is fixed in ...
CVE-2026-75594	8.2	HIGH		0.005		Kirby is an open-source content management system. Prior to 4.9.5 and 5.5.2, depending on the release line, Kirby's media handler in src/Cms/Media.php allowed Kirby\Cms\Media::thumb() to append a path-bearing filename to a validated parent media directory. On nginx, PHP's built-in server, or Apache with AllowEncodedSlashes enabled, a remote attacker could submit encoded slash characters such as %2f in the filename...
CVE-2026-77822	8.2	HIGH		0.002		IBM ContextForge MCP Gateway could allow a remote authenticated attacker to obtain sensitive information due to server-side request forgery via DNS rebinding.
CVE-2026-81354	8.2	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-82586	8.2	HIGH		0.003		Improper Protection of Alternate Path vulnerability in ash-project ash_lua allows a user-supplied Lua script to read attributes that are not on the exposed-field allow-list. AshLua exposes Ash resources to Lua scripts, gated by a manifest declaring which fields are exposed. The read action's operation aggregate path in AshLua.Runtime took the field name straight from the Lua call and resolved it with only String....

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83939	8.2	HIGH		0.003	microsoft:windows_11_26h1	Untrusted pointer dereference in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-84370	8.2	HIGH		0.003		SVGO, short for SVG Optimizer, is a Node.js library and command-line application for optimizing SVG files. From version 1.0.0 until versions 2.8.4, 3.3.5, and 4.1.0, the opt-in removeScripts plugin, named removeScriptElement in versions 2 and 3, incompletely filters executable links in plugins/removeScripts.js and lib/svggo/tools.js. The plugin does not recognize namespace-prefixed SVG anchor elements such as svg:a...
CVE-2026-85596	8.2	HIGH		0.002		Traefik versions >= v3.7.0 and <= v3.7.10 contain an authentication bypass in the Kubernetes Ingress NGINX provider. The TLS option generated for an Ingress carrying the nginx.ingress.kubernetes.io/auth-tls-secret annotation was named after the Ingress namespace and name. As a result, two Ingress objects sharing the same host, the same client CA secret, and the same client-authentication mode produced two distinct...
CVE-2026-86253	8.2	HIGH		0.004		h3 (npm package) versions <= 2.0.1-rc.14 contain a path traversal vulnerability in serveStatic(). On Node.js deployments, event.url.pathname is not normalized, so percent-encoded dot segments (%2e%2e) are passed to decodeURI() and decoded to ../ sequences without sanitization. An unauthenticated remote attacker can send crafted requests to endpoints served by serveStatic() to read arbitrary files outside the inten...
CVE-2026-86600	8.2	HIGH		0.003		In affected Snowflake drivers, WORKLOAD_IDENTITY authentication requests a cloud workload-identity token and attaches it to the login request without verifying that the configured host is a Snowflake endpoint. An attacker who can modify the connection configuration can cause the driver to mint a fresh attestation and send it to a host they control. The captured token can be replayed to Snowflake for its remaining ...
CVE-2026-88032	8.2	HIGH				A use-after-free in the reactive client-side encryption component of the MongoDB Java Driver can cause native resources to be freed while an affected encrypted operation is still using them when the operation is cancelled. A party able to cause such an operation to be cancelled may cause the hosting application process to terminate. Reaching the issue requires an affected reactive encryption configuration that ret...
CVE-2026-89054	8.2	HIGH				A missing authorization vulnerability in OpenNMS Horizon allows configuration changes without authentication. The Spring Security policy for the /api/v2 REST API defines authorization rules for every HTTP method except PATCH, so the shipped @PATCH configuration endpoints for event configuration and SNMP data collection (which enable and disable event definitions and data-collection sources) are reachable with no a...
CVE-2026-18147	8.1	HIGH		0.003		A flaw was found in FreeIPA. An unauthenticated remote attacker could exploit a DOM Cross-Site Scripting (XSS) vulnerability in the FreeIPA/IdM Web UI password reset page. By enticing a victim to click a specially crafted link and complete a password reset, the attacker could inject and execute arbitrary JavaScript code. This allows the attacker to perform actions within the victim's authenticated session, potenti...
CVE-2026-19303	8.1	HIGH		0.004	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to delete arbitrary local files or directories due to improper limitation of a pathname to a restricted directory.
CVE-2026-19594	8.1	HIGH		0.004		Insufficient input sanitization in Snowflake Python API (snowflake.core) versions prior to 1.13.0 allowed confused-deputy privilege escalation through two related weaknesses: path traversal (CWE-22) via unencoded `..` identifier path segments, and HTTP parameter pollution (CWE-141) via unencoded `&`/`#`/`= characters in query string values. An attacker with access to a downstream application built on snowflake....
CVE-2026-33997	8.1	HIGH		0.004	docker:engine	Moby is an open source container framework. Prior to version 29.3.1, a security vulnerability has been detected that allows plugins privilege validation to be bypassed during docker plugin install. Due to an error in the daemon's privilege comparison logic, the daemon may incorrectly accept a privilege set that differs from the one approved by the user. Plugins that request exactly one privilege are also affected,...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description						
CVE-2026-44745	8.1	HIGH		0.005	sap:approuter	SAP Approuter does not properly validate incoming request headers during the OAuth2 login flow under certain configurations. This allows an unauthenticated remote attacker to craft a malicious link which, when clicked by a victim, could lead to unauthorized access. Successful exploitation results in a high impact to the confidentiality and integrity with no impact on the availability of the application.						
CVE-2026-46099	8.1	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: ipv6: fix NOREF dst use in seg6 and rpl lwtunnels seg6_input_core() and rpl_input() call ip6_route_input() which sets a NOREF dst on the skb, then pass it to dst_cache_set_ip6() invoking dst_hold() unconditionally. On PREEMPT_RT, ksoftirqd is preemptible and a higher-priority task can release the underlying pcpu_rt between the lookup and th...						
CVE-2026-48081	8.1	HIGH		0.001		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, a TENANT_ADMIN can store `javascript:` URLs in the tenant `links` configuration (`website`, `imprint`, `privacyStatement`). These values are returned to the patient-facing landing page via `/api/public`, hydrated into the SvelteKit Button component, and rendered as ` <a #"="" href="javascript...</td></tr><tr><td>CVE-2026-54330	8.1	HIGH		0.002		Ceph is an open-source distributed storage platform providing object, block, and file storage. In versions prior to 20.2.4 and 19.2.6, the Ceph Object Gateway (RGW) SigV4 handler does not reject requests that carry x-amz-* headers absent from the signed header set, allowing anyone holding a presigned URL to attach arbitrary unsigned x-amz-* headers that RGW will honor. AWS S3 requires every x-amz-* header on a Sig...
CVE-2026-55007	8.1	HIGH		0.007		Double free in Microsoft Exchange Server allows an unauthorized attacker to execute code over a network.						
CVE-2026-65181	8.1	HIGH		0.004	apache:impala	Insufficient authorization of Data Source tables in Impala 2.7-4.5 allows a client with privileges to upload a file to remote storage and create a table to execute arbitrary Java code. Users are recommended to upgrade to version 4.5.2, which fixes this issue.						
CVE-2026-69325	8.1	HIGH		0.006		Heap-based buffer overflow in Microsoft JScript allows an unauthorized attacker to execute code over a network.						
CVE-2026-69380	8.1	HIGH		0.007		Missing authorization in Microsoft Exchange Server allows an authorized attacker to elevate privileges over a network.						
CVE-2026-69438	8.1	HIGH		0.007		Incorrect conversion between numeric types in Microsoft JScript allows an unauthorized attacker to execute code over a network.						
CVE-2026-69510	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.						
CVE-2026-69524	8.1	HIGH		0.007		Use after free in Active Directory Domain Services allows an unauthorized attacker to execute code over a network.						
CVE-2026-69546	8.1	HIGH		0.007		Use after free in Active Directory Domain Services allows an unauthorized attacker to execute code over a network.						
CVE-2026-69620	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.						

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69680	8.1	HIGH		0.003		Origin validation error in Windows DNS allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-69732	8.1	HIGH		0.007		Heap-based buffer overflow in Windows Link Layer Topology Discovery Protocol allows an unauthorized attacker to execute code over a network.
CVE-2026-69786	8.1	HIGH		0.007		Heap-based buffer overflow in Windows Text Shaping allows an unauthorized attacker to execute code over a network.
CVE-2026-69813	8.1	HIGH		0.007		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69858	8.1	HIGH		0.007		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-70342	8.1	HIGH		0.009		Use after free in Windows Ancillary Function Driver for WinSock allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-70465	8.1	HIGH		0.007	fortinet:forticlient	A buffer copy without checking size of input ('classic buffer overflow') vulnerability in Fortinet FortiClientWindows 7.4.0 through 7.4.3, FortiClientWindows 7.2.0 through 7.2.11 may allow an unauthenticated attacker in a position to alter or craft DNS responses to the targeted host to execute arbitrary code via malicious packets.
CVE-2026-70468	8.1	HIGH		0.007	fortinet:fortimanager, fortinet:fortimanager_cloud	A authentication bypass using an alternate path or channel vulnerability in Fortinet FortiManager 7.6.1, FortiManager 7.4.3 through 7.4.5, FortiManager 7.2.5 through 7.2.9, FortiManager Cloud 7.6.1, FortiManager Cloud 7.4.3 through 7.4.5, FortiManager Cloud 7.2.5 through 7.2.9 may allow attacker to improper access control via <insert attack vector here>
CVE-2026-70563	8.1	HIGH		0.009		Improper link resolution before file access ('link following') in Windows Shell allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-71407	8.1	HIGH		0.005	fortinet:fortios	A Stack-based Buffer Overflow vulnerability [CWE-121] vulnerability in Fortinet FortiOS 7.6.1 through 7.6.6 may allow an unauthenticated attacker who can bypass stack protection and ASLR to execute arbitrary code or commands in the context of the WAD daemon via crafted sockets, only if the explicit proxy is configured with Kerberos authentication and SOCKS enabled.
CVE-2026-72903	8.1	HIGH		0.004		Tabby (formerly Terminus) is a highly configurable terminal emulator. Prior to 1.0.235, a malicious SFTP server can return a backslash traversal filename through entry.name. In tabby-ssh/src/session/sftp.ts, SFTPSession.readdir() and _makeFile() use POSIX path processing that preserves the backslashes as ordinary filename characters. In tabby-ssh/src/components/sftpPanel.component.ts, downloadFolderRecursive() pro...
CVE-2026-72936	8.1	HIGH		0.006		Use after free in Windows SMB Client allows an unauthorized attacker to execute code over a network.
CVE-2026-72987	8.1	HIGH		0.006		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-73334	8.1	HIGH		0.002	apache:parquet	Potential problem for users of the org.apache.parquet.crypto.keytools package in Apache Parquet, versions 1.12 to 1.18. This package enables users to encrypt Parquet files via an envelope encryption mechanism that wraps (encrypts) data keys via a Key Management Service (KMS). On the reader side, the KMS URL can be application-controlled or file-controlled. If the user does not leverage application control for th...
CVE-2026-75021	8.1	HIGH		0.004		fastify-cli starts the Node.js Inspector when a debug flag is used, but it ignores the explicit bind address the user supplies and binds the Inspector to a broadly reachable address instead of the intended loopback. As a result the debugging interface can be exposed beyond the local machine, and because the Inspector protocol allows arbitrary code evaluation, a remote party that reaches it can achieve remote code ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78444	8.1	HIGH		0.005		Untrusted pointer dereference in Windows Failover Cluster allows an unauthorized attacker to execute code over a network.
CVE-2026-78583	8.1	HIGH		0.002	elastic:kibana	Incorrect Authorization (CWE-863) in Kibana can lead to privilege escalation via Input Data Manipulation (CAPEC-153). Elasticsearch cluster privilege declarations originating from integration packages were not validated before being used to mint credentials for enrolled Elastic Agents. A user holding Fleet management privileges could therefore cause every Elastic Agent on a targeted policy to receive a credential ...
CVE-2026-78626	8.1	HIGH		0.002		The Okta Access Gateway improperly handles input sanitization and regular expression evaluation within its Protected Rule authorization check, resulting in an authorization bypass when an administrator has explicitly configured a Protected Rule policy on one or more application resources.
CVE-2026-80354	8.1	HIGH		0.001		Authorization bypass through User-Controlled key vulnerability in Apache Camel K. An authorization vulnerability in custom resource resolution allows a tenant to reference secrets by name in the operator namespace, potentially exposing secrets belonging to other tenants or operator components. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users are recommended to u...
CVE-2026-81268	8.1	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute flows and obtain sensitive information due to insufficient session expiration of API keys after user deactivation.
CVE-2026-81891	8.1	HIGH		0.005		elFinder is an open-source file manager for web, written in JavaScript using jQuery UI. Prior to 2.1.70, checkExtractItems() in php/elFinderVolumeDriver.class.php calls mimeTypeInternalDetect() without passing the result through mimeTypeNormalize(). Because the .html, .phar, .php5, and .php3 extensions are absent from mimeTypeMap, the staticMimeMap entries that map them to text/x-php are not applied, and allowPutM...
CVE-2026-83997	8.1	HIGH		0.005	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-84381	8.1	HIGH		0.001		HTTPX2 is a next generation HTTP client for Python. Prior to 2.10.0, httpcore2 fails to start TLS in src/httpcore2/httpcore2/_sync/socks_proxy.py and src/httpcore2/httpcore2/_async/socks_proxy.py when the remote origin uses wss through a SOCKS5 proxy because the TLS upgrade condition only recognizes https. HTTPX2 exposes the flaw through Client.websocket() and AsyncClient.websocket() from 2.6.0 through 2.9.1, so t...
CVE-2026-84393	8.1	HIGH		0.002		A improper validation of certificate with host mismatch vulnerability in Fortinet FortiOS 7.6.1 through 7.6.6, FortiProxy 7.6.2 through 7.6.6 may allow attacker to information disclosure via <insert attack vector here>
CVE-2026-86242	8.1	HIGH		0.006		Bifrost HTTP transport before 2.0.0 accepts an enabled custom plugin whose path is an HTTP URL through unauthenticated POST /api/plugins when management authentication is disabled (the default, governance.auth_config.is_enabled=false). The shared-object loader treats an http-prefixed path as a download URL, writes the body to a temporary .so, and passes it to Go's plugin.Open. After a successful open, optional Ini...
CVE-2026-87016	8.1	HIGH		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.6.41 until 0.11.1, get_user_by_oauth_sub and get_user_by_scim_external_id in backend/open_webui/models/users.py used JSON contains matching that compiled to SQL LIKE substring matching on SQLite. An OAuth subject containing percent or underscore wildcard characters could resolve to a different stored identity, potentially ...
CVE-2026-87457	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Medium)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87467	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to potentially execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-87509	8.1	HIGH		0.001	google:chrome, microsoft:windows	Incorrect authorization in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Low)
CVE-2026-87530	8.1	HIGH		0.001	google:chrome, microsoft:windows	Uncontrolled search path element in CredentialProvider in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Medium)
CVE-2026-87554	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Chromoting in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-87874	8.1	HIGH		0.004		A flaw was found in the memcached cache plugin of the community.general Ansible collection. Although its documentation states that records are stored in JSON format, the plugin performs no explicit serialization and relies on python-memcached, which pickles values on write and unpickles them on read. Because memcached is unauthenticated and cache keys are predictable, an attacker able to reach a network-exposed or...
CVE-2026-87958	8.1	HIGH				IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 is vulnerable to a denial of service where a specific functionality on a Db2 server can be disabled by a privileged user under certain conditions.
CVE-2026-47858	8.0	HIGH		0.002	broadcom:spring_tools	Starting Spring Boot applications in the Spring Tools with the live information mode enabled makes the running application vulnerable against JMX-based remote code execution. Affected Spring Products and Versions: Spring Tools for Eclipse: 5.2.0 and earlier Spring Tools for VSCode / Cursor / Theia: 2.2.0 and earlier
CVE-2026-48080	8.0	HIGH		0.003		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Prior to version 1.0.2, the `GET /api/tenants/{id}` endpoint returns the full tenant record to any authenticated `TENANT_ADMIN` of that tenant, including the `databaseUrl` field. This field contains the live PostgreSQL connection string the application uses to connect to that tenant's database. In the tested...
CVE-2026-52831	8.0	HIGH		0.003		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.16.4, the Nuclio controller builds a curl invocation string for each cron trigger and stores it as the args of a Kubernetes CronJob container (/bin/sh, -c, <command>). Two fields in the trigger specification flow into this string without adequate sanitization: event.headers keys and event.body. This issue has been patch...
CVE-2026-52833	8.0	HIGH		0.003		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.16.5, Nuclio's Java runtime generates a build.gradle file during function builds using Go's text/template package. The template renders runtimeAttributes.repositories[] values with the {{ . }} action, which performs no escaping. An attacker can embed a closing brace (}) to break out of the repositories {} block and appe...
CVE-2026-68827	8.0	HIGH		0.004		Integer underflow (wrap or wraparound) in Windows GDI+ allows an authorized attacker to elevate privileges over a network.
CVE-2026-68834	8.0	HIGH		0.006		Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68838	8.0	HIGH		0.004		Stack-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68876	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-68878	8.0	HIGH		0.005		Stack-based buffer overflow in Windows Fast FAT Driver allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68880	8.0	HIGH		0.004		Heap-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-68894	8.0	HIGH		0.006		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges over a network.
CVE-2026-69271	8.0	HIGH		0.007		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69301	8.0	HIGH		0.008		Stack-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69322	8.0	HIGH		0.007		Double free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges over a network.
CVE-2026-69332	8.0	HIGH		0.007		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69346	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-69365	8.0	HIGH		0.007		Out-of-bounds read in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69371	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges over a network.
CVE-2026-69412	8.0	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69423	8.0	HIGH		0.007		Heap-based buffer overflow in Windows USB Video Driver allows an authorized attacker to elevate privileges over a network.
CVE-2026-69427	8.0	HIGH		0.007		Out-of-bounds read in Windows VOLSnap.SYS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69458	8.0	HIGH		0.007		Out-of-bounds read in Windows BitLocker allows an authorized attacker to elevate privileges over a network.
CVE-2026-69462	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges over a network.
CVE-2026-69481	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Enterprise App Management allows an authorized attacker to elevate privileges over a network.
CVE-2026-69503	8.0	HIGH		0.008		Stack-based buffer overflow in Windows USB Driver allows an authorized attacker to elevate privileges over a network.
CVE-2026-69505	8.0	HIGH		0.008		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69512	8.0	HIGH		0.008		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69619	8.0	HIGH		0.008		Out-of-bounds read in Windows exFAT File System allows an authorized attacker to elevate privileges over a network.
CVE-2026-69623	8.0	HIGH		0.009		Heap-based buffer overflow in Windows HTTP Print Provider allows an authorized attacker to execute code over a network.
CVE-2026-69625	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges over a network.
CVE-2026-69643	8.0	HIGH		0.008		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69689	8.0	HIGH		0.008		Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69714	8.0	HIGH		0.008		Stack-based buffer overflow in Windows Device Association Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69717	8.0	HIGH		0.007		Untrusted pointer dereference in Windows Group Policy allows an authorized attacker to elevate privileges over a network.
CVE-2026-69727	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69762	8.0	HIGH		0.007		Stack-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69773	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69777	8.0	HIGH		0.005	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Heap-based buffer overflow in Windows DHCP Client allows an authorized attacker to elevate privileges over an adjacent network.
CVE-2026-69807	8.0	HIGH		0.009		Improper limitation of a pathname to a restricted directory ('path traversal') in Windows PowerShell allows an authorized attacker to elevate privileges over a network.
CVE-2026-69826	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69847	8.0	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69875	8.0	HIGH		0.008		Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69876	8.0	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-79755	8.0	HIGH		0.004		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.17.4, on the Nuclio local Docker platform, the function namespace is interpolated—unvalidated—into a double-quoted docker ps --filter "label=nuclio.io/namespace=<value>" command that is executed via the host shell (/bin/sh -c). Because the default auth kind is nop (unauthenticated), a remote attacker can inject arbitrar...
CVE-2026-83948	8.0	HIGH		0.004		Improper neutralization of special elements used in a command ('command injection') in Microsoft Azure CLI allows an authorized attacker to execute code over a network.
CVE-2026-84935	8.0	HIGH		0.002		The HT Menu WordPress plugin before 1.2.7 does not perform any capability or object-ownership check when saving navigation menu-item settings, and does not escape those stored settings when the menu is rendered, allowing users with minimal permissions such as Subscribers to store JavaScript that executes in the browser of any visitor, administrators included, who views the affected menu.
CVE-2026-43133	7.9	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: KVM: nSVM: Always use vmcb01 in VMLOAD/VMSAVE emulation Commit cc3ed80ae69f ("KVM: nSVM: always use vmcb01 to for vmsave/vmload of guest state") made KVM always use vmcb01 for the fields controlled by VMSAVE/VMLOAD, but it missed updating the VMLOAD/VMSAVE emulation code to always use vmcb01. As a result, if VMSAVE/VMLOAD is executed by an L2 g...
CVE-2026-44629	7.9	HIGH		0.001		Improper access control to the Synergis Softwire installation folder. This vulnerability affects Streamvault all-in-one appliances (SV-100E and SV-300E series) and Synergis Softwire installed on Windows servers.
CVE-2026-0065	7.8	HIGH		0.001		In areBackgroundActivityStartsAllowed of BackgroundLaunchProcessController.java, there is a possible unintended way to launch activities in the background due to a logic error in the code. This could lead to local escalation of privilege with User execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-0084	7.8	HIGH		0.001		In multiple functions of HostEmulationManager.java, there is a possible background activity launch due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-12410	7.8	HIGH		0.001		Link following vulnerability in the Uninstaller component in CCleaner prior to 7.10.1464 on Windows allows a local, low-privileged attacker to escalate privileges to SYSTEM via a symlink/junction created during application uninstallation, which CCleaner follows when deleting the application's data folder with elevated integrity.
CVE-2026-16826	7.8	HIGH		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-17499	7.8	HIGH		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-17523	7.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: can: bcm: switch timer to HRTIMER_MODE_SOFT and remove hrtimer_tasklet This patch switches the timer to HRTIMER_MODE_SOFT, which executed the timer callback in softirq context and removes the hrtimer_tasklet.
CVE-2026-19820	7.8	HIGH		0.003		A vulnerability in the Backblaze Client allows a local user to make the system not bootable by creating a link from Backblaze's folder to Windows OS system files during a backup. Successful exploitation requires an administrator-level system change that results in the absence of specific Windows OS security controls. This vulnerability is due to improper link resolution.
CVE-2026-2310	7.8	HIGH				IBM webMethods Integration Server 11.1 IBM webMethods Integration is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-28593	7.8	HIGH		0.001		In getItemList of SettingsFragment.java, there is a possible user interaction bypass due to misleading or insufficient UI. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28599	7.8	HIGH		0.001		In addCreatorToken of ActivityManagerService.java, there is a possible Intent Redirection Bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28600	7.8	HIGH		0.001		In onCreate of PaymentDefaultDialog.java, there is a possible way to change default payment app due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28602	7.8	HIGH		0.001		In setClipboardAccessNotificationsEnabledForUser of ClipboardService.java, there is a possible multi-user isolation due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28603	7.8	HIGH		0.001		In assertSafeToStartCustomActivity of AppRestrictionsFragment.java, there is a possible read/write access to private files due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28611	7.8	HIGH		0.001		In multiple functions of NfcService.java, there is a possible silent payment session hijacking enablement due to a missing permission check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28612	7.8	HIGH		0.001		In resolveActivity of ActivityStarter.java, there is a possible way to perform Intent Redirection attacks due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28614	7.8	HIGH		0.001		In onCreate of SlicePermissionActivity.java, there is a possible permission bypass due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28631	7.8	HIGH		0.001		In buildMiniResolver of IntentForwarderActivity.java, there is a possible consent bypass due to a tapjacking/overlay attack. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28634	7.8	HIGH		0.001		In handleUssdRequest of PhoneInterfaceManager.java, there is a possible way to send a USSD request without permission due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28636	7.8	HIGH		0.001		In setupLayout of PickActivity.java, there is a possible bypass of the "Install unknown apps" security restriction due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28642	7.8	HIGH		0.001		In executeRequest of ActivityStarter.java, there is a possible background activity launch due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28644	7.8	HIGH		0.001		In startNextMatchingActivity of ActivityTaskManagerService.java, there is a possible permission bypass due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-28650	7.8	HIGH		0.001		In setHiddenWhileSuspended of WindowState.java, there is a possible overlay bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28655	7.8	HIGH		0.001		In multiple functions of RemoteViews.java, there is a possible background activity launch bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28657	7.8	HIGH		0.001		In onActivityResult of AppWidgetConfigActivityProxy.java, there is a possible unauthorized URI permission grant due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28658	7.8	HIGH		0.001		In findMetaAuthUid of AccountsDb.java, there is a possible frp bypass due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28663	7.8	HIGH		0.001		In buildIntentSenderForUser of LauncherAppsService.java, there is a possible way to launch an activity from the background due to BAL Bypass. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-30512	7.8	HIGH		0.001		A local privilege escalation vulnerability exists in the Restricted Access (Kiosk) Mode implementation of Scheidt & Bachmann entervo HMI prior to V2 R5 P0 M5. The vulnerability affects the external PDF viewer functionality used to display the application manual and its interaction with the underlying Windows operating system. An authenticated low-privileged user can escape the kiosk environment by opening the appl...
CVE-2026-34398	7.8	HIGH		0.002		FreeCAD is a free and open-source multiplatform 3D parametric modeler. From 0.19 until 1.1.1, src/Mod/BIM/bimcommands/BimProjectManager.py in the BIM Project Manager Load Template flow passes attacker-controlled FCStd Meta property values for wposition, wpu, wpv, and wpaxis directly to eval(), allowing arbitrary Python code execution when a user loads a malicious BIM project template. This issue is fixed in versi...
CVE-2026-34399	7.8	HIGH		0.001		FreeCAD is a free and open-source multiplatform 3D parametric modeler. From 0.19 until 1.1.1, FreeCAD's BIM Workbench contains an eval() call on untrusted data from SVG template files. When a user creates a TechDraw page from a malicious SVG template, arbitrary Python code executes. The vulnerable code is in src/Mod/BIM/bimcommands/BimTDPPage.py (line 87). This issue is fixed in version 1.1.1.
CVE-2026-45520	7.8	HIGH		0.002		In onAttach of BiometricsSettingsBase.java, there is a possible authentication bypass due to a confused deputy. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-45998	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: rxrpc: Fix potential UAF after skb_unshare() failure If skb_unshare() fails to unshare a packet due to allocation failure in rxrpc_input_packet(), the skb pointer in the parent (rxrpc_io_thread()) will be NULL'd out. This will likely cause the call to trace_rxrpc_rx_done() to oops. Fix this by moving the unsharing down to where rxrpc_input_cal...
CVE-2026-46117	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: RDMA/mana: Remove user triggerable WARN_ON() in mana_ib_create_qp_rss() Sashiko points out that the user can specify WQs sharing the same CQ as a part of the uAPI and this will trigger the WARN_ON() then go on to corrupt the kernel. Just reject it outright and fail the QP creation.
CVE-2026-46145	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: RDMA/mana: Validate rx_hash_key_len Sashiko points out that rx_hash_key_len comes from a uAPI structure and is blindly passed to memcpy, allowing the userspace to trash kernel memory. Bounds check it so the memcpy cannot overflow.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-46189	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: RDMA/vmw_pvrmdma: Fix double free on pvrmdma_alloc_ucontext() error path Sashiko points out that pvrmdma_uar_free() is already called within pvrmdma_dealloc_ucontext(), so calling it before triggers a double free.
CVE-2026-49881	7.8	HIGH		0.002		In serviceClassExists of InCallController.java, there is a possible arbitrary code execution due to a logic error in the code. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-49932	7.8	HIGH		0.001		In parseParts of PduParser.java, there is a possible out of bounds read due to a heap buffer overflow. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-52987	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: avoid double drm_exec_fini() in userq validate When new_addition is true, amdgpu_userq_vm_validate() calls drm_exec_fini(&exec) before iterating over the collected HMM ranges and calling amdgpu_ttm_tt_get_user_pages(). If amdgpu_ttm_tt_get_user_pages() fails in that path, the code jumps to unlock_all and calls drm_exec_fini(&exec) a...
CVE-2026-53000	7.8	HIGH		0.001	linux:linux_kernel, redhat:enterprise_linux	In the Linux kernel, the following vulnerability has been resolved: netfilter: nat: use kfree_rcu to release ops Florian Westphal says: "Historically this is not an issue, even for normal base hooks: the data path doesn't use the original nf_hook_ops that are used to register the callbacks. However, in v5.14 I added the ability to dump the active netfilter hooks from userspace. This code will peek back into t...
CVE-2026-53009	7.8	HIGH		0.001	linux:linux_kernel, redhat:enterprise_linux	In the Linux kernel, the following vulnerability has been resolved: ice: fix double-free of tx_buf skb If ice_tso() or ice_tx_csum() fail, the error path in ice_xmit_frame_ring() frees the skb, but the 'first' tx_buf still points to it and is marked as valid (ICE_TX_BUF_SKB). 'next_to_use' remains unchanged, so the potential problem will likely fix itself when the next packet is transmitted and the tx_buf gets o...
CVE-2026-53016	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: crypto: ccp - copy IV using skcipher ivsize AF_ALG rfc3686-ctr-aes-ccp requests pass an 8-byte IV to the driver. ccp_aes_complete() restores AES_BLOCK_SIZE bytes into the caller's IV buffer while RFC3686 skciphers expose an 8-byte IV, so the restore overruns the provided buffer. Use crypto_skcipher_ivsize() to copy only the algorithm's IV length.
CVE-2026-53185	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: zram: fix use-after-free in zram_bvec_write_partial() zram_read_page() picks the sync or async backing device read path based on whether the parent bio is NULL. zram_bvec_write_partial() passes its parent bio down, so for ZRAM_WB slots the read is dispatched asynchronously and zram_read_page() returns 0 while the bio is still in flight. The ca...
CVE-2026-54757	7.8	HIGH		0.002		Compliance-trestle (Trestle) is a Python SDK and command-line tool for managing OSCAL compliance documents. In versions before 3.12.4 and versions 4.0.0 through 4.0.3, Trestle is vulnerable to server-side template injection that can lead to remote code execution. This occurs because the MDCleanInclude and MDSectionInclude Jinja2 tags re-parse untrusted Markdown content as template source code using a non-sandboxed...
CVE-2026-55426	7.8	HIGH		0.002		linuxfabrik-lib provides Python modules for database access, caching, shell execution, and API integrations, and Linuxfabrik Monitoring Plugins uses those modules to run external monitoring commands. From the earliest affected releases until linuxfabrik-lib 5.0.0 and Linuxfabrik Monitoring Plugins 6.0.0, check plugins embedded user-controlled values in command strings passed to lib.shell.shell_exec(), which split ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55522	7.8	HIGH		0.002		PraisonAI is a multi-agent teams system. In versions 3.9.26 through 4.6.57 of praiseonai and 0.12.12 through 1.6.57 of praiseonaiagents, the workflow "include" feature is vulnerable to code execution. Workflow._execute_include() implicitly imports and runs an included recipe's tools.py via a raw importlib.util.spec_from_file_location() and spec.loader.exec_module() call, without honoring the PRAISONAI_ALLOW_TEMPLA...
CVE-2026-56172	7.8	HIGH		0.003		Use after free in Windows VHD miniport driver allows an authorized attacker to elevate privileges locally.
CVE-2026-56177	7.8	HIGH		0.003		Use after free in Windows Server allows an authorized attacker to elevate privileges locally.
CVE-2026-56198	7.8	HIGH		0.002		Out-of-bounds read in Microsoft Trace Data Helper allows an authorized attacker to elevate privileges locally.
CVE-2026-57170	7.8	HIGH		0.002		Compliance-trestle (Trestle) is a Python SDK and command-line tool for managing OSCAL compliance documents. In versions prior to 3.12.4 and 4.0.0 through 4.0.3, the custom Jinja2 include tags mdsection_include and md_clean_include re-parse the content of an included Markdown file as Jinja2 template code in a non-sandboxed environment, allowing server-side template injection that can lead to arbitrary code executio...
CVE-2026-58599	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code locally.
CVE-2026-58600	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to elevate privileges locally.
CVE-2026-58874	7.8	HIGH		0.001		In multiple functions of SmsController.java, there is a possible escalation of privilege due to a missing permission check. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-62697	7.8	HIGH		0.003		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-62804	7.8	HIGH		0.003	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	External control of file name or path in Microsoft Office Word allows an unauthorized attacker to execute code locally.
CVE-2026-62810	7.8	HIGH		0.002		Heap-based buffer overflow in Active Directory Certificate Services (AD CS) allows an authorized attacker to elevate privileges locally.
CVE-2026-62886	7.8	HIGH		0.004	microsoft:.net, microsoft:visual_studio_2022, microsoft:visual_studio_2026, microsoft:windows	Integer overflow or wraparound in .NET allows an unauthorized attacker to elevate privileges locally.
CVE-2026-64372	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: cpufreq: pcc: fix use-after-free and double free in _OSC evaluation pcc_cpufreq_do_osc() calls acpi_evaluate_object() twice for the two-phase _OSC negotiation. Between the two calls it freed output.pointer but left output.length unchanged. Since acpi_evaluate_object() treats a non-zero length with a non-NULL pointer as an existing buffer to writ...
CVE-2026-64375	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: proc: protect ptrace_may_access() with exec_update_lock (FD links) proc_pid_get_link() and proc_pid_readlink() currently look up the task from the pid once, then do the ptrace access check on that task, then look up the task from the pid a second time to do the actual access. That's racy in several ways. To fix it, pass the task to the ->proc_g...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-64377	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: cpufreq: qcom-cpufreq-hw: Fix possible double free qcom_cpufreq.data is allocated with devm_kzalloc() in probe() as an array of per-domain data. qcom_cpufreq_hw_cpu_init() stores a pointer to one element of this array in policy->driver_data. qcom_cpufreq_hw_cpu_exit() currently calls kfree() on policy->driver_data. This is not valid because the...
CVE-2026-64378	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: writeback: fix race between cgroup_writeback_umount() and inode_switch_wbs() When a container exits, the following BUG_ON() is occasionally triggered: ===== VFS: Busy inodes after unmount of sdb (ext4) -----[cut here]----- kernel BUG at fs/super.c:695! CPU: 3 PID: ...
CVE-2026-64381	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: smb: client: Fix next buffer leak in receive_encrypted_standard() receive_encrypted_standard() allocates next_buffer before checking whether the number of compound PDUs already reached MAX_COMPOUND. If the limit check fails, the function returns immediately and the newly allocated next_buffer is not assigned to server->smallbuf/server->bigbuf, m...
CVE-2026-67309	7.8	HIGH		0.005		Traefik versions >= v3.7.0 and <= v3.7.7 contain a path traversal vulnerability in the Kubernetes Ingress NGINX provider's RewriteTarget middleware (generated from the nginx.ingress.kubernetes.io/rewrite-target annotation). When an Ingress path uses a regex that captures attacker-controlled text without requiring a path separator (e.g., path /api(.*) with rewrite target /\$1), a crafted request such as /api../admin...
CVE-2026-68508	7.8	HIGH		0.003		Hydra is a framework for elegantly configuring complex applications. Prior to 1.3.4, hydra.utils.instantiate() resolves and calls Python objects selected by configuration through _resolve_target() in hydra/_internal/instantiate/_instantiate2.py, allowing attacker-controlled target values and arguments to choose dangerous callables. A consuming application, library, CLI workflow, or model loader that passes untrust...
CVE-2026-68832	7.8	HIGH		0.002		Integer overflow or wraparound in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68841	7.8	HIGH		0.002		Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-68844	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to execute code locally.
CVE-2026-68845	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-68848	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-68850	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Account allows an authorized attacker to elevate privileges locally.
CVE-2026-68875	7.8	HIGH		0.002		Buffer over-read in Windows NTFS allows an authorized attacker to execute code locally.
CVE-2026-68877	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to execute code locally.
CVE-2026-68885	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68888	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68890	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68892	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68896	7.8	HIGH		0.004		Absolute path traversal in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69265	7.8	HIGH		0.002		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69269	7.8	HIGH		0.003		Integer underflow (wrap or wraparound) in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-69270	7.8	HIGH		0.002		Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69277	7.8	HIGH		0.003		Stack-based buffer overflow in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges locally.
CVE-2026-69283	7.8	HIGH		0.002		Heap-based buffer overflow in Windows CD-ROM Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69284	7.8	HIGH		0.002		Heap-based buffer overflow in Windows DCOM Server allows an authorized attacker to elevate privileges locally.
CVE-2026-69289	7.8	HIGH		0.004		Improper link resolution before file access ('link following') in Windows Setup Files Cleanup allows an authorized attacker to elevate privileges locally.
CVE-2026-69290	7.8	HIGH		0.002		Stack-based buffer overflow in Windows Storage Spaces Controller allows an authorized attacker to elevate privileges locally.
CVE-2026-69293	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69295	7.8	HIGH		0.003		Out-of-bounds read in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69298	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69307	7.8	HIGH		0.003		Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69312	7.8	HIGH		0.003		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69323	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69324	7.8	HIGH		0.003		Access of resource using incompatible type ('type confusion') in Windows Performance Monitor allows an authorized attacker to elevate privileges locally.
CVE-2026-69328	7.8	HIGH		0.003		Untrusted search path in Windows Storage allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69348	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69352	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69359	7.8	HIGH		0.003		Heap-based buffer overflow in Active Directory Domain Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69368	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69377	7.8	HIGH		0.003		Missing authorization in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-69389	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Storage Management Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-69391	7.8	HIGH		0.003		Stack-based buffer overflow in Windows Broker Infrastructure Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69392	7.8	HIGH		0.003		Use after free in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69420	7.8	HIGH		0.003		Heap-based buffer overflow in Windows VOLSnap.SYS allows an authorized attacker to elevate privileges locally.
CVE-2026-69421	7.8	HIGH		0.003		Integer underflow (wrap or wraparound) in Windows Kernel Mode Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69424	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Distributed File System (DFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69426	7.8	HIGH		0.003		Heap-based buffer overflow in Windows VOLSnap.SYS allows an authorized attacker to execute code locally.
CVE-2026-69433	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69436	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69444	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Speech allows an authorized attacker to elevate privileges locally.
CVE-2026-69445	7.8	HIGH		0.004		Improper limitation of a pathname to a restricted directory ('path traversal') in Windows Compressed Folder allows an authorized attacker to elevate privileges locally.
CVE-2026-69447	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69450	7.8	HIGH		0.003		Out-of-bounds read in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69455	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69456	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Speech allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69459	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Power Dependency Coordinator allows an authorized attacker to elevate privileges locally.
CVE-2026-69467	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69475	7.8	HIGH		0.003		Untrusted pointer dereference in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69476	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69478	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69480	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Partition Management Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69489	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69508	7.8	HIGH		0.003		Stack-based buffer overflow in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69509	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69513	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69528	7.8	HIGH		0.003		Missing authentication for critical function in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69532	7.8	HIGH		0.003		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69534	7.8	HIGH		0.006		Improper neutralization of special elements used in a command ('command injection') in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69535	7.8	HIGH		0.002		Numeric truncation error in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-69538	7.8	HIGH		0.002		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-69542	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Camera Frame Server Monitor allows an authorized attacker to elevate privileges locally.
CVE-2026-69544	7.8	HIGH		0.003		Heap-based buffer overflow in Windows SMB Client allows an authorized attacker to elevate privileges locally.
CVE-2026-69561	7.8	HIGH		0.003		Out-of-bounds read in Windows CD-ROM Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69571	7.8	HIGH		0.003		Heap-based buffer overflow in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69580	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69582	7.8	HIGH		0.003		Buffer over-read in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69583	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69584	7.8	HIGH		0.003		Integer overflow or wraparound in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69585	7.8	HIGH		0.004		Incorrect type conversion or cast in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69589	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69592	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69593	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69594	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges locally.
CVE-2026-69604	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69608	7.8	HIGH		0.003		Integer overflow or wraparound in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69612	7.8	HIGH		0.004		Absolute path traversal in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69685	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Kerberos allows an authorized attacker to elevate privileges locally.
CVE-2026-69687	7.8	HIGH		0.003		Integer underflow (wrap or wraparound) in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69691	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-69707	7.8	HIGH		0.003		Integer overflow or wraparound in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69709	7.8	HIGH		0.003		Heap-based buffer overflow in Windows NTFS allows an authorized attacker to execute code locally.
CVE-2026-69720	7.8	HIGH		0.003		Heap-based buffer overflow in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69725	7.8	HIGH		0.003		Double free in Windows Hello allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69738	7.8	HIGH		0.003		Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69758	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69785	7.8	HIGH		0.003		Untrusted search path in Windows Smart Card allows an authorized attacker to elevate privileges locally.
CVE-2026-69787	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69790	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Credential Providers allows an authorized attacker to elevate privileges locally.
CVE-2026-69799	7.8	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69801	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69821	7.8	HIGH		0.003		Improper encoding or escaping of output in Active Directory Certificate Services (AD CS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69822	7.8	HIGH		0.003		Numeric truncation error in Windows Kerberos allows an authorized attacker to elevate privileges locally.
CVE-2026-69841	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Encrypting File System (EFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69844	7.8	HIGH		0.003		Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69864	7.8	HIGH		0.002		Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69907	7.8	HIGH		0.003		Improper handling of insufficient permissions or privileges in Windows Enterprise App Management allows an authorized attacker to elevate privileges locally.
CVE-2026-69921	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-70289	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Win32 Kernel Subsystem allows an authorized attacker to elevate privileges locally.
CVE-2026-70564	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-70569	7.8	HIGH		0.003		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-70572	7.8	HIGH		0.003		Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70581	7.8	HIGH		0.003		Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70583	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Core Messaging allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70584	7.8	HIGH		0.003		Access of resource using incompatible type ('type confusion') in Windows Core Messaging allows an authorized attacker to elevate privileges locally.
CVE-2026-71334	7.8	HIGH		0.002		Heap-based buffer overflow in Windows NFS Portmapper allows an authorized attacker to elevate privileges locally.
CVE-2026-71337	7.8	HIGH		0.003		Stack-based buffer overflow in Windows Storage Management Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-71343	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Remote Access Connection Manager allows an authorized attacker to execute code locally.
CVE-2026-71345	7.8	HIGH		0.003		Out-of-bounds write in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-72929	7.8	HIGH		0.002		Improper validation of integrity check value in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-72941	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72944	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72953	7.8	HIGH		0.003		Heap-based buffer overflow in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-72957	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Deployment Services allows an authorized attacker to execute code locally.
CVE-2026-72965	7.8	HIGH		0.003		Use after free in Windows WebClient Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72967	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Network Connection Broker allows an authorized attacker to elevate privileges locally.
CVE-2026-72988	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72990	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72991	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72992	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72993	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72994	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72995	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72996	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72997	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73000	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73001	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73002	7.8	HIGH		0.002		Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73007	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73011	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73015	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73020	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73021	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73024	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Services for NFS ONCRPC XDR Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-73026	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73231	7.8	HIGH		0.002		Faker generates massive amounts of fake data in the browser and Node.js. Prior to 10.5.0, the faker.helpers.fake method in src/modules/helpers/eval.ts allows attacker-controlled fake templates to access the Function constructor through fakeEval.resolveProperty when a function returns another function, enabling arbitrary JavaScript code execution. This issue is fixed in version 10.5.0.
CVE-2026-76967	7.8	HIGH		0.002		SAP NetWeaver Business Client does not perform sufficient validation when processing certain locally stored data during application startup. An attacker with low privileges on the local system could replace this data with specially crafted content. When the application is next launched, the crafted content is processed and could lead to arbitrary code execution in the context of the user. This results in a high im...
CVE-2026-77489	7.8	HIGH		0.003		Null pointer dereference in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77500	7.8	HIGH		0.003		Release of invalid pointer or reference in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77503	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an unauthorized attacker to elevate privileges locally.
CVE-2026-77904	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-78447	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-78448	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-79907	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Double Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-79908	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-79909	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80075	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:wi	Heap-based buffer overflow in Windows Work Folders allows an authorized attacker to elevate privileges locally.
CVE-2026-80161	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Access of Resource Using Incompatible Type ('Type Confusion') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81353	7.8	HIGH		0.004		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code locally.
CVE-2026-81386	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81388	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81396	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81397	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81398	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81947	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81948	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81949	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Integer overflow or wraparound in Microsoft Office Excel allows an unauthorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81950	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Double free in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81951	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81953	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81954	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use after free in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81956	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81957	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81959	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81960	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81973	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81975	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81976	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81979	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81980	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81981	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81983	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds write vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81985	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81986	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81987	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Integer Overflow or Wraparound vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81988	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81989	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81990	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81992	7.8	HIGH		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Heap-based Buffer Overflow vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83498	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83942	7.8	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Missing authorization in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-83952	7.8	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Heap-based buffer overflow in Windows Resilient File System (ReFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-83954	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83955	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83967	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83968	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83969	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83970	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83971	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83972	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83973	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83974	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83975	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83976	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83977	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83978	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83979	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83980	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83981	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83982	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83983	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83985	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83986	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83987	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83988	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83990	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to elevate privileges locally.
CVE-2026-83995	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-84000	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Graphics Component allows an authorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-15140	7.7	HIGH		0.002		A privilege-escalation issue in the Portworx Operator when deployed on Red Hat OpenShift (OCP). Only under specific conditions during the initial provisioning of a Portworx storage cluster, a user holding only limited, namespace-scoped permissions could cause the operator to grant broader access than intended, potentially resulting in elevated privileges within the Kubernetes cluster.
CVE-2026-18905	7.7	HIGH		0.003		IBM ContextForge MCP Gateway (`mcp-contextforge-gateway`) <= v1.0.6 MCP Context Forge could allow a remote authenticated attacker to obtain sensitive information due to a DNS rebinding vulnerability during tool invocation.
CVE-2026-19283	7.7	HIGH		0.003		IBM Observability with Instana (Agent) Build 1.0.303 through 1.0.323 IBM Instana Agent Operator could allow an authenticated remote attacker to obtain sensitive information, caused by missing destination namespace validation when copying etcd mTLS client credentials from the openshift-etcd system namespace into an attacker-controlled namespace.
CVE-2026-19304	7.7	HIGH		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information from internal services due to a URL parser discrepancy.
CVE-2026-19306	7.7	HIGH		0.004	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 allows an authenticated attacker to read arbitrary files from the server filesystem — including server secret material (secret_key, JWT signing keys, the application database, /proc/self/environ, and other tenants' upload directories) — by supplying absolute paths or traversal sequences in the files parameter of an authenticated build request. The file contents were embedded a...
CVE-2026-28802	7.7	HIGH		0.004	authlib:authlib	Authlib is a Python library which builds OAuth and OpenID Connect servers. From version 1.6.5 to before version 1.6.7, previous tests involving passing a malicious JWT containing alg: none and an empty signature was passing the signature verification step without any changes to the application code when a failure was expected.. This issue has been patched in version 1.6.7.
CVE-2026-44293	7.7	HIGH		0.004	protobufjs_project:protobufjs	protobufjs compiles protobuf definitions into JavaScript (JS) functions. Prior to 7.5.6 and 8.0.2, protobufjs generated JavaScript for toObject conversion could include an unsafe expression derived from a schema-controlled bytes field default value. A crafted descriptor with a non-string default value for a bytes field could cause attacker-controlled code to be emitted into the generated conversion function. This ...
CVE-2026-44495	7.7	HIGH		0.008	axios:axios, redhat:advanced_cluster_management_for_kubernetes, redhat:advanced_cluster_security, redhat:ansible_automat	Axios is a promise based HTTP client for the browser and Node.js. From 0.19.0 to before 0.31.1 and 1.15.2, Axios contains prototype-pollution gadgets in request config processing. If another vulnerability in the same JavaScript process has already polluted Object.prototype.transformResponse, affected Axios versions may treat that inherited value as request configuration or as an option validator. Axios does not it...
CVE-2026-54493	7.7	HIGH		0.003		Koel is a free, open-source music streaming solution. Prior to 9.7.0, the Subsonic-compatible createInternetRadioStation.view and updateInternetRadioStation.view routes accept an authenticated user's streamUrl without the SafeUrl and HasAudioContentType checks used by the regular radio API. app/Http/Requests/Subsonic/CreateInternetRadioStationRequest.php and app/Http/Requests/Subsonic/UpdateInternetRadioStationReq...
CVE-2026-57171	7.7	HIGH		0.002		Compliance-trestle (Trestle) is a Python SDK and command-line tool for managing OSCAL compliance documents. In versions before 3.12.4 and versions 4.0.0 through 4.0.3, the catalog-generate, profile-generate, and ssp-generate author commands write generated Markdown to an attacker-influenced output path without path-traversal validation, allowing arbitrary file write outside the Trestle workspace. These commands jo...
CVE-2026-66738	7.7	HIGH		0.004		SPIP before 4.4.18 contains a code injection vulnerability in SQLite-backed installations. The navigation menu endpoint improperly handles array-typed user input, which bypasses input sanitization and allows the value to break out of an internal quoted string context when evaluated as PHP. An authenticated attacker with at minimum editor (redacteur) privileges can submit a single crafted GET request to /ecrire/?ex...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-66767	7.7	HIGH		0.003		SAP NetWeaver Application Server for ABAP and ABAP Platform allows an unauthenticated user to send a specially crafted packet that triggers reprocessing of a previously buffered user request, potentially hijacking another user's session under narrow timing conditions. Successful exploitation could result in high impact on confidentiality and integrity, with low impact on availability of the application.
CVE-2026-69192	7.7	HIGH		0.004		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.3.1, Address4 accepts an octet written with a leading zero and decodes it as decimal, while the WHATWG URL host parser, inet_aton, and getaddrinfo all decode a leading zero as octal. The library and the network stack therefore disagree about which host a string names. new Address4('012.0.0.1') reports correctFor...
CVE-2026-69683	7.7	HIGH		0.008	microsoft:sharepoint_server	Server-side request forgery (ssrf) in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-70479	7.7	HIGH		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.9.6 until 0.11.0, with WEB_LOADER_ENGINE=playwright, the Playwright web loader validates only the top-level page request and lets sub-resource requests pass unvalidated. A page supplied by an authenticated user can use JavaScript to reach blocked internal addresses, and returned DOM can include data read from those address...
CVE-2026-73217	7.7	HIGH		0.003		Cursor is a code editor built for programming with AI. Prior to 3.1.2, Cursor IDE for macOS allows an agent running in Auto-Run Sandbox mode to replace a virtual environment's Python executable with a malicious wrapper that the Microsoft Python extension invokes outside the sandbox, allowing arbitrary host commands with the user's privileges, including modifying files outside the workspace and launching applicatio...
CVE-2026-73218	7.7	HIGH		0.008		Cursor is a code editor built for programming with AI. Prior to 3.0.0, Cursor IDE for macOS allows an agent running in Auto-Run Sandbox mode, when Docker Desktop and the Dev Containers CLI are installed, to launch a privileged container and mount Docker's virtiofs0, granting read and write access to the user's home directory and enabling host command execution with the user's privileges without an additional permi...
CVE-2026-77775	7.7	HIGH		0.004		Headroom's LLM proxy lets a client choose the upstream destination with the x-headroom-base-url request header. _resolve_openai_upstream_base in headroom/proxy/handlers/openai.py accepts the header value, requires only that it parse with an http or https scheme and a hostname, and returns it for use as the upstream base; _select_passthrough_base_url in headroom/providers/proxy_routes.py reads the same header for t...
CVE-2026-77909	7.7	HIGH		0.006		Insufficiently protected credentials in Azure CycleCloud allows an authorized attacker to disclose information over a network.
CVE-2026-78623	7.7	HIGH		0.002		The Okta Access Gateway does not sanitize SAML assertion values before interpolating them into database queries in the advanced mode datastore configuration. The unsanitized values are substituted directly into the query string prior to preparation, resulting in unintended SQL execution against the configured backend database.
CVE-2026-81210	7.7	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 concatenates three caller-supplied strings into a String.format path on the shared /ds-storage RWX PVC and returns the file with no project ACL — pure IDOR plus traversal. Read is constrained to files named job.log/error.log, but DataStage job logs routinely carry connection strings, {dsnextenc} ciphertxts (decryptable via d2-f023), and customer-data row samples. This i...
CVE-2026-81832	7.7	HIGH		0.003	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 SAP Adapter is vulnerable to an XML external entity (XXE) attack.
CVE-2026-84256	7.7	HIGH		0.004		An argument parsing issue in OpenVPN 2.1_rc10 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows remote authenticated users to execute arbitrary commands via a crafted certificate subject

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87996	7.7	HIGH		0.002		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.9.6 until 0.11.1, SafePlaywrightURLLoader in backend/open_webui/retrieval/web/utlis.py validated a user-controlled hostname in Python and then let the Playwright browser resolve it again in the sync and async request interceptors. An authenticated user controlling authoritative DNS could return a public address to validati...
CVE-2026-47666	7.6	HIGH		0.002		Penpot is an open-source design and prototyping platform. In versions up to and including 2.14.3, Penpot is vulnerable to stored cross-site scripting through custom font family names, which are interpolated into a @font-face CSS rule and injected into the page as HTML without sanitization. Because the backend accepts an arbitrary font-family string and the frontend writes the resulting style through innerHTML, a n...
CVE-2026-53958	7.6	HIGH		0.004		4gaBoards is a boards system for realtime project management. Prior to 3.3.9, 4gaBoards allows an authenticated user to modify ssoGoogleId, ssoGoogleEmail, ssoGithubId, ssoGithubUsername, ssoGithubEmail, ssoMicrosoftId, ssoMicrosoftEmail, ssoOidcId, and ssoOidcEmail through PATCH /api/users/:id. The whitelist in server/api/controllers/users/update.js mass assigns these backend-managed identity attributes from user...
CVE-2026-54245	7.6	HIGH		0.003		Fleet is an open-source device management platform built on osquery. In versions prior to 4.86.2, the Okta conditional access integration in Fleet Premium is vulnerable to SQL injection through a host-supplied value that is used in a database query without proper parameterization, allowing an attacker who controls a single enrolled host to read or modify arbitrary data in the Fleet database. The value is reported ...
CVE-2026-70454	7.6	HIGH		0.002		rsync 3.2.0 through 3.2.3 (openssl mode) and rsync-ssl through 3.4.4 (stunnel mode) contain a TLS certificate validation vulnerability that allows on-path attackers to intercept encrypted sessions by presenting self-signed or otherwise invalid certificates. Attackers can exploit the failure to validate server TLS certificates against a trusted CA or verify certificate hostname matching to decrypt or tamper with rs...
CVE-2026-71048	7.6	HIGH		0.003	oracle:product_lifecycle_analytics	Vulnerability in the Oracle Product Lifecycle Analytics product of Oracle Supply Chain (component: Installation Issues). The supported version that is affected is 3.6.1. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Product Lifecycle Analytics. Successful attacks of this vulnerability can result in unauthorized access to critical data or compl...
CVE-2026-71327	7.6	HIGH		0.004		Traefik is an open source HTTP reverse proxy and load balancer. From 3.0.0 until 3.6.25 and 3.7.10, Traefik's Kubernetes Gateway API provider in pkg/provider/kubernetes/gateway/httproute.go, grpcroute.go, tcpoute.go, and tlsroute.go builds HTTPRoute, GRPCRoute, TCPRoute, and TLSRoute router and service identities by hyphen-concatenating namespace, route name, Gateway identity, entry point, and rule index, allowin...
CVE-2026-73083	7.6	HIGH		0.002		Activepieces is an open source AI workflow automation platform. Prior to 0.80.0, in SANDBOX_CODE_ONLY mode, the engine loads the compiled user module with importFresh(), a wrapper around Node.js require(), before the V8 isolate is applied. Top-level module code can therefore call require('child_process'), access fs, and use other Node.js APIs in the host engine process outside the sandbox. An authenticated user wh...
CVE-2026-73408	7.6	HIGH		0.003		Budibase is an open-source low-code platform. Prior to 3.39.18, packages/server/src/integrations/mysql.ts enabled multipleStatements and inserted an unescaped tableName into a DESCRIBE statement. An attacker able to create a MySQL table with a backtick and stacked statement in its name could wait for a Budibase administrator to run schema discovery, causing the second statement to execute. The fix applies quoteMyS...
CVE-2026-82053	7.6	HIGH		0.002		A security issue exists in MongoDB's LDAP authorization integration where pooled LDAP connections can retain stale authentication identities after user authentication under certain configurations. Subsequent authorization queries may execute under an unintended LDAP identity rather than the expected one. This can result in incorrect role assignments based on the LDAP directory's access control configuration, poten...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-48431	7.5	HIGH		0.011	apache:thrift	Mismatched Memory Management Routines vulnerability in Apache Thrift c_glib language bindings. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue. Description: Specially crafted requests can crash an c_glib-based Thrift server with a clean but fatal "free(): invalid pointer" error message.
CVE-2025-69223	7.5	HIGH		0.006	aiohttp:aiohttp	AIOHTTP is an asynchronous HTTP client/server framework for asyncio and Python. Versions 3.13.2 and below allow a zip bomb to be used to execute a DoS against the AIOHTTP server. An attacker may be able to send a compressed request that when decompressed by AIOHTTP could exhaust the host's memory. This issue is fixed in version 3.13.3.
CVE-2026-13297	7.5	HIGH		0.002		IBM Verify Identity Access Advanced Access Control may be vulnerable to an information disclosure attack.
CVE-2026-17255	7.5	HIGH		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service due to improper validation of the prefix length in ICMPv6 Router Advertisements.
CVE-2026-17470	7.5	HIGH		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service due to a buffer overflow.
CVE-2026-18175	7.5	HIGH		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to manipulate database transactions due to improper authorization in the DDM target dispatcher.
CVE-2026-19300	7.5	HIGH		0.004	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote attacker to obtain sensitive information due to incomplete scrubbing of sensitive credential fields.
CVE-2026-19305	7.5	HIGH		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote attacker to obtain sensitive information due to server-side request forgery.
CVE-2026-19534	7.5	HIGH		0.004		undici's WebSocket client crashes the whole Node.js process during the opening handshake when a server responds with a subprotocol that the client never requested. A default WebSocket connection sends no subprotocol, but if the server's 101 response includes a Sec-WebSocket-Protocol header, undici dereferences a null value while checking it against the requested list and throws an uncaught TypeError. Because that ...
CVE-2026-23490	7.5	HIGH		0.007	debian:debian_linux, pyasn1:pyasn1	pyasn1 is a generic ASN.1 library for Python. Prior to 0.6.2, a Denial-of-Service issue has been found that leads to memory exhaustion from malformed RELATIVE-OID with excessive continuation octets. This vulnerability is fixed in 0.6.2.
CVE-2026-24301	7.5	HIGH		0.022	microsoft:copilot	Improper neutralization of special elements used in a command ('command injection') in Microsoft Copilot allows an unauthorized attacker to disclose information over a network.
CVE-2026-25639	7.5	HIGH		0.028	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to versions 0.30.3 and 1.13.5, the mergeConfig function in axios crashes with a TypeError when processing configuration objects containing __proto__ as an own property. An attacker can trigger this by providing a malicious configuration object created via JSON.parse(), causing complete denial of service. This vulnerability is fixed in versions...
CVE-2026-26456	7.5	HIGH		0.003		A null pointer dereference vulnerability exists in the server-side session management logic of ccoap 77f55c4b466e99327c24ace8a2913d3ba7e2ccd5. The issue is caused by a race condition between the request dispatch thread and the session cleanup thread when accessing shared session list nodes without proper synchronization.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-29074	7.5	HIGH		0.006	svgo:svgo	SVGO, short for SVG Optimizer, is a Node.js library and command-line application for optimizing SVG files. From version 2.1.0 to before version 2.8.1, from version 3.0.0 to before version 3.3.3, and before version 4.0.1, SVGO accepts XML with custom entities, without guards against entity expansion or recursion. This can result in a small XML file (811 bytes) stalling the application and even crashing the Node.js ...
CVE-2026-3039	7.5	HIGH		0.01	isc:bind	BIND servers that are configured to use TKEY-based authentication via GSS-API tokens are vulnerable to excessive memory consumption when receiving and processing maliciously-constructed packets. Typically these servers will be found in Active Directory integrated DNS deployments and/or Kerberos-secured DNS environments. This issue affects BIND 9 versions 9.0.0 through 9.16.50, 9.18.0 through 9.18.48, 9.20.0 throu...
CVE-2026-30922	7.5	HIGH		0.008	pyasn1:pyasn1	pyasn1 is a generic ASN.1 library for Python. Prior to 0.6.3, the `pyasn1` library is vulnerable to a Denial of Service (DoS) attack caused by uncontrolled recursion when decoding ASN.1 data with deeply nested structures. An attacker can supply a crafted payload containing thousands of nested `SEQUENCE` (`0x30`) or `SET` (`0x31`) tags with "Indefinite Length" (`0x80`) markers. This forces the decoder to recursivel...
CVE-2026-32286	7.5	HIGH		0.006	jackc:pgproto3	The DataRow.Decode function fails to properly validate field lengths. A malicious or compromised PostgreSQL server can send a DataRow message with a negative field length, causing a slice bounds out of range panic.
CVE-2026-32597	7.5	HIGH		0.003	pyjwt_project:pyjwt	PyJWT is a JSON Web Token implementation in Python. Prior to 2.12.0, PyJWT does not validate the crit (Critical) Header Parameter defined in RFC 7515 §4.1.11. When a JWS token contains a crit array listing extensions that PyJWT does not understand, the library accepts the token instead of rejecting it. This violates the MUST requirement in the RFC. This vulnerability is fixed in 2.12.0.
CVE-2026-33231	7.5	HIGH		0.012	nlk:nlk	NLTK (Natural Language Toolkit) is a suite of open source Python modules, data sets, and tutorials supporting research and development in Natural Language Processing. In versions 3.9.3 and prior, `nlk.app.wordnet_app` allows unauthenticated remote shutdown of the local WordNet Browser HTTP server when it is started in its default mode. A simple `GET /SHUTDOWN%20THE%20SERVER` request causes the process to terminat...
CVE-2026-33894	7.5	HIGH		0.005	digitalbazaar:forge	Forge (also called `node-forge`) is a native implementation of Transport Layer Security in JavaScript. Prior to version 1.4.0, RSASSA PKCS#1 v1.5 signature verification accepts forged signatures for low public exponent keys (e=3). Attackers can forge signatures by stuffing "garbage" bytes within the ASN structure in order to construct a signature that passes verification, enabling Bleichenbacher style forgery. Thi...
CVE-2026-34355	7.5	HIGH		0.012	apache:http_server	A buffer overflow in mod_proxy_html in Apache HTTP Server 2.4.67 and earlier allows an attack by an untrusted backend. Users are recommended to upgrade to version 2.4.68, which fixes this issue.
CVE-2026-34986	7.5	HIGH		0.007	go-jose_project:go-jose	Go JOSE provides an implementation of the Javascript Object Signing and Encryption set of standards in Go, including support for JSON Web Encryption (JWE), JSON Web Signature (JWS), and JSON Web Token (JWT) standards. Prior to 4.1.4 and 3.0.5, decrypting a JSON Web Encryption (JWE) object will panic if the alg field indicates a key wrapping algorithm (one ending in KW, with the exception of A128GCMKW, A192GCMKW, a...
CVE-2026-35172	7.5	HIGH		0.005	distribution:distribution	Distribution is a toolkit to pack, ship, store, and deliver container content. Prior to 3.1.0, distribution can restore read access in repo a after an explicit delete when storage.cache.blobdescriptor: redis and storage.delete.enabled: true are both enabled. The delete path clears the shared digest descriptor but leaves stale repo-scoped membership behind, so a later Stat or Get from repo b repopulates the shared ...
CVE-2026-41602	7.5	HIGH		0.012	apache:thrift	Integer Overflow or Wraparound vulnerability in Apache Thrift TFramedTransport Go language implementation This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-42151	7.5	HIGH		0.004	prometheus:prometheus	Prometheus is an open-source monitoring system and time series database. Prior to versions 3.5.3 and 3.11.3, the client_secret field in the Azure AD remote write OAuth configuration (storage/remote/azuread) was typed as string instead of Secret. Prometheus redacts fields of type Secret when serving the configuration via the /-/config HTTP API endpoint. Because the field was a plain string, the Azure OAuth client s...
CVE-2026-42536	7.5	HIGH		0.01	apache:http_server	Heap-based Buffer Overflow vulnerability in Apache HTTP Server with mod_xml2enc, xml2StartParse, and untrusted content This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.
CVE-2026-43003	7.5	HIGH		0.01	openstack:ironic_python_agent	An issue was discovered in OpenStack ironic-python-agent 1.0.0 through 11.5.0. Ironic Python Agent (IPA) sometimes executes grub-install from within a chroot of the deployed partition image, leading to code execution in the case of a malicious image.
CVE-2026-44250	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. In netty-codec-redis prior to versions 4.1.135.Final and 4.2.15.Final, an attacker can cause DoS by sending a crafted Redis payload with deeply nested arrays. This forces the server to allocate a massive number of state objects and collections, leading to memory exhaustion and an OutOfMemoryError. Versions 4.1.135.Final and 4...
CVE-2026-44486	7.5	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 0.32.0 and 1.16.0, Axios' Node.js HTTP adapter can leak proxy credentials to a redirect target in affected versions. When a request is sent through an authenticated proxy, Axios may add a Proxy-Authorization header. If Axios then follows a redirect and the redirected request is no longer sent through that proxy, the stale Proxy-Authorizatio...
CVE-2026-44488	7.5	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Axios versions 1.7.0 through 1.15.x did not enforce configured request and response size limits when requests were sent with the fetch adapter. Applications that selected adapter: 'fetch', or ran in environments where axios resolved to the fetch adapter, could receive or send bodies larger than maxContentLength or maxBodyLength despite those limits ...
CVE-2026-44496	7.5	HIGH		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Axios versions before 0.32.0 on the 0.x line and before 1.16.0 on the 1.x line build a regular expression from the configured XSRF cookie name without escaping regex metacharacters. In standard browser environments, an attacker who can influence the cookie name passed to axios can cause expensive regex backtracking while axios reads document.cookie....
CVE-2026-44890	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. In netty-codec-redis prior to versions 4.1.135.Final and 4.2.15.Final, an attacker can cause DoS by sending crafted Redis payloads across multiple connections without '\r\n'. This exhausts the server's direct memory pool (OutOfDirectMemoryError), preventing legitimate connections from being processed. Versions 4.1.135.Final a...
CVE-2026-45736	7.5	HIGH		0.007	ws_project:ws	ws is an open source WebSocket client and server for Node.js. Prior to 8.20.1, the websocket.close() implementation is vulnerable to uninitialized memory disclosure when a TypedArray is passed as the reason argument. This vulnerability is fixed in 8.20.1.
CVE-2026-45741	7.5	HIGH		0.008		Gotenberg is a Docker-powered stateless API for PDF files. In 8.32.0 and earlier, the IsPublicIP function in pkg/gotenberg/outbound.go does not reject the 2002::/16 6to4 prefix, the 64:ff9b::/96 and 64:ff9b:1::/48 NAT64 prefixes, the fec0::/10 deprecated site-local prefix, Teredo, and other transition prefixes that can embed or route to non-public IPv4 destinations. The addr.Unmap operation only handles IPv4-mappe...
CVE-2026-45742	7.5	HIGH		0.006		Gotenberg is a Docker-powered stateless API for PDF files. From 8.10.0 until 8.33.0, the newContext function in pkg/modules/api/context.go starts one errgroup.Go goroutine for each multipart downloadFrom entry and allows those goroutines to concurrently write to the shared ctx.files, ctx.diskToOriginal, and ctx.filesByField maps and slices. Go maps and slices are not safe for concurrent mutation, so a crafted mult...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-46625	7.5	HIGH		0.009	js-cookie:javascript_cookie, redhat:3scale_api_management, redhat:ansible_automation_platform, redhat:enterprise_linux,	JavaScript Cookie is a JavaScript API for handling cookies, client-side. Prior to version 3.0.7, js-cookie's internal assign() helper copies properties with for...in + plain assignment. When the source object is produced by JSON.parse, the JSON object's "__proto__" member is an own enumerable property, so the for...in enumerates it and the target[key] = source[key] write triggers the Object.prototype.__proto__ sette...
CVE-2026-47885	7.5	HIGH		0.003	vmware:spring_framework	The PartEventHttpMessageReader in Spring WebFlux does not enforce the maxPartSize limit when maxInMemorySize is set to -1. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28
CVE-2026-47886	7.5	HIGH		0.003	vmware:spring_framework	Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial of Service (DoS) attack when the power operator (^) is used with a BigDecimal or BigInteger operand and a large exponent value. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framew...
CVE-2026-47888	7.5	HIGH		0.003	vmware:spring_framework	A Spring RSocket application is exposed to a memory leak via a malformed SETUP frame. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.0.RELEASE - 5.2.25.RELEASE
CVE-2026-47889	7.5	HIGH		0.003	vmware:spring_framework	A WebFlux application running on the Jetty 12 Core reactive adapter serializes response cookies without the sameSite attribute. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19
CVE-2026-48779	7.5	HIGH		0.008	ws_project:ws	ws is an open source WebSocket client and server for Node.js. All versions from 1.1.0 up to (but not including) 5.2.5, from 6.0.0 up to 6.2.4, from 7.0.0 up to 7.5.11, and from 8.0.0 up to 8.21.0 are affected by a memory exhaustion DoS vulnerability. A peer can send a high volume of exceptionally small fragments and data chunks, with modest network traffic, to force the remote peer into allocating and holding stru...
CVE-2026-48804	7.5	HIGH		0.003		python-socketio is a Python implementation of the Socket.IO realtime client and server. The python-socketio server stores binary `EVENT` and `ACK` messages in memory while it waits to receive their binary attachments. Once all the attachments are received, these messages are then processed. Prior to version 5.16.4, an attacker can submit a binary message and intentionally omit sending one or more of its attachment...
CVE-2026-49362	7.5	HIGH		0.002		An unauthenticated remote attacker can create arbitrary durable queues via the CORE protocol, leading to unauthorized broker state manipulation and potential denial of service. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-49363	7.5	HIGH		0.003		An unauthenticated remote attacker connecting with the CORE protocol can discover cluster node details by sending a SUBSCRIBE_TOPOLOGY request prior to authentication. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-50010	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, SimpleTrustManagerFactory.engineGetTrustManagers() and related paths wrap any user-supplied plain X509TrustManager in X509TrustManagerWrapper, which extends X509ExtendedTrustManager but implements the 3-arg checkServerTrusted(chain, authType, SSLEngine) by discarding the SSLEn...
CVE-2026-50011	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, RedisArrayAggregator pre-allocates ArrayList with initial capacity equal to the RESP array element count declared in an array header. That count is taken from the wire before the corresponding child messages exist. A small malicious header can claim a huge initial capacity. Ve...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-52880	7.5	HIGH		0.003		Klever-Go is the Go implementation of the Klever blockchain protocol. Versions from 1.7.14 through 1.7.17 are vulnerable to a remotely triggerable denial of service. Both REST APIs are started with the Gin Engine.Run convenience method, which serves requests through Go's default HTTP server with no ReadHeaderTimeout, ReadTimeout, or MaxHeaderBytes configured. As a result, incoming connections that never complete t...
CVE-2026-54293	7.5	HIGH		0.006	nlk:nlk	NLTK (Natural Language Toolkit) is a suite of open source Python modules, data sets, and tutorials supporting research and development in Natural Language Processing. Prior to 3.10.0-rc1, nltk.data.load() in NLTK is vulnerable to path traversal via URL-encoded path separators and traversal segments when using the nltk: URL scheme. The unsafe-path regex check is performed before url2pathname() decodes the %xx seque...
CVE-2026-55099	7.5	HIGH		0.004		icalendar is an RFC 5545 compatible parser and generator of iCalendar files for Python. From 7.1.0 until 7.1.3, the Component equality method in src/icalendar/cal/component.py compares nested subcomponents with two membership loops, and each membership test invokes the same method on child components, causing O(2^n) work relative to nesting depth. Component.from_ical accepts arbitrarily nested BEGIN:VEVENT blocks ...
CVE-2026-55215	7.5	HIGH		0.004		MariaDB Connector/Node.js is used to connect applications developed on Node.js to MariaDB and MySQL databases. Prior to versions 3.3.3, 3.4.6, and 3.5.3, when ssl is enabled without a pinned CA or server certificate, MariaDB Connector/Node.js sends credentials before completing certificate fingerprint validation. In lib/cmd/handshake/auth/handshake.js, a server that selects mysql_clear_password as the initial auth...
CVE-2026-55552	7.5	HIGH		0.004		Yamcs is a mission control framework. Prior to 5.11.13, Yamcs StaticFileHandler.locateFile resolves an unauthenticated request path without using Path.normalize and Path.toAbsolutePath to confirm that the absolute path remains within the configured staticRoots. A path containing traversal segments can escape the intended web root and return an arbitrary readable host file. The flaw is in yamcs-core/src/main/java/o...
CVE-2026-55553	7.5	HIGH		0.004		urllib is an HTTP client for Node.js that supports authentication, redirects, timeouts, and other request features. Prior to 4.9.1 and 2.44.1, urllib follows redirects through followRedirect but reuses caller-supplied options across origins. In src/HttpClient.ts, #requestInternal recursively calls this.#requestInternal(nextUrl.href, options, requestContext), causing options.headers and auth or digestAuth values to...
CVE-2026-55620	7.5	HIGH		0.004		eml_parser serves as a python module for parsing eml files and returning various information found in the e-mail as well as computed information. Prior to 3.0.2, eml_parser.routing.noparenthesis in eml_parser/routing.py removes parenthesized CFWS comments from Received: headers with a regex-based fix-point loop whose running time is quadratic in the nesting depth. A single Received: header with 5,000 nested parent...
CVE-2026-55841	7.5	HIGH		0.004		Graylog is a free and open log management platform. Prior to Graylog Server versions 6.3.12, 7.0.7, and 7.1.2 and Graylog Forwarder version 7.3, the FortiGate key-value syslog parser in graylog2-server/src/main/java/org/graylog2/inputs/codecs/GLFortiGateSyslogEvent.java and graylog2-server/src/main/java/org/graylog2/inputs/codecs/SyslogCodec.java mishandles field-like text inside quoted values. GLFortiGateSyslogEv...
CVE-2026-56671	7.5	HIGH		0.007		ComfyUI is a modular diffusion model GUI, api and backend with a graph/nodes interface. Prior to 0.28.0, get_model_preview in app/model_manager.py joins an unrestricted filename route capture to a selected model directory without a containment check, allowing an unauthenticated remote attacker to use traversal, encoded traversal, absolute paths, or an unbounded path_index to read image-decodable files and enumerat...
CVE-2026-57098	7.5	HIGH		0.006		Improper verification of cryptographic signature in Windows RDP Client allows an unauthorized attacker to disclose information over a network.
CVE-2026-57099	7.5	HIGH		0.008		Allocation of resources without limits or throttling in ASP.NET Core allows an unauthorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-5946	7.5	HIGH		0.019	isc:bind	Multiple flaws have been identified in `named` related to the handling of DNS messages whose CLASS is not Internet (`IN`) — for example, `CHAOS` or `HESIOD`, or DNS messages that specify meta-classes (`ANY` or `NONE`) in the question section. Specially crafted requests reaching the affected code paths — recursion, dynamic updates (`UPDATE`), zone change notifications (`NOTIFY`), or processing of `IN`-specific reco...
CVE-2026-59902	7.5	HIGH		0.004		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Final and 4.2.17.Final, io.netty.handler.codec.sctp.SctpMessageCompletionHandler limits incomplete messages and fragment counts but not maxBufferedBytes, allowing unauthenticated peers to exhaust memory with large SCTP fragments. This issue is fixed in versions 4.1.137.Final and 4.2.17.Final.
CVE-2026-62295	7.5	HIGH		0.003		HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to 6.9.11, the JSON utility parser in org.hl7.fhir.utilities.json.parser.JsonParser enforces no maximum nesting depth for arrays or objects. As a result, a small but deeply nested, syntactically valid FHIR JSON document can trigger unbounded readArray() or readObject() recursion, raising a StackOverflowEr...
CVE-2026-62296	7.5	HIGH		0.003		HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to 6.9.11, XhtmlParser.java imposes no maximum element nesting depth, so a deeply nested text.div narrative triggers unbounded recursion between parseElementInner() and parseElement(), raising a StackOverflowError. An attacker who can submit FHIR resources containing such narratives can thus crash a pars...
CVE-2026-62759	7.5	HIGH		0.003		Authentication bypass by spoofing in Windows Netlogon allows an unauthorized attacker to perform spoofing over an adjacent network.
CVE-2026-62813	7.5	HIGH		0.006		Use after free in Active Directory Domain Services allows an authorized attacker to execute code over a network.
CVE-2026-63408	7.5	HIGH		0.004		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.0-rc.16, the Grav API plugin JwtAuthenticator::extractBearerToken() accepts a JWT from the token URL query parameter on every /api/v1 route, including state-changing endpoints. Request URLs consequently expose valid access tokens through Apache, proxy, and CDN logs, browser history, and Referer he...
CVE-2026-63421	7.5	HIGH		0.005		Keystone is a content management system for Node.js. Prior to 6.5.3, the findMany resolver in packages/core/src/lib/core/queries/resolvers.ts compares the signed take argument directly with graphql.maxTake, allowing a remote unauthenticated GraphQL client to provide a negative take value whose magnitude exceeds the configured bound. The bypass also applies to relationship queries and can return more records than t...
CVE-2026-64374	7.5	HIGH		0.004	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: sched/rt: Have RT_PUSH_IPI be default off for non PREEMPT_RT RT migration is done aggressively. When a CPU schedules out a high priority RT task for a lower priority task, it will look to see if there's any RT tasks that are waiting to run on another CPU that is of higher priority than the task this CPU is about to run. If it finds one, it will ...
CVE-2026-66373	7.5	HIGH		0.006		Redis before 8.8.0, in the unusual case where an authenticated attacker can execute RESTORE, allows remote code execution via a RESTORE payload where the same NACK (pending entry) is referenced by more than one consumer, because deleting both consumers via XGROUP DELCONSUMER leads to a double free. NOTE: this issue exists because of an incomplete fix for CVE-2026-25243.
CVE-2026-67422	7.5	HIGH		0.006		pymdown-extensions is a collection of extensions for the Python Markdown library. In versions up to and including 11.0, four inline processors (caret, tilde, betterem, and magiclink) use regular expressions whose content groups can partition a run of delimiter characters in exponentially many ways, causing catastrophic backtracking. As a result, a single untrusted Markdown line under 50 bytes rendered with markdow...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68887	7.5	HIGH		0.008		Out-of-bounds read in Windows Message Queuing Queue Manager allows an unauthorized attacker to deny service over a network.
CVE-2026-69222	7.5	HIGH		0.004		LiquidJS is a Shopify / GitHub Pages compatible template engine in pure JavaScript. Prior to 10.27.2, the join filter in src/filters/array.ts computes complexity from array.length and separator length instead of the total string length produced by array.join(sep). The concat filter can cheaply double arrays of references, after which join materializes the referenced content while charging only for element count, a...
CVE-2026-69342	7.5	HIGH		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-69378	7.5	HIGH		0.011		Uncontrolled recursion in Microsoft Exchange Server allows an unauthorized attacker to deny service over a network.
CVE-2026-69397	7.5	HIGH		0.006		Use after free in OpenSSH for Windows allows an unauthorized attacker to execute code over a network.
CVE-2026-69428	7.5	HIGH		0.011		Out-of-bounds read in Windows LDAP - Lightweight Directory Access Protocol allows an unauthorized attacker to deny service over a network.
CVE-2026-69429	7.5	HIGH		0.006		Heap-based buffer overflow in Windows IKE Extension allows an authorized attacker to execute code over a network.
CVE-2026-69443	7.5	HIGH		0.01		Out-of-bounds read in Windows Device Health Attestation (DHA) allows an unauthorized attacker to disclose information over a network.
CVE-2026-69514	7.5	HIGH		0.007		Heap-based buffer overflow in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69539	7.5	HIGH		0.005		Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69587	7.5	HIGH		0.012		Null pointer dereference in Windows IKE Extension allows an unauthorized attacker to deny service over a network.
CVE-2026-69588	7.5	HIGH		0.012		Missing release of memory after effective lifetime in Windows TCP/IP allows an unauthorized attacker to deny service over a network.
CVE-2026-69599	7.5	HIGH		0.007		Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69607	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an unauthorized attacker to execute code over a network.
CVE-2026-69631	7.5	HIGH		0.012		Integer overflow or wraparound in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-69710	7.5	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Hello allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69739	7.5	HIGH		0.009	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-69744	7.5	HIGH		0.011		Null pointer dereference in Windows Kerberos allows an unauthorized attacker to deny service over a network.
CVE-2026-69760	7.5	HIGH		0.011		Out-of-bounds read in Windows Kerberos allows an unauthorized attacker to deny service over a network.
CVE-2026-69793	7.5	HIGH		0.008		Improper validation of consistency within input in Windows TCP/IP allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-69803	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69804	7.5	HIGH		0.005	microsoft:sharepoint_server	Time-of-check time-of-use (toctou) race condition in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69805	7.5	HIGH		0.005		External control of file name or path in .NET allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-69809	7.5	HIGH		0.011		Missing release of memory after effective lifetime in Active Directory Domain Services allows an unauthorized attacker to deny service over a network.
CVE-2026-69852	7.5	HIGH		0.006		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-69881	7.5	HIGH		0.012		Null pointer dereference in Windows IKE Extension allows an unauthorized attacker to deny service over a network.
CVE-2026-69890	7.5	HIGH		0.003		Use after free in Windows Virtual Trusted Platform Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69929	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69930	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70065	7.5	HIGH		0.012	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-70124	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-70570	7.5	HIGH		0.004		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-70579	7.5	HIGH		0.01		Out-of-bounds read in Windows Mobile Broadband allows an unauthorized attacker to disclose information over a network.
CVE-2026-70587	7.5	HIGH		0.008		Improper null termination in Windows Remote Desktop Protocol allows an unauthorized attacker to disclose information over a network.
CVE-2026-70601	7.5	HIGH		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.9, 40.9.2, 41.2.2, and 42.0.0-beta.5, apps that expose Promise-returning functions to web content via contextBridge may be vulnerable to a context isolation bypass. Untrusted web content could obtain access to the isolated preload world and, through it, every capability the preload script has. In r...
CVE-2026-71092	7.5	HIGH		0.001	oracle:peoplesoft_lease_administrat ion	Vulnerability in the PeopleSoft Enterprise FIN Lease Administration product of Oracle PeopleSoft (component: Lease Administration). The supported version that is affected is 9.2. Difficult to exploit vulnerability allows low privileged attacker with logon to the infrastructure where PeopleSoft Enterprise FIN Lease Administration executes to compromise PeopleSoft Enterprise FIN Lease Administration. While the vu...
CVE-2026-71330	7.5	HIGH		0.008		Exposure of sensitive system information to an unauthorized control sphere in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to disclose information over a network.
CVE-2026-72923	7.5	HIGH		0.012		In Microsoft.OpenApi.YamlReader from 2.0.0-preview.11 until 2.12.0 and from 3.0.0 until 3.10.0, and in Microsoft.OpenApi.Readers prior to 1.6.30, a small YAML OpenAPI document containing nested anchors and aliases can cause uncontrolled resource consumption when parsed through the public YAML reader APIs. YAML is parsed through SharpYaml, which represents aliases as shared nodes in a directed acyclic graph, so the...
CVE-2026-72928	7.5	HIGH		0.006		Use after free in Windows DNS allows an authorized attacker to execute code over a network.
CVE-2026-72932	7.5	HIGH		0.01		Buffer over-read in Windows Message Queuing Queue Manager allows an unauthorized attacker to disclose information over a network.
CVE-2026-72943	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an authorized attacker to execute code over a network.
CVE-2026-72949	7.5	HIGH		0.011		Null pointer dereference in Windows SMB Server Network Transport Driver (srvnet.sys) allows an unauthorized attacker to deny service over a network.
CVE-2026-72954	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an authorized attacker to execute code over a network.
CVE-2026-72989	7.5	HIGH		0.008		Use of uninitialized resource in Windows Failover Cluster allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73017	7.5	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Graphics Kernel allows an authorized attacker to execute code locally.
CVE-2026-73088	7.5	HIGH		0.004		Browserslist is a configuration tool for sharing target browsers and Node.js versions between front-end tools. Prior to 4.28.7, normalizeStats() in node.js, reached unconditionally through getStat() and loadStat() on every browserslist() call, processes untrusted browserslist-stats.json, opts.stats, and CLI --stats data with an unguarded for...in loop and plain-object bracket access and assignment, allowing inheri...
CVE-2026-73089	7.5	HIGH		0.004		Browserslist is a configuration tool for sharing target browsers and Node.js versions between front-end tools. Prior to 4.28.7, index.js retains every distinct `(queries, context)` result in cache and every parseQueries() AST in parseCache without a size cap, TTL, or eviction, allowing an attacker who can influence repeated browserslist() query values, including valid since ` <year><-<month>-<day>` queries, to bypas...</year>
CVE-2026-73246	7.5	HIGH		0.004		Kestra is an open-source, event-driven orchestration platform. Prior to 2.0.0-rc6, Kestra's worker/src/main/java/io/kestra/worker/endpoint/WorkerEndpoint.java serves GET /worker without authentication and serializes the complete live Task object, which can expose commands, environment variables, HTTP headers, connection details, plaintext credentials, and execution identifiers while the main API on port 8080 remai...
CVE-2026-73507	7.5	HIGH		0.005		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.136.Final and 4.2.16.Final, io.netty.handler.codec.xml.XmlFrameDecoder.decode() failed to preserve closing-tag parser state across invocations, so an unauthenticated remote attacker could trickle-feed repeated </ sequences that repeatedly rescanned the accumulated buffer and exhausted an EventLoop thread's CPU, causing denial of ser...
CVE-2026-73561	7.5	HIGH		0.004		Hub is a Node.js WebSocket server and client with added features. Prior to 0.2.16, every incoming unauthenticated WebSocket connection triggers loadDefaultConnectionEventListeners to call requestClientId, which calls rpc.send for the get-client-id action and pushes a request into RPC.requests. The RPC.waitForReply function starts a setInterval polling loop every 10 milliseconds that is cleared only after a matchin...
CVE-2026-74761	7.5	HIGH		0.002		Improper input validation in TopicRegion in Apache ActiveMQ, Apache ActiveMQ Broker, and Apache ActiveMQ All on all platforms. An authenticated client can spoof clientId when removing a durable topic subscription. This issue affects Apache ActiveMQ Broker: before 5.19.11, from 6.0.0 before 6.3.2; Apache ActiveMQ All: before 5.19.11, from 6.0.0 before 6.3.2; Apache ActiveMQ: before 5.19.11, from 6.0.0 before...
CVE-2026-75328	7.5	HIGH		0.003		In DocSys-master V2.02.85, the downloadDocEx interface in src/com/DocSystem/controller/DocController.java has an arbitrary file read vulnerability:
CVE-2026-76098	7.5	HIGH		0.003		Mistune is a Python Markdown parser with renderers and plugins. Versions 3.3.0 through 3.3.2 are vulnerable to DoS through deeply nested tokens. HTML rendering creates deeply nested emphasis tokens from consecutive asterisk characters, and recursive rendering in HTMLRenderer.render_token() can exceed Python's recursion limit and raise RecursionError, allowing crafted Markdown to crash a parsing process. This issue...
CVE-2026-77384	7.5	HIGH		0.003		libp2p is a JavaScript implementation of the libp2p networking stack. Prior to version 4.2.9, the reservation refresh path in reservation-store.ts reuses the same retimeableSignal but unconditionally registers another abort listener on every refresh. As a result, a remote peer can repeatedly send valid RESERVE requests for the same reservation, causing unbounded listener and closure growth in @libp2p/circuit-relay...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77438	7.5	HIGH		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the public share-search endpoint does not enforce the per-note shareCredentials and shareHiddenFromTree controls, allowing an unauthenticated visitor to read the titles, tree paths, and content of protected shared notes. The endpoint authorizes only the ancestor note supplied in the request and then runs a full...
CVE-2026-77465	7.5	HIGH		0.004		toml-node is a TOML parser for Node.js and the browser. Prior to 4.2.0, toml.parse() uses a Peggy 5.1.0 generated recursive-descent parser in lib/parser.js whose peg\$parsevalue, peg\$parsearray, and peg\$parseinline_table_entry functions recurse through nested arrays and inline tables without a depth limit. A remote unauthenticated application parsing an attacker-controlled TOML document containing a few thousand ne...
CVE-2026-77494	7.5	HIGH		0.012		Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77498	7.5	HIGH		0.008		Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77499	7.5	HIGH		0.009		Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77501	7.5	HIGH		0.008		Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77502	7.5	HIGH		0.008		Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77886	7.5	HIGH		0.008		Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77888	7.5	HIGH		0.009		Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77889	7.5	HIGH		0.009		Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77890	7.5	HIGH		0.009		Access of resource using incompatible type ('type confusion') in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77893	7.5	HIGH		0.008		Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77895	7.5	HIGH		0.011		Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-77898	7.5	HIGH		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78523	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-78543	7.5	HIGH		0.004	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a remote attacker to cause a denial of service due to an infinite loop.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78574	7.5	HIGH		0.001		The Okta Hyperdrive Integration plugin resolves a required assembly using a registry path within the current user's hive without integrity verification. The referenced path is loaded via Assembly.LoadFrom without signature validation, resulting in an unverified assembly executing within the context of the host process or elevated installer.
CVE-2026-80229	7.5	HIGH		0.006		When performing transfers via libcurl's multi interface, pooled TLS connections can outlive their originating easy handles. In OpenSSL 3 provider configurations, libcurl attaches an allocated library context to the easy handle's state and passes it to OpenSSL without acquiring an ownership reference; destroying the easy handle prematurely frees this context while the active connection retains a dangling pointer, l...
CVE-2026-80924	7.5	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: crypto: krb5 - use kfree_sensitive() for derived key buffers crypto_krb5_prepare_encryption() and crypto_krb5_prepare_checksum() free the buffer holding the freshly derived keys with plain kfree(), leaving the key material behind in the freed slab object.
CVE-2026-81265	7.5	HIGH				IBM Langflow OSS 1.0.0 through 1.11.5.
CVE-2026-81270	7.5	HIGH		0.004		Apache Allura: exposure of non-public information via search. This issue affects Apache Allura: through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.
CVE-2026-82397	7.5	HIGH		0.004		Tornado is a Python web framework and asynchronous networking library. Prior to 6.5.8, Tornado parses application/x-www-form-urlencoded request bodies with urlib.parse.parse_qs in tornado/escape.py without passing max_num_fields. RequestHandler._execute in tornado/web.py parses the body before handler dispatch through HTTPServerRequest._parse_body and parse_body_arguments in tornado/httputil.py, so an unauthentic...
CVE-2026-83989	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to deny service over a network.
CVE-2026-84001	7.5	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Key Distribution Center allows an unauthorized attacker to deny service over a network.
CVE-2026-84219	7.5	HIGH		0.002		The Kirki WordPress plugin before 6.3.0 does not hold back every spelling of the HTML entities it decodes when rendering, allowing unauthenticated users to store JavaScript in a comment which then runs in the session of anyone viewing a page that displays it, including an administrator, and on every page of the site when its header or footer is built to show comments.
CVE-2026-84375	7.5	HIGH		0.004		js-yaml is a JavaScript YAML parser and dumper. From 3.0.0 until 3.15.2 and 4.3.2, maxTotalMergeKeys in lib/js-yaml/loader.js and lib/loader.js does not count empty mapping sources while processing the merge key <<. An attacker can alias a large sequence of empty mappings into many merge targets, causing O(N * K) processing while totalMergeKeys remains unchanged and the configured resource limit is never reached. ...
CVE-2026-84382	7.5	HIGH		0.004		HTTPX2 is a next generation HTTP client for Python. Prior to 2.12.0, the HTTPX2 content decoders in src/httpx2/httpx2/_decoders.py fully inflate each gzip, deflate, br, or zstd network chunk before iter_bytes() or aiter_bytes() yields bounded pieces to the application. A 64 KiB compressed chunk can expand to approximately 64 MiB in one intermediate allocation, so an attacker-controlled or compromised server can ca...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84469	7.5	HIGH		0.003		fastify versions before 5.12.2 decide whether to compile a request schema based on JavaScript truthiness, but JSON Schema Draft 7 defines the boolean false as a valid schema that rejects every instance. When an application assigns false to a route's body, querystring, params, or headers schema to deny all input, fastify treats it as a missing schema, compiles no validator, and runs the route handler on any request...
CVE-2026-86093	7.5	HIGH				IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an attacker with the ability to control or impersonate a DRDA server endpoint to execute arbitrary commands on Db2 clients due to a stack-based buffer overflow that improperly copies user-controlled data into a fixed-size stack buffer without bounds checking.
CVE-2026-87776	7.5	HIGH				compression is a Node.js and Express compression middleware. In versions before 1.8.2, when a client aborts the connection while a compressed response is still being sent, the zlib stream created to compress that response is never destroyed, so each aborted compressed response leaks its native zlib memory. A remote unauthenticated attacker can repeatedly open requests and disconnect early, exhausting the available...
CVE-2026-87908	7.5	HIGH				multipart is a Node.js library for parsing multipart/form-data request bodies. In versions from 2.1.0 up to but not including 4.3.1, the parser does not bound the amount of memory used while accumulating the headers of a single multipart part. An unauthenticated attacker can send a single request whose part carries a very large volume of header bytes, forcing the parser to buffer all of them and exhausting the pr...
CVE-2026-8862	7.5	HIGH		0.002	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 has credentials that are hardcoded in the application source code, allowing unauthorized access to the container registry. The exposed secret enables attackers to pull private container images, potentially revealing proprietary code, configuration details, and other sensitive information.
CVE-2026-18489	7.4	HIGH		0.003		IBM ContextForge MCP Gateway - Translate utility <= 1.0.8 MCP Context Forge could allow a remote attacker to obtain sensitive information from other sessions due to exposure of data elements to the wrong session.
CVE-2026-19651	7.4	HIGH		0.003		IBM Enterprise Build of Quarkus 3.27.1 through 3.27.5, and 3.33.1 through 3.33.3 could allow an attacker to bypass authorization by manipulating URL query parameters due to incorrect mapping of values to untrusted query string input.
CVE-2026-32589	7.4	HIGH		0.002	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay's container image upload process. An authenticated user with push access to any repository on the registry can interfere with image uploads in progress by other users, including those in repositories they do not have access to. This could allow the attacker to read, modify, or cancel another user's in-progress image upload.
CVE-2026-42033	7.4	HIGH		0.008	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, when Object.prototype has been polluted by any co-dependency with keys that axios reads without a hasOwnProperty guard, an attacker can (a) silently intercept and modify every JSON response before the application sees it, or (b) fully hijack the underlying HTTP transport, gaining access to request credentials, headers, an...
CVE-2026-48084	7.4	HIGH		0.004		OpenReception's appointment booking software provides an end-to-end encrypted appointment booking platform. Versions prior to 1.0.2 don't throttle failed passphrase login attempts. An attacker can submit unlimited wrong passphrase guesses against any known email address, capped only by the Argon2 verification cost (about 100 milliseconds per attempt on the tested host, giving 10 attempts per second sustained). The...
CVE-2026-48526	7.4	HIGH		0.004	pyjwt_project:pyjwt	PyJWT is a JSON Web Token implementation in Python. Prior to 2.13.0, when the verifier is decoding JSON Web Tokens, while supporting both asymmetric and HMAC algorithms, the library does not validate use of JSON Web Keys in HMAC algorithm, allowing attacker to use the issuer public key as the secret key for HMAC algorithm. This vulnerability is fixed in 2.13.0.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54550	7.4	HIGH		0.004		IzPack is a widely used tool for packaging applications on the Java platform as cross-platform installers. In 5.2.6 and earlier, UnpackerBase.unpack() in izpack-installer/src/main/java/com/izforge/izpack/installer/unpacker/UnpackerBase.java obtains an attacker-controlled PackFile targetPath, passes it through IoHelper.translatePath(), which only converts separators, and constructs a File without normalizing parent...
CVE-2026-62906	7.4	HIGH		0.007		Improper neutralization of special elements in data query logic in Microsoft Discovery Studio allows an unauthorized attacker to disclose information over a network.
CVE-2026-69347	7.4	HIGH		0.003		Heap-based buffer overflow in Windows Fast FAT Driver allows an unauthorized attacker to execute code locally.
CVE-2026-70604	7.4	HIGH		0.003		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.10, 40.9.3, 41.4.0, and 42.0.0, a custom scheme registered with supportFetchAPI: true but without corsEnabled: true was not subject to CORS enforcement. A page loaded from a remote origin could therefore fetch() or XMLHttpRequest that scheme cross-origin and read the full response body, rather than...
CVE-2026-73086	7.4	HIGH		0.003		nanoid is a secure, URL-friendly, unique string ID generator for JavaScript. Prior to versions 3.3.12 and 5.1.11, the nanoid(size) function in index.js and index.cjs coerces the user-influenced size parameter to a signed 32-bit integer, allowing a value of 2147483648 to become -2147483648 and corrupt the process-wide CSPRNG poolOffset in fillPool(), which causes subsequent session tokens, CSRF tokens, API keys, an...
CVE-2026-78254	7.4	HIGH		0.005	apache:ant	The ftp and scp tasks of Apache Ant can download files from a remote server. A malicious server can provide relative paths that allow it to write outside of the dedicated target directory for the download, making it possible to overwrite files of the attacker's choice using the permissions of the user running Ant in versions prior to Ant 1.10.18. In order to exploit this vulnerability, the server would either...
CVE-2026-80434	7.4	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to manipulate runtime caches and cause a denial of service due to an insecure direct object reference.
CVE-2026-81383	7.4	HIGH		0.007	microsoft:visual_studio_code	Use of incorrectly-resolved name or reference in Visual Studio Code allows an unauthorized attacker to disclose information over a network.
CVE-2026-84003	7.4	HIGH		0.004		Authentication bypass by capture-replay in Microsoft Authentication Library (MSAL) for Node.js allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-84366	7.4	HIGH		0.002		Scrapy is a high-level web crawling and scraping framework for Python. Prior to 2.17.0, in scrapy/core/downloader/handlers/s3.py, Scrapy's S3DownloadHandler converts an S3-scheme bucket and key request into a plaintext HTTP request to the corresponding S3 endpoint unless request.meta["is_secure"] is explicitly enabled, then signs and sends the plaintext request with configured AWS credentials. A network attacker w...
CVE-2026-85525	7.4	HIGH		0.001		Improper OCSP response validation in the Snowflake Python, Go, JDBC, and Node.js drivers allowed a revoked TLS certificate to be accepted as valid, because OCSP responses were not reliably bound to the certificate being validated and definitive verification failures were treated as transient. A man-in-the-middle attacker holding a revoked certificate and its private key for a Snowflake or stage hostname could caus...
CVE-2026-87812	7.4	HIGH		0.002		SiYuan before v3.8.2 contains a stored cross-site scripting vulnerability in Bazaar package cards where the iconURL metadata is inserted directly into HTML img src attributes without escaping. Attackers can inject malicious URLs with event handlers that execute JavaScript in the authenticated SiYuan origin when users view Bazaar listings, enabling API requests and application state manipulation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-13201	7.3	HIGH		0.002	kubevirt:kubevirt, redhat:openshift_virtualization	A flaw was found in KubeVirt's safepath package used by virt-handler. The OpenAtNoFollow function uses O_PATH O_NOFOLLOW to obtain a file descriptor to a path leaf, but downstream operations resolve the path via /proc/self/fd/N using link-following syscalls. When the leaf is a symlink, the kernel dereferences it, defeating the intended no-follow protection. An attacker with access to a virt-launcher pod can exploi...
CVE-2026-28613	7.3	HIGH		0.001		In initAppLinkTypeAndIntent of ChannelImpl.java, there is a possible launch an arbitrary intent due to improper input validation. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-28626	7.3	HIGH		0.001		In onCreate of SetupPassthroughActivity.java, there is a possible way to launch arbitrary activity due to Intent redirection . This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-28656	7.3	HIGH		0.001		In multiple functions of DeviceAdminAdd.java, there is a possible way to an overlay due to a tapjacking/overlay attack. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-40542	7.3	HIGH		0.006	apache:HttpClient	Missing critical step in authentication in Apache HttpClient 5.6 allows an attacker to cause the client to accept SCRAM-SHA-256 authentication without proper mutual authentication verification. Users are recommended to upgrade to version 5.6.1, which fixes this issue.
CVE-2026-41605	7.3	HIGH		0.009	apache:thrift	Integer Overflow or Wraparound vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-43869	7.3	HIGH		0.006	apache:thrift	Improper Validation of Certificate with Host Mismatch vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-44185	7.3	HIGH		0.007	apache:http_server	Buffer Over-read vulnerability in Apache HTTP Server via outbound OCSP requests to an attacker controlled OCSP server This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.
CVE-2026-45528	7.3	HIGH		0.001		In getManageSpaceActivityIntent of StorageManagerService.java, there is a possible LaunchAnyWhere chain due to an unsafe PendingIntent. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is needed for exploitation.
CVE-2026-47878	7.3	HIGH		0.002	broadcom:spring_batch	DefaultExecutionContextSerializer, used by default in Spring Batch's JDBC job repository, passes Base64-decoded bytes directly to ObjectInputStream.readObject() without an ObjectInputFilter that restricts types to a trusted class allowlist. Spring Batch 6.0.0 - 6.0.4 Spring Batch 5.2.6 and earlier
CVE-2026-63404	7.3	HIGH		0.002		Faktory is a language-agnostic background job server. In versions prior to 1.10.0, the embedded Redis bootstrapper is vulnerable to an insecure temporary file flaw that lets a local unprivileged user hijack the Redis configuration and escalate to root. It writes its startup configuration to a fixed, predictable, world-writable path, /tmp/redis.conf, only creating the file if it does not already exist and never val...
CVE-2026-67326	7.3	HIGH		0.003		GitPython before 3.1.50 fails to validate newline characters in the section parameter of config_writer(), allowing attackers to inject arbitrary section headers into .git/config. Attackers can inject newlines to create a forged [core] section with hooksPath pointing to attacker-controlled directories, achieving remote code execution when git hooks are triggered.
CVE-2026-69097	7.3	HIGH		0.003		GitPython before 3.1.53 fails to properly escape section names in git config files, allowing attackers to inject arbitrary configuration directives through malicious submodule names. Attackers can inject core.sshCommand or other dangerous config keys into the victim's .git/config via create_submodule or clone_from operations, achieving remote code execution when git performs ssh operations.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69477	7.3	HIGH		0.004	microsoft:365_apps, microsoft:access, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office Access allows an authorized attacker to execute code locally.
CVE-2026-75857	7.3	HIGH		0.002		CodeWhale versions >= 0.8.41 and < 0.8.64 contain a vulnerability in the exec_shell_interact (alias exec_interact) tool, whose approval_requirement returns ApprovalRequirement::Auto. This overrides the default Required approval for code-executing tools, so LLM-controlled stdin is written into an already-approved long-running interactive shell (e.g., a python3 -i REPL, mysql, ssh, or sudo -i session) without any ap...
CVE-2026-78627	7.3	HIGH		0.001		The Okta Hyperdrive Integration installer does not mask the OAuth client secret when passed as an MSI property. The credential is recorded in plaintext in the installer log, the Application Event Log, and the process command line, all of which are readable by an authenticated local user on the workstation.
CVE-2026-85028	7.3	HIGH		0.001		Creation of a temporary file in a directory with insecure permissions in the FPGA management tool installation component in AWS FPGA Development Kit (aws-fpga) before 2.3.4 might allow local users to execute arbitrary code with root privileges via crafted shell content placed at a predictable path in a world-writable temporary directory, which the installation step reads after elevating its own privileges. To r...
CVE-2026-88885	7.3	HIGH				Renovate before 44.14.7 contains a command injection vulnerability in the gomod manager when processing unescaped depName parameters in import-path update commands with binarySource=docker mode. Attackers can inject shell metacharacters through malicious dependency names to execute arbitrary commands as the Renovate user during Go module major version updates with postUpdateOptions gomodUpdateImportPaths enabled.
CVE-2026-88888	7.3	HIGH				Renovate before 44.14.7 contains a command injection vulnerability in the Mix manager when processing private dependencies with unescaped organization parameters. Attackers can inject shell metacharacters through malicious package names to execute arbitrary commands as the Renovate user in binarySource=docker mode.
CVE-2026-0310	7.2	HIGH		0.003		A buffer overflow vulnerability in the XML processing functionality of Palo Alto Networks PAN-OS® software enables an unauthenticated attacker with network access to the management web or dataplane interface to cause a denial of service (DoS) condition on VM-Series firewalls or execute arbitrary code with root privileges on the PA-Series firewalls. The security risk posed by this issue is minimized when the manag...
CVE-2026-19769	7.2	HIGH		0.002		The Ninja Forms – The Contact Form Builder That Grows With You plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Repeater Child 'type' Confusion via Unmatched Array Key in all versions up to, and including, 3.15.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a ...
CVE-2026-27459	7.2	HIGH		0.007	pyopenssl:pyopenssl	pyOpenSSL is a Python wrapper around the OpenSSL library. Starting in version 22.0.0 and prior to version 26.0.0, if a user provided callback to `set_cookie_generate_callback` returned a cookie value greater than 256 bytes, pyOpenSSL would overflow an OpenSSL provided buffer. Starting in version 26.0.0, cookie values that are too long are now rejected.
CVE-2026-41567	7.2	HIGH		0.002		Moby is an open source container framework. In versions prior to 29.5.1 and in moby/moby v2 prior to v2.0.0-beta.14, when a compressed archive is uploaded to a container via `PUT /containers/{id}/archive` or piped through `docker cp -`, the daemon resolves decompression binaries (such as `xz` or `unpigz`) from the container's filesystem rather than the host's due to incorrect ordering of operations. A malicious co...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45019	7.2	HIGH		0.003		Chainlit is a Python framework for building production-ready conversational AI applications. From 2.4.0rc0 until 2.12.0, Chainlit deployments with features.mcp.enabled set to true in .chainlit/config.toml expose the POST /mcp endpoint without requiring authentication. For sse and streamable-http transports, ConnectSseMCPRequest and ConnectStreamableHttpMCPRequest in backend/chainlit/types.py accept a user-controll...
CVE-2026-70608	7.2	HIGH		0.003		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.10, 41.10.3, and 42.0.1, a sandboxed iframe without the allow-popups keyword could still open a new window or trigger setWindowOpenHandler with no user interaction because new-window navigations taking the OpenURL path did not apply the iframe sandbox popup restriction. Apps that embed untrusted co...
CVE-2026-73624	7.2	HIGH		0.003		GitPython versions before 3.1.54 contain an arbitrary file overwrite vulnerability in the Diffable.diff method that fails to validate git options passed through kwargs. Attackers can supply the --output argument via the other parameter or output kwarg to write patch content to attacker-chosen file paths at process privilege level.
CVE-2026-81349	7.2	HIGH		0.007		Improper neutralization of special elements used in an os command ('os command injection') in Azure HDInsights allows an authorized attacker to elevate privileges over a network.
CVE-2026-82071	7.2	HIGH		0.003		Insufficient validation of storage engine configuration options in MongoDB Server allows an authenticated user with write privileges to supply crafted parameters during collection creation that override internal storage metadata. This results in an out-of-bounds memory write in the server process, causing a denial of service via server crash, with potential for further impact including arbitrary code execution.
CVE-2026-84387	7.2	HIGH		0.009		A improper neutralization of special elements used in a command ('command injection') vulnerability in Fortinet FortiSandbox 5.2.0, FortiSandbox 5.0.0 through 5.0.6, FortiSandbox 4.4.0 through 4.4.9 may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2024-14047	7.1	HIGH		0.001	elastic:winlogbeat	A local vulnerability in the Winlogbeat Windows installer caused runtime files to be placed in a directory writable by unprivileged users. A low-privileged attacker with existing access to the system could pre-position malicious filesystem links, causing a subsequent elevated Winlogbeat operation to write to or delete arbitrary files. Successful exploitation could result in a denial of service.
CVE-2026-17627	7.1	HIGH		0.002	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to obtain sensitive information and inject messages into workflow history due to improper authorization.
CVE-2026-18737	7.1	HIGH		0.003		Shlink contains a blind SQL injection vulnerability that allows any authenticated API key holder to inject arbitrary SQL fragments by supplying an unvalidated direction value in the orderBy query parameter of the tag statistics endpoint. Attackers can craft a malicious direction string containing SQL subqueries that flows unsanitized into a Doctrine QueryBuilder ORDER BY clause, enabling time-based, boolean-oracle...
CVE-2026-19671	7.1	HIGH		0.004		Malcolm's upload-processing pipeline (scripts/safe-extract.py) enforces entry-count, nesting-depth, and total-uncompressed-byte limits when extracting container archives (zip/tar/rar/7z via libarchive), but those limits are not applied when the uploaded file is a single-stream compressed format (.gz, .bz2, .xz, .lzma, .lz) that isn't a .tar.*-style archive. Any authenticated user permitted to upload PCAP/log files...
CVE-2026-20293	7.1	HIGH		0.001		A vulnerability in the Unified Extensible Firmware Interface (UEFI) Shell implementation of Cisco UCS Servers and UCS-based appliances could allow an authenticated attacker with valid credentials for a user account with the role of user or admin or an unauthenticated attacker with physical access to an affected device to bypass UEFI Secure Boot validation checks and execute unauthorized software. This vuln...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-48494	7.1	HIGH		0.004		TypeBot is a chatbot builder tool. In version 3.16.1, an authenticated user who has read access to any typebot can resume a WhatsApp preview webhook session that belongs to a different typebot by mixing an authorized `typebotId` and `blockId` and a foreign preview phone number tied to another preview session. The WhatsApp test-webhook handler authorizes the parent typebot first, but then resolves the preview chat ...
CVE-2026-54085	7.1	HIGH		0.002		Wazuh is an open-source security platform providing unified XDR and SIEM protection for endpoints and cloud workloads. In versions 4.2.0 through 4.14.6, multiple active response scripts pass attacker-influenced alert fields to privileged system commands without validating their format, allowing argument injection into tools that run as root. Five of the eight scripts that handle the srcip field, route-null.c, nets...
CVE-2026-55520	7.1	HIGH		0.004		Protego is a pure-Python robots.txt parser with support for modern conventions. Prior to 0.6.2, protego._urlpattern._URLPattern._prepare_pattern_for_regex translates every asterisk in an Allow or Disallow directive into a lazy regular-expression wildcard, so a directive containing many asterisks creates exponential backtracking. After protego.Protego.parse processes a crafted robots.txt file, protego.Protego.can_f...
CVE-2026-55673	7.1	HIGH		0.004		PowSyBI (Power System Blocks) is a framework to build power system oriented software. Prior to 7.2.2, UnixLocalCommandExecutor and WindowsLocalCommandExecutor concatenate command arguments and environment variables into strings interpreted through bash -c or cmd /c without sufficient escaping. Attacker-controlled values reaching UnixLocalCommandExecutor.execute, WindowsLocalCommandExecutor.execute, LocalComputatio...
CVE-2026-62680	7.1	HIGH		0.003		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.22.0, Orval resolves remote and local external \$ref values without an allowlist or confinement to the input directory. Processing an attacker-controlled OpenAPI description can cause requests from the developer or CI host to attacker-selected or internal HTTP services, read absolute or out-of-tree l...
CVE-2026-63177	7.1	HIGH		0.002		Malcolm is a network traffic analysis tool suite. Prior to version 26.07.0, role-based access control enforced in the Nginx OpenResty Lua layer evaluates the raw, unnormalized `ngx.var.request_uri`, while Nginx itself routes requests using the normalized path. An authenticated low-privilege user can prepend a traversal segment (for example `/x/..upload/...`) so that Nginx routes the request to a restricted backen...
CVE-2026-64379	7.1	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: smb: client: mask server-provided mode to 07777 in modefromsid When modefromsid is active, parse_dacl() applies the server-provided sub_auth[2] value from the NFS mode SID to cf_mode without masking to 07777. Apply the correct masking, same as in the read path.
CVE-2026-64816	7.1	HIGH		0.003		RapidRAW before 1.6.0 does not validate the lutPath field in preset files before passing it to File::open() in lut_processing.rs. On Windows, a UNC path in lutPath causes an outbound SMB connection to an attacker-controlled host, leaking the victim's NTLMv2 credentials. The vulnerable code path is reachable through two vectors: community presets fetched automatically from the remote preset repository when the vict...
CVE-2026-66003	7.1	HIGH		0.003		Frappe is a full-stack web application framework written in Python and JavaScript. Prior to version 15.115.0, an access control bypass in the REST API allows a user to read data from Linked DocTypes that they are not authorized to access. When a document references another document through a Link field, the framework does not consistently enforce the linked DocType's own permissions when the record is retrieved th...
CVE-2026-68553	7.1	HIGH		0.003		Coturn is a free open source implementation of TURN and STUN Server. Prior to 4.13.0, an authenticated TURN user can place printf-style format specifiers in the STUN USERNAME or REALM attribute, which passes is_secure_string() validation and is embedded into Redis keys at nine call sites in src/apps/relay/ns_ioalib_engine_impl.c. send_message_to_redis() in src/apps/relay/hiredis_libevent2.c then passes the attacke...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68835	7.1	HIGH		0.005		Use after free in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-68846	7.1	HIGH		0.006		Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.
CVE-2026-68889	7.1	HIGH		0.004		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68893	7.1	HIGH		0.005		Use after free in Windows Remote Desktop Licensing Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69244	7.1	HIGH		0.003		AIOHTTP is an asynchronous HTTP client/server framework for asyncio and Python. Prior to 3.14.3, an out-of-bounds heap read could occur in the C response parser while building an error message for a malformed response. An attacker controlled server, or possibly an accidental response, could trigger a DoS in the client. The vulnerable path was error message construction in aiohttp/_http_parser.pyx, where an llhttp ...
CVE-2026-69272	7.1	HIGH		0.004		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69274	7.1	HIGH		0.004		Use after free in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69296	7.1	HIGH		0.005		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69305	7.1	HIGH		0.006		Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges over a network.
CVE-2026-69313	7.1	HIGH		0.005		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69314	7.1	HIGH		0.005		Use after free in Windows Device Association Broker service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69336	7.1	HIGH		0.005		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69337	7.1	HIGH		0.007		Double free in Windows Registry allows an authorized attacker to elevate privileges over a network.
CVE-2026-69340	7.1	HIGH		0.005		Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69357	7.1	HIGH		0.004		Use after free in Windows NDIS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69364	7.1	HIGH		0.005		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-69366	7.1	HIGH		0.006		Use after free in Windows Kernel allows an authorized attacker to elevate privileges over a network.
CVE-2026-69396	7.1	HIGH		0.005		Use after free in Windows NDIS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69451	7.1	HIGH		0.007		Use after free in Windows Management Instrumentation allows an authorized attacker to elevate privileges over a network.
CVE-2026-69460	7.1	HIGH		0.005		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69482	7.1	HIGH		0.003		Creation of temporary file in directory with insecure permissions in Windows Error Reporting allows an authorized attacker to perform tampering locally.
CVE-2026-69536	7.1	HIGH		0.004		Use after free in Windows Remote Desktop Services allows an authorized attacker to execute code over a network.
CVE-2026-69553	7.1	HIGH		0.005		Missing authorization in Windows Hyper-V allows an authorized attacker to elevate privileges over a network.
CVE-2026-69597	7.1	HIGH		0.006		Use after free in Windows HTTP.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69602	7.1	HIGH		0.006		Use after free in Windows PrintWorkflowUserSvc allows an authorized attacker to elevate privileges over a network.
CVE-2026-69688	7.1	HIGH		0.006		Heap-based buffer overflow in Windows Encrypting File System (EFS) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69706	7.1	HIGH		0.004		Use after free in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69757	7.1	HIGH		0.007		Use after free in Windows TCP/IP allows an authorized attacker to elevate privileges over a network.
CVE-2026-69761	7.1	HIGH		0.005		Use after free in Windows TCP/IP allows an authorized attacker to elevate privileges over a network.
CVE-2026-69775	7.1	HIGH		0.005		Use after free in Windows DWM Core Library allows an authorized attacker to elevate privileges over a network.
CVE-2026-71553	7.1	HIGH		0.003		ApostropheCMS is an open-source Node.js content management system. In 4.32.0 and earlier, PATCH /api/v1/article/:id accepts the inherited path toString.call and passes it through the utility module to apos.util.set() and apos.util.get(), allowing an authenticated editor to overwrite the shared Object.prototype.toString function's call property and cause a persistent process-wide denial of service until restart.
CVE-2026-74881	7.1	HIGH		0.003	jahlives:openssl_encrypt	openssl_encrypt versions before 1.4.0 configure CORS with allow_origins set to wildcard and allow_credentials enabled to true. Attackers can create malicious websites that make authenticated cross-origin requests to the API on behalf of any user who visits them.
CVE-2026-75132	7.1	HIGH		0.003		WAPT Server versions 2.6.1.17834 and earlier contains a SQL injection vulnerability in the `columns` parameter of the GET `/api/v3/hosts` endpoint. A remote authenticated user with read-only privileges can inject arbitrary PostgreSQL expressions into the SQL query constructed by WAPT. By exploiting the injection point, an attacker can inject additional PostgreSQL statements, bypass the host scope restrictions appl...
CVE-2026-76223	7.1	HIGH		0.002		ArcadeDB (com.arcadedb) versions 26.7.3 and earlier fail to enforce the UPDATE_SCHEMA permission check when a DEFINE FUNCTION statement targets an already-existing function library. A user with only database access can add or overwrite SQL or Cypher functions in an existing library and persist the change, enabling tampering with admin-defined function logic. The issue is fixed in 26.8.1. (JavaScript functions stil...
CVE-2026-79754	7.1	HIGH		0.004		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. From version 1.6.19 to before version 1.17.2, Nuclio's Dashboard build pipeline does not sanitize the spec.build.tempDir field before using it to construct a shell command. When the Kaniko container builder is enabled, a user with function-create permission can inject shell metacharacters into this field and achieve arbitrary command exec...
CVE-2026-80380	7.1	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote attacker to perform unauthorized actions due to cross-site request forgery.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82052	7.1	HIGH		0.004		The \$regexFindAll expression can be used by an authenticated user who can run aggregation pipeline stages to crash a MongoDB server (mongod). Under certain specific conditions the regex match can start in the middle of a multi-code-unit character, triggering an assertion during query execution.
CVE-2026-82054	7.1	HIGH		0.003		A security issue exists in MongoDB server's JSON Pointer parser used during \$jsonSchema query filter processing. When a find command includes a specially crafted \$jsonSchema filter field, the parser processes the input without enforcing adequate limits on iteration count or total allocation size, resulting in significant memory amplification. Under concurrent request load, the cumulative memory consumption can exh...
CVE-2026-82055	7.1	HIGH		0.003		A security issue exists in MongoDB's 2dsphere index key generation that can cause a server crash due to a null pointer dereference. When a specially crafted GeoJSON document is inserted into a collection with a 2dsphere index, an inconsistency in geometry parsing can leave an internal object in an invalid, partially initialized state. During subsequent index key generation, access to this improperly initialized ob...
CVE-2026-82057	7.1	HIGH		0.003		A security issue was discovered in MongoDB where an authenticated user with readWrite privileges could crash the mongod server process. By specifying a custom WiredTiger storage configuration option with an incompatible value during collection creation, a user could cause a type confusion in the storage engine layer. When documents were subsequently read from the misconfigured collection, the resulting mismatch in...
CVE-2026-82058	7.1	HIGH		0.003		A flaw in MongoDB's JSON Schema validation error generation code allows an authenticated user with readWrite privileges to crash the mongod server. When a BSON document containing an array with a malformed numeric field name fails a \$jsonSchema items type constraint, the error generation path performs unsafe numeric conversion on the user-controlled field name without proper exception handling, resulting in an unc...
CVE-2026-82065	7.1	HIGH		0.003		A security issue in the MongoDB Server's storage engine integration layer allows an authenticated user with collection creation privileges to cause a persistent denial of service. Insufficient validation of user-supplied storage configuration options permits values that, once persisted to durable metadata, trigger a fatal assertion failure when the metadata is subsequently read by diagnostic operations. The corrup...
CVE-2026-82068	7.1	HIGH		0.003		A security issue in MongoDB Server allows an authenticated user with write privileges to trigger a persistent fatal assertion crash by sending specially crafted retryable write commands. The crash state is durably persisted, causing the server process to repeatedly crash on restart and potentially propagating to additional nodes in a sharded cluster. Manual intervention is required to restore service availability.
CVE-2026-82070	7.1	HIGH		0.002		A security issue in MongoDB Server's diagnostic reporting interface allows an authenticated user with monitoring privileges to access insufficiently protected credentials from concurrent administrative operations. The same credentials are properly redacted in server log output, but the diagnostic interface omits equivalent redaction. Successful exploitation requires a valid authenticated session with monitoring-le...
CVE-2026-82073	7.1	HIGH		0.003		A security issue in the MongoDB Server aggregation framework allows an authenticated user with limited read privileges to bypass view-level authorization checks and access data from unauthorized collections when Atlas Search features are in use. The issue stems from insufficient validation of an internal command parameter that can be set by external clients, causing a security check to be improperly skipped.
CVE-2026-82074	7.1	HIGH		0.002		MongoDB Server contains an incorrect authorization vulnerability in the aggregation framework. An authenticated user with minimal privileges can craft a specially formatted aggregation request that causes the server's authorization subsystem to evaluate a different operation than what is actually executed, resulting in unauthorized read access to collection data within the target database.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82076	7.1	HIGH		0.003		An integer overflow in the query planning component of MongoDB Server can allow an authenticated user with ordinary database-level read/write privileges to bypass an internal resource limit. Submitting a specially crafted query causes the server to consume memory without bound during query planning, and the resulting exhaustion terminates the server process. This may result in a denial of service affecting all dat...
CVE-2026-82864	7.1	HIGH		0.002		pdfme pdf-lib versions before 5.5.10 contain an unbounded buffer growth vulnerability in the DecodeStream.ensureBuffer() method that allows attackers to cause denial of service by supplying a crafted PDF with a FlateDecode stream containing a decompression bomb. Attackers can upload a small compressed PDF that decompresses to hundreds of megabytes, exhausting memory and crashing the Node.js process or freezing bro...
CVE-2026-84192	7.1	HIGH		0.002		LibreNMS before 26.3.1 contains a stored cross-site scripting vulnerability in legacy PHP templates that output SNMP-sourced and syslog-sourced data without escaping. An attacker who controls a monitored network device can inject arbitrary JavaScript through SNMP interface descriptions or syslog program fields that executes when authenticated users view affected pages.
CVE-2026-85390	7.1	HIGH		0.003		Checkmate through 3.11.0 omits the isAllowed role guard middleware on maintenance-window, notification, and check-deletion routes, allowing read-only users to perform administrative actions. Attackers with user-role sessions can create arbitrary maintenance windows to silence alerts, modify notification channels, and delete monitor check history to erase incident evidence.
CVE-2026-85654	7.1	HIGH		0.001		Improper neutralization of special elements used in a template engine in the CDK generator in Amazon awslabs.dynamodb-mcp-server before 2.1.6 might allow a context-dependent actor to execute arbitrary code on the host that deploys the generated application via crafted table, index, or attribute names in a data model file.
CVE-2026-85689	7.1	HIGH		0.003		Ilmware 0.4.6 contains an SQL injection vulnerability in the collection-database layer (Ilmware/resources.py) where filter and lookup values are directly string-interpolated into SQL WHERE clauses without parameterization or escaping, in both the SQLite and PostgreSQL backends. The filter validator only checks keys against an allow-list and never sanitizes values. Attacker-controlled filter values reaching the pub...
CVE-2026-85787	7.1	HIGH		0.002		An incomplete list of disallowed inputs in the SQL validation component in Amazon awslabs postgres-mcp-server before version 1.1.7 might allow an unauthenticated actor to modify data beyond the read-only scope by placing crafted SQL into the content that is submitted when an authenticated user interacts with the MCP server. To remediate this issue, users should upgrade to version 1.1.7 or above.
CVE-2026-87803	7.1	HIGH		0.003		An authorization bypass vulnerability exists in the County Server DBViewer due to flawed sub-pipeline detection in the aggregation stage sanitizer. The /o/db aggregation endpoint parses user-controlled aggregation JSON and passes it through a stage sanitizer that determines whether a nested array is a sub-pipeline by checking if every element contains a key present in a hardcoded KNOWN_STAGE_OPERATORS set. If any...
CVE-2026-87818	7.1	HIGH		0.002		GitPython 3.1.59 fails to restrict the --no-index option in the high-level diff API, allowing attackers to read arbitrary filesystem paths as repository operands. Attackers can combine --no-index with -I/--ignore-matching-lines to create a content-dependent Boolean oracle, repeatedly querying local files to recover single-line secrets through distinguishable success or error responses.
CVE-2026-87999	7.1	HIGH		0.002		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. Prior to 0.11.1, POST /api/v1/retrieval/process/web and POST /api/v1/retrieval/process/web/search in backend/open_webui/retrieval/web/utils.py treated Python's globally routable address classification as proof that a destination was external. An authenticated user could make an Azure-hosted instance fetch and return content from ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88026	7.1	HIGH				Improper neutralization of regular-expression metacharacters in the LINQ query translation component of the MongoDB C# Driver can cause a caller-supplied character sequence to alter a regular-expression predicate generated by an affected application. An authenticated user who can influence such a value may cause the application to return records beyond those intended by the original filter.
CVE-2026-88027	7.1	HIGH				Improper neutralization of special elements in data query logic in the embedded-document relation handling of the MongoDB integration for Laravel can cause a caller-supplied embedded record identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence such an identifier may delete all embedded documents in a targeted record or overwrite an embedded d...
CVE-2026-88028	7.1	HIGH				Improper neutralization of special elements in data query logic in the polymorphic relation handling of the MongoDB integration for Laravel can cause a caller-supplied relation identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence a stored relation identifier may cause an affected application to return a document other than the intended relat...
CVE-2026-34789	7.0	HIGH		0.002		FreeCAD is a free and open-source multiplatform 3D parametric modeler. Prior to 1.1.2, src/App/PropertyPythonObject.cpp in PropertyPythonObject::Restore() passes the attacker-controlled module attribute from serialized PropertyPythonObject XML directly to PyImport_ImportModule() while restoring a crafted FCStd document, which executes module-level Python code, and the legacy pickle branch also imports an attacker-...
CVE-2026-50349	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Ancillary Function Driver for WinSock allows an authorized attacker to elevate privileges locally.
CVE-2026-58230	7.0	HIGH		0.002	sap:approuter	SAP Approuter does not sufficiently validate certain token content under specific configurations. An unauthenticated attacker could send a specially crafted token to cause sensitive credential material to be sent to an attacker-controlled destination. The attack complexity is high due to non-default preconditions required in the target environment. This results in a high impact on confidentiality and a low impact ...
CVE-2026-62694	7.0	HIGH		0.003		Use after free in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-62727	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Telephony Service allows an authorized attacker to elevate privileges locally.
CVE-2026-68824	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges locally.
CVE-2026-68825	7.0	HIGH		0.003		Use after free in Windows Bind Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-68837	7.0	HIGH		0.002		Use after free in Windows File History Service allows an authorized attacker to elevate privileges locally.
CVE-2026-68840	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows USB Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-68847	7.0	HIGH		0.002		Use after free in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges locally.
CVE-2026-68884	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Kernel allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-68897	7.0	HIGH		0.002		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-69279	7.0	HIGH		0.003		Use after free in Windows Cloud Files Mini Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69280	7.0	HIGH		0.002		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-69281	7.0	HIGH		0.003		Use after free in Windows License Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69287	7.0	HIGH		0.003		Use after free in Windows Remote Desktop Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69299	7.0	HIGH		0.002		Use after free in Microsoft COM for Windows allows an authorized attacker to elevate privileges locally.
CVE-2026-69300	7.0	HIGH		0.002		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-69309	7.0	HIGH		0.003		Double free in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-69310	7.0	HIGH		0.003		Use after free in Windows DNS allows an authorized attacker to elevate privileges locally.
CVE-2026-69311	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69319	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69331	7.0	HIGH		0.002		Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69333	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69335	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69341	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69362	7.0	HIGH		0.003		Use after free in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69379	7.0	HIGH		0.003		Improper link resolution before file access ('link following') in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69383	7.0	HIGH		0.002		External control of file name or path in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69385	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows TCP/IP allows an authorized attacker to elevate privileges locally.
CVE-2026-69388	7.0	HIGH		0.003		Use after free in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69394	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69398	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69404	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows TCP/IP allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69410	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69413	7.0	HIGH		0.003		Use after free in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69422	7.0	HIGH		0.003		Use after free in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69430	7.0	HIGH		0.003		Use after free in Windows Embedded Mode Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69440	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69441	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-69448	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69466	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69468	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69470	7.0	HIGH		0.003		Use after free in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges locally.
CVE-2026-69472	7.0	HIGH		0.003		Use after free in Windows Devices Human Interface allows an authorized attacker to elevate privileges locally.
CVE-2026-69473	7.0	HIGH		0.003		Use after free in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69488	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69492	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Partition Management Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69498	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69500	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69501	7.0	HIGH		0.002		Untrusted pointer dereference in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-69517	7.0	HIGH		0.003		Use after free in Windows Wireless Networking allows an authorized attacker to elevate privileges locally.
CVE-2026-69540	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69560	7.0	HIGH		0.003		Use after free in Windows Work Folder Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69563	7.0	HIGH		0.002		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69564	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Online Certificate Status Protocol (OCSP) allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69567	7.0	HIGH		0.003		Use after free in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-69573	7.0	HIGH		0.003		Use after free in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69574	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69575	7.0	HIGH		0.003		Use after free in Windows Storage Spaces Controller allows an authorized attacker to elevate privileges locally.
CVE-2026-69578	7.0	HIGH		0.002		Numeric truncation error in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-69581	7.0	HIGH		0.002		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69600	7.0	HIGH		0.003		Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69605	7.0	HIGH		0.003		Use after free in Microsoft Install Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69606	7.0	HIGH		0.003		Use after free in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69610	7.0	HIGH		0.003		Buffer over-read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69613	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69617	7.0	HIGH		0.003		Out-of-bounds read in Windows Resilient File System (ReFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69621	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69630	7.0	HIGH		0.003		Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69645	7.0	HIGH		0.003		Use after free in Windows Message Queuing allows an authorized attacker to elevate privileges locally.
CVE-2026-69648	7.0	HIGH		0.003		Use after free in Windows Notification allows an authorized attacker to elevate privileges locally.
CVE-2026-69652	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69654	7.0	HIGH		0.003		Use after free in Windows Accounts Control allows an authorized attacker to elevate privileges locally.
CVE-2026-69682	7.0	HIGH		0.002		Use after free in Windows Host Guardian Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69692	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69693	7.0	HIGH		0.003		Use after free in Windows Device Association Broker service allows an authorized attacker to elevate privileges locally.
CVE-2026-69694	7.0	HIGH		0.017		Deserialization of untrusted data in Windows IP Address Management (IPAM) Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69708	7.0	HIGH		0.003		Use after free in Windows Web Platform Storage allows an authorized attacker to elevate privileges locally.
CVE-2026-69711	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69735	7.0	HIGH		0.003		Use after free in Windows Broadcast DVR User Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69779	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69791	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69806	7.0	HIGH		0.018		Exposure of sensitive information to an unauthorized actor in .NET allows an authorized attacker to elevate privileges locally.
CVE-2026-69814	7.0	HIGH		0.003		Use after free in Windows Credential Providers allows an authorized attacker to elevate privileges locally.
CVE-2026-69816	7.0	HIGH		0.003		Use after free in Windows Accounts Control allows an authorized attacker to elevate privileges locally.
CVE-2026-69817	7.0	HIGH		0.003		Use after free in Windows Bluetooth Port Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69818	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69834	7.0	HIGH		0.003		Use after free in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2026-69838	7.0	HIGH		0.003		Use after free in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-69859	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to elevate privileges locally.
CVE-2026-69866	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69889	7.0	HIGH		0.003		Use after free in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69891	7.0	HIGH		0.003		Use after free in Windows Media allows an authorized attacker to elevate privileges locally.
CVE-2026-69896	7.0	HIGH		0.003		Use after free in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69911	7.0	HIGH		0.003		Use after free in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-70283	7.0	HIGH		0.002		Incorrect authorization in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-70562	7.0	HIGH		0.003		Double free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70565	7.0	HIGH		0.003		Use after free in Windows AF_UNIX Socket Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-70567	7.0	HIGH		0.003		Double free in Windows Display Enhancement Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70568	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Defender Firewall Service allows an authorized attacker to elevate privileges locally.
CVE-2026-70573	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70577	7.0	HIGH		0.003		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-70578	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Credential Guard allows an authorized attacker to elevate privileges locally.
CVE-2026-70585	7.0	HIGH		0.003		Use after free in Windows Services for NFS ONCRPC XDR Driver allows an authorized attacker to execute code locally.
CVE-2026-71332	7.0	HIGH		0.003		Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to elevate privileges locally.
CVE-2026-71333	7.0	HIGH		0.003		Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-71340	7.0	HIGH		0.003		Use after free in Windows File History Service allows an authorized attacker to elevate privileges locally.
CVE-2026-71342	7.0	HIGH		0.003		Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-71351	7.0	HIGH		0.003		Double free in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to elevate privileges locally.
CVE-2026-71353	7.0	HIGH		0.002		Double free in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to elevate privileges locally.
CVE-2026-72926	7.0	HIGH		0.003		Use after free in Windows Internet Connection Sharing (ICS) allows an authorized attacker to elevate privileges locally.
CVE-2026-72930	7.0	HIGH		0.003		Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to execute code locally.
CVE-2026-72952	7.0	HIGH		0.003		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-72963	7.0	HIGH		0.003		Use after free in Windows Modern Execution Server allows an authorized attacker to elevate privileges locally.
CVE-2026-73003	7.0	HIGH		0.002		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-73005	7.0	HIGH		0.002		Use after free in Windows Authentication Methods allows an authorized attacker to elevate privileges locally.
CVE-2026-73022	7.0	HIGH		0.002		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-77894	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-77899	7.0	HIGH		0.002		Use after free in Windows Security Center allows an authorized attacker to elevate privileges locally.
CVE-2026-77905	7.0	HIGH		0.002		Use after free in Windows Management Instrumentation allows an authorized attacker to elevate privileges locally.
CVE-2026-78457	7.0	HIGH		0.002		Use after free in Windows Security Health Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78464	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1	Time-of-check time-of-use (toctou) race condition in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-80093	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Cloud Files Mini Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-81192	7.0	HIGH		0.001		`OpenTelemetry.Resources.Host` NuGet package, which provides OpenTelemetry resource detectors for host, is affected by an untrusted search path vulnerability on macOS. Prior to version 1.16.0-beta.2, the `host.id` resource attribute detector launches the `sh` and `ioreg` executables by bare name rather than by absolute path, so both are resolved through the `PATH` environment variable. A local attacker who is less...
CVE-2026-81389	7.0	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-82062	7.0	HIGH		0.004		A security issue in MongoDB Server allows an authenticated user with elevated internal privileges to bypass a disabled feature gate in the applyOps command by specifying an internal replication mode value that was not intended to be client-selectable. This bypass enables execution of container operations that are disabled by default in production configurations, allowing direct storage-engine writes to arbitrary i...
CVE-2026-83940	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83999	7.0	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Improper link resolution before file access ('link following') in Windows Resilient File System (ReFS) Deduplication Service allows an authorized attacker to elevate privileges locally.
CVE-2026-85360	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-85594	7.0	HIGH		0.002		Traefik versions from v3.7.1 fail to enforce crossProviderNamespaces restrictions on the traefik.ingress.kubernetes.io/service.middlewares Service annotation in the Kubernetes Ingress provider. A namespace-limited tenant excluded from the allowlist can attach an operator-owned middleware to its Service, and if that middleware injects backend credentials, recover them at a controlled backend.
CVE-2025-15613	6.9	MEDI		0.003		Kyverno before v1.13.4 is vulnerable to server-side request forgery (SSRF) via its Service Call functionality. An attacker with permission to create Kyverno (Cluster)Policies can specify an external URL in a policy's apiCall/service configuration; although Service Call is documented for in-cluster services, it also resolves external addresses, allowing requests to an attacker-controlled server. Because policy cont...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-15417	6.9	MEDI				In the silabser.sys Windows 8 driver for CP210x devices, a local unprivileged user can use incorrect driver settings to cause a kernel crash.
CVE-2026-15933	6.9	MEDI		0.004		OptimiDoc Server (On-Premise) stores credentials for external services in cleartext. An authenticated administrator can view previously configured service passwords, including SMTP, FTP (for scan delivery), Active Directory (for user list import), and SharePoint credentials, in cleartext via the web administration panel page source, allowing exposure of sensitive third-party authentication data. This issue was f...
CVE-2026-18401	6.9	MEDI		0.003		The non-blocking (asynchronous) JSON parser in jackson-core does not enforce the maxNumberLength constraint defined in StreamReadConstraints (default: 1000 characters). An attacker able to submit JSON to an application that uses the async parser API can supply a number token of arbitrary length, leading to excessive memory allocation and potential CPU exhaustion, resulting in a denial of service. The synchronou...
CVE-2026-21098	6.9	MEDI		0.001		Improper access control in Link to Windows prior to SMR Sep-2026 Release 1 allows local attackers to establish a connection with the PC without proper user interaction.
CVE-2026-39892	6.9	MEDI		0.007	cryptography.io:cryptography	cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. From 45.0.0 to before 46.0.7, if a non-contiguous buffer was passed to APIs which accepted Python buffers (e.g. Hash.update()), this could lead to buffer overflows. This vulnerability is fixed in 46.0.7.
CVE-2026-42039	6.9	MEDI		0.007	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, toFormData recursively walks nested objects with no depth limit, so a deeply nested value passed as request data crashes the Node.js process with a RangeError. This vulnerability is fixed in 1.15.1 and 0.31.1.
CVE-2026-52873	6.9	MEDI		0.003		Streambert is a cross-platform Electron Desktop App to stream and download video content. From version 2.5.0 until version 2.6.0, the wyzie-open-redeem IPC handler in index.js creates the partition:wyzie-redeem Electron session and registers an onHeadersReceived hook that removes the Content-Security-Policy header from every response in that session. The redeem window also lacks a setWindowOpenHandler restriction,...
CVE-2026-54272	6.9	MEDI		0.004		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Versions 10.1.1 through 10.2.0 are vulnerable to SSRF through misclassification of IPv4-mapped/NAT64 IPv6 addresses. Address6.getType() classifies an address by matching it against a table of known IPv6 special-use prefixes, returning Global unicast when nothing matches. That table had no entry for the IPv4-mapped range (:...
CVE-2026-55758	6.9	MEDI		0.004		CC: Tweaked is a mod for Minecraft which adds programmable computers, turtles, and more to the game. Prior to 1.120.0, the SSRF protection in projects/core/src/main/java/dan200/computercraft/core/apis/http/options/AddressPredicate.java blocks the RFC 6052 64:ff9b::/96 NAT64 prefix but omits the RFC 8215 64:ff9b:1::/48 local-use prefix. On a dual-stack server using RFC 8215 NAT64, an unauthenticated user who can ex...
CVE-2026-69092	6.9	MEDI		0.003		Admidio versions before 5.0.11 contain a reflected cross-site scripting vulnerability in the SSO/SAML endpoint that echoes unencoded exception messages to the HTTP response. Unauthenticated attackers can inject arbitrary JavaScript through SAML Issuer elements or LightSaml library parameters to execute code in users' browsers and hijack sessions.
CVE-2026-69198	6.9	MEDI		0.003		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. From 10.1.1 until 10.2.2, every special-use classification method is built on isInSubnet, which short-circuits to false whenever the address's own subnet mask is shorter than the reference range's mask. That mask comes verbatim from the CIDR suffix on the parsed input, so appending a suffix such as /0 suppresses classificat...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69248	6.9	MEDI		0.002		cryptography is a package designed to expose cryptographic primitives and recipes to Python developers. In versions 45.0.0 through 48.0.0, if an intermediate constrained CA permits the DNS name foo.example.com, and the leaf certificate has a wildcard in its DNS SAN of *.example.com, python-cryptography's verifier accepts which allows escaping outside of the permitted names. The core issue is in DNSConstraint::matc...
CVE-2026-70611	6.9	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.9, 40.9.2, 41.2.1, and 42.0.0-beta.3, the DevTools reveal in file manager action could launch the target file rather than reveal it. An attacker with a separate means of running script inside the DevTools frontend, such as a malicious DevTools extension, could use showItemInFolder handling to execu...
CVE-2026-71313	6.9	MEDI		0.003		rclone is a command-line program to sync files and directories to and from different cloud storage providers. From v1.51.0 until v1.75.0, the local backend in backend/local/local.go relies on the configurable filename encoder to prevent remote filename data from becoming operating-system path syntax, so a local destination using Slash, None, Raw, or on Windows an encoding that preserves backslash can decode a stan...
CVE-2026-73848	6.9	MEDI		0.003		Emlog is an open source website building system. In versions 2.6.29 and prior, tag names in emlog are not HTML-encoded when rendered in the article editor. An attacker can create a tag containing ');alert(document.domain);//. The addslashes() function does not escape HTML entities, so ' is stored as-is. When the browser renders the page, it decodes ' back to a literal single quote before evaluating the JavaScript,...
CVE-2026-74871	6.9	MEDI		0.001	jahllives:openssl_encrypt	openssl_encrypt versions before 1.4.6 contain a key derivation flaw in sequential XOR composition mode where the last stage cancels out during key generation. When configured with a single KDF and no prior hashing stage, attackers can bypass memory-hard key derivation and perform offline password cracking at SHA-256 speed instead of the configured KDF cost.
CVE-2026-75135	6.9	MEDI		0.001		UpSignOn for Windows before 7.19.0 contains a sensitive data exposure vulnerability that allows local attackers to recover the master password and decrypt vault contents by reading a retained backup key from the process memory of UpSignOn.exe, even after the vault has been re-locked. Attackers can extract the backup key from process memory to decrypt the encrypted master password backup stored in v6-vault1.DAT.tx...
CVE-2026-75136	6.9	MEDI		0.001		UpSignOn for Windows before 7.19.0 contains an insecure credential storage vulnerability that allows local attackers to retrieve the biometric unlock key stored in the Windows PasswordVault API without triggering any authentication prompt. Attackers can access the stored biometric key from a standard local process within the same Windows session to decrypt the protected vault files and export the entire password m...
CVE-2026-75137	6.9	MEDI		0.001		UpSignOn for Windows before 7.19.0 contains a sensitive data exposure vulnerability that allows local attackers to recover cleartext vault data from process memory even after the application has been locked. Attackers can use the PROCESS_VM_READ permission to read the memory space of UpSignOn.exe and extract sensitive fields including entry names, URLs, usernames, passwords, TOTP secrets, and notes.
CVE-2026-78325	6.9	MEDI		0.001		Cross-site scripting in the Evernote and Google Keep note importers in Standard Notes for Android through 3.201.24 allows an attacker to execute arbitrary JavaScript in the application context when a victim imports a crafted .enex or Google Keep HTML file, leading to theft of encryption keys and note data, and arbitrary invocation of native device APIs.
CVE-2026-82398	6.9	MEDI		0.003		pypdf is a free and open-source pure-python PDF library. Prior to 6.15.0, an attacker can craft a PDF that causes long runtimes when the pypdf/_utils.py function read_until_whitespace reads a stream containing a long run of bytes without whitespace. The function repeatedly performs immutable bytes concatenation in a one-byte loop, causing quadratic processing cost for the long non-whitespace input. This issue is f...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83611	6.9	MEDI		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, DOMParser.parseFromString() can silently accept an end tag such as </\junk>, close the element, and discard the trailing content. On 0.9.x, the lib/sax.js end-tag validator inherits the multiline flag from reg(), all...
CVE-2026-84309	6.9	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.16.0, an attacker can craft a PDF whose cyclic tree structure causes pypdf/generic/_data_structures.py TreeObject.insert_child to follow /Next links indefinitely when a writing code path inserts a child, producing an infinite loop. This issue is fixed in version 6.16.0.
CVE-2026-84697	6.9	MEDI		0.002		Mailpit's IsInternalIP deny list function fails to block the Azure WireServer address 168.63.129.16 and the RFC 2765/6145 IPv4-translated IPv6 prefix, allowing server-side request forgery to internal destinations. Attackers can supply hostnames resolving to these addresses in message content to reach the link check API and proxy endpoint for accessing internal resources.
CVE-2026-84968	6.9	MEDI		0.002	mongodb:php_driver	An out-of-bounds read in the BSON decoding component of the MongoDB PHP driver may allow an unauthenticated party who supplies specially formed input to have a small amount of adjacent process memory copied into an error message that is returned to application code. This may result in unintended disclosure of limited memory contents.
CVE-2026-86188	6.9	MEDI		0.003		AVideo with YPTSocket plugin enabled contains a cross-site scripting vulnerability allowing unauthenticated attackers to execute arbitrary JavaScript in other users' browsers via the websocket callback mechanism. Attackers can send crafted socket messages with callback names resolving to global functions like avideoConfirmHTML that accept untrusted data and assign it to innerHTML, achieving script execution in the...
CVE-2026-86431	6.9	MEDI		0.002	thephpleague:commonmark	league/commonmark (thephpleague/commonmark) versions >= 2.7.0 and < 2.9.1 contain a cross-site scripting vulnerability in the AttributesExtension. Prefixing an attribute name with a single U+000C form feed byte (e.g. {x0Conclick="alert(1)}) bypasses the AttributesHelper::filterAttributes() 'on*' event-handler filter because PHP's trim() does not strip U+000C, causing the attribute to be written verbatim into the...
CVE-2026-8794	6.9	MEDI		0.004		PaperCut NG/MF contains an observable timing discrepancy in its authentication component. An unauthenticated remote attacker can exploit this vulnerability to perform username enumeration by measuring response times during login attempts. The system executes a password hash comparison only when a valid account is supplied, creating a measurable timing oracle that reveals account existence.
CVE-2026-88884	6.9	MEDI				Renovate is a dependency update automation tool. In versions before 44.3.1 (and Mend Renovate CE/EE images before 15.4.0, mend-renovate-ce Helm chart before 15.4.0, mend-renovate-enterprise-edition Helm chart before 10.4.0), digest updates are not subject to the internal `minimumReleaseAge` (stability age) checks. When a repository configures `minimumReleaseAge` and has dependencies with `updateType=digest` — for ...
CVE-2026-15927	6.8	MEDI		0.005		A flaw was found in Red Hat Quay's repository-level mirror configuration feature. The POST and PUT handlers in endpoints/api/mirror.py accept an external_reference parameter without SSRF validation, unlike the organization-level mirror handlers which apply validate_external_registry_url(). A repository administrator can supply a crafted hostname that causes the Quay mirror worker to make requests via Skopeo to int...
CVE-2026-18796	6.8	MEDI		0.001		Any application that uses external QSPI flash for encrypted XIP on nRF5340 and relies on that encryption for confidentiality and/or integrity of the externally stored code. No specific nRF Connect SDK version is the root cause; the weakness is in the on-the-fly decryption scheme.
CVE-2026-47763	6.8	MEDI		0.002		pdm is a Python package and dependency manager supporting the latest PEP standards. In versions prior to 2.27.0, pdm writes several project-local state or configuration files without symlink protection. If a malicious repository places those files as symlinks, local PDM operations can overwrite the symlink targets. This creates an arbitrary file clobber primitive relative to the privileges of the invoking user. Co...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-49349	6.8	MEDI		0.002		regclient is a Docker and OCI Registry Client in Go. Prior to version 0.11.5, credentials for a registry may be inadvertently leaked to external servers. A prerequisite for this attack is a malicious registry server, a malicious blob store, or a registry that does not restrict the external URLs for foreign blobs. Version 0.11.5 fixes the issue.
CVE-2026-53196	6.8	MEDI		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: USB: serial: io_ti: fix heap overflow in get_manuf_info() get_manuf_info() reads le16_to_cpu(rom_desc->Size) bytes from the device I2C EEPROM into a buffer allocated with kmalloc_obj(), which is sizeof(struct edge_ti_manuf_descriptor) = 10 bytes. The Size field comes from the device and is only validated (in check_i2c_image()) to make sure the ...
CVE-2026-65812	6.8	MEDI		0.005		Insertion of sensitive information into sent data in Microsoft Teams for Android allows an authorized attacker to disclose information over a network.
CVE-2026-67352	6.8	MEDI		0.002		luci-app-https-dns-proxy contains a stored cross-site scripting vulnerability in the resolver_url parameter that allows authenticated users to inject active HTML. When an administrator views the HTTPS DNS Proxy status page, the resolver URL is rendered as raw HTML and executes JavaScript in the administrator's browser origin.
CVE-2026-68833	6.8	MEDI		0.003		Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-69415	6.8	MEDI		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing authentication for critical function in Windows DHCP Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-69490	6.8	MEDI		0.004		Out-of-bounds read in Windows USB Mass Storage Class Driver allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-69566	6.8	MEDI		0.004		Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71329	6.8	MEDI		0.003		Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71348	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71349	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71350	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-72985	6.8	MEDI		0.003		Heap-based buffer overflow in Windows Volume Shadow Copy allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-72999	6.8	MEDI		0.003		Out-of-bounds read in Windows USB Hub Driver allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-76227	6.8	MEDI		0.001		Renovate versions from 42.68.1 before 42.96.3 (and from 42.68.1 before 43.4.4), including corresponding Docker images (renovate/renovate, mend/renovate-ce, renovate-ee-server, renovate-ee-worker >=13.3.0 <13.6.0), fail to restrict environment variables to an allowlist when spawning child processes. As a result, child processes (e.g. npm install, postUpgradeTasks, postUpdateOptions) gain full access to all environm...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77892	6.8	MEDI		0.003		No cwe for this issue in Windows Boot Manager allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-78451	6.8	MEDI		0.004		Untrusted pointer dereference in Microsoft Windows SCSI Class System File allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-78579	6.8	MEDI		0.002		The Okta Access Gateway does not sanitize SAML assertion attribute values before interpolating them into LDAP search filters in the LDAP datastore configuration. The raw values are substituted directly into the filter string and passed to the LDAP search operation, resulting in modification of the intended query logic.
CVE-2026-83545	6.8	MEDI				The CoolClock WordPress plugin before 4.3.8 does not properly escape a custom skin setting before outputting it inside an inline script, allowing users with contributor-level access and above to inject arbitrary JavaScript that executes when the content is viewed.
CVE-2026-84896	6.8	MEDI		0.002		The King Addons for Elementor WordPress plugin before 51.1.77 does not escape a widget display-style setting before outputting it in an HTML attribute, allowing users with Contributor-level access and above to store JavaScript that executes in the browser of any visitor to the affected page, including logged-in administrators.
CVE-2026-84899	6.8	MEDI		0.002		The VikWidgetsLoader WordPress plugin before 1.12.0 does not sanitise or escape a block attribute before outputting it inside an inline script, allowing users with the Contributor role to store arbitrary JavaScript that executes in the browser of any user viewing the affected post, including the administrator who reviews the pending submission.
CVE-2026-84931	6.8	MEDI		0.002		The Joli Table Of Contents WordPress plugin before 3.0.3 does not sanitise or escape a shortcode attribute value before outputting it inside an HTML element's attribute, allowing users with the Author role and above to inject arbitrary HTML attributes and JavaScript that execute in the browser of any user who views the post, including higher-privileged users such as administrators. This crosses a privilege boundar...
CVE-2026-85456	6.8	MEDI		0.001		MOOS-IvP through 24.8.1 fails to properly validate variable names extracted from alog files in the SplitHandler, allowing attackers to write files outside the split directory. Attackers can supply crafted alog files with backslash sequences in variable names to escape the output directory and append to arbitrary files on Windows systems.
CVE-2026-85678	6.8	MEDI				The AI Builder WordPress plugin before 2.7.8 does not sanitise custom JavaScript saved against a post before echoing it inside a script tag on the front end, allowing users with contributor level access and above to store arbitrary JavaScript that will execute in the browser of anyone who views the post, including the editor or administrator who reviews it.
CVE-2026-48121	6.7	MEDI		0.002		@langchain/langgraph-checkpoint-mongodb provides a LangGraph.js CheckpointSaver implementation that uses MongoDB for storage. Versions 1.3.0 and below are vulnerable to NoSQL injection: checkpoint identifiers (thread_id, checkpoint_ns, checkpoint_id) from config.configurable are passed into MongoDB find() queries in MongoDBSaver.getTuple() without type enforcement. If an attacker supplies an object payload (such a...
CVE-2026-5522	6.7	MEDI		0.001		IBM QRadar 7.5.0 through 7.5.0 UP15 Interim Fix 005 contains hard-coded credentials, such as a password or cryptographic key, which it uses for its own inbound authentication, outbound communication to external components, or encryption of internal data.
CVE-2026-69350	6.7	MEDI		0.003		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69373	6.7	MEDI		0.003		Integer overflow or wraparound in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69449	6.7	MEDI		0.004		Heap-based buffer overflow in Windows BitLocker allows an authorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70594	6.7	MEDI		0.002		Ghost is a Node.js content management system. From 2.2.0 until 6.54.1, Ghost Admin did not invalidate existing sessions on login which could have allowed for session fixation attacks. Successful exploitation would have required another vulnerability on the same domain where Ghost Admin was hosted. This issue is fixed in version 6.54.1.
CVE-2026-71339	6.7	MEDI		0.003		Heap-based buffer overflow in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-72935	6.7	MEDI		0.003		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-72948	6.7	MEDI		0.004		Relative path traversal in Windows DNS allows an authorized attacker to elevate privileges locally.
CVE-2026-78625	6.7	MEDI		0.002		The Okta Access Gateway does not sanitize dashboard label values before writing them into generated PHP configuration files. The generated file is automatically included during authentication requests, resulting in execution with the privileges of the web server process.
CVE-2026-78630	6.7	MEDI		0.002		The Okta Access Gateway does not neutralize shell metacharacters in SNMP configuration values before a privileged script uses them to construct OS commands. An authenticated local user with access to the management interface can supply crafted values, resulting in the execution of arbitrary OS commands with root privileges.
CVE-2026-85981	6.7	MEDI		0.001		The administrative panel of the Auth0 AD/LDAP Connector (versions 6.5.0 and earlier) listens on the local loopback interface without requiring authentication. This allows a local, low-privileged user or process on the host system to access the panel's management endpoints without credentials. Through these endpoints, a local user can read configuration details, including plaintext Active Directory service account ...
CVE-2026-9176	6.7	MEDI				IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a security bypass due to improper authentication controls. A local attacker could exploit this vulnerability to escalate privileges and gain unauthorized access to protected resources.
CVE-2026-19201	6.6	MEDI		0.003		An uncontrolled recursion vulnerability in the Windows SIPA event log parser of Google go-attestation versions up to and including 0.6.1 allows an attacker to cause a denial of service (DoS). The (*WinEvents).readELAMAggregation function recurses for every nested elamAggregation sub-event without enforcing a maximum recursion depth limit, while the size guard is bypassed on recursive execution paths. By submitting...
CVE-2026-69469	6.6	MEDI		0.004		Integer overflow or wraparound in Windows USB Audio Class driver (usbaudio.sys) allows an unauthorized attacker to elevate privileges with a physical attack.
CVE-2026-70593	6.6	MEDI		0.003		Ghost is a Node.js content management system. From 0.10.0 until 6.54.1, a vulnerability in custom themes allowed a staff user to write files outside of the uploads directory. This could be used to alter the behavior of the installation through custom theme upload path traversal in LocalStorageBase and theme storage name handling. This issue is fixed in version 6.54.1.
CVE-2026-70602	6.6	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, extension tab and scripting APIs were not scoped to the extension's own session. A malicious or compromised extension loaded into one session could navigate, script, and read from windows belonging to a different session. Apps are only affected if they load Chr...
CVE-2026-78545	6.6	MEDI		0.004		The Okta Access Gateway does not sanitize the application label field before including it in the generated nginx configuration file. The unsanitized value is interpolated into an nginx server block directive, resulting in execution of injected directives.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78550	6.6	MEDI		0.004		The Okta Access Gateway management console passes user-supplied input to eval() without sanitization during an authenticated administrator SSH session. As a result, the unsanitized input is executed directly, leading to code execution with the privileges of the management console.
CVE-2024-9355	6.5	MEDI		0.003		A vulnerability was found in Golang FIPS OpenSSL. This flaw allows a malicious user to randomly cause an uninitialized buffer length variable with a zeroed buffer to be returned in FIPS mode. It may also be possible to force a false positive match between non-equal hashes when comparing a trusted computed hmac sum to an untrusted input sum if an attacker can send a zeroed buffer in place of a pre-computed sum. It...
CVE-2026-14470	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow an authenticated attacker to traverse directories on the system. An attacker could send a specially crafted URL request containing "dot dot" sequences (/../) to view arbitrary files on the system.
CVE-2026-15154	6.5	MEDI		0.005	redhat:openshift_ai	A flaw was found in `guardrails-detectors`, a component of Red Hat OpenShift AI. This vulnerability, known as Regular Expression Denial of Service (ReDoS), allows a remote attacker to provide specially crafted regular expressions to the public detection API. This can cause catastrophic backtracking, leading to a worker process consuming 100% CPU indefinitely and resulting in a denial of service for the entire guar...
CVE-2026-17259	6.5	MEDI		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to a stack-based buffer overflow.
CVE-2026-17273	6.5	MEDI		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to a NULL pointer dereference.
CVE-2026-17443	6.5	MEDI		0.003	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity (XXE) injection flaw.
CVE-2026-17444	6.5	MEDI		0.003	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity (XXE) injection.
CVE-2026-17622	6.5	MEDI		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to obtain sensitive information due to improper limitation of a pathname to a restricted directory.
CVE-2026-17631	6.5	MEDI		0.002	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to obtain sensitive information due to a server-side request forgery (SSRF) vulnerability.
CVE-2026-18076	6.5	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to a memory leak.
CVE-2026-18078	6.5	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to cause a denial of service due to an integer overflow.
CVE-2026-18887	6.5	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow an authenticated attacker to obtain sensitive information in PASE. An attacker could exploit this vulnerability to access information about process they shouldn't be permitted to access.
CVE-2026-19299	6.5	MEDI		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information due to path traversal.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19301	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information due to server-side request forgery.
CVE-2026-19302	6.5	MEDI		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of symbolic links.
CVE-2026-19645	6.5	MEDI		0.003		IBM MQ Agent CD: v1.0.0, v1.0.1, v2.0.0, v2.0.1 An authenticated user with a valid session cookie can submit arbitrarily large or computationally expensive requests that cause the LLM agent workers to be held for extended periods — ranging from tens of seconds to over ten minutes per request. When multiple such requests are sent concurrently, the agent worker pool becomes exhausted, causing all other IBM MQ Console u...
CVE-2026-2377	6.5	MEDI		0.004	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay and mirror registry for Red Hat OpenShift. The log export feature in these products allows an authenticated user to specify an arbitrary callback URL. A backend process then makes server-side HTTP requests to this provided URL. This vulnerability, known as Server-Side Request Forgery (SSRF), could allow an attacker to send requests from the application's internal network, potential...
CVE-2026-41607	6.5	MEDI		0.009	apache:thrift	Out-of-bounds Read vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-42041	6.5	MEDI		0.006	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.1 and 0.31.1, the Axios library is vulnerable to a Prototype Pollution "Gadget" attack that allows any Object.prototype pollution to silently suppress all HTTP error responses (401, 403, 500, etc.), causing them to be treated as successful responses. This completely bypasses application-level authentication and error handling. The root...
CVE-2026-44766	6.5	MEDI		0.002		SAP S/4HANA (Intercompany Matching and Reconciliation) allows a low-privileged authenticated user to inject malicious input into certain functions, which may be processed by the database without proper validation. This could allow the user to access sensitive information, resulting in high impact on confidentiality, with no impact on integrity and availability of the application.
CVE-2026-46370	6.5	MEDI		0.003		Fleet is an open-source device management platform built on osquery. In versions up to and including 4.84.1, the labels host-listing endpoint (GET /api/v1/fleet/labels/{id}/hosts) allowed an authenticated user with the lowest-privilege Observer role to extract host enrollment secrets through a sort-order oracle. The endpoint accepted a user-supplied order_key parameter that was not validated against a column allow...
CVE-2026-46371	6.5	MEDI		0.002		Fleet is an open-source device management platform built on osquery. In versions up to and including 4.84.1, the Apple MDM commands listing endpoint (GET /api/v1/fleet/mdm/apple/commands) allowed an authenticated user with the lowest-privilege Observer role to extract sensitive values from joined database tables, including host enrollment secrets and Apple Push Notification Service tokens, through a sort-order ora...
CVE-2026-48093	6.5	MEDI		0.002		The Code Embed WordPress plugin prior to version 2.6.1 is vulnerable to stored Cross-Site Scripting (XSS) through the external URL embed feature in post content. The vulnerable code scans rendered content for URL embed tokens, fetches the remote URL, and inserts the remote response body into the page without output sanitization or an `unfiltered_html` capability check. This allows a Contributor attacker to submit ...
CVE-2026-48786	6.5	MEDI		0.003		Fleet is an open-source device management platform built on osquery. In versions prior to 4.87.0, the target search endpoint (POST /api/latest/fleet/targets) returned unmasked team enroll secrets and full team configuration, including credential-bearing agent options, to low-privilege observer-class users. Other team-facing endpoints mask these fields for observers, but the target search endpoint did not apply the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-49466	6.5	MEDI		0.002		Draft List is a WordPress plugin to manage and promote unpublished content. Versions 2.6.3 and below are vulnerable to stored Cross-Site Scripting (XSS) in the `[drafts]` shortcode and Draft List widget when the documented custom `template` option places the `{{draft}}` placeholder inside an HTML attribute. The vulnerable code inserts the raw draft `post_title` into `{{draft}}` when the current viewer cannot edit ...
CVE-2026-52733	6.5	MEDI		0.003		ZEBRA is a Zcash node written entirely in Rust. Prior to 4.5.0, a natural or attacker-influenced chain fork can leave stale Sapling and Orchard note-commitment subtree roots in Zebra state. In zebra-state/src/service/non_finalized_state/chain.rs, Chain::pop_tip removed a reverted tip block but did not remove subtree entries whose end_height belonged to that block, unlike the cleanup performed by pop_root. When the...
CVE-2026-53583	6.5	MEDI		0.002		libgit2 is a portable C implementation of the Git core methods provided as a linkable library with a solid API, allowing to build Git functionality into your application. Prior to 1.8.6 and 1.9.5, verify_server_cert in src/libgit2/streams/openssl.c uses an inverted !memcmp result in the GEN_IPADD branch when comparing an IP-literal host with a certificate IP SubjectAltName. OpenSSL builds reject matching IP address...
CVE-2026-54732	6.5	MEDI		0.003		libreoffice-convert is a Node.js module for converting office documents to different formats. Prior to 1.8.2, index.js uses the caller-controlled options.fileName value in path.join(tempDir.name, fileName) without reducing it to a base name. A filename containing ../ can escape the temporary directory because path.basename() normalization is missing and write the supplied document buffer to an arbitrary path write...
CVE-2026-54738	6.5	MEDI		0.004		Lemmy is a link aggregator and forum for the fediverse. Prior to 0.19.19 and 1.0.0-beta.1, actix-web ConnectionInfo::realip_remote_addr reads the first value of X-Forwarded-For as the client address used by raw_ip_key in crates/utils/src/rate_limit/mod.rs. Lemmy's bundled docker/nginx.conf uses \$proxy_add_x_forwarded_for instead of \$remote_addr, which appends the real client address to an X-Forwarded-For value sup...
CVE-2026-55545	6.5	MEDI		0.003		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs WebSocket subscription handlers fail to enforce the privileges required by equivalent REST endpoints. PacketsApi.subscribePackets exposes the packets WebSocket topic without ObjectPrivilegeType.ReadPacket, ProcessingApi.subscribeAlgorithmStatus exposes the algorithm-status WebSocket topic without ObjectPrivilegeType.ReadAlgorithm, and MdbOverr...
CVE-2026-55549	6.5	MEDI		0.004		Yamcs is a mission control framework. Prior to 5.9.4, Yamcs reflects an attacker-controlled redirect_uri parameter from GET /auth/authorize into yamcs-core/src/main/resources/auth/templates/authorize.html without adequate HTML escaping by yamcs-core/src/main/java/org/yamcs/http/auth/AuthHandler.java and yamcs-core/src/main/java/org/yamcs/http/HandlerContext.java. A crafted authorization URL can execute JavaScript ...
CVE-2026-55618	6.5	MEDI		0.003		eml_parser serves as a python module for parsing eml files and returning various information found in the e-mail as well as computed information. Prior to 3.0.2, the clean_found_uri function in eml_parser/parser.py validates potential URL strings before unescaping HTML entities used for colon, slash, or period characters. Valid encoded URLs and their host names are therefore rejected and omitted from the extracted...
CVE-2026-55855	6.5	MEDI		0.003		MariaDB Connector/Node.js is used to connect applications developed on Node.js to MariaDB and MySQL databases. Prior to 3.2.4, 3.3.3, 3.4.6, and 3.5.3, MariaDB Connector/Node.js permits SQL injection when attacker-controlled Buffer parameters are escaped client-side under the big5, gbk, sjis, cp932, or gb18030 client character sets. PacketOutputStream.writeBufferEscape in lib/io/packet-output-stream.js escaped byt...
CVE-2026-56818	6.5	MEDI		0.003		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.136.Final and 4.2.16.Final, the RedisArrayAggregator Redis codec clears retained partial aggregate state when the maxNestedArrayDepth limit is exceeded, but it does not clear the same state when the sibling maxElements limit is exceeded. A peer can start a valid RESP array, send a bulk string child, then send a nested array header l...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-57822	6.5	MEDI		0.002		When the broker is processing message-based management requests, sent by an authenticated messaging client that is authorized with MANAGE permission to perform management-via-messaging, the parameter processing can trigger Java deserialization of certain method parameters that the broker will not utilise. The permitted types allow to craft a payload causing excessive computation and pinning the processing thread, ...
CVE-2026-58649	6.5	MEDI		0.003		Origin validation error in .NET allows an unauthorized attacker to disclose information over a network.
CVE-2026-59903	6.5	MEDI		0.002		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Final and 4.2.17.Final, io.netty.handler.codec.http.cors.CorsHandler setVaryHeader replaces application Vary headers such as Authorization or Cookie with Origin, allowing a caching proxy or CDN to reuse authenticated responses across users and disclose sensitive information. This issue is fixed in versions 4.1.137.Final and 4.2....
CVE-2026-62762	6.5	MEDI		0.008		Null pointer dereference in Active Directory Domain Services allows an authorized attacker to deny service over a network.
CVE-2026-62801	6.5	MEDI		0.005		Improper limitation of a pathname to a restricted directory ('path traversal') in Windows PowerShell allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-63667	6.5	MEDI		0.004		ApostropheCMS is an open-source Node.js content management system. Prior to 3.6.2, the import-export module in packages/import-export/lib/formats/gzip.js constructs an attachment source path from the attacker-controlled _id, name, and extension fields in aposAttachments.json without ensuring that the resolved path remains under the extracted attachments directory, allowing an authenticated contributor to import a ...
CVE-2026-63669	6.5	MEDI		0.002		ApostropheCMS is an open-source Node.js content management system. Prior to 4.32.0, the page module's move() operation fails to enforce the destination parent's _create permission because its oldParent archive condition disables the check for ordinary moves, allowing an authenticated editor or contributor to use _targetId and _position through the page REST update endpoint to move a controlled page into a restrict...
CVE-2026-64918	6.5	MEDI		0.005	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Insufficiently protected credentials in Microsoft Office allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-68898	6.5	MEDI		0.006		Out-of-bounds read in Windows iSCSI allows an unauthorized attacker to deny service over a network.
CVE-2026-69267	6.5	MEDI		0.003		Insufficient granularity of access control in Windows Connected User Experiences and Telemetry allows an authorized attacker to disclose information locally.
CVE-2026-69297	6.5	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Storing passwords in a recoverable format in Windows DHCP Server allows an authorized attacker to disclose information over a network.
CVE-2026-69361	6.5	MEDI		0.008		Server-side request forgery (ssrf) in Microsoft Exchange Server allows an authorized attacker to perform spoofing over a network.
CVE-2026-69374	6.5	MEDI		0.011		Allocation of resources without limits or throttling in Windows SMB Server allows an authorized attacker to deny service over a network.
CVE-2026-69375	6.5	MEDI		0.006		Authorization bypass through user-controlled key in Microsoft Exchange Server allows an authorized attacker to perform tampering over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69395	6.5	MEDI		0.009		Use of externally-controlled format string in Active Directory Certificate Services (AD CS) allows an authorized attacker to disclose information over a network.
CVE-2026-69409	6.5	MEDI		0.01	microsoft:sharepoint_server	Execution with unnecessary privileges in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-69497	6.5	MEDI		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an authorized attacker to deny service over a network.
CVE-2026-69624	6.5	MEDI		0.007		Incomplete list of disallowed inputs in Active Directory Certificate Services (AD CS) allows an authorized attacker to perform tampering over a network.
CVE-2026-69626	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Buffer over-read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-69636	6.5	MEDI		0.01	microsoft:sharepoint_server	Improper neutralization of special elements used in an sql command ('sql injection') in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-69719	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Buffer over-read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-69734	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Integer overflow or wraparound in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-69781	6.5	MEDI		0.005	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Missing release of memory after effective lifetime in Windows DHCP Client allows an unauthorized attacker to deny service over an adjacent network.
CVE-2026-69839	6.5	MEDI		0.011		Uncaught exception in Windows iSCSI Target Service allows an authorized attacker to deny service over a network.
CVE-2026-69855	6.5	MEDI		0.005	microsoft:azure_copilot	Server-side request forgery (ssrf) in Microsoft Copilot in Azure allows an authorized attacker to disclose information over a network.
CVE-2026-70019	6.5	MEDI		0.011		Windows hard link in Windows Compressed Folder allows an unauthorized attacker to disclose information over a network.
CVE-2026-70429	6.5	MEDI		0.002	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier handles case-insensitivity in user names and group names inconsistently, allowing attackers able to create new users or groups with names that case-insensitively match other characters to impersonate other users or be granted their permissions in some circumstances.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70491	6.5	MEDI		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. In 0.10.2 and earlier, the GET /api/v1/tools/, GET /api/v1/tools/list, and GET /api/v1/tools/id/{id} endpoints in backend/open_webui/routers/tools.py returned full Python tool source to authenticated non-admin read-only users. ToolResponse deliberately omitted source and specs, but ToolUserResponse permitted extra fields and hand...
CVE-2026-70493	6.5	MEDI		0.003		Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.9.6 until 0.11.0, the built-in knowledge search path in backend/open_webui/tools/knowledge_fs.py and backend/open_webui/tools/builtin.py let a chat participant choose a pattern used to grep knowledge files. Patterns containing regex metacharacters were compiled with Python's backtracking re engine and run against every lin...
CVE-2026-71437	6.5	MEDI		0.004		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. From version 11.5.0 until 11.16.1, Mermaid Architecture Diagrams are vulnerable to prototype pollution when a diagram defines a group with an id of __proto__. Because the group id is used directly as an object property key without validation, an attacker who can supply diagram text can pollute Object.prototype, ...
CVE-2026-72739	6.5	MEDI		0.006		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, the createCommand() function constructs shell commands by interpolating compose service names and configuration into bash command strings. When a compose with a maliciously crafted name or service definition is deployed, the shell metacharacters are interpreted as command separators, allowing arbitrary command execution on the Docker ...
CVE-2026-72938	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Access of resource using incompatible type ('type confusion') in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-72939	6.5	MEDI		0.011		Null pointer dereference in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to deny service over a network.
CVE-2026-72942	6.5	MEDI		0.009		Out-of-bounds read in Windows Spaceport.sys allows an unauthorized attacker to disclose information over a network.
CVE-2026-72956	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Untrusted pointer dereference in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-72974	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Buffer over-read in Microsoft Office Excel allows an unauthorized attacker to disclose information over a network.
CVE-2026-72975	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72977	6.5	MEDI		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-75509	6.5	MEDI		0.001		joserfc is a Python library that provides an implementation of several JSON Object Signing and Encryption (JOSE) standards. Prior to version 1.7.3, JWTClaimsRegistry applies membership matching to list-valued iss and sub claims, allowing an array-valued iss that contains the expected issuer to pass an intended equality check and enabling issuer-validation bypass. This issue is fixed in version 1.7.3.
CVE-2026-75880	6.5	MEDI		0.002		An authenticated client could attach a consumer with a selector containing crafted wildcard usage that results in excessive evaluation during message delivery attempts, occupying a shared broker thread and leading to denial of service. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes...
CVE-2026-76968	6.5	MEDI		0.002		SAP Web Dispatcher, Internet Communication Manager and SAP Content Server allows an authenticated low-privileged attacker to access certain administrative functionality or interface and obtain sensitive information about the system state, resulting in information disclosure. This disclosed information could potentially be used to facilitate further attacks. This vulnerability has a high impact on the confidentiality...
CVE-2026-76971	6.5	MEDI		0.001		Due to a Server-Side Request Forgery (SSRF) vulnerability in SAP Manufacturing Integration and Intelligence, an attacker could cause the server to initiate arbitrary outbound requests. If processed by the application, this behavior could be combined with XML/XSL processing to enable execution of scripts. Successful exploitation could result in a low impact on the confidentiality, integrity, and availability of the...
CVE-2026-77911	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-78441	6.5	MEDI		0.007		Out-of-bounds read in Windows OLE DB allows an unauthorized attacker to disclose information over a network.
CVE-2026-78453	6.5	MEDI		0.009		Integer underflow (wrap or wraparound) in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information over a network.
CVE-2026-78502	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-78503	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78515	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information over a network.
CVE-2026-78520	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78522	6.5	MEDI		0.007	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-78658	6.5	MEDI		0.003		IBM UCD - IBM UrbanCode Deploy 7.2 through 7.2.3.25, and 7.3 through 7.3.2.20 and IBM UCD - IBM DevOps Deploy 8.0 through 8.0.1.15, 8.1 through 8.1.2.8, and 8.2 through 8.2.2.1 IBM DevOps Deploy / IBM UrbanCode Deploy (UCD) is susceptible to an formation disclosure vulnerability when processing redacted property values. If a deployment is configured with a secure property that starts with certain non-ASCII charact...
CVE-2026-78838	6.5	MEDI		0.004		A reflected cross-site scripting (XSS) vulnerability in the grid_datasource.php component of AppNitro MachForm v30 allows attackers to execute arbitrary Javascript in the context of the victim's browser via injecting a crafted payload into the filter[filters][0][field] parameter.
CVE-2026-79725	6.5	MEDI				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to read arbitrary files due to improper access control.
CVE-2026-80073	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to disclose information over a network.
CVE-2026-80076	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80078	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80079	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-80082	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80084	6.5	MEDI		0.007	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to disclose information over a network.
CVE-2026-80086	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-80087	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80088	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.
CVE-2026-80089	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80090	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80091	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Use of uninitialized resource in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-84365	6.5	MEDI		0.003		Hono is a Web application framework that provides support for any JavaScript runtime. From 4.12.12 until 4.13.5, the fix released for CVE-2026-39408 does not cover every traversal sequence, and toSSG() can still write files outside the configured output directory when a route parameter contains consecutive parent-directory segments. Static site generation builds each output path from the route path and values supp...
CVE-2026-84391	6.5	MEDI		0.002		A use of uninitialized variable vulnerability in Fortinet FortiAnalyzer 7.6.3 through 7.6.6 may allow attacker to denial of service via <insert attack vector here>
CVE-2026-86332	6.5	MEDI		0.002		A flaw was found in odh-dashboard in Red Hat OpenShift AI. The backend-for-frontend route GET /api/nim-serving/:nimResource reads Kubernetes Secrets using the dashboard service account and returns the full Secret object, including .data, without an authorization check. Any authenticated dashboard user can retrieve the cluster NVIDIA NGC API key Secret (apiKeySecret) and the NIM image pull secret (nimPullSecret). C...
CVE-2026-86550	6.5	MEDI		0.003		NuBrowser lacks protocol whitelist validation for the S.browser_fallback_url field of intent://, allowing attackers to inject javascript: URLs via 302 redirects. This results in a universal cross-site scripting (UXSS) vulnerability that enables script execution within the origin of arbitrary websites.
CVE-2026-86597	6.5	MEDI		0.001		Insertion of sensitive information into log files in the Snowflake Python, Go, JDBC, Node.js, PHP PDO, and ODBC drivers allowed authentication tokens, query-result encryption keys, pre-signed cloud-storage URLs, and SAML assertions to be written to diagnostic logs in circumstances where the available log redaction did not cover all affected log paths and data types. An attacker with read access to the log destinat...
CVE-2026-87454	6.5	MEDI		0.002	google:chrome, microsoft:windows	Information leak in Enterprise in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to obtain sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-9138	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 Langflow could allow an authenticated attacker to write arbitrary files to the server due to improper input validation in the SaveToFileComponent. The application constructs local file paths using attacker-controlled input without sufficient sanitization when handling requests to the /api/v1/run/{flow_id} endpoint. An attacker with low-privileged authenticated access (such as ...
CVE-2026-9186	6.5	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 allows remote authenticated attackers to bypass localhost-only MCP configuration installation by spoofing X-Forwarded-For: 127.0.0.1 header, enabling arbitrary writes to IDE config files (~/.cursor/mcp.json, etc.).
CVE-2026-9225	6.5	MEDI				IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an authenticated attacker to access sensitive files belonging to other users due to improper access control in the File/Read File component. When executing flows through the /api/v1/run/advanced/{flow_id} endpoint, the application allows component inputs to reference storage paths using arbitrary user or flow identifiers without verifying ownership. An att...
CVE-2026-9336	6.5	MEDI				IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted HTTP request to an administrative endpoint. A remote attacker could exploit this vulnerability to cause the server to exhaust filesystem space.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-9745	6.5	MEDI		0.002	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 has operations that are performed without validating bucket ownership using the ExpectedBucketOwner parameter. This omission may allow a remote attacker to exploit misconfigurations or naming collisions to redirect application requests to an unintended S3 bucket under their control.
CVE-2026-19634	6.4	MEDI		0.002		PostgreSQL Anonymizer contains a SQL injection vulnerability in two import functions. A user can create a malicious JSON document containing specially crafted object names. If a superuser subsequently calls anon.import_database_rules() or anon.import_roles_rules(), the malicious code is executed with superuser privileges. The issue is fixed in PostgreSQL Anonymizer 3.1.4 and later
CVE-2026-3853	6.4	MEDI		0.002		The Divi theme for WordPress is vulnerable to DOM-Based Stored Cross-Site Scripting via the `image_src` attribute of the `et_pb_video_slider_item` shortcode in all versions up to, and including, 4.27.6. This is due to the `image_src` field not being included in the `\$url_options` whitelist (which only contains `url`, `button_link`, `button_url`), so it never receives `esc_url_raw()` at save time. On the server sid...
CVE-2026-54743	6.4	MEDI		0.005		Lemmy is a link aggregator and forum for the fediverse. Prior to lemmy-ui 0.19.19-beta.1, LemmyNet/lemmy-ui renders Markdown in src/shared/markdown.ts for post bodies, comment bodies, private messages, and community and site sidebars through mdToHtml, which returns a raw __html object that Inferno injects without a sanitizer pass. setupMarkdown configures html as false but registers markdown-it-html5-embed@1.0.0 w...
CVE-2026-66760	6.4	MEDI		0.001	sap:approuter	SAP Approuter does not correctly validate client certificates in certain callback flows. An attacker with low privileges, holding a certificate from the same trusted authority with matching subject values, could bypass the identity check. This complexity makes the attack difficult to execute. Successful exploitation could allow impersonation of a trusted internal component, resulting in a high impact on integrity ...
CVE-2026-69878	6.4	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-70582	6.4	MEDI		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Management Instrumentation allows an authorized attacker to elevate privileges locally.
CVE-2026-71338	6.4	MEDI		0.003		Double free in Windows Failover Cluster allows an authorized attacker to elevate privileges locally.
CVE-2026-72881	6.4	MEDI		0.005		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, database backup and restore command builders in packages/server/src/utlis/backups/utlis.ts and packages/server/src/utlis/restore/utlis.ts interpolate database names, usernames, and passwords into nested shell command strings passed to child_process.exec(). An authenticated administrator with permission to create databases and configur...
CVE-2026-72947	6.4	MEDI		0.003		Integer underflow (wrap or wraparound) in Windows File History Service allows an authorized attacker to elevate privileges locally.
CVE-2026-77887	6.4	MEDI		0.002		Out-of-bounds read in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-77891	6.4	MEDI		0.002		Out-of-bounds read in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-83534	6.4	MEDI		0.002		PostgreSQL Anonymizer contains a vulnerability in the anon.anonymize_database_parallel() function that allows the owner of a table to run arbitrary code with superuser privilege. The issue is fixed in PostgreSQL Anonymizer 3.2.0 and later versions

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-62718	6.3	MEDI		0.012	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Prior to 1.15.0 and 0.31.0, Axios does not correctly handle hostname normalization when checking NO_PROXY rules. Requests to loopback addresses like localhost. (with a trailing dot) or [::1] (IPv6 literal) skip NO_PROXY matching and go through the configured proxy. This goes against what developers expect and lets attackers force requests through a ...
CVE-2026-25552	6.3	MEDI		0.002		Ghost CLI before 1.30.1 contains an IP spoofing vulnerability that allows unauthenticated remote attackers to bypass rate-limiting controls by manipulating the X-Forwarded-For header through a misconfigured Nginx configuration. Attackers can append attacker-controlled values to the header chain using the \$proxy_add_x_forwarded_for directive to present an arbitrary IP address, circumventing Ghost's rate-limiting me...
CVE-2026-43980	6.3	MEDI		0.002		Malla is a web analyzer for Meshtastic networks based on MQTT data. Prior to commit 4086e2b5f61615a813b70b25bc76095083552135, code names (long_name, short_name) received via MQTT are stored in SQLite without sanitization and rendered into the DOM without escaping. Any participant on a public Meshtastic MQTT broker can set a malicious node name that executes JavaScript in the browser of every Malla dashboard visito...
CVE-2026-50544	6.3	MEDI		0.001		NortheBridge/luminalshine is a Sunshine-compatible game stream host for Moonlight. Prior to version 26.05.0-rc4, a latent gap exists on a default install, the file at `src/platform/windows/misc.cpp` lives at `C:\ProgramData\LuminalShine\config\apps.json` and is created by the `SYSTEM` service. Under Windows' default `C:\ProgramData` inheritance, that gives `BUILTIN\Users` only Read+Execute — not writable — so the ...
CVE-2026-5588	6.3	MEDI		0.006		Use of a Broken or Risky Cryptographic Algorithm vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcpkix on all (pkix modules), Legion of the Bouncy Castle Inc. BCPKIX-FIPS bcpkix on All (pkix modules), Legion of the Bouncy Castle Inc. BCPIX-LTS bcpkix on All (pkix modules). This vulnerability is associated with program files JcaContentVerifierProviderBuilder.Java, JcaContentVerfierProviderBuilder.Java....
CVE-2026-61807	6.3	MEDI		0.003		Snipe-IT is an IT asset/license management system. Prior to 8.6.2, a stored manufacturer or supplier name passed as the table component \$name becomes data-selected-count-id in resources/views/partials/bootstrap-table.blade.php. Client-side code reads the browser-decoded countId, uses it as a selector, concatenates countId.substring(1) into an HTML string, and passes the string to jQuery .after(). A crafted name ca...
CVE-2026-63335	6.3	MEDI		0.003		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.31.0, inbound AMQP command assembly in src/main/java/com/rabbitmq/client/impl/CommandAssembler.java processes a content-bearing method and header whose remainingBodyBytes value is smaller than a following AMQP.FRAME_BODY payload. CommandAssembler.consumeBodyFrame subtracts the peer-con...
CVE-2026-63642	6.3	MEDI		0.005		MagicMirror ² is an open source modular smart mirror platform. Prior to 2.37.0, checkArticleUrl in defaultmodules/newsfeed/node_helper.js accepts the CHECK_ARTICLE_URL notification through the unauthenticated Socket.IO namespace /newsfeed and performs fetch(url, { method: "HEAD" }) without validating the attacker-controlled URL. The helper returns ARTICLE_URL_STATUS containing the URL and framing result, providing ...
CVE-2026-69243	6.3	MEDI		0.004		AIOHTTP is an asynchronous HTTP client/server framework for asyncio and Python. Prior to 3.14.2, the HTTP parsers were vulnerable to a request smuggling attack relating to WebSocket upgrades. If using the server-side component, an attacker may be able to execute a request smuggling vulnerability using an edge case in the WebSocket upgrade procedure. A WebSocket upgrade request with a body could cause the parser to...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70597	6.3	MEDI		0.001		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, the check Electron uses on macOS to confirm it was launched by a same-signed parent process could be bypassed by a local process. Apps that enable fuse-based hardening restricting ELECTRON_RUN_AS_NODE and NODE_OPTIONS to same-signed parents rely on this check, ...
CVE-2026-73411	6.3	MEDI		0.003		Shescape is a simple shell escape library for JavaScript. Prior to 2.1.14 and 3.0.1, getEscapeFunction in src/internal/unix/dash.js fails to escape ~ after : or = when applications use the escape or escapeAll APIs on Unix with shell set to dash, or with shell set to true when Dash is the default, and interpolate the result into an assignment prefixed to a command. An attacker who controls the input can supply a va...
CVE-2026-73412	6.3	MEDI		0.003		Shescape is a simple shell escape library for JavaScript. Prior to 2.1.14 and 3.0.1, this impacts users of Shescape on Unix systems that explicitly configure shell to Zsh, or true when the default shell is Zsh, using the escape and escapeAll. The Zsh options EXTENDED_GLOB and MAGIC_EQUAL_SUBST exacerbate the problem. In certain case, an attacker can leverage home directory expansion and extended glob syntax to obt...
CVE-2026-81824	6.3	MEDI		0.003		The vulnerability, if exploited, could allow a miscreant to run arbitrary JavaScript code in a browser session of a PIMBoards user who was socially engineered to click on a malicious link.
CVE-2026-81994	6.3	MEDI		0.003	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Improperly Controlled Modification of Object Prototype Attributes ('Prototype Pollution') vulnerability that could lead to arbitrary file system read. An attacker could exploit this vulnerability to access sensitive files and directories outside the intended access scope. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is chan...
CVE-2026-81997	6.3	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Incorrect Authorization vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized write access. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.
CVE-2026-83610	6.3	MEDI		0.004		xmldom is a pure JavaScript W3C standard-based (XML DOM Level 2 Core) DOMParser and XMLSerializer module. Prior to @xmldom/xmldom versions 0.8.15 and 0.9.12, and in xmldom version 0.6.0 and earlier, Document.createEntityReference(name) accepts an invalid name and the ENTITY_REFERENCE_NODE serializer emits the resulting nodeName directly in &name; form. Directly serializing the node or fragment with XMLSerializer.s...
CVE-2026-84942	6.3	MEDI		0.003		Improper input validation in the Vega expression function implementation in OpenSearch Dashboards allows a remote authenticated actor with dashboard write permissions to execute arbitrary JavaScript in the context of other users' browser sessions by saving a crafted Vega visualization. The checkForFunctionProperty validation routine failed to recurse into arrays of objects, allowing a function property nested insi...
CVE-2026-84969	6.3	MEDI		0.002	mongodb:c_driver	A memory-handling error in the BSON-to-JSON conversion helpers of the MongoDB C Driver can write a small number of bytes past the end of a heap buffer when a binary field is encoded and the output is cut short at a caller-configured length limit. A party who supplies the document content, with no privileges on the application that links the driver, may cause a small amount of data outside the intended buffer to be...
CVE-2026-85167	6.3	MEDI		0.002	n8n:n8n	n8n before 2.35.4 and 2.36.x before 2.36.2 contain a query injection vulnerability in the Elasticsearch Document Get All and Google Cloud Firestore Document Query operations, which build their JSON query by interpolating expression values directly into the query string before parsing. A value containing quote and brace characters can close the intended field and introduce new query operators, turning an intended s...
CVE-2026-86079	6.3	MEDI		0.003		n8n is an open source workflow automation platform. Prior to 1.123.76, 2.37.7, and 2.38.2, the Elasticsearch and ElasticSecurity nodes interpolated workflow-controlled index and document identifiers directly into REST request paths. An identifier containing path separators or dot segments could select another index or a cluster administration endpoint under the stored Elasticsearch credential. The affected request...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86590	6.3	MEDI		0.004		In Eclipse Che versions 7.79.0 through 7.121.0, the dashboard backend's POST /dashboard/api/data/resolver endpoint passes a caller-supplied URL directly to an outbound HTTP GET request with no host filtering. An authenticated user can exploit this server-side request forgery (SSRF) to read responses from internal network addresses, including the cloud instance metadata service (169.254.169.254), loopback interface...
CVE-2026-88859	6.3	MEDI				A flaw was found in Evolution. A remote attacker can exploit this vulnerability by sending a specially crafted HTML email containing a spoofed vCard control. When a victim clicks on this control, Evolution's trusted JavaScript handler incorrectly assigns an attacker-controlled JavaScript URL to an iframe's source. This action leads to arbitrary JavaScript execution within the mail-viewing context, effectively bypa...
CVE-2026-9327	6.3	MEDI				IBM WebSphere Application Server 9.0, and 8.5 could allow an authenticated user with a low-privilege administrative role to modify security configuration. This could result in information disclosure or denial of service.
CVE-2026-68499	6.2	MEDI		0.001		re2 provides Node.js bindings for Google's RE2 regular expression engine. Prior to 1.25.2, re2's String.prototype.match implementation with a global RE2 pattern that can match the empty string fails to advance its native matching cursor in lib/match.cc, causing an infinite loop and unbounded native memory growth that blocks the event loop and can exhaust host memory. This issue is fixed in 1.25.2.
CVE-2026-71429	6.2	MEDI		0.001		stream-json is a micro-library of stream components for processing JSON and JSONC with a minimal memory footprint. Prior to 3.5.0, the path filters pick, ignore, filter, and replace in src/core/filters/filter-base.js recompute the full path string from the nesting stack for every checkable token. Because the stack length equals the current nesting depth and a checkable token is emitted at every level, a depth D do...
CVE-2026-71430	6.2	MEDI		0.001		node-re2 provides RE2 regular expression bindings for Node.js. Prior to version 1.25.1, the WrappedRE2::Replace function built its replacement result and passed it to V8 using ToLocalChecked without checking for the empty MaybeLocal that V8 returns when the resulting string or buffer exceeds V8's maximum string length. When a global replace uses an output amplifying replacement template, the result can grow quadra...
CVE-2026-81859	6.2	MEDI		0.001		CP4BA - IBM Enterprise Records could allow a local attacker to obtain sensitive information due to the use of a broken or risky cryptographic algorithm.
CVE-2026-86314	6.2	MEDI		0.001		Integer overflow in the source-bounds check in Memory::init() (src/runtime/Memory.cpp) in Samsung walrus on all platforms allows a remote attacker to cause an out-of-bounds heap read and denial of service via a crafted WebAssembly module in which a 32-bit unsigned addition wraps around and bypasses the bounds check. This issue affects Walrus: ff3bf5ff5c4878f8e5572c9593d303f6bc997443.
CVE-2026-86315	6.2	MEDI		0.001		An out-of-bounds write caused by numeric truncation Samsung Open Source Escargot on Linux x86-64 allows an attacker who can supply JavaScript for execution to corrupt native memory and crash the host process via a crafted class definition whose instance initialization entry count exceeds UINT16_MAX. This issue affects Escargot: 5dc93606abd42b859045add05d704a038e197359.
CVE-2025-24291	6.1	MEDI		0.004	versa-networks:versa_director	The Versa Director SD-WAN orchestration platform provides functionality to upload various types of files. However, the Java code handling file uploads contains an argument injection vulnerability. By appending additional arguments to the file name, an attacker can bypass MIME type validation, allowing the upload of arbitrary file types. This flaw can be exploited to place a malicious file on disk. Versa Network...
CVE-2025-51684	6.1	MEDI		0.003		CleverTap Web SDK v1.15.1 is vulnerable to Cross Site Scripting (XSS). The application does not sanitize untrusted data received via window.postMessage before injecting it into the page DOM. An attacker can craft a malicious message that, when processed by renderCustomHtml, results in execution of arbitrary JavaScript in the context of the hosting site.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-18562	6.1	MEDI				The HUSKY – Products Filter Professional for WooCommerce plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via SEO-friendly permalink filter URL segments in versions up to, and including, 1.4.3. This is due to insufficient input sanitization and output escaping in the wp_load_js() function, which reads filter values from the URL path via the url_request extension's parse_url_query() and embeds t...
CVE-2026-22029	6.1	MEDI		0.009	shopify:react-router, shopify:remix-runVreact	React Router is a router for React. In @remix-run/router version prior to 1.23.2 and react-router 7.0.0 through 7.11.0, React Router (and Remix v1/v2) SPA open navigation redirects originating from loaders or actions in Framework Mode, Data Mode, or the unstable RSC modes can result in unsafe URLs causing unintended javascript execution on the client. This is only an issue if you are creating redirect paths from u...
CVE-2026-32773	6.1	MEDI		0.006	apache:spark	There is a lack of XSS escaping in the Spark History Server prior to 3.5.8 which allows a malicious Spark job to generate arbitrary unescaped frontend code which could lead to a minimal privilege escalation in browser. Users are encouraged to upgrade to Spark 3.5.8 or later. This CVE is marked as "low" since the path to exploit requires both relatively high permissions (ability to launch a Spark job) and requires...
CVE-2026-47883	6.1	MEDI		0.002	vmware:spring_framework	UrlHandlerFilter can be vulnerable to an open redirect when configured with very broadly matching patterns. The issue applies to the filter variants in both Spring MVC and Spring WebFlux. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19
CVE-2026-47887	6.1	MEDI		0.002	vmware:spring_framework	A Spring MVC application that uses UriFileNameViewController that is mapped with an end-of-path, and does not have a configured prefix is vulnerable to an open redirect. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.25.RELEASE and earlier
CVE-2026-50980	6.1	MEDI		0.004		Cross-Site Scripting (XSS) vulnerability in the DNS lookup/management component of oPanel before v1.20.25 allows remote attackers to execute arbitrary JavaScript and perform session hijacking via a crafted DNS TXT record
CVE-2026-52232	6.1	MEDI		0.002		A reflected cross-site scripting (XSS) vulnerability in the /logo.asp component of FS Inc S3150-8T2F Switch 2.2.0D Build 118101 allows attackers to execute arbitrary Javascript in the context of the victim's browser via a crafted URL.
CVE-2026-52370	6.1	MEDI		0.002		A reflected cross-site scripting (XSS) vulnerability in the Forum posting function of O2OA v10 allows attackers to execute arbitrary Javascript in the context of the victim's browser via a crafted URL.
CVE-2026-52773	6.1	MEDI		0.005		YesWiki is a wiki system written in PHP. From version 4.1.0 to before version 4.6.6, YesWiki's archived-revision view reflects the time GET parameter into a hidden HTML input in handlers/page/show.php without escaping. Because MySQL coerces malformed DATETIME strings, an attacker can append HTML or JavaScript to a valid archived revision timestamp, still load that archived revision, and execute arbitrary JavaScrip...
CVE-2026-52774	6.1	MEDI		0.005		YesWiki is a wiki system written in PHP. Prior to version 4.6.6, YesWiki's Bazar widget handler reflects the id GET parameter into HTML attributes using strip_tags() only. Because strip_tags() does not escape double quotes, an attacker can break out of the attribute value, inject an event handler such as onmouseover, and execute arbitrary JavaScript in the victim's browser. This issue is reachable without authenti...
CVE-2026-55087	6.1	MEDI		0.005		Etherpad is a real-time collaborative editor. From 2.1.0 until 3.1.0, Etherpad uses the attacker-controlled x-proxy-path request header in src/node/hooks/express/admin.ts when substituting paths into HTML, JavaScript, and CSS under /admin without sanitization, Vary: x-proxy-path, or Cache-Control: private, no-store. A shared proxy or CDN can cache the resulting response and serve attacker-injected script to an adm...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-61526	6.1	MEDI		0.002		AdonisJS HTTP Server is a package for handling HTTP requests in the AdonisJS framework. In versions 8.0.0-next.0 through 8.2.0 and 9.0.0 through 9.0.2, the error.message is interpolated into the default HTML exception response without escaping, allowing a crafted missing-route URL to execute attacker-controlled JavaScript when a victim opens it and no custom status page or JSON response handles the error. When de...
CVE-2026-63670	6.1	MEDI		0.003		ApostropheCMS is an open-source Node.js content management system. Prior to 2.17.6, sanitizeHtml() can pass disallowed executable markup through packages/sanitize-html/index.js when textarea or xmp is included in allowedTags because a literal solidus after the raw-text end-tag name is treated as text by htmlparser2 and the ontext handler emits that content without escaping, while a browser parses the following img...
CVE-2026-71478	6.1	MEDI		0.002		league/commonmark is a PHP library for parsing and rendering CommonMark Markdown. From 1.5.0 until 2.9.0, the AttributesExtension's href and src unsafe-link filter can be bypassed by embedding control bytes, such as a tab, carriage return, line feed, or leading C0 control character, in a javascript: URL that browsers discard before parsing the scheme, causing the browser to still execute the script even when the u...
CVE-2026-73084	6.1	MEDI		0.002		Activepieces is an open source AI workflow automation platform. Prior to 0.83.0, the /api/redirect OAuth callback endpoint embeds the user-supplied code query parameter directly into an inline script block without proper escaping. A crafted request to /api/redirect with a malicious code value can break out of the script context and execute arbitrary JavaScript in the Activepieces origin when a logged-in user opens...
CVE-2026-75170	6.1	MEDI		0.002		Cross-site scripting (XSS) vulnerability in the /loginController/doLogin endpoint of the HubCore platform (version 14.1.1) allows a remote unauthenticated attacker to inject arbitrary JavaScript into the application's response via the language POST parameter.
CVE-2026-76002	6.1	MEDI		0.007		ColdFusion is affected by a reflected Cross-Site Scripting (XSS) vulnerability. If an attacker is able to convince a victim to visit a URL referencing a vulnerable page, malicious JavaScript content may be executed within the context of the victim's browser. Scope is changed.
CVE-2026-79419	6.1	MEDI		0.002		A reflected cross-site scripting (XSS) vulnerability exists in EMX Tecnologia Gestao X Business Suite 8.4 and earlier. The vulnerability is caused by insufficient validation and sanitization of the mensagem parameter in the /Configuracao/Imagens.aspx endpoint, allowing an authenticated attacker to inject arbitrary JavaScript code that is reflected and executed in the context of a victim's browser.
CVE-2026-80180	6.1	MEDI		0.002		Stored XSS via markdown HTML processing in Apache Allura. This issue affects Apache Allura: from through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.
CVE-2026-80190	6.1	MEDI		0.002		Apache Allura: stored XSS via SVN code repositories. Git repositories are not known to be affected. The vulnerability is likely mitigated via default CSP headers. This issue affects Apache Allura: through 1.20.0. Users are recommended to upgrade to version 1.21.0, which fixes the issue.
CVE-2026-84369	6.1	MEDI		0.003		SVGO, short for SVG Optimizer, is a Node.js library and command-line application for optimizing SVG files. From version 1.0.0 until versions 2.8.4, 3.3.5, and 4.1.0, the opt-in removeScripts plugin, named removeScriptElement in versions 2 and 3 and implemented in plugins/removeScripts.js, removes SVG and XHTML script elements but does not inspect executable HTML content inside SVG foreignObject elements. Event-han...
CVE-2026-8447	6.1	MEDI		0.002	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.11.2 suffer from a stored cross-site scripting vulnerability in the Playground chat interface.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85227	6.1	MEDI		0.003	misp-project:misp	MISP contains a reflected Cross-Site Scripting (XSS) vulnerability in the event attribute filtering query builder. The taggedAttributes and galaxyAttachedAttributes URL parameters were inserted into the query-builder rules without HTML escaping before being serialized as JSON and embedded inside a <script> element. Because JsonTool::encode() uses JSON_UNESCAPED_SLASHES, an attacker-controlled value containing a ...
CVE-2026-85229	6.1	MEDI		0.002		** UNSUPPORTED WHEN ASSIGNED ** Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Apache SkyWalking Booster UI. This issue affects Apache SkyWalking UI : from 10.2.0 through 10.4.0. Users are recommended to upgrade to Horizon UI 1.0.0, which fixes the issue.
CVE-2026-85484	6.1	MEDI		0.002		HTML::FormHandler versions before 0.410002 for Perl render option group labels and radio button labels into HTML without escaping. The Select, RadioGroup, CheckboxGroup and HorizCheckboxGroup widgets render a group label unescaped, Select into a label attribute and the other three into element content. RadioGroup also renders each radio button's own label unescaped. Any application whose option list is built fro...
CVE-2026-85485	6.1	MEDI		0.002		HTML::FormHandler versions before 0.410002 for Perl render some error messages into HTML without escaping. The Table form layout and the Bootstrap 2 and 3 wrappers splice each error string straight into the surrounding markup. Version 0.410000, the fix for CVE-2026-19872, escaped the equivalent values in the other layouts and wrappers, and 0.410002 extended that to these three. Error messages that contain attack...
CVE-2026-85630	6.1	MEDI		0.002		HTML::FormHandler versions before 0.410002 for Perl render field attributes into HTML without escaping using the process_attrs method. Any application with fields or field labels where some attributes are built from data rather than literals allows attacker-influenced text in an attribute value that can override the field attributes or embed JavaScript in rendered pages. For example, the RadioGroup widget uses t...
CVE-2026-88023	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB PHP Library can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88024	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Rust Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88025	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C# Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file c...
CVE-2026-88029	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Python Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS fi...
CVE-2026-88030	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Ruby Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88031	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Go Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may cause all GridFS file chunks in the affected bucket to be removed, rendering sto...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88033	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Java Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88034	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C++ Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ...
CVE-2026-88036	6.1	MEDI				Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ch...
CVE-2023-6717	6.0	MEDI		0.007		A flaw was found in the SAML client registration in Keycloak that could allow an administrator to register malicious JavaScript URLs as Assertion Consumer Service POST Binding URLs (ACS), posing a Cross-Site Scripting (XSS) risk. This issue may allow a malicious admin in one realm or a client with registration access to target users in different realms or applications, executing arbitrary JavaScript in their conte...
CVE-2026-0294	6.0	MEDI		0.001	apple:macos, microsoft:windows, paloaltonetworks:prisma_access_agent	A privilege escalation (PE) vulnerability in the Palo Alto Networks Prisma® Access Agent app on Windows and macOS devices enables a local user to execute code with elevated privileges. The Prisma Access Agent on Linux, iOS, Android, and ChromeOS is not affected.
CVE-2026-58139	6.0	MEDI		0.003		The DuckDB AWS extension for DuckDB contains a security policy bypass vulnerability that allows any database user with SQL execution permissions to extract plaintext AWS credentials by calling the load_aws_credentials function with the redact_secret parameter set to false, circumventing the database-wide allow_unredacted_secrets=false policy. Attackers can invoke this single function to retrieve the underlying AWS...
CVE-2026-65985	6.0	MEDI		0.003		FUXA is a web-based Process Visualization (SCADA/HMI/Dashboard) software. In 1.3.2 and earlier, the device-webapi-request Socket.IO handler in server/runtime/index.js permits an authenticated non-admin runtime user to control property.address, causing the FUXA server to issue an outbound HTTP or HTTPS request and return the response body to the requesting socket. The attacker can use the server as a read SSRF orac...
CVE-2026-70603	6.0	MEDI		0.001		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.6, 40.9.0, 41.1.1, and 42.0.0-beta.1, shell.openPath() did not reject paths containing embedded null bytes. Apps that perform string-only validation of file paths, for example checking the file extension, before passing them to shell.openPath() could be bypassed, allowing an attacker-controlled pat...
CVE-2026-78552	6.0	MEDI		0.003		The Okta Access Gateway does not apply its Lua directive restriction to the application-level custom configuration field. The field is interpolated directly into the nginx server block without inspection, resulting in execution of injected directives.
CVE-2026-78622	6.0	MEDI		0.001		The Okta Verify for Windows uninstaller does not verify whether the user data directory is a filesystem junction before deleting its contents with elevated privileges. The delete operation follows the junction target, resulting in recursive deletion of unintended directory contents.
CVE-2026-79780	6.0	MEDI		0.001		rcclone before v1.75.0 fails to sanitize IBM IAM bearer tokens and SSE-C encryption keys during S3 redirect callbacks, allowing credentials to be preserved across scheme or host changes. Attackers observing network traffic from a trusted endpoint can capture reusable IBM IAM tokens on same-host HTTPS-to-HTTP downgrades or SSE-C keys on cross-origin redirects to access protected S3 objects.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82056	6.0	MEDI		0.002		A race condition in MongoDB server's text index query parsing can cause a heap use-after-free read when handling upsert retry paths. Under certain concurrent index lifecycle operations, a raw pointer to internal text index metadata may be dereferenced after the underlying structures have been freed, leading to a server crash. An authenticated user with readWrite privileges can trigger this condition through specif...
CVE-2026-82059	6.0	MEDI		0.003		An internal aggregation expression in MongoDB Server was incorrectly registered as accessible to any authenticated user rather than being restricted to internal cluster operations. By crafting a malformed index specification within this expression, an authenticated user with read-only privileges could trigger an assertion failure in the index key generation code path. In certain build configurations, this assertio...
CVE-2026-82063	6.0	MEDI		0.003		A use-after-free security issue in the cursor management component of MongoDB Server allows an authenticated user to cause a denial of service. Under specific timing conditions during cursor operations, a stale pointer to a freed resource may be retained and subsequently dereferenced during cursor cleanup, leading to a server process crash.
CVE-2017-4971	5.9	MEDI		0.168	broadcom:spring_web_flow	An issue was discovered in Pivotal Spring Web Flow through 2.4.4. Applications that do not change the value of the MvcViewFactoryCreator useSpringBinding property which is disabled by default (i.e., set to 'false') can be vulnerable to malicious EL expressions in view states that process form submissions but do not have a sub-element to declare explicit data binding property mappings.
CVE-2017-8039	5.9	MEDI		0.01	broadcom:spring_web_flow	An issue was discovered in Pivotal Spring Web Flow through 2.4.5. Applications that do not change the value of the MvcViewFactoryCreator useSpringBinding property which is disabled by default (i.e., set to 'false') can be vulnerable to malicious EL expressions in view states that process form submissions but do not have a sub-element to declare explicit data binding property mappings. NOTE: this issue exists becau...
CVE-2026-0307	5.9	MEDI		0.001		Multiple local privilege escalation vulnerabilities in the Palo Alto Networks GlobalProtect™ app allows a local user to escalate their privileges to NT AUTHORITY\SYSTEM on Windows and root on macOS and Linux. This enables a non-administrative user to execute arbitrary commands with administrative privileges. This GlobalProtect app on iOS, Android and ChromeOS is not impacted.
CVE-2026-32637	5.9	MEDI		0.005		Velero is an open source tool for backing up, restoring, and migrating Kubernetes cluster resources and persistent volumes. Prior to 1.18.1, an attacker who compromises the backup object-storage backend can upload a malicious backup tarball containing parent-directory paths that escape the extraction directory during restore and overwrite sensitive files in the Velero pod filesystem. This issue is fixed in version...
CVE-2026-52739	5.9	MEDI		0.004		ZEBRA is a Zcash node written entirely in Rust. Prior to 4.5.0, a malicious block producer can terminate zebra by placing the same shielded transaction in a non-finalized parent block and its child. In zebra-state/src/service/non_finalized_state/chain.rs, Chain::push originally inserted the transaction hash into tx_loc_by_hash and asserted uniqueness before updating shielded data and running the duplicate Sprout,...
CVE-2026-55854	5.9	MEDI		0.003		MariaDB Connector/Node.js is used to connect applications developed on Node.js to MariaDB and MySQL databases. Prior to 3.2.4, 3.3.3, 3.4.6, and 3.5.3, MariaDB Connector/Node.js can disclose an account password when PAM dialog authentication is negotiated over an insecure transport. In lib/cmd/handshake/auth/pam-password-auth.js and lib/cmd/handshake/authentication.js, the SendPamAuthPacketFactory behavior for the...
CVE-2026-55856	5.9	MEDI		0.002		MariaDB Connector/J is used to connect applications developed in Java to MariaDB and MySQL databases. Prior to 2.7.14, 3.3.5, 3.4.3, and 3.5.9, when a Java application connects with sslMode=verify-full or sslMode=verify-ca, supplies a password, and does not configure serverSslCert or trustStore, Connector/J can accept an untrusted self-signed certificate through the fallbackToSystemTrustStore=true ephemeral trust ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55857	5.9	MEDI		0.002		MariaDB Connector/J is used to connect applications developed in Java to MariaDB and MySQL databases. Prior to 2.7.14, 3.3.5, 3.4.3, and 3.5.9, PAM dialog authentication can be coerced into transmitting the account password over an insecure connection. The mysql_clear_password plugin is gated behind a secure transport, but the sibling PAM handler SendPamAuthPacketFactory, named dialog by the server, does not decla...
CVE-2026-55858	5.9	MEDI		0.003		MariaDB Connector/J is used to connect applications developed in Java to MariaDB and MySQL databases. Prior to 2.7.14, 3.3.5, 3.4.3, and 3.5.9, the connector encodes and decodes protocol text and performs client-side escaping under the assumption that the connection character set is UTF-8. The server can report a mid-session change to character_set_client through OK-packet session-state tracking, including a chang...
CVE-2026-55859	5.9	MEDI		0.003		MariaDB Connector/R2DBC is a non-blocking MariaDB and MySQL client implemented in Java. Prior to 1.4.1, org.mariadb:r2dbc-mariadb encodes and decodes all character data under the assumption that the connection character set is UTF-8. A server can announce a mid-session change to character_set_client through the OK-packet session-state-tracking mechanism, including through SET NAMES executed by a stored routine or ...
CVE-2026-55860	5.9	MEDI		0.002		MariaDB Connector/R2DBC is a non-blocking MariaDB and MySQL client implemented in Java. Prior to 1.4.1, org.mariadb:r2dbc-mariadb does not gate clear-text password authentication plugins on transport encryption because the AuthenticationPlugin interface has no capability for a plugin to require a secure connection. A hostile or man-in-the-middle MariaDB server can send an AuthSwitchRequest naming mysql_clear_passw...
CVE-2026-58237	5.9	MEDI		0.002	sap:approuter	WebSocket of SAP Approuter does not perform sufficient authorization checks in certain functionality. An attacker with low privileges could exploit this to access restricted functionality. Successful exploitation could allow the attacker to read sensitive information and perform limited modifications, resulting in a high impact on confidentiality and a low impact on integrity. There is no impact on availability.
CVE-2026-58238	5.9	MEDI		0.003	sap:approuter	SAP Approuter does not sufficiently handle certain requests under specific conditions. An unauthenticated attacker could send specially crafted input that causes the component to crash and restart. Successful exploitation requires specific runtime conditions to be met, making the attack complex to execute. This results in a high impact on availability. There is no impact on confidentiality and integrity.
CVE-2026-66776	5.9	MEDI		0.001	sap:approuter	SAP Approuter does not consistently enforce integrity verification on certain session-related request headers under specific conditions. An attacker with low privileges could send a specially crafted request that bypasses the integrity check and loads another user's session context. Successful exploitation requires the attacker to have previously observed matching session values out-of-band, which makes the attack...
CVE-2026-66777	5.9	MEDI		0.003	sap:approuter	SAP Approuter does not sufficiently validate certain incoming requests before forwarding them to backend destinations. Due to the complexity of the required conditions, an attacker with low privileges could send specially crafted requests to bypass authorization checks and reach protected resources beyond their assigned scope. Successful exploitation could allow the attacker to read sensitive data and perform limi...
CVE-2026-69304	5.9	MEDI		0.008		Improper handling of highly compressed data (data amplification) in ASP.NET Core allows an unauthorized attacker to deny service over a network.
CVE-2026-69382	5.9	MEDI		0.004		Use of a broken or risky cryptographic algorithm in Microsoft Exchange Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-70091	5.9	MEDI		0.007		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows DNS allows an unauthorized attacker to deny service over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70599	5.9	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.7, 40.9.0, 41.2.0, and 42.0.0-beta.1, serial-port and media permission checks made from an iframe passed the top-level frame origin to session.setPermissionCheckHandler instead of the requesting iframe origin. Origin-based handler logic could grant a cross-origin iframe device access intended only ...
CVE-2026-70605	5.9	MEDI		0.003		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, when following HTTP redirects, net.fetch() and net.request() did not restrict which schemes a redirect could target. A remote server could redirect a request to a local resource, and if the app returns or forwards the response body, local file contents could be...
CVE-2026-70606	5.9	MEDI		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 40.10.6, 41.9.1, 42.5.1, and 43.0.0, when a custom protocol handler returned a ProtocolResponse with a url and no session, Electron made the upstream request through defaultSession instead of the session that handled the protocol. A cached response could then be reused across otherwise isolated session ...
CVE-2026-72978	5.9	MEDI		0.008		Allocation of resources without limits or throttling in Active Directory Federation Services (AD FS) allows an unauthorized attacker to deny service over a network.
CVE-2026-78123	5.9	MEDI				strongSwan 5.0.2 through 6.0.7 has an Expired Pointer Dereference in PKCS#7 parsing in the openssl plugin.
CVE-2026-78221	5.9	MEDI		0.001		An incorrect buffer size calculation in the Windows Interactive Service in OpenVPN 2.7_alpha1 through 2.7.6 allows local authenticated users to cause memory corruption or disclose sensitive information via crafted NRPT inputs.
CVE-2026-78620	5.9	MEDI		0.003		The Okta Access Gateway Kerberos configuration handler does not validate file paths specified in event payloads before writing file contents. The path from the event payload is used directly as the write destination, resulting in files being written to unintended locations on the appliance filesystem.
CVE-2026-84185	5.9	MEDI		0.001		A flaw was found in the jwcrypto library, which is used for implementing Javascript Object Signing and Encryption (JOSE) standards. The issue occurs when the library verifies a General JSON Serialization JWS using a set of keys. Due to a coding error, the library fails to correctly identify the specific key ID (kid) and may instead accept a signature made by any valid key in the set. This can allow an attacker wit...
CVE-2026-84363	5.9	MEDI		0.003		Hono is a Web application framework that provides support for any JavaScript runtime. Prior to 4.13.5, Hono's query helpers treat a question mark after a literal hash fragment as the start of a query string, so the application can read request parameters that browsers, new URL(), reverse proxies, filtering rules, parameter allow and deny lists, access logging, request validation, and other middleware do not observ...
CVE-2026-84378	5.9	MEDI		0.003		HTTPX2 is a next generation HTTP client for Python. From 2.5.0 until 2.10.0, the HTTPX2 Server-Sent Events parser in src/httpx2/httpx2/_sse.py repeatedly copies and rescans buffered text in _SSELineDecoder.decode() when an attacker-controlled or compromised SSE endpoint splits one unterminated line across many response chunks. The behavior affects httpx2.Client.sse() and httpx2.AsyncClient.sse(), and the total pro...
CVE-2026-84970	5.9	MEDI		0.001	mongodb:c\+\+_driver	A numeric truncation weakness exists in the JSON parsing component of the MongoDB C++ Driver's BSON library. An actor who controls the text that an embedding application hands to the library's public JSON parsing interface, when that text is very large, can cause the library to read memory beyond the supplied buffer and return it to the caller, to silently accept only part of the input as a complete document, or t...
CVE-2026-85014	5.9	MEDI		0.004		undici's experimental WebSocketStream client crashes the whole Node.js process when a remote peer closes the TCP connection without a WebSocket close handshake. On an unclean close the internal socket-close handler calls abort on the writable stream unconditionally and discards the returned promise, but per the WHATWG Streams standard aborting a locked writable returns a promise that rejects with a TypeError. Beca...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85024	5.9	MEDI		0.003		undici bundles a WebSocket client whose permessage-deflate size-limit cleanup removes all listeners from the internal zlib inflate stream, including its error listener, while that stream can still emit. When a remote peer sends a compressed payload that crosses the built-in 128 MiB decompressed-payload limit and then contains a malformed DEFLATE byte, the inflate stream emits a data error with no listener attached...
CVE-2026-87123	5.9	MEDI				hbs is an Express view engine wrapper for Handlebars. Version 4.3.0 can crash the Node.js process during output escaping when an async helper, registered with registerAsyncHelper, resolves to an object whose toHTML property is truthy but not callable. Handlebars escapeExpression calls the toHTML method on any value that has a truthy toHTML, so such a value throws a TypeError, and because the async substitution run...
CVE-2026-88763	5.9	MEDI		0.003		A flaw was found in the skupper-router component of Red Hat Service Interconnect, which is used to provide secure communication between distributed services. The issue occurs when the router processes a specially crafted network message using its AMQP field parser. Due to a lack of bounds on recursion during parsing, the router can run out of stack memory and crash, leading to a denial of service for the interconn...
CVE-2026-9036	5.9	MEDI		0.001	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 does not validate or improperly validates TLS certificate validation, which could allow an attacker to obtain sensitive information using man in the middle techniques.
CVE-2026-9744	5.9	MEDI		0.001	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 does not validate or improperly validates TLS certificate validation, which could allow an attacker to obtain sensitive information using man in the middle techniques.
CVE-2026-0306	5.8	MEDI		0.001		A vulnerability in the EndPoint Data Loss Prevention (DLP) enforcement of Palo Alto Networks Prisma® Access Agent enables a local user to bypass configured DLP policy enforcement controls and exfiltrate sensitive data. This Prisma Access Agent on macOS, Linux, iOS, Android and Chrome OS is not affected.
CVE-2026-69129	5.8	MEDI		0.002		KubePi is a Kubernetes multi-cluster management panel. In versions up to and including 2.0.0, cluster-scoped APIs do not consistently validate per-cluster access, allowing an authenticated user with cluster management permissions to operate on clusters outside the scope they were granted. Because the affected endpoints act on cluster-specific data without confirming that the requesting user is authorized for that ...
CVE-2026-69559	5.8	MEDI		0.003		Origin validation error in Microsoft Teams for Android allows an authorized attacker to disclose information over a network.
CVE-2026-72764	5.8	MEDI		0.004		n8n's JavaScript task runner shared a single module cache across all users' Code-node executions. In affected versions (before 1.123.67, 2.31.5, and 2.32.1), a user able to run a Code node could poison a cached module and thereby alter other users' Code-node executions on the same runner, affecting their confidentiality, integrity, or availability. This is a cross-user isolation break within a single n8n instance ...
CVE-2026-73243	5.8	MEDI		0.004		kkFileView is a universal file online preview project based on Spring Boot. Prior to 5.0.1, the unauthenticated GET /addTask endpoint in kkFileView is omitted from TrustHostFilter and TrustDirFilter in server/src/main/java/cn/keking/config/WebConfig.java, allowing FileConvertQueueTask to fetch an attacker-selected URL after FileHandlerService#getFileAttribute uses the fullfilename parameter to force an OFFICE, COM...
CVE-2026-74866	5.8	MEDI		0.002	fastify:fastifyV/busyboy	@fastify/busboy is a multipart form-data parser for Node.js. Its multipart part-header parser splits header lines only on the two-byte carriage-return line-feed sequence, so a lone carriage return or line feed embedded in a part header is not treated as a line break and is carried verbatim into the parsed Content-Disposition filename and field name handed to the application. An attacker who uploads a file whose fi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84193	5.8	MEDI		0.003		LibreNMS through 26.2.0 contains a stored cross-site scripting vulnerability in legacy PHP template pages that render unescaped SNMP-sourced data fields including BGP peer descriptions, VRF names, process information, and SLA tags. Attackers with device management access or network access to enroll a rogue SNMP device can inject malicious JavaScript that executes when admins view affected routing and device pages,...
CVE-2026-16180	5.7	MEDI		0.002	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 Toolkit could allow an authenticated user to cause a denial-of-service condition due to improper validation of XML entities.
CVE-2026-67550	5.7	MEDI		0.001		re2 provides Node.js bindings for Google's RE2 regular expression engine. Prior to 1.25.2, re2 validates lastIndex against the UTF-8 byte length of a subject but uses it as a UTF-16 code-unit offset in exec, test, match, replace, and split, allowing an attacker-influenced lastIndex on a non-ASCII subject to trigger an out-of-bounds heap read and an uncatchable process crash, with limited heap information disclosur...
CVE-2026-68874	5.7	MEDI		0.008		Out-of-bounds read in Windows Program Compatibility Assistant Service allows an authorized attacker to disclose information over a network.
CVE-2026-69349	5.7	MEDI		0.008		Use of uninitialized resource in Windows Management Instrumentation allows an authorized attacker to disclose information over a network.
CVE-2026-69372	5.7	MEDI		0.008		Out-of-bounds read in Windows Network File System allows an authorized attacker to deny service over a network.
CVE-2026-69393	5.7	MEDI		0.008		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information over a network.
CVE-2026-69405	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69416	5.7	MEDI		0.006		Buffer over-read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69507	5.7	MEDI		0.008		Insertion of sensitive information into externally-accessible file or directory in Microsoft Windows Search Component allows an authorized attacker to disclose information over a network.
CVE-2026-69552	5.7	MEDI		0.009		Generation of error message containing sensitive information in Windows Print Spooler Components allows an authorized attacker to disclose information over a network.
CVE-2026-69569	5.7	MEDI		0.009		Untrusted pointer dereference in Windows Print Spooler Components allows an authorized attacker to deny service over a network.
CVE-2026-69572	5.7	MEDI		0.009		Out-of-bounds read in Windows SMB Client allows an authorized attacker to disclose information over a network.
CVE-2026-69591	5.7	MEDI		0.009		Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69637	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69679	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69723	5.7	MEDI		0.01		Exposure of sensitive system information to an unauthorized control sphere in Windows Kernel allows an authorized attacker to disclose information over a network.
CVE-2026-70609	5.7	MEDI		0.004		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.7, 40.9.0, 41.2.0, and 42.0.0-beta.1, the mode option of webContents.openDevTools() was not sanitized before use by the DevTools frontend. If an attacker can influence this value, script under their control may run in the DevTools context, which in unsandboxed configurations has access to Node.js, ...
CVE-2026-85788	5.7	MEDI		0.001		Incomplete list of disallowed inputs in the mutable SQL detector component in Amazon awslabs mysql-mcp-server might allow context-dependent actors to bypass the read-only enforcement gate and reach file-read and file-write SQL sinks via SQL inline comments that the regex engine does not treat as whitespace. To remediate this issue, users should upgrade to version 1.0.23.
CVE-2026-88035	5.7	MEDI				A size check in the client-side authentication path of the MongoDB C Driver can wrap around, so an unusually large user-name value is accepted and copied past the end of a small buffer. A party able to set the driver's connection settings may cause the application that embeds the driver to terminate unexpectedly. Reaching this code requires a build in which the optional external SASL authentication backend is pres...
CVE-2026-0293	5.6	MEDI		0.001	microsoft:windows, paloaltonetwork s:prisma_access_agent	A vulnerability in Palo Alto Networks Prisma® Access Agent on Windows enables a local attacker with administrator privileges to bypass the anti-tamper protection, enabling unauthorized access to protected processes and files. The Prisma Access Agent on Linux, macOS, iOS, Android, and Chrome OS is not affected.
CVE-2026-69832	5.6	MEDI		0.004		Exposure of sensitive system information to an unauthorized control sphere in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-73647	5.6	MEDI		0.004		Quasar Framework is a framework for building high-performance Vue.js user interfaces. Prior to 2.22.0, the public extend() utility in ui/src/utls/extend/extend.js recursively copied attacker-controlled object keys during extend(true, target, source) deep merges without rejecting an own __proto__ property. The merge could descend into the prototype object and write attacker-controlled properties to Object.prototype...
CVE-2026-78043	5.6	MEDI		0.002		The Windows Interactive Service in OpenVPN 2.7_alpha1 through 2.7.6 allows local authenticated users to bypass the trusted configuration directory constraint and load arbitrary configuration files via specially crafted paths
CVE-2026-78629	5.6	MEDI		0.001		The Okta Hyperdrive agent plugin returns a success response without a signed SAML assertion when the organization's policy requires no MFA for a given user. The response contains only a bare boolean validation indicator with no cryptographic artifact, resulting in an unverifiable authentication verdict being delivered to the relying application.
CVE-2026-81830	5.6	MEDI		0.001		The Windows interactive service in OpenVPN 2.4.0 through 2.6.22 allows local authenticated users to bypass the trusted configuration directory constraint via incorrect file path validation

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83557	5.6	MEDI		0.006		DefaultBaseTypeLimitingValidator is the PolymorphicTypeValidator applied automatically whenever @JsonTypeInfo is used without an explicitly configured custom validator. It denies polymorphic resolution only for a fixed set of "unsafe base types", and its isSafeSubType method returns true unconditionally for every base type outside that set. java.lang.Comparable was absent from the list despite being implemented by...
CVE-2026-84380	5.6	MEDI		0.002		HTTPX2 is a next generation HTTP client for Python. Prior to 2.11.0, Request._prepare() in src/httpx2/httpx2/_models.py can add a body-derived Content-Length header to a request that already contains a caller-supplied Transfer-Encoding header because its setdefault() processing checks each default header independently rather than treating the two framing headers as mutually exclusive. Fixed-size byte, JSON, form, ...
CVE-2025-48651	5.5	MEDI		0.001	google:android	In importWrappedKey of KMKeymasterApplet.java, there is a possible way access keys that should be restricted due to improper input validation. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2025-51619	5.5	MEDI		0.001		A vulnerability in the Thesycon DPC Latency Checker driver (dpc.sys) thru 1.4.0 allows local unprivileged users to cause a denial-of-service (BSOD) condition on Windows systems. The driver exposes an IOCTL interface (0x81772008) that accepts user-controlled input without validating pointers before passing them to kernel APIs. Specifically, it dereferences a user-supplied pointer and uses the resulting value in a c...
CVE-2026-0636	5.5	MEDI		0.005		Improper neutralization of special elements used in an LDAP query ('LDAP injection') vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcprov on all (prov modules). This vulnerability is associated with program files LDAPStoreHelper. This issue affects BC-JAVA: from 1.74 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.
CVE-2026-16689	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to obtain sensitive information due to improper logging of credentials.
CVE-2026-17270	5.5	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to cause a denial of service due to a stack-based buffer overflow.
CVE-2026-17440	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to cause a denial of service due to uncontrolled recursion.
CVE-2026-17442	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to obtain sensitive information due to credentials being written to trace logs in cleartext.
CVE-2026-17469	5.5	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local authenticated attacker to cause a denial of service due to an off-by-one write in the LPD queue name parser.
CVE-2026-18622	5.5	MEDI		0.001	apple:macos, foxit:pdf_editor, foxit:pdf_reader, microsoft:windows	Foxit PDF Editor/Reader inconsistently alerts users when signature fields are abnormally modified, including alterations to appearance, coordinates, or field duplication. This may mislead users into trusting tampered documents, since the UI cannot accurately reflect the actual integrity status of signatures.
CVE-2026-18858	5.5	MEDI		0.001	ibm:i	IBM i 7.6, and 7.5 could allow a local authenticated attacker to obtain information from a privileged file when using SSH.
CVE-2026-19649	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to obtain sensitive information due to improper logging of database credentials.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-24049	5.5	MEDI		0.003	wheel_project:wheel	wheel is a command line tool for manipulating Python wheel files, as defined in PEP 427. In versions 0.40.0 through 0.46.1, the unpack function is vulnerable to file permission modification through mishandling of file permissions after extraction. The logic blindly trusts the filename from the archive header for the chmod operation, even though the extraction process itself might have sanitized the path. Attackers...
CVE-2026-28584	5.5	MEDI		0.001		In createSessionInternal of PackageInstallerService.java, there is a possible way to permanently DoS the device due to a logic error in the code. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28596	5.5	MEDI		0.001		In parseInterventionFromXml of GameManagerService.java, there is a possible permanent denial of service due to resource exhaustion. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28617	5.5	MEDI		0.001		In add of WifiNetworkSuggestionsManager.java, there is a possible persistent DOS due to resource exhaustion. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28633	5.5	MEDI		0.001		In initForUserNoTracing of VoiceInteractionManagerService.java, there is a possible persistent denial of service due to resource exhaustion. This could lead to local denial of service with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-32591	5.5	MEDI		0.003	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay's Proxy Cache configuration feature. When an organization administrator configures an upstream registry for proxy caching, Quay makes a network connection to the specified registry hostname without verifying that it points to a legitimate external service. An attacker with organization administrator privileges could supply a crafted hostname to force the Quay server to make request...
CVE-2026-45376	5.5	MEDI		0.003		Decidim is a participatory democracy framework. Prior to 0.30.9, from 0.31.0 before 0.31.5, and in 0.32.0.rc1 before 0.32.0.rc2, the GET /admin/organization/users search interpolates params[:term] into raw Arel.sql ORDER BY similarity expressions before sanitization, allowing an authenticated organization administrator to execute blind PostgreSQL expressions and infer data through timing differences. This issue is...
CVE-2026-49831	5.5	MEDI		0.003		DSpace open source software is a repository application which provides durable access to digital resources. Prior to versions 7.6.7, 8.4, 9.3, and 10.0, the Curation Task feature allows an output path to be used by the reporter (-r parameter), typically used to stream results and status of curation task operations. It is not restricted to any particular base path, meaning that any path writable by the DSpace (ofte...
CVE-2026-49833	5.5	MEDI		0.003		DSpace open source software is a repository application which provides durable access to digital resources. From versions 8.0-rc1 to before 8.4, 9.0-rc1 to before 9.3, and 10-rc1 to before 10.0, a path traversal vulnerability is possible via the COAR Notify / LDN service in DSpace. The attacker MUST already have DSpace administrator credentials in order to perform the attack. When reading a file input stream of an...
CVE-2026-54422	5.5	MEDI		0.001		In OpenStack Ironic Python Agent through 11.5.0, a malicious bootc container, when deployed using ironic-python-agent, may be able to extract the credentials used to download it.
CVE-2026-63004	5.5	MEDI		0.003		Unleash is an open-source feature management platform. Prior to 7.5.2, 7.6.5, and 8.0.2, the addon and integration subsystem passes the operator-controlled parameters.url value from src/lib/addons/webhook.ts and the Slack, Microsoft Teams, Datadog, and New Relic integrations to Addon.fetchRetry in src/lib/addons/addon.ts without restricting loopback, link-local, private, or cloud metadata addresses. An authenticat...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-64369	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: s390: Revert support for DCACHE_WORD_ACCESS load_unaligned_zeropad() reads eight bytes from unaligned addresses and may cross page boundaries. It handles exceptions which may happen if reading from the second page results in an exception. For pages which are donated to the Ultravisor for secure execution purposes the do_secure_storage_access() ...
CVE-2026-64370	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: posix-cpu-timers: Fix pid refcount leak in do_cpu_nanosleep() error path In do_cpu_nanosleep(), posix_cpu_timer_create() takes a pid reference via get_pid() and stores it in timer.it.cpu.pid. If the subsequent posix_cpu_timer_set() call fails, the function returns immediately without calling posix_cpu_timer_del() to release the pid reference, ca...
CVE-2026-64371	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: proc: protect ptrace_may_access() with exec_update_lock (part 1) Fix the easy cases where procfs currently calls ptrace_may_access() without exec_update_lock protection, where the fix is to simply add the extra lock or use mm_access(): - do_task_stat(): grab exec_update_lock - proc_pid_wchan(): grab exec_update_lock - proc_map_files_lookup()...
CVE-2026-64376	5.5	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: firmware_loader: fix device reference leak in firmware_upload_register() firmware_upload_register() -> fw_create_instance() -> device_initialize() After fw_create_instance() succeeds, the lifetime of the embedded struct device is expected to be managed through the device core reference counting, since fw_create_instance() has already cal...
CVE-2026-68514	5.5	MEDI		0.002		OpenEXR is the reference implementation and specification for the EXR image file format, widely used in the motion picture industry. In versions 3.3.0 through 3.3.12 and 3.4.0 through 3.4.13, the PyOpenEXR Python bindings contain a heap out-of-bounds write triggered when reading a crafted deep scanline EXR file. When a deep file declares a literal channel named left alongside layer-prefixed RGB channels left.R, le...
CVE-2026-68830	5.5	MEDI		0.003		Improper link resolution before file access ('link following') in Windows Universal Plug and Play (UPnP) Device Host allows an authorized attacker to disclose information locally.
CVE-2026-68831	5.5	MEDI		0.003		Files or directories accessible to external parties in Windows Defender Firewall Service allows an authorized attacker to disclose information locally.
CVE-2026-68842	5.5	MEDI		0.004		Exposure of sensitive system information to an unauthorized control sphere in Windows MIDI Service Module allows an authorized attacker to disclose information locally.
CVE-2026-68843	5.5	MEDI		0.003		Use after free in Microsoft Office Word allows an authorized attacker to disclose information locally.
CVE-2026-68851	5.5	MEDI		0.003		Buffer over-read in Windows NTFS allows an authorized attacker to disclose information locally.
CVE-2026-68852	5.5	MEDI		0.003		Use of uninitialized resource in Microsoft Account allows an authorized attacker to disclose information locally.
CVE-2026-68873	5.5	MEDI		0.005		Insertion of sensitive information into log file in Windows Program Compatibility Assistant Service allows an authorized attacker to disclose information locally.
CVE-2026-68881	5.5	MEDI		0.003		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-68886	5.5	MEDI		0.005		Use after free in Windows Network Connection Broker allows an authorized attacker to disclose information locally.
CVE-2026-69286	5.5	MEDI		0.004		Out-of-bounds read in Windows USB Audio Class driver (usbaudio.sys) allows an authorized attacker to disclose information locally.
CVE-2026-69288	5.5	MEDI		0.003		Use of uninitialized resource in Windows GDI+ allows an authorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69294	5.5	MEDI		0.003		Generation of error message containing sensitive information in Microsoft COM for Windows allows an authorized attacker to disclose information locally.
CVE-2026-69308	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69315	5.5	MEDI		0.005		Exposure of sensitive system information to an unauthorized control sphere in Windows License Manager allows an authorized attacker to disclose information locally.
CVE-2026-69318	5.5	MEDI		0.004		Out-of-bounds read in Windows Imaging Component allows an authorized attacker to disclose information locally.
CVE-2026-69321	5.5	MEDI		0.003		Missing authentication for critical function in Windows Power Dependency Coordinator allows an authorized attacker to perform tampering locally.
CVE-2026-69339	5.5	MEDI		0.005		Exposure of sensitive system information to an unauthorized control sphere in Windows MIDI Service Module allows an authorized attacker to disclose information locally.
CVE-2026-69343	5.5	MEDI		0.004		Out-of-bounds read in Windows Overlay Filter allows an authorized attacker to disclose information locally.
CVE-2026-69344	5.5	MEDI		0.004		Out-of-bounds read in Windows Print Spooler Components allows an authorized attacker to disclose information locally.
CVE-2026-69345	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69351	5.5	MEDI		0.005		Exposure of private personal information to an unauthorized actor in Windows Universal Plug and Play (UPnP) Device Host allows an authorized attacker to disclose information locally.
CVE-2026-69353	5.5	MEDI		0.004		Out-of-bounds read in Windows Text Shaping allows an authorized attacker to disclose information locally.
CVE-2026-69367	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69369	5.5	MEDI		0.003		Out-of-bounds read in Windows DNS allows an authorized attacker to disclose information locally.
CVE-2026-69376	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69390	5.5	MEDI		0.004		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-69403	5.5	MEDI		0.003		Missing authorization in Windows SMB Server allows an authorized attacker to disclose information locally.
CVE-2026-69406	5.5	MEDI		0.005		Exposure of sensitive system information to an unauthorized control sphere in Windows Kernel allows an authorized attacker to disclose information locally.
CVE-2026-69453	5.5	MEDI		0.003		Missing authorization in Microsoft Windows Search Component allows an authorized attacker to perform tampering locally.
CVE-2026-69457	5.5	MEDI		0.004		Out-of-bounds read in Windows USB Driver allows an authorized attacker to disclose information locally.
CVE-2026-69504	5.5	MEDI		0.004		Out-of-bounds read in Windows NTFS allows an authorized attacker to disclose information locally.
CVE-2026-69527	5.5	MEDI		0.004		Out-of-bounds read in Windows USB Mass Storage Class Driver allows an authorized attacker to disclose information locally.
CVE-2026-69531	5.5	MEDI		0.003		Unintended proxy or intermediary ('confused deputy') in Microsoft Windows Speech allows an authorized attacker to perform tampering locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69554	5.5	MEDI		0.003		Missing authentication for critical function in Microsoft Windows Search Component allows an authorized attacker to perform tampering locally.
CVE-2026-69568	5.5	MEDI		0.004		Out-of-bounds read in Windows Storage Spaces Controller allows an authorized attacker to disclose information locally.
CVE-2026-69609	5.5	MEDI		0.004		Out-of-bounds read in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69616	5.5	MEDI		0.004		Out-of-bounds read in Windows Remote Desktop Services allows an authorized attacker to disclose information locally.
CVE-2026-69618	5.5	MEDI		0.004		Out-of-bounds read in Windows SMB Client allows an authorized attacker to disclose information locally.
CVE-2026-69627	5.5	MEDI		0.004		Out-of-bounds read in Windows Remote Desktop Licensing Service allows an authorized attacker to disclose information locally.
CVE-2026-69672	5.5	MEDI		0.004		Use of uninitialized resource in Windows DNS allows an authorized attacker to disclose information locally.
CVE-2026-69674	5.5	MEDI		0.003		Missing authentication for critical function in Windows Modern Device Management (MDM) allows an authorized attacker to bypass a security feature locally.
CVE-2026-69684	5.5	MEDI		0.005		Generation of error message containing sensitive information in Windows Error Reporting allows an authorized attacker to disclose information locally.
CVE-2026-69741	5.5	MEDI		0.004		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-69770	5.5	MEDI		0.004		Use of uninitialized resource in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-69794	5.5	MEDI		0.004		Buffer over-read in Windows Encrypting File System (EFS) allows an authorized attacker to disclose information locally.
CVE-2026-69808	5.5	MEDI		0.004		Out-of-bounds read in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69862	5.5	MEDI		0.005		Out-of-bounds read in Windows Wireless Wide Area Network Service allows an authorized attacker to disclose information locally.
CVE-2026-70145	5.5	MEDI		0.004		Out-of-bounds read in Microsoft Windows Search Component allows an authorized attacker to disclose information locally.
CVE-2026-70290	5.5	MEDI		0.004		Use of uninitialized resource in Windows Win32 Kernel Subsystem allows an authorized attacker to disclose information locally.
CVE-2026-70592	5.5	MEDI		0.003		Ghost is a Node.js content management system. From 1.20.1 until 6.54.1, an Administrator-level user could remotely overwrite certain files on the filesystem through the database backup filename, leading to integrity and availability issues. The database export endpoint failed to reject path separators in the caller-supplied filename. This issue is fixed in version 6.54.1.
CVE-2026-71341	5.5	MEDI		0.004		Out-of-bounds read in Windows Partition Management Driver allows an authorized attacker to disclose information locally.
CVE-2026-71441	5.5	MEDI		0.002	adobe:illustrator, apple:macos, microsoft:windows	Illustrator is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72945	5.5	MEDI		0.004		Use of uninitialized resource in Windows Task Scheduler allows an authorized attacker to disclose information locally.
CVE-2026-72964	5.5	MEDI		0.003		Missing authentication for critical function in Windows Internet Connection Sharing (ICS) allows an authorized attacker to perform tampering locally.
CVE-2026-72966	5.5	MEDI		0.003		Missing authorization in Windows Remote Access Connection Manager allows an authorized attacker to perform tampering locally.
CVE-2026-73004	5.5	MEDI		0.002		Missing authentication for critical function in Windows Autopilot allows an authorized attacker to perform tampering locally.
CVE-2026-73008	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of private personal information to an unauthorized actor in Windows Biometric Service allows an authorized attacker to disclose information locally.
CVE-2026-73973	5.5	MEDI		0.003		Linuxfabrik Monitoring Plugins provides monitoring plugins for Icinga, Nagios, and related systems. Prior to version 7.0.0, check-plugins/logfile/logfile accepted a free-form --filename path and opened it as root when invoked through the shipped nagios or icinga sudoers allowlist, without confining the resolved path to /var/log. An attacker who controls the monitoring account can select a root-readable file such a...
CVE-2026-73974	5.5	MEDI		0.002		linuxfabrik-lib provides Python modules for database access, caching, shell execution, and API integrations, and Linuxfabrik Monitoring Plugins uses its shared testing helper across check plugins. Prior to linuxfabrik-lib 6.1.0 and Linuxfabrik Monitoring Plugins 7.0.0, lib.lftest.test() treated the first or second element of a --test CSV argument as a filesystem path and returned the file contents as simulated sta...
CVE-2026-77491	5.5	MEDI		0.004		Out-of-bounds read in Windows GDI allows an unauthorized attacker to disclose information locally.
CVE-2026-78454	5.5	MEDI		0.004		Out-of-bounds read in Windows CD-ROM Driver allows an authorized attacker to disclose information locally.
CVE-2026-78506	5.5	MEDI		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Improper null termination in Microsoft Office Word allows an unauthorized attacker to disclose information locally.
CVE-2026-78513	5.5	MEDI		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information locally.
CVE-2026-79910	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-80160	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80162	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81387	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Exposure of sensitive system information to an unauthorized control sphere in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81390	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81391	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use of uninitialized resource in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81392	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81393	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81394	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Exposure of sensitive system information to an unauthorized control sphere in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81395	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81399	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Buffer over-read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81400	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81401	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Access of resource using incompatible type ('type confusion') in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81958	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use of uninitialized resource in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81977	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Integer Underflow (Wrap or Wraparound) vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81978	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81982	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81984	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Use After Free vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81991	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an out-of-bounds read vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-81993	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by a Heap-based Buffer Overflow vulnerability that could lead to disclosure of sensitive memory. An attacker could leverage this vulnerability to disclose sensitive information. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-82001	5.5	MEDI		0.002	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Uncontrolled Resource Consumption vulnerability that could lead to application denial-of-service. An attacker could exploit this vulnerability to exhaust system resources, resulting in an application denial-of-service condition. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-83501	5.5	MEDI		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Out-of-bounds read in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to disclose information locally.
CVE-2026-83949	5.5	MEDI		0.004	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Buffer over-read in Microsoft Office Word allows an unauthorized attacker to disclose information locally.
CVE-2026-83951	5.5	MEDI		0.004	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:word	Buffer over-read in Microsoft Office Word allows an unauthorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83991	5.5	MEDI		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Missing authentication for critical function in Windows Cloud Files Mini Filter Driver allows an authorized attacker to perform tampering locally.
CVE-2026-85875	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-86213	5.5	MEDI		0.003		A vulnerability was found in Mstfakts College-Management-System. This issue affects the function mysqli_query of the file Front-end/university.php of the component Search Handler. The manipulation of the argument book_name/book_author results in sql injection. The attack may be performed from remote. The exploit has been made public and could be used. This product utilizes a rolling release system for continuous d...
CVE-2026-86220	5.5	MEDI		0.003		A vulnerability was detected in SourceCodester Class and Exam Timetabling System 1.0. The affected element is the function mysqli_query of the file /admin/modal_add_course.php. The manipulation of the argument course results in sql injection. The attack can be launched remotely. The exploit is now public and may be used.
CVE-2026-86221	5.5	MEDI		0.003		A flaw has been found in SourceCodester Class and Exam Timetabling System 1.0. The impacted element is the function mysqli_query of the file /admin/modal_add_course1.php. This manipulation of the argument course causes sql injection. The attack may be initiated remotely. The exploit has been published and may be used.
CVE-2026-86222	5.5	MEDI		0.003		A vulnerability has been found in SourceCodester Class and Exam Timetabling System 1.0. This affects the function mysqli_query of the file /admin/modal_add_course2.php. Such manipulation of the argument course leads to sql injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-86223	5.5	MEDI		0.003		A vulnerability was found in SourceCodester Class and Exam Timetabling System 1.0. This impacts the function mysqli_query of the file /admin/modal_add_coursea.php. Performing a manipulation of the argument course results in sql injection. Remote exploitation of the attack is possible. The exploit has been made public and could be used.
CVE-2026-86224	5.5	MEDI		0.003		A vulnerability was determined in SourceCodester Class and Exam Timetabling System 1.0. Affected is the function mysqli_query of the file /admin/modal_add_product.php. Executing a manipulation of the argument fname can lead to sql injection. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-86225	5.5	MEDI		0.003		A vulnerability was identified in SourceCodester Class and Exam Timetabling System 1.0. Affected by this vulnerability is the function mysqli_query of the file /admin/modal_add_room.php. The manipulation of the argument room_name leads to sql injection. The attack is possible to be carried out remotely. The exploit is publicly available and might be used.
CVE-2026-86260	5.5	MEDI		0.004		A security flaw has been discovered in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. The affected element is the function modifyPassWord of the file ssm_pro/src/main/java/cn/sfturing/web/CommonUserController.java of the component Password Recovery. Performing a manipulation results in unverified password change. Remote exploitation of the attack is possible. The exploit has been released to t...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86261	5.5	MEDI		0.004		A weakness has been identified in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. The impacted element is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Controller. Executing a manipulation of the argument userIdenf can lead to authorization bypass. The attack can be executed remotely. The exploit has been made available to the ...
CVE-2026-86262	5.5	MEDI		0.004		A security vulnerability has been detected in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This affects the function updateOrderSta1/updateOrderdiseaseInfo of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Handler. The manipulation of the argument userID/id leads to authorization bypass. The attack is possible to be carried out remotely. The exploi...
CVE-2026-86263	5.5	MEDI		0.004		A vulnerability was detected in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This impacts the function orderRecordsService.cancelOrder of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Cancellation. The manipulation of the argument ID results in authorization bypass. The attack may be performed from remote. The exploit is now public and may be used...
CVE-2026-86273	5.5	MEDI		0.003		A weakness has been identified in projeto-siga siga up to 11.1.1. Affected by this issue is the function DownloadExterno.getUrl of the file sigaex/src/main/java/br/gov/jfrj/siga/vraptor/ExUtilController.java of the component HTML-to-PDF Endpoint. This manipulation of the argument html causes server-side request forgery. The attack may be initiated remotely. The exploit has been made available to the public and cou...
CVE-2026-86274	5.5	MEDI		0.004		A security vulnerability has been detected in projeto-siga siga up to 11.0.2.10/11.0.2.13/11.1.1. This affects the function ExAutenticacaoController.autenticar of the file sigaex/src/main/java/br/gov/jfrj/siga/vraptor/ExAutenticacaoController.java of the component Authentication Flow. Such manipulation of the argument cod/jwt leads to missing authorization. The attack may be launched remotely. The exploit has been...
CVE-2026-86282	5.5	MEDI		0.003		A weakness has been identified in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddf3ee02d1632a70a9a132. Affected is an unknown function of the file travel/src/main/java/com/controller/CommonController.java of the component CommonDao. Executing a manipulation of the argument table/column/xColumn/yColumn can lead to sql injection. The attack can be launched remotely. The exploit has been made avai...
CVE-2026-86284	5.5	MEDI		0.003		A security vulnerability has been detected in jaychouchannel Tourism-Management-System up to 8122bf020d91199eddf3ee02d1632a70a9a132. Affected by this vulnerability is the function getOption of the file travel/src/main/java/com/controller/CommonController.java. The manipulation of the argument tableName/columnName leads to information disclosure. The attack may be initiated remotely. The exploit has been disclose...
CVE-2026-86318	5.5	MEDI		0.004		A flaw has been found in java-json-tools json-patch up to 1.13. Affected is the function JsonMergePatch.fromJson of the file JsonMergePatchDeserializer.java. Executing a manipulation can lead to stack-based buffer overflow. The attack may be performed from remote. The exploit has been published and may be used. The project was informed of the problem early through an issue report but has not responded yet.
CVE-2026-86319	5.5	MEDI		0.004		A vulnerability has been found in java-json-tools json-patch up to 1.13. Affected by this vulnerability is the function JsonPatch.apply of the file src/main/java/com/github/fge/jsonpatch/JsonPatch.java of the component Patch Operation Handler. The manipulation leads to resource consumption. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The project was...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86321	5.5	MEDI		0.004		A vulnerability was found in java-json-tools jackson-coreutils 2.0. Affected by this issue is the function JsonLoader.fromURL of the file src/main/java/com/github/fge/jackson/JsonLoader.java of the component URL Validation. The manipulation results in server-side request forgery. It is possible to launch the attack remotely. The exploit has been made public and could be used. The project was informed of the proble...
CVE-2026-86511	5.5	MEDI		0.004		A vulnerability was found in java-json-tools jackson-coreutils 2.0. Affected by this vulnerability is the function BigDecimal.toPlainString of the file src/main/java/com/github/fge/jackson/JacksonUtils.java. Performing a manipulation results in resource consumption. The attack may be initiated remotely. The exploit has been made public and could be used. The project was informed of the problem early through an iss...
CVE-2026-86513	5.5	MEDI		0.004		A security flaw has been discovered in java-json-tools jackson-coreutils 2.0. This vulnerability affects the function TreePointer.tokensFromInput of the file src/main/java/com/github/fge/jackson/jsonpointer/TreePointer.java of the component JSON Pointer parser. The manipulation results in allocation of resources. The attack can be executed remotely. The exploit has been released to the public and may be used for a...
CVE-2026-86672	5.5	MEDI		0.003		A vulnerability has been found in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected is an unknown function of the file example.7z of the component Backup Handler. The manipulation leads to information disclosure. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used. Continious delivery with rolling releases is used by this pr...
CVE-2026-86673	5.5	MEDI		0.003		A vulnerability was determined in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this issue is the function mysqli_connect of the file config/database.php of the component Database Connection. This manipulation causes hard-coded credentials. The attack may be initiated remotely. The exploit has been publicly disclosed and may be utilized. This product uses a rollin...
CVE-2026-88055	5.5	MEDI				AnythingLLM is an application that turns pieces of content into context that any LLM can use as references during chatting. In 1.16.1 and earlier, the manager role can store meta_page_title or meta_page_favicon through /api/admin/system-preferences, and MetaGenerator inserts those values into production homepage HTML without escaping attribute values or text content. The values pass unchanged through server/models...
CVE-2022-26961	5.4	MEDI		0.001		Italtel NetMatch-S 5.0.0-20200703 allows Multiple Stored XSS under NP_IBCF-NATUP-01/NMSCI-WebGui/backup_restore.jsp and NP_IBCF-MIBER-03/NMSCI-WebGui/storage.jsp via the name parameter. A malicious user leveraging this vulnerability could inject arbitrary JavaScript. The malicious payload will then be triggered every time an authenticated user browses the page containing it.
CVE-2024-11831	5.4	MEDI		0.011		A flaw was found in npm-serialize-javascript. The vulnerability occurs because the serialize-javascript module does not properly sanitize certain inputs, such as regex or other JavaScript object types, allowing an attacker to inject malicious code. This code could be executed when deserialized by a web browser, causing Cross-site scripting (XSS) attacks. This issue is critical in environments where serialized data...
CVE-2025-64542	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-64584	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64588	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64589	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64610	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64618	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64830	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64838	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64854	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64866	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2025-64868	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-14565	5.4	MEDI				The advanced-customized-prompts WordPress plugin through 1.0.1 does not perform any capability, ownership, or nonce check before saving popup configuration to a product, nor escape the stored values on output, allowing any authenticated user such as a subscriber to store JavaScript that executes in the browser of visitors viewing the affected product.
CVE-2026-16892	5.4	MEDI		0.003	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to bypass security restrictions due to improper authentication during service-name matching.
CVE-2026-17274	5.4	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to bypass security restrictions due to predictable server seeds.
CVE-2026-17621	5.4	MEDI		0.003	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote attacker to traverse directories on the system. An attacker could send a specially crafted URL request containing "dot dot " sequences (/.. /) to view arbitrary files on the system.
CVE-2026-19135	5.4	MEDI		0.002		A JEXL expression sandbox bypass exists in multiple versions of OpenNMS Meridian and Horizon. A low-privileged authenticated user can submit a crafted expression to the Measurements REST API that escapes the sandbox and loads arbitrary Java classes on the server. This can potentially allow an attacker to gain access to confidential information and compromise integrity. The solution is to upgrade to Meridian 2024....
CVE-2026-19479	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19612	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19644	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-19713	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-21269	5.4	MEDI		0.005	adobe:coldfusion	ColdFusion is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-27222	5.4	MEDI		0.003	adobe:bridge, apple:macos, microsoft:windows	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-27227	5.4	MEDI		0.003		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-27238	5.4	MEDI		0.002	adobe:indesign, apple:macos, microsoft:windows	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-27258	5.4	MEDI		0.002	adobe:dng_software_development_kit	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-38725	5.4	MEDI		0.002		xipblog module v2.0.1 and before for PrestaShop allows unauthenticated remote attackers to inject arbitrary JavaScript via the name and content parameters in ajax.php. The input is stored in the database without HTML sanitization and rendered in Smarty templates without output escaping, resulting in Stored Cross-Site Scripting (XSS). When an administrator reviews comments in the back office, the payload executes w...
CVE-2026-38961	5.4	MEDI		0.002		Cross-Site Scripting (XSS) vulnerability in the RSS Widget of Netgate pfSense Plus (versions 26.03, 25.11.1) and pfSense CE (version 2.8.1) allows remote authenticated attackers to inject arbitrary JavaScript via malicious content in an RSS feed title. The injected script executes in the browser of any authenticated user who views the dashboard, due to insufficient sanitization of feed title data before rendering ...
CVE-2026-45694	5.4	MEDI		0.001		LibreNMS is a network monitoring system. In versions up to and including 26.4.0, the Proxmox application view is vulnerable to reflected cross-site scripting through the user-supplied instance and vmid GET parameters, which are reflected into the page title without adequate encoding. The parameters are placed into the page title with only strip_tags applied, and the title is then written into an inline document.ti...
CVE-2026-47880	5.4	MEDI		0.002	vmware:spring_integration	A producer who can publish to a JMS destination consumed by any Spring Integration JMS inbound component can set String JMS properties named replyChannel, errorChannel, or json__TypeId__ which are copied verbatim into the Spring Integration MessageHeaders. Spring Integration 7.1.0 Spring Integration 7.0.0 - 7.0.5 Spring Integration 6.5.0 - 6.5.10 Spring Integration 6.4.0 - 6.4.12 Spring Integration 5.5.21 and earlier
CVE-2026-48483	5.4	MEDI		0.004		TypeBot is a chatbot builder tool. Prior to version 3.17.0, Typebot's WhatsApp status forwarding feature stores a workspace-configured webhook forwarding URL and later POSTs WhatsApp marketing/error status events to it from the server. The stored URL is only validated as a generic URL in settings, but the forwarding code uses the raw `ky` instance instead of the repository's SSRF-protected `safeKy` client. A works...
CVE-2026-54553	5.4	MEDI		0.003		Starlette-Admin is a fast, beautiful and extensible administrative interface framework for FastAPI and Starlette applications. Prior to 0.16.1, the list API does not validate user-supplied order_by and structured where field names against the configured sortable_fields and searchable_fields allowlists. An authenticated user with access to an affected list endpoint can submit arbitrary field names to starlette_admin...
CVE-2026-55779	5.4	MEDI		0.002		Silverstripe Versioned provides versioning for Silverstripe models. Prior to 3.2.1, RestoreAction::getRestoreMessage() in src/RestoreAction.php builds ArchiveAdmin restore notifications rendered as CAST_HTML and inserts \$restoredItem->Title, \$restoredItem->URLSegment, \$restoredItem->CMSEditLink(), and \$changedProperty['value'] without applying Convert::raw2xml(). When an administrator restores an archived page con...
CVE-2026-62324	5.4	MEDI		0.002		Jodit Editor is a WYSIWYG editor with a built-in file browser & image editor. Prior to 4.12.31, Jodit's sanitizeHTMLElement method fails to use isDangerousUrl to normalize javascript: href values before checking the scheme, allowing case variants, control-byte prefixes, and embedded tabs or newlines to bypass filtering and execute attacker-controlled script when a victim clicks a stored link rendered by an applica...
CVE-2026-69402	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69417	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-69690	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-70610	5.4	MEDI		0.005		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.9, 40.9.2, 41.2.2, and 42.0.0-beta.4, objects copied across the contextBridge boundary from untrusted content could carry an attacker-influenced prototype, enabling prototype-pollution-style attacks against preload code despite context isolation being enabled. Apps are only affected if their preloa...
CVE-2026-70612	5.4	MEDI		0.005		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, requests to open external protocol URLs from web content did not take iframe sandbox restrictions into account, so a sandboxed iframe could cause an OS-registered external application to be launched. The frame sandbox state was also not made available to the ap...
CVE-2026-71356	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71357	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71388	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71440	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-71565	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-71803	5.4	MEDI		0.002		money-pos 1.0 contains a stored Cross-Site Scripting (XSS) vulnerability. When processing returns, the backend fails to filter or escape the goodsName parameter, directly concatenating it into the order log description; the frontend subsequently renders this content using v-html. An attacker with product creation privileges can inject a malicious JavaScript payload, causing unauthorized code execution when an admi...
CVE-2026-72626	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72627	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-73250	5.4	MEDI		0.001		Notepad++ is a free and open-source source code editor. Prior to 8.9.7, the Notepad++ Windows 11 x64 and ARM64 installer passes the attacker-influenced installation directory '\$INSTDIR' from PowerEditor/installer/nppSetup.nsi into a PowerShell '-Command' string used by RegisterMSIX to invoke Add-AppxPackage, allowing PowerShell subexpression syntax such as '\$()' in the installation path to execute commands in the ...
CVE-2026-73262	5.4	MEDI		0.002		Prowler is a cloud security platform. Prior to 5.37.0, Prowler's HTML output formatter in prowler/lib/outputs/html/html.py inserted finding.resource_tags, assembled by unroll_dict and parse_html_string, into generated reports without HTML escaping, allowing a cloud principal who can modify a scanned resource tag to store HTML or JavaScript that executes when another user opens the report. This issue is fixed in ve...
CVE-2026-73295	5.4	MEDI		0.002		Material for MkDocs is a powerful documentation framework built on top of MkDocs. From 7.2.0 until 9.7.7, the mountSearchSuggest function in src/templates/assets/javascripts/components/search/suggest/index.ts contains a DOM-based cross-site scripting vulnerability in the optional search.suggest feature that allows a crafted q URL parameter to execute JavaScript in a documentation site's origin after user interacti...
CVE-2026-75629	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75635	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75636	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75637	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75639	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75640	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75642	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75643	5.4	MEDI		0.002		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75644	5.4	MEDI		0.002		Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75646	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75647	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75651	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75652	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75657	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75659	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75660	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75661	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75666	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75667	5.4	MEDI		0.002		Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75668	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75669	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75670	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75671	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75672	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75674	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75675	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75677	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75678	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75679	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75680	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75681	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75683	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75685	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75687	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75690	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75691	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75692	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75693	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75694	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75695	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75696	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75700	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75701	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75702	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75704	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75705	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75706	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75707	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75708	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75709	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75710	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75711	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75712	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75713	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75714	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75715	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75716	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75717	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75718	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75719	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75720	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75722	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75724	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75725	5.4	MEDI		0.002	adobe:experience_manager	Adobe Experience Manager is affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.
CVE-2026-75727	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75729	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75730	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75731	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75733	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75734	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75735	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75736	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75737	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75738	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75739	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75740	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75741	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-75742	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-79418	5.4	MEDI		0.002		EMX Tecnologia Gestao X version <= 8.4 contains a Stored Cross-Site Scripting (XSS) vulnerability in the Help Chat functionality. Improper neutralization of user-controlled input during web page generation allows authenticated attackers to execute arbitrary JavaScript in the context of other authenticated users, potentially resulting in session hijacking, account takeover, and unauthorized actions.
CVE-2026-79905	5.4	MEDI		0.003	adobe:experience_manager	Adobe Experience Manager is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by a low-privileged attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field. Scope is changed.
CVE-2026-81890	5.4	MEDI		0.002		elFinder is an open-source file manager for web, written in JavaScript using jQuery UI. Prior to 2.1.70, the netmount command is omitted from elFinderConnector::\$csrfProtectedCmds in php/elFinderConnector.class.php, so validateCsrfToken() is not called for this state-changing operation. In the shipped php/connector.minimal.php-dist configuration, FTP network mounts are enabled by default, and attacker-controlled p...
CVE-2026-82396	5.4	MEDI		0.002		Sulu is an open-source PHP content management system based on the Symfony framework. Prior to versions 2.6.25 and 3.0.8, src/Sulu/Bundle/MediaBundle/Controller/MediaStreamController.php allows the /media/{id}/download/{slug} route and its administration variant to honor the inline query parameter for scriptable MIME types. The vulnerable stored Content-Type values include text/html, application/xhtml+xml, text/xml...
CVE-2026-84371	5.4	MEDI		0.002		ApostropheCMS is an open-source Node.js content management system, and sanitize-html provides a simple HTML sanitizer with a clear API. From version 1.9.0 until version 2.17.7, packages/sanitize-html/index.js validates an animation value attribute as one flat URL and does not recognize that attributeName selecting href or xlink:href gives the sibling values, from, to, or by attribute SVG SMIL URL semantics. In con...
CVE-2026-84385	5.4	MEDI		0.001		A improper access control vulnerability in Fortinet FortiSOAR PaaS 7.6.0 through 7.6.6, FortiSOAR PaaS 7.5.0 through 7.5.3, FortiSOAR PaaS 7.4 all versions, FortiSOAR PaaS 7.3 all versions, FortiSOAR on-premise 7.6.0 through 7.6.6, FortiSOAR on-premise 7.5.0 through 7.5.3, FortiSOAR on-premise 7.4 all versions, FortiSOAR on-premise 7.3 all versions may allow attacker to escalation of privilege via <insert attack v...
CVE-2026-87653	5.4	MEDI		0.002	google:chrome, microsoft:windows	UI misrepresentation in FullScreen in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-14350	5.3	MEDI		0.003		IBM Cloud Pak for Data System 11.3.0.2 through Interim Fix 001 could allow an unauthorized user to inject data into log messages due to improper neutralization of special elements when written to log files.
CVE-2026-16660	5.3	MEDI		0.004	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 could allow a remote attacker to cause a denial of service due to an out-of-bounds read.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19032	5.3	MEDI		0.005		jackson-databind's deserializer for java.nio.file.Path resolves an attacker-supplied URI without restricting the URI scheme. In JDKFromStringDeserializer.NioPathHelper.deserialize, a string bound from untrusted JSON is passed to new URI(value) and then to Path.of(uri). When that throws FileSystemNotFoundException, the code enumerates ServiceLoader<FileSystemProvider> and calls provider.getPath(uri) on the first pr...
CVE-2026-19670	5.3	MEDI		0.002		Malcolm's nginx Lua role-based access control (RBAC) layer decides whether an authenticated user may reach a role-restricted path (e.g. /htadmin, /auth, /admin_login, /arkime/api/esadmin, NetBox, upload endpoints) by pattern-matching the raw, percent-encoded request URI. Nginx itself, however, selects which location block actually serves the request using the percent-decoded, normalized URI. Because the RBAC check...
CVE-2026-41606	5.3	MEDI		0.011	apache:thrift	Uncontrolled Recursion vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-42338	5.3	MEDI		0.005	beaugunderson:ip-address	ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.1.1, Address6.group() and Address6.link() do not HTML-escape attacker-controlled content before embedding it in the HTML strings they return, and AddressError.parseMessage (emitted by the Address6 constructor for invalid input) can contain unescaped attacker-controlled content in one branch. An application that ...
CVE-2026-45292	5.3	MEDI		0.011		opentelemetry-java is the Java implementation of the OpenTelemetry API for recording telemetry, and SDK for managing telemetry recorded by the API. Prior to 1.62.0, a vulnerability affects the baggage propagation implementation in opentelemetry-api and opentelemetry-extension-trace-propagators. Parsing oversized baggage causes unbounded memory allocation and CPU consumption. Because baggage is automatically re-inj...
CVE-2026-47680	5.3	MEDI		0.003		The source-controller is a Kubernetes operator, specialised in artifacts acquisition from external sources such as Git, OCI, Helm repositories and S3-compatible buckets. In versions 0.0.17 through 1.8.4, an actor with the ability to influence the contents of a bucket referenced by a 'Bucket' resource can cause source-controller to write fetched object data to paths outside the per-reconciliation working directory....
CVE-2026-48094	5.3	MEDI		0.003		The ShareOpenly WordPress plugin prior to version 1.2.1 contains a Cross-Site Scripting vulnerability caused by the absence of WordPress's `esc_url()` escaping function on the `\$url` variable before it is rendered into HTML content. This variable is constructed from `home_url( add_query_arg( array(), \$wp->request ) )` and is concatenated directly into an HTML `href` attribute on every singular post or page where t...
CVE-2026-48796	5.3	MEDI		0.003		CefSharp provides .NET bindings for the Chromium Embedded Framework for Windows Forms and Windows Presentation Foundation applications. Prior to version 148.0.90, CefSharp/SchemeHandler/FolderSchemeHandlerFactory.cs used filePath.StartsWith(rootFolder, StringComparison.OrdinalIgnoreCase) to decide whether a decoded and canonicalized request path remained inside rootFolder. That raw prefix test did not enforce a di...
CVE-2026-49392	5.3	MEDI		0.003		Wazuh is a free and open source platform used for threat prevention, detection, and response. From 4.6.0 until 4.14.6 and 5.0.0-beta3, DB::getFile() and DB::searchFile() in src/syscheckd/src/db/src/file.cpp concatenate a monitored file path into SQLite row filters. On non-Windows systems, FIMDBCreator::encodeString() does not escape the value. A local user who can create a filename in a File Integrity Monitoring d...
CVE-2026-50159	5.3	MEDI		0.006		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. Prior to 10.9.8 and 11.16.1, Mermaid is vulnerable to CSS injection via sibling combinator selectors generated from diagram-supplied class or id names. An attacker who can supply diagram text can inject arbitrary CSS into the rendered page, potentially altering the appearance or behavior of unrelated page elemen...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54048	5.3	MEDI		0.002	apache:impala	Specifying tblproperties('avro.schema.url=' http://...') or with a 'file:/// URI on a table in Impala 2.0.0 to 4.5.1 on all platforms allows an attacker to trigger a GET request to internal endpoints they may not have access to but that Impala does and the response may be exposed via parsing error messages. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-55619	5.3	MEDI		0.003		eml_parser serves as a python module for parsing eml files and returning various information found in the e-mail as well as computed information. Prior to 3.0.2, eml_parser.parser.HeaderParser.header_fetch_parse in eml_parser/parser.py uses email.utils.getaddresses() to parse address-bearing e-mail headers. A deeply nested CFWS comment construct exhausts the standard-library recursive descent parser's call stack a...
CVE-2026-55867	5.3	MEDI		0.003		Graylog is a free and open log management platform. From 6.2.0 until 6.3.12, 7.0.7, and 7.1.2, the DELETE /users/{userId}/tokens/{idOrToken} endpoint implemented by UsersResource.revokeToken() in graylog2-server/src/main/java/org/graylog2/rest/resources/users/UsersResource.java checks USERS_TOKENREMOVE permission against the attacker-controlled userId path parameter before resolving the token selected by idOrToken...
CVE-2026-56704	5.3	MEDI		0.002		Adminer before 5.4.3 inserts unsanitized database server version strings into script tags with valid CSP nonces without proper validation. Attackers controlling a rogue MySQL server can return crafted version strings that break out of the JavaScript context and execute arbitrary code, bypassing Content Security Policy protections.
CVE-2026-61632	5.3	MEDI		0.004		PyMdown Extensions is a set of extensions for the Python-Markdown markdown project. In versions up to and including 10.21.3, the b64 extension is vulnerable to a path traversal that discloses arbitrary files: it inlines images referenced by by joining the src onto the configured base_path with os.path.normpath and opening the result directly, without verifying that the resolved path stays inside ba...
CVE-2026-66778	5.3	MEDI		0.002	sap:approuter	SAP Approuter does not sufficiently sanitize certain request headers before forwarding traffic to internal components. An unauthenticated attacker could send a specially crafted request to obtain limited unauthorized access to information. This results in a low impact on confidentiality. There is no impact on integrity and availability.
CVE-2026-69207	5.3	MEDI		0.005		Hono is a Web application framework that provides support for any JavaScript runtime. Prior to 4.12.34, the built-in CORS middleware, hono/cors, is vulnerable to a regular expression denial of service (ReDoS). During a preflight OPTIONS request, the middleware parses the attacker-controlled Access-Control-Request-Headers header using a whitespace-tolerant regular expression whose backtracking makes its running tim...
CVE-2026-70466	5.3	MEDI		0.003	fortinet:fortiweb	A incomplete list of disallowed inputs vulnerability in Fortinet FortiWeb 8.0.0 through 8.0.2, FortiWeb 7.6.0 through 7.6.5, FortiWeb 7.4 all versions, FortiWeb 7.2 all versions, FortiWeb 7.0 all versions may allow attacker to improper access control via <insert attack vector here>
CVE-2026-70575	5.3	MEDI		0.008		Null pointer dereference in Windows Schannel allows an authorized attacker to deny service over a network.
CVE-2026-70607	5.3	MEDI		0.004		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, some window options supplied by web content in the window.open() features string were applied to the new BrowserWindow without an allowlist. Untrusted content could set window options it should not control, including options that cause the main process to acces...
CVE-2026-71216	5.3	MEDI		0.001		PagerDuty alarm hook transmits the integration routing key over cleartext HTTP. PagerDuty serves this endpoint over HTTPS and will normally answer plain HTTP with a redirect. That does not remove the exposure. The initial POST -- including the JSON body containing the routing key -- is written to the socket unencrypted before any redirect response is received. Redirection affects only whether the request is ret...
CVE-2026-71408	5.3	MEDI		0.005	fortinet:fortios	A allocation of resources without limits or throttling vulnerability in Fortinet FortiOS 7.6.0 through 7.6.6, FortiOS 7.4 all versions, FortiOS 7.2 all versions may allow attacker to denial of service via <insert attack vector here>

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71436	5.3	MEDI		0.004		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. From version 10.6.0 until 10.9.8 and 11.16.1, Mermaid XY Charts are vulnerable to an infinite loop denial of service in the setXAxisRangeData function when configuring an X-Axis with invalid parameters. Because each loop iteration appends an element to an array, this generally causes a RangeError to appear after...
CVE-2026-71439	5.3	MEDI		0.004		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. From version 11.6.0 until 11.16.1, Mermaid Radar Diagrams allow arbitrary large values for the ticks parameter, which can cause high CPU usage and freeze the rendering webpage or JavaScript process for long periods of time, potentially until the process is killed from memory exhaustion. This issue is fixed in ve...
CVE-2026-71848	5.3	MEDI		0.003		Hono is a Web application framework that provides support for any JavaScript runtime. From 4.12.0 to 4.12.33, the languageDetector middleware is vulnerable to algorithmic complexity denial of service when processing a crafted language tag containing a large number of hyphen separated subtags. To implement progressive language tag truncation, normalizeLanguage() repeatedly calls parts.slice(0, i).join('-') for ever...
CVE-2026-72834	5.3	MEDI		0.002		filebrowser before 2.63.19 contains a permission bypass in the /api/resources endpoint. The checksum (?checksum=) branch of resourceGetHandler reads the entire file to compute a digest and returns it without performing a Perm.Download check (unlike the sibling raw, preview, and subtitle paths). As a result, an authenticated user provisioned with Perm.Download=false can obtain a content-hash oracle for any same-sco...
CVE-2026-73244	5.3	MEDI		0.004		kkFileView is a universal file online preview project based on Spring Boot. Prior to 5.0.1, the unauthenticated POST /listFiles endpoint in server/src/main/java/cn/keking/web/controller/FileController.java passes the user-controlled path parameter from FileController#getFiles to Files.newDirectoryStream without confinement to the demo directory, allowing directory enumeration outside the intended root. This issue ...
CVE-2026-73422	5.3	MEDI		0.004		Astro is a web framework for content-driven websites. From 2.9.0 until 7.1.0, Astro's server-side View Transition CSS generator interpolates animation properties into an inline style element without escaping them for CSS and HTML contexts. An attacker-controlled View Transition animation value such as duration can terminate the generated style element and inject arbitrary HTML or JavaScript. The affected code is p...
CVE-2026-73508	5.3	MEDI		0.003		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.136.Final and 4.2.16.Final, io.netty.handler.codec.dns.AbstractDnsRecord, io.netty.handler.codec.dns.DefaultDnsRecordDecoder.decodeRecord(), and io.netty.handler.codec.dns.DnsCodecUtil.decompressDomainName() failed to release retained or newly allocated ByteBuf objects when IDN.toASCII() or encodeDomainName() rejected a malformed do...
CVE-2026-73531	5.3	MEDI		0.002		django-helpdesk before 2.3.3 contains a stored cross-site scripting vulnerability that allows unauthenticated attackers to inject arbitrary JavaScript by submitting HTML-formatted email messages or uploading .html/.htm file attachments through public ticket submission channels. Attackers can exploit the lack of sanitization and Content-Disposition headers at the attachment-serving layer to execute malicious script...
CVE-2026-73555	5.3	MEDI		0.003		vLLM is an inference and serving engine for large language models. Prior to 0.26.0, the validation_exception_handler in vllm/entrypoints/openai/server_utils.py converts FastAPI RequestValidationError objects with str(exc), and sanitize_message in vllm/entrypoints/utils.py does not remove traceback-style file paths, allowing unauthenticated malformed JSON requests to /v1/chat/completions, /v1/completions, /tokenize...
CVE-2026-73565	5.3	MEDI		0.004		@hono/node-server allows running the Hono application on Node.js. From 2.0.0 until 2.0.10, a WebSocket upgrade request to an upgradeWebSocket route with a missing or malformed Sec-WebSocket-Key header causes src/websocket.ts to retain the request's IncomingMessage in waiterMap and leave waitForWebSocket pending because ws.handleUpgrade emits no connection event. The aborted handshake therefore has no cleanup path,...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73628	5.3	MEDI		0.002		Serendipity versions >= 2.3.5 and <= 2.6.0 contain a reflected cross-site scripting vulnerability in the search clean-URL route (/search/<term>). In include/functions_routing.inc.php serveSearch(), the sanitisation pipeline runs urldecode() after HTML-encoding, so a single URL-encoded HTML payload survives strip_tags() and htmlspecialchars() and is then decoded back into live HTML in the page. A crafted search lin...
CVE-2026-73840	5.3	MEDI		0.002		OpenChoreo is a complete, open-source developer platform for Kubernetes. Prior to 1.0.3, 1.1.3, and 1.2.0-rc.2, the POST /api/v1alpha1/autobuild endpoint in internal/openchoreo-api/api/handlers/webhook_handler.go selected a webhook provider from caller-controlled X-Event-Key, accepted Bitbucket requests without HMAC-SHA256 in X-Hub-Signature or a configured bitbucket-secret, and allowed unauthenticated build trigg...
CVE-2026-77310	5.3	MEDI		0.002		jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. Prior to versions 2.18.9, 2.21.5, 2.22.1, 3.1.5, and 3.2.1 on their respective release lines, the java.net.InetAddress branch of FromStringDeserializer.Std._deserialize() calls InetAddress.getByName() on attacker-controlled input, causing eager DNS resolution during deserialization and enabling DNS-b...
CVE-2026-78446	5.3	MEDI		0.006		Use after free in Windows Distributed File System (DFS) allows an authorized attacker to deny service over a network.
CVE-2026-78631	5.3	MEDI		0.001		The Okta Hyperdrive Agent writes the decoded SAML bearer assertion to a local application log file at the default log level on every successful MFA completion. This insertion of sensitive information into the log file makes a live authentication credential readable by any local user with access to the log file.
CVE-2026-80339	5.3	MEDI		0.002		The Payment Plugins for Stripe WooCommerce WordPress plugin before 4.0.12 does not validate the order key before adding order data to the JavaScript configuration it outputs on the front end, allowing unauthenticated users to obtain the billing details of any order, together with the secret that gates access to it, by iterating sequential order identifiers.
CVE-2026-80340	5.3	MEDI		0.002		The Payment Plugins for PayPal WooCommerce WordPress plugin before 2.0.26 does not validate the order key before adding order data to the JavaScript configuration it outputs on the front end, allowing unauthenticated users to obtain the secret that gates access to any order and, through it, that customer's billing and shipping details, by iterating sequential order identifiers.
CVE-2026-82066	5.3	MEDI		0.002		A heap out-of-bounds read security issue exists in the query planning component of MongoDB Server. An authenticated user with database read and write privileges can trigger the security issue through crafted query operations, causing the server to read memory beyond allocated buffer boundaries. The revealed memory contents may be partially observable through diagnostic query statistics output.
CVE-2026-82867	5.3	MEDI		0.002		@pdfme/schemas before 5.5.9 contains a cross-site scripting vulnerability in the Select schema plugin that fails to sanitize option values before interpolating them into HTML via innerHTML. Attackers can supply malicious templates with crafted option values containing HTML and JavaScript to execute arbitrary code in users' browsers.
CVE-2026-82868	5.3	MEDI		0.002		@pdfme/schemas before 5.5.9 contains a cross-site scripting vulnerability in the SVG schema plugin that renders user-supplied SVG content directly to innerHTML without sanitization. Attackers can inject malicious SVG with embedded scripts, event handlers, or foreignObject elements to execute arbitrary JavaScript in users' browsers when viewing or filling templates.
CVE-2026-84191	5.3	MEDI		0.002		LibreNMS before 26.5.0 contains stored cross-site scripting vulnerabilities in VRF display pages where mplsVpnVrfDescription, vrf_name, and mplsVpnVrfRouteDistinguisher fields from SNMP polling are rendered without sanitization. Attackers controlling a monitored network device can inject arbitrary JavaScript through SNMP responses that executes in the browser of any user viewing VRF-related pages.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84364	5.3	MEDI		0.004		Hono is a Web application framework that provides support for any JavaScript runtime. Prior to 4.13.5, when <code>parseBody()</code> expands dot-separated form field names into nested objects with dot-notation parsing enabled, it does not limit the nesting depth or the total number of intermediate objects created. Empty segments are preserved, so one deeply dotted field name can encode one nesting level per byte, while a large...
CVE-2026-84379	5.3	MEDI		0.003		HTTPX2 is a next generation HTTP client for Python. Prior to 2.11.0, <code>FormField.render_headers()</code> in <code>src/httpx2/httpx2/_multipart.py</code> directly interpolates attacker-controlled <code>content_type</code> values and custom headers from the <code>files=</code> three-element (filename, content, <code>content_type</code>) tuple and the <code>files=</code> four-element (filename, content, <code>content_type</code> , headers) tuple into multipart/form-data part headers without validating h...
CVE-2026-85158	5.3	MEDI		0.002		AVideo through commit c91b5975d contains a reflected cross-site scripting vulnerability in <code>videoEmbedded.php</code> that echoes the link parameter inside an HTML comment with zero escaping. Attackers can close the comment with <code>--></code> and inject arbitrary JavaScript that executes when victims visit the crafted embed URL.
CVE-2026-85159	5.3	MEDI		0.002		AVideo through commit c91b5975d contains a reflected cross-site scripting vulnerability in <code>userLogin.php</code> where the <code>cancelUri</code> parameter is echoed in an href attribute after <code>isSafeRedirectURL</code> checks protocol only, not HTML characters. Unauthenticated attackers can inject event handlers via relative URLs with embedded quotes to execute arbitrary JavaScript when users interact with the Cancel button.
CVE-2026-85230	5.3	MEDI		0.003	misp-project:misp	A persistent unsafe URL injection vulnerability exists in the MISP dashboard <code>ButtonWidget</code> configuration. Dashboard widget URLs were validated only when the widget was rendered and were not validated when the configuration was saved. As a result, an authenticated user able to modify dashboard widget settings could persist arbitrary URL values, including URLs using the javascript: scheme, through either of the dashb...
CVE-2026-85577	5.3	MEDI		0.003		AVideo through commit c91b5975d contains a reflected cross-site scripting vulnerability in <code>userLogin.php</code> that allows unauthenticated attackers to inject arbitrary JavaScript by closing the script tag with <code></script></code> . Attackers can craft a malicious URL with an error parameter containing script breakout sequences to execute arbitrary JavaScript in the victim's browser context on the login page.
CVE-2026-87859	5.3	MEDI				morgan is an HTTP request logger middleware for Node.js. In versions before 1.12.1, its <code>escapeLogField()</code> function does not escape the double quote character, which delimits the quoted fields of the Apache combined log format that morgan emits. An unauthenticated remote attacker who controls a value written to a quoted field, such as the User-Agent or Referer header, can include a double quote to close that field e...
CVE-2026-88011	5.3	MEDI				Traefik is an open source HTTP reverse proxy and load balancer. Prior to 2.11.56, and from 3.0.0 until 3.7.12, a client-supplied dot-form header such as <code>X.Authenticated.User</code> survives <code>ForwardAuth</code> replacement and <code>underscoreHeadersStrategy</code> because Go treats it as distinct from <code>X-Authenticated-User</code> while normalization-prone CGI, WSGI, PHP, and NGINX backends collapse both names. A backend can consequently consume the ...
CVE-2026-88046	5.3	MEDI				rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone core does not reject parent-directory segments in source <code>Object.Remote()</code> values before <code>fs/list</code> , <code>fs/walk</code> , <code>fs/sync</code> , and <code>fs/operations</code> pass those values to destination backends. A flat-keyspace source object store populated with native non-rclone tooling can contain a raw .. key segmen...
CVE-2026-88057	5.3	MEDI				Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.0, Angular's compiler and runtime in <code>@angular/core</code> and <code>@angular/compiler</code> could omit or select an incorrect sanitizer for security-sensitive directive host bindings because <code>SecurityContext</code> was derived from the declaring directive or component selecto...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-88879	5.3	MEDI				Traefik is an HTTP reverse proxy and load balancer. In Traefik v1.x, v2.x through v2.11.55, and v3.0.0 through v3.7.11, header names are canonicalized only on dashes, so X-Auth-User, X_Auth_User and X.Auth.User are treated as three distinct headers by Traefik, while backends that derive variable names from header names (CGI, WSGI, PHP, NGINX and others) collapse them into a single variable. A client can therefore ...
CVE-2026-88892	5.3	MEDI				OpenPanel is an analytics platform. In all versions (no patched release available at time of publication), the data importer fetches a caller-supplied URL with plain fetch instead of the project's existing SSRF guard (apps/api/src/utlis/safe-fetch.ts). In packages/importer/src/providers/umami.ts, parseRemoteFile calls fetch() on config.apiUrl, which is validated only by z.string().url(), so values such as http://...
CVE-2026-89239	5.3	MEDI				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a reflected cross-site scripting vulnerability in the showAlertMessage() function that inserts the raw Referer header into a JavaScript comment without encoding. Attackers can craft a Referer header containing */ to close the comment and inject arbitrary JavaScript that executes in the site origin for visitors arriving from the attacker-c...
CVE-2026-89240	5.3	MEDI				WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a reflected cross-site scripting vulnerability in plugin/Live/confirmLivePassword.php. The script interpolates the unauthenticated GET parameter u (which is not covered by \$securityFilter) directly into an attribute without URL- or HTML-encoding. A remote attacker can craft a link containing a double-quote character in u (...)
CVE-2026-9338	5.3	MEDI				IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted request. A remote attacker could exploit this vulnerability to trigger excessive resource consumption, potentially leading to reduced availability of the affected service.
CVE-2026-9667	5.3	MEDI				IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to server-side request forgery (SSRF) that could allow a remote, unauthenticated attacker to cause the server to send outbound requests to arbitrary endpoints.
CVE-2025-7062	5.2	MEDI		0.003		A stored cross-site scripting (XSS) vulnerability has been identified in the H5P module `h5p-nodejs-library` by Lumi Education UG in versions up to and including 10.0.4. The library allows users to upload H5P content that contains malicious JavaScript. This code is then executed in the browsers of other users who view the affected H5P content.
CVE-2026-0297	5.2	MEDI		0.002	paloaltonetworks:globalprotect	A buffer overflow vulnerability exists in the Palo Alto Networks GlobalProtect™ app that enables a man-in-the-middle (MitM) attacker or a rogue gateway to disrupt system processes and potentially execute arbitrary code with elevated privileges (SYSTEM privileges on Windows, and root privileges on macOS and Linux).
CVE-2026-0298	5.2	MEDI		0.002	paloaltonetworks:globalprotect	An improper input validation vulnerability exists in the Windows Pre-Logon Access Provider (PLAP) component of the Palo Alto Networks GlobalProtect™ app on Windows devices which enables a man-in-the-middle (MitM) attacker to execute arbitrary code with SYSTEM privileges on an affected client. The GlobalProtect app on Linux, macOS, iOS, Android, and Chrome OS is not affected.
CVE-2025-71404	5.1	MEDI		0.004		better-auth versions after v0.0.2 and before 1.1.16 contain a reflected cross-site scripting (XSS) vulnerability on the /api/auth/error page, where the value of the 'error' URL parameter is reflected as HTML without proper neutralization. An attacker who coerces a user into visiting a specially-crafted URL can execute arbitrary JavaScript in the context of the user's browser. The issue is fixed in version 1.1.16.
CVE-2026-40507	5.1	MEDI		0.003		OpenEMR before 8.3.0 contains a reflected cross-site scripting vulnerability in the patient portal template import handler. The templateHtml GET parameter is reflected into the page response without sanitization. An attacker can craft a URL that executes arbitrary JavaScript in the browser of any authenticated user with Forms Administration permissions who visits the link, enabling session hijacking.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-40508	5.1	MEDI		0.002		OpenEMR before 8.3.0 contains a stored cross-site scripting vulnerability in the patient portal template import handler that allows authenticated attackers with Forms Administration permissions to upload template files containing arbitrary HTML or JavaScript. Attackers can inject malicious scripts through the template upload functionality, which are stored without sanitization and execute in the browser of any oth...
CVE-2026-48550	5.1	MEDI		0.003		Nagios Core before 4.5.14 and Nagios XI before 2026R1.7 are vulnerable to reflected cross-site scripting in cmd.cgi via the NagFormId parameter. An unauthenticated remote attacker can craft a malicious link that, when followed by an authenticated user, executes arbitrary JavaScript in the victim's browser.
CVE-2026-48552	5.1	MEDI		0.002		Nagios Core before 4.5.14 and Nagios XI before 2026R1.7 are vulnerable to DOM-based cross-site scripting in jquery.js. Unencoded JSON string values reflected from stored fields are inserted into the DOM without sanitization, allowing attackers to run arbitrary JavaScript in the victim's browser.
CVE-2026-56126	5.1	MEDI		0.004		pfSense Plus before 26.07 and CE before 2.9.0 allow authenticated users with the Status: Monitoring privilege to inject arbitrary JavaScript via graph configuration parameters in /status_monitoring.php. Multiple POST parameters including graph-left, graph-right, time-period, resolution, start-date, end-date, start-time, end-time, graph-type, invert, and refresh-interval are concatenated and written to the global p...
CVE-2026-56127	5.1	MEDI		0.004		pfSense Plus before 26.07 and CE before 2.9.0 allow authenticated users with the Firewall: Rules: Edit privilege to inject arbitrary JavaScript via the descr parameter in /firewall_rules_edit.php. The firewall rule description is stored in the pfSense XML configuration with only backslash-escaping applied and no HTML sanitization, then rendered without encoding in the firewall log table in /status_logs_filter.php....
CVE-2026-56128	5.1	MEDI		0.004		pfSense Plus before 26.07 and CE before 2.9.0 allow authenticated users with the Firewall: Schedules: Edit privilege to inject arbitrary JavaScript via the descr parameter in /firewall_schedule_edit.php. The schedule description is stored without HTML sanitization and subsequently inserted into an HTML attribute value in /firewall_rules.php with only single-quote escaping applied, permitting double-quote breakout....
CVE-2026-63105	5.1	MEDI		0.001		ReadyEcommerce before 4.5.2 contains a stored cross-site scripting (XSS) vulnerability that allows authenticated customers to inject malicious HTML payloads through the chat and support ticket messaging systems by exploiting unsanitized rendering via the v-html directive in Messages.vue, RightChatSidebar.vue, SupportTicketMessages.vue, and SupportTicketDetails.vue. Attackers can submit crafted message content that...
CVE-2026-63336	5.1	MEDI		0.002		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.33.0, com.rabbitmq.client.ConnectionFactory.useSslProtocol() and ConnectionFactory.useSslProtocol(String) configure com.rabbitmq.client.TrustEverythingTrustManager and leave hostname verification disabled, causing arbitrary server certificates, including self-signed certificates, to be...
CVE-2026-67196	5.1	MEDI		0.002		Perspective 5.0.0 contains a cross-site scripting vulnerability in the built-in Debug plugin that allows attackers to inject arbitrary HTML and JavaScript by writing table cell values containing unescaped HTML markup, which are interpolated directly into innerHTML during CSV serialization rendering. Attackers can craft table rows with payloads such as unquoted attribute injections containing event handler attribut...
CVE-2026-67333	5.1	MEDI		0.002		better-auth before 1.6.13 (and pre-release builds 1.7.0-beta.0 through 1.7.0-beta.3) fail to validate the scheme of redirect_uris registered via the deprecated oidc-provider plugin and the mcp plugin (which wraps the same provider). An attacker can register an OAuth client with a javascript: redirect_uri, which the authorization server later returns unchanged in the consent response. If the deployment's consent pa...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67338	5.1	MEDI		0.002		JupyterLab before 4.5.9 contains a stored cross-site scripting vulnerability in the Extension Manager that fails to validate URI protocols in package metadata URLs. Attackers can publish malicious PyPI packages with javascript: URLs in project metadata that execute arbitrary JavaScript in the JupyterLab origin when users click the extension name.
CVE-2026-71498	5.1	MEDI		0.002		node-re2 provides RE2 regular expression bindings for Node.js. Prior to version 1.26.1, passing a Buffer whose final bytes form a truncated (incomplete) multi-byte UTF-8 sequence could cause the native binding to read past the end of the allocated buffer while attempting to decode the final, incomplete code point. This could result in an out-of-bounds read and potential disclosure of adjacent memory contents. This...
CVE-2026-71503	5.1	MEDI		0.002		Dolibarr before 24.0.0 contains a reflected cross-site scripting vulnerability in the extra fields administration template where the type request parameter is echoed without JavaScript-context encoding into an inline script block and no Content-Security-Policy header is emitted. An unauthenticated attacker can cause an authenticated administrator to open a crafted URL to execute arbitrary JavaScript in that sessio...
CVE-2026-72747	5.1	MEDI		0.003		AVideo fails to sanitize the phone field during user registration, allowing unauthenticated attackers to inject malicious JavaScript that persists in the database. When administrators visit the users management page, the unsanitized phone value is rendered via innerHTML, executing the injected script in the admin's browser session.
CVE-2026-73037	5.1	MEDI		0.002		Next AI Draw.io 0.2.1 through 0.4.16 contains a reflected cross-site scripting vulnerability in the mcp query parameter that is interpolated without escaping into HTML and JavaScript. Attackers can craft malicious URLs to execute arbitrary JavaScript in the localhost origin, enabling exfiltration of diagram sessions and API data.
CVE-2026-73319	5.1	MEDI		0.003		XenForo before 2.3.13 contains a cross-site scripting vulnerability in the dynamic redirect handler that allows unauthenticated attackers to execute arbitrary JavaScript in the board origin by crafting a malicious javascript: URI that bypasses host validation. Attackers can embed the board hostname in the URI authority component and use percent-encoded newlines to evade server-side filters, causing authenticated u...
CVE-2026-73409	5.1	MEDI		0.002		Budibase is an open-source low-code platform. Prior to 3.40.1, packages/server/src/integrations/mongodb.ts passed builder-controlled tlsCertificateKeyFile and tlsCAFile values directly to MongoClient on Budibase Cloud. A builder could submit absolute server paths through /api/datasources/verify and distinguish readable existing files from missing files by comparing the driver error, exposing a filesystem existence...
CVE-2026-75107	5.1	MEDI		0.002		Grav Form Plugin before 9.1.19 fails to escape field-definition properties including prepend, append, spacer text, section text, and select option labels in form templates. Attackers with form authoring privileges can inject arbitrary HTML and JavaScript that executes for all form visitors through unescaped raw filters and unquoted attributes.
CVE-2026-75831	5.1	MEDI		0.003		Grav before 2.0.15 contains a stored cross-site scripting vulnerability in the audio and video media rendering through the sourceParsedownElement method. The media URL fragment is concatenated unescaped into rawHtml source elements, allowing attackers to inject arbitrary HTML and JavaScript that executes in viewers' sessions.
CVE-2026-75834	5.1	MEDI		0.002		Grav before 2.0.14 contains a stored cross-site scripting vulnerability in the Security::detectXss() function (system/src/Grav/Common/Security.php). All XSS detection patterns use the PCRE /u (UTF-8) modifier, so a single invalid UTF-8 byte anywhere in page content causes preg_match() to return false for every pattern, silently bypassing the save-time XSS safety gate (Validation::checkSafety()). An authenticated a...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81887	5.1	MEDI		0.005		Livewire is a full-stack framework for Laravel. From 3.0.0-beta.1 until 3.8.3 and 4.3.4, the dot-notated query-string parser in js/plugins/history/index.js, including fromQueryString() and insertDotNotatedValueIntoData(), accepts the __proto__, constructor, and prototype path segments and creates inherited objects. Client-side state handlers then access effects.html, effects.js, effects.xjs, and effects.scripts wi...
CVE-2026-82024	5.1	MEDI		0.001		LearnPress WordPress Plugin before 4.4.6 contains a stored cross-site scripting vulnerability that allows authenticated attackers with the Instructor role to inject persistent malicious payloads by submitting unsanitized input into quiz question answer title fields. Attackers can store arbitrary JavaScript through the answer title parameter, which is rendered through an unescaped HTML sink to execute in the browse...
CVE-2026-82069	5.1	MEDI		0.003		A security issue in MongoDB Server's query statistics serialization on the router allows users with monitoring privileges to access unredacted search query text from other users' operations. An improper conditional check in the serialization logic causes the data redaction mechanism to be bypassed when processing search queries through the sharded cluster router. This results in sensitive query literals being stor...
CVE-2026-82881	5.1	MEDI		0.002		Aix-DB through 1.2.4 renders markdown with raw HTML enabled into v-html bindings without sanitization, allowing stored cross-site scripting attacks. Attackers can inject malicious HTML and JavaScript through markdown content in chat responses, skill descriptions, or knowledge messages that execute in users' browsers when viewed.
CVE-2026-84305	5.1	MEDI		0.001		sqlparse is a non-validating SQL parser module for Python. Prior to 0.6.0, sqlparse.format(sql, reindent=True) and sqlformat --reindent route attacker-controlled parenthesized tuple lists through ReindentFilter._get_offset() in sqlparse/filters/reindent.py, where _flatten_up_to_token() repeatedly rebuilds and joins the statement prefix. Thousands of offset calculations walk an expanding token tree, producing quadr...
CVE-2026-84386	5.1	MEDI		0.001		A unverified ownership vulnerability in Fortinet FortiClientWindows 7.4.0 through 7.4.7, FortiClientWindows 7.2 all versions may allow attacker to improper access control via <insert attack vector here>
CVE-2026-84967	5.1	MEDI		0.002	mongodb:mongodb	A component of the MongoDB extension for Visual Studio Code does not neutralize special characters in a connection string before that value is placed into a command line the extension composes for an integrated terminal. An unauthenticated remote unauthorized-user who persuades a developer to accept a user-supplied connection target, and then to open the extension's shell feature, can place characters of the unaut...
CVE-2026-85593	5.1	MEDI		0.001		phpMyFAQ versions before 4.1.8 contain a stored cross-site scripting vulnerability in FaqHelper::convertOldInternalLinks() that calls html_entity_decode() on sanitized FAQ content, reversing entity-encoding protection. Authenticated users with FAQ editing privileges can inject JavaScript payloads that execute in the browsers of all users viewing the affected FAQ pages.
CVE-2026-85599	5.1	MEDI		0.002		Grav Shortcode Core before 6.2.5 contains stored cross-site scripting vulnerabilities in the [lorem] tag parameter and [details] summary parameter that are written to rendered pages without escaping. Attackers with page-edit access can inject arbitrary HTML and JavaScript that executes in the browsers of all page visitors, including administrators.
CVE-2026-85601	5.1	MEDI		0.002		Grav Admin before 2.0.20 fails to sanitize output from marked.parse() before injecting it into the DOM via Svelte's {@html} directive in MarkdownEditor and MarkdownModal components. Attackers can inject javascript: URI schemes in plugin or theme changelogs to execute arbitrary code in authenticated admin sessions without requiring site access.
CVE-2026-85781	5.1	MEDI		0.003		Unverified ownership of a storage access point in the volume deletion component of the Amazon EFS CSI Driver before v3.4.1 might allow an authenticated Kubernetes user with PersistentVolume creation privileges to cause recursive deletion of directories on an EFS filesystem they are not authorized to access, via a crafted PersistentVolume volumeHandle that pairs an access point from one filesystem with a different ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86440	5.1	MEDI		0.001	misp-project:misp	Affected versions of MISP insufficiently validate URLs used by dashboard widgets, particularly the Button widget. The widget's URL is stored configuration controlled by a user. The previous renderer considered a URL safe if it appeared relative or if its parsed hostname matched the configured MISP hostname. That logic failed to reject dangerous schemes and URL forms that browsers normalize differently from PHP's...
CVE-2026-86516	5.1	MEDI		0.002		A vulnerability was detected in elenavanengelenmaslova mocknest-serverless 0.9.0. The affected element is an unknown function of the file deployment/aws/shared/github-oidc-role.yaml of the component AWS GitHub OIDC Deployment Helper Script. Performing a manipulation results in improper privilege management. It is possible to initiate the attack remotely. The patch is named 6ab3147282d867c1993f995272750db091c2290b....
CVE-2026-86742	5.1	MEDI		0.003		Snipe-IT through 8.6.3 does not neutralize formula elements in the "unaccepted assets" acceptance report CSV export. ReportsController::postAssetAcceptanceReport builds the CSV by hand (stripping commas and joining rows manually) and, unlike the six sibling exports in the same controller, never applies League\Csv\EscapeFormula or honors the config('app.escape_formulas') setting. An authenticated low-privilege user...
CVE-2026-86745	5.1	MEDI		0.004		Snipe-IT is an IT asset management application. In Snipe-IT master-branch builds after 8.6.3 (the code was never included in a tagged release), SettingsController::downloadLocationScopingReport streams the FMCS location-scoping mismatch report (GET /admin/settings/location-scoping-report.csv) through a bare fputcsv() call without applying League\Csv\EscapeFormula, unlike the other CSV exports which honor config('a...
CVE-2026-87912	5.1	MEDI				A missing S3 bucket ownership verification in the AWS Security Agent plugin in Amazon aws-agents-for-devsecops before 1.1.0 might allow remote attackers to obtain the private source archive of a scanned workspace, including credentials and infrastructure state contained in that archive, via a pre-registered storage bucket whose name is derived from a publicly known account identifier. To remediate this issue, u...
CVE-2026-87913	5.1	MEDI				A missing S3 bucket ownership verification in the AWS Security Agent MCP server before 0.2.0 version might allow remote attackers to obtain the private source archive of a scanned workspace, including credentials and infrastructure state contained in that archive, via a pre-registered storage bucket whose name is derived from a publicly known account identifier. To remediate this issue, users should upgrade to ...
CVE-2026-4361	5.0	MEDI		0.003		The Divi theme for WordPress is vulnerable to Server-Side Request Forgery in all versions up to, and including, 4.27.6. This is due to the `et_pb_set_video_oembed_thumbnail_resolution()` function using `wp_remote_get()` instead of `wp_safe_remote_get()` to fetch a remote image URL, which does not restrict requests to private or reserved IP ranges. This makes it possible for authenticated attackers, with Contributo...
CVE-2026-55425	5.0	MEDI		0.003		Graylog is a free and open log management platform. From 7.1.0 until 7.1.4 and 7.2.0-alpha.2, the System Catalog entity titles endpoint in graylog2-server/src/main/java/org/graylog2/rest/resources/system/contentpacks/titles/EntityTitleServiceImpl.java allows an authenticated user to request composite display fields without verifying that every selected field is readable. A user can retrieve protected values, inclu...
CVE-2026-62293	5.0	MEDI		0.002		HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to 6.9.11, the hidden scan command concatenates attacker-controlled Implementation Guide titles, profile titles, and source references into scan.html without escaping in Scanner.java. As a result, a user who scans an attacker-supplied IG/profile and then opens or publishes the generated local/CI HTML repo...
CVE-2026-70588	5.0	MEDI		0.003		Ghost is a Node.js content management system. From 5.26.0 until 6.54.1, the Universal Import feature in Ghost Admin failed to properly sanitize imported content resulting in XSS in post content. This issue is fixed in version 6.54.1.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72976	5.0	MEDI		0.004	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Word allows an authorized attacker to disclose information locally.
CVE-2026-78635	5.0	MEDI		0.002		The Okta Privileged Access client URL handler does not insert an option terminator before appending the target value to the command-line arguments. When a scaleft:// protocol handler link contains a value beginning with a hyphen, the underlying CLI framework interprets it as a command-line flag, causing unintended modification of the SSH client's behavior.
CVE-2026-79723	5.0	MEDI				IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of user-controlled API endpoints.
CVE-2026-16693	4.9	MEDI		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to obtain sensitive information due to the use of hardcoded cryptographic constants to obfuscate encryption keys.
CVE-2026-19729	4.9	MEDI		0.005		A flaw was found in the key provider component of the keycloak-services library, which is the core engine for the Red Hat Build of Keycloak. The issue occurs because a previous fix for path probing was incomplete, allowing a realm administrator to still submit arbitrary filesystem paths as keystore parameters. This can be used to determine the existence and readability of files on the server, potentially exposing ...
CVE-2026-22575	4.9	MEDI		0.002		An improper access control vulnerability in Fortinet FortiManager 7.6.0 through 7.6.4, FortiManager 7.4.0 through 7.4.10, FortiManager 7.2 all versions, FortiManager Cloud 7.6.2 through 7.6.4, FortiManager Cloud 7.4.1 through 7.4.10, FortiManager Cloud 7.2 all versions may allow an administrator to bypass the approval process for workflow sessions via crafted HTTP or HTTPs requests.
CVE-2026-78624	4.9	MEDI		0.004		The Okta Access Gateway backup restore function does not validate the filename embedded in an encrypted backup payload. This results in writing file contents to unintended locations on the appliance filesystem.
CVE-2026-0304	4.8	MEDI		0.002		A privilege escalation vulnerability in Palo Alto Networks Cortex XDR Broker VM enables an authenticated low privileged user with man-in-the-middle (MitM) access to execute code with root privileges on the Broker VM.
CVE-2026-40175	4.8	MEDI		0.019	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Versions prior to 1.15.0 and 0.3.1 are vulnerable to a specific gadget-style attack chain in which prototype pollution in a third-party dependency may be leveraged to inject unsanitized header values into outbound requests. This vulnerability is fixed in 1.15.0 and 0.3.1.
CVE-2026-45572	4.8	MEDI		0.002		Decidim is a participatory democracy framework. Prior to 0.30.9, from 0.31.0 before 0.31.5, and in 0.32.0.rc1 before 0.32.0.rc2, an administrator with landing-page editing privileges can store arbitrary HTML and JavaScript in an HTML content block, which Decidim::ContentBlocks::HtmlCell#html_content renders without sanitization, causing the script to execute in visitors' browsers. This issue is fixed in versions 0...
CVE-2026-53529	4.8	MEDI		0.002		LeafWiki is a self-hosted wiki. Prior to version 0.10.2, page titles returned by the search API could be rendered as raw HTML in the frontend. A user with editor or administrator permissions could create or modify a page title containing an HTML/JavaScript payload. When another user searched for a matching term, the payload could execute in the victim's browser. The impact depends on deployment configuration. With...
CVE-2026-67612	4.8	MEDI		0.001		OpenEMR through 8.2.0 contains a stored cross-site scripting vulnerability in the patient portal template system that allows authenticated administrators to inject arbitrary HTML and JavaScript by storing malicious payloads through the template save mode, which only filters literal PHP open tags. Attackers can exploit the lack of output encoding at the template retrieval endpoint combined with missing HttpOnly coo...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67617	4.8	MEDI		0.002		Microweber CMS through 2.0.20 contains a stored cross-site scripting vulnerability in the content tagging system that allows admin-authenticated attackers to inject arbitrary JavaScript by submitting malicious payloads via the tag_names parameter of the GET /api/save_content_admin endpoint, bypassing three independent sanitization controls including XSS middleware that ignores GET requests, a strip_unsafe() functi...
CVE-2026-69474	4.8	MEDI		0.007		Use after free in Windows Overlay Filter allows an authorized attacker to disclose information over a network.
CVE-2026-69615	4.8	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-70589	4.8	MEDI		0.002		Ghost is a Node.js content management system. From 4.22.0 until 6.54.1, a missing validation check allowed users to redeem subscription offers that were no longer active. This issue is fixed in version 6.54.1.
CVE-2026-70590	4.8	MEDI		0.002		Ghost is a Node.js content management system. Prior to 6.54.1, any staff-level user was able to leak the hashed passwords of other staff users through the Ghost Admin API. An offline password-guessing attack against the hashes could lead to account takeover if successful, but Device Verification should have prevented an attacker from logging in with a recovered password. Depending on the database used, leaked hash...
CVE-2026-71325	4.8	MEDI		0.001		Traefik is an open-source edge router that makes publishing services a fun and easy experience. Prior to 2.11.54, 3.6.25, and 3.7.10, cross-namespace @kubernetescrd references are not rejected for TraefikService backend references resolved by the service resolver. A tenant confined by RBAC to a single namespace can therefore bind its own router to a TraefikService owned by another namespace and expose or reroute t...
CVE-2026-71850	4.8	MEDI		0.002		Hono is a Web application framework that provides support for any JavaScript runtime. From 3.8.0 to 4.12.33, memo() from hono/jsx retains the result of a server side render and reuses it for later renders with comparator equal props, and request scoped values read inside the component take no part in that comparison, so a response can contain HTML rendered for another user's request. Components wrapped with memo()...
CVE-2026-71852	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.15.0, a crafted PDF can cause long runtimes and large memory consumption when pypdf/_font.py function Font._collect_cid_character_widths expands unusually large CID font /W width ranges or excessive width entries during text extraction. This issue is fixed in 6.15.0.
CVE-2026-71870	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.15.0, a crafted PDF can cause large memory consumption when pypdf/_cmap.py function parse_bfrange parses unusually large source-code or destination-string tokens in a font /ToUnicode CMap during text extraction. This issue is fixed in 6.15.0.
CVE-2026-75904	4.8	MEDI		0.001		libmodplug through 0.8.9.1 contains an out-of-bounds read in pat_smplooped in src/load_pat.cpp. The function validates only the upper bound of its sample index against MAXSMP and then subtracts one before indexing the 191-byte static array pat_loops, so an index of zero reads pat_loops[-1], one byte before the array. The index is the smpno field of a parsed MIDI event, which is initialised to zero and only later o...
CVE-2026-78560	4.8	MEDI		0.002		The Okta Access Gateway includes an optional pass-through authentication source that accepts user identity from a client-supplied HTTP header without cryptographic validation. In architectures where this optional source is enabled without an upstream reverse proxy or firewall configured to sanitize and enforce client headers, an unauthenticated user can supply an arbitrary identity value to initiate a session.
CVE-2026-84310	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.16.1, an attacker can craft a PDF that causes pypdf/_doc_common.py _get_outline to consume long runtimes and large amounts of memory when retrieving document outlines with large numbers of entries or deeply nested reused paths because the traversal lacked global entry-count and nesting-depth limits. This issue is fixed in version 6.16.1.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84311	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.16.1, an attacker can craft a PDF that causes pypdf/_page.py PageObject._extract_text and PageObject.extract_xform_text to traverse a directed acyclic graph of reused form XObjects in which each form invokes a child multiple times, creating exponentially many traversal paths and causing long runtimes and large memory consumption. This issue is fix...
CVE-2026-85541	4.8	MEDI		0.003		DreamMaker developed by Interinfo has a Reflected Cross-site Scripting vulnerability. Authenticated remote attackers can execute arbitrary JavaScript codes in user's browser via a malicious website.
CVE-2026-88038	4.8	MEDI				cookies is a Node.js library for reading and writing HTTP cookies, used by Koa via ctx.cookies. In versions before 0.9.2 the library validates the cookie name and value against character sets that reject the semicolon separator, but the domain and path options are checked only against a permissive RFC 7230 field-content matcher that allows semicolons, and both are written into the Set-Cookie header unescaped. An a...
CVE-2026-18567	4.7	MEDI		0.001	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 could allow a local attacker to obtain information due to a race condition involving a predictable Unix domain socket path in a world-writable directory.
CVE-2026-62845	4.7	MEDI		0.002		Kamaji is the Hosted Control Plane Manager for Kubernetes. Prior to 26.7.4-edge, the PostgreSQL and MySQL datastore drivers build DDL statements by interpolating the user-supplied DataStoreUsername/DataStoreSchema directly into SQL via fmt.Sprintf, without escaping identifiers. These fields have no format validation, so a value containing a quote character breaks out of the quoted identifier — SQL injection execut...
CVE-2026-64373	4.7	MEDI		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: cpufreq: Fix hotplug-suspend race during reboot During system reboot, cpufreq_suspend() is called via the kernel_restart() -> device_shutdown() path. Unlike the normal system suspend path, the reboot path does not call freeze_processes(), so userspace processes and kernel threads remain active. This allows CPU hotplug operations to run concurre...
CVE-2026-68849	4.7	MEDI		0.002		Out-of-bounds read in Windows Bluetooth Port Driver allows an authorized attacker to disclose information locally.
CVE-2026-68891	4.7	MEDI		0.002		Out-of-bounds read in Microsoft Standard XPS allows an authorized attacker to disclose information locally.
CVE-2026-69316	4.7	MEDI		0.003		Buffer over-read in Windows Overlay Filter allows an authorized attacker to disclose information locally.
CVE-2026-69425	4.7	MEDI		0.003		Improper link resolution before file access ('link following') in Windows NTFS allows an authorized attacker to perform tampering locally.
CVE-2026-69483	4.7	MEDI		0.003		Out-of-bounds read in Windows Image Acquisition allows an authorized attacker to disclose information locally.
CVE-2026-69771	4.7	MEDI		0.003		Improper link resolution before file access ('link following') in Windows Container Manager Service allows an authorized attacker to bypass a security feature locally.
CVE-2026-69792	4.7	MEDI		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Win32K allows an authorized attacker to bypass a security feature locally.
CVE-2026-69853	4.7	MEDI		0.003		Use of uninitialized resource in Windows Win32K allows an authorized attacker to disclose information locally.
CVE-2026-69895	4.7	MEDI		0.003		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to disclose information locally.
CVE-2026-71497	4.7	MEDI		0.002		jsoup is a Java library for working with real-world HTML. From 1.14.3 until 1.23.1, jsoup's HTML parser could incorrectly handle a malformed tag name ending in a control character, causing the tag to acquire the parsing behavior of a different element. When a custom Safelist permits certain raw-text elements, this misparsing can cause content that should remain inert text to be emitted as active markup after seria...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72931	4.7	MEDI		0.003		Missing release of resource after effective lifetime in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to deny service locally.
CVE-2026-87602	4.7	MEDI		0.002	google:chrome, microsoft:windows	Out of bounds read in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially read memory outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-18741	4.6	MEDI		0.001		Worksuite SaaS versions prior to 6.0.14 contains a stored cross-site scripting vulnerability in the Asset Management module that allows authenticated administrators to inject arbitrary JavaScript by entering malicious payloads into the Location and Description fields when creating a new asset. Attackers can store crafted HTML script tags in the application database that execute automatically in the browsers of any...
CVE-2026-44401	4.6	MEDI		0.003		Typemill CMS version 2.x contains a persistent cross-site scripting vulnerability in the Markdown parser extension that allows authenticated users with theme-configuration access to inject malicious JavaScript URIs by supplying unsanitized href values in Markdown links. Attackers can craft Markdown links using the javascript: scheme through ParsedownExtension.php or TwigMarkdownExtension.php, storing a persistent ...
CVE-2026-49836	4.6	MEDI				psd-tools is a Python package for working with Adobe Photoshop PSD files. Prior to version 1.17.1, `SmartObject.save()` writes an embedded smart object to a path taken verbatim from the PSD file. Because that name is attacker-controlled and unsanitised, a tool that extracts embedded objects from an untrusted `.psd` can be made to write attacker-chosen bytes to an attacker-chosen path (absolute or `../`-traversing)...
CVE-2026-61607	4.6	MEDI		0.003		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.2, the Grav API plugin POST /api/v1/media pipeline in HandlesMediaUploads::processUploadedFile() validates an SVG filename extension but does not invoke Security::sanitizeSVG(). An attacker with api.media.write permission can store an SVG containing JavaScript, and the server returns the file as Co...
CVE-2026-69381	4.6	MEDI		0.004		Out-of-bounds read in Windows Storage Port Driver allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-69548	4.6	MEDI		0.005		Heap-based buffer overflow in Windows RNDIS allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-76959	4.6	MEDI		0.001		SAP S/4HANA Finance (Advanced Payment Management) does not perform sufficient Cross-Site Request Forgery protection on certain requests due to this an attacker with low privileges could craft a malicious link or page. If an authenticated victim interacts with it, unintended actions could be triggered on the web server on their behalf. This results in a low impact on confidentiality and integrity. There is no impac...
CVE-2026-78452	4.6	MEDI		0.005		Out-of-bounds read in Microsoft Windows SCSI Class System File allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78508	4.6	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows CD-ROM Driver allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-9852	4.6	MEDI		0.002	hitachienergy:microscada_x_sys600	A CSV injection vulnerability exists in SYS600. Injected malicious formulas can add or modify data to the spreadsheet, insert links, exfiltrate data, and in some cases, depending on how the user has their environment configured, execute malicious code on the user's machine. To exploit this issue attackers would need a way to create arbitrary log messages. This could be achieved through normal functionality via SCI...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-0296	4.5	MEDI		0.001	paloaltonetworks:globalprotect	Improper certificate validation vulnerabilities in Palo Alto Networks GlobalProtect™ app enable an unauthenticated attacker with man-in-the-middle (MitM) access to intercept and modify application communications. VPN tunnel traffic is not impacted. The GlobalProtect app on iOS, Android, and Chrome OS is not affected.
CVE-2026-18073	4.4	MEDI		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local authenticated attacker to inject parameters into a CL command due to improper neutralization of special elements.
CVE-2026-69713	4.4	MEDI		0.003		Dependency on vulnerable third-party component in Windows Secure Boot allows an authorized attacker to bypass a security feature locally.
CVE-2026-72980	4.4	MEDI		0.003		Uncontrolled search path element in Windows Hello allows an authorized attacker to bypass a security feature locally.
CVE-2026-0305	4.3	MEDI		0.001		An information disclosure vulnerability in the Palo Alto Networks Prisma® Access Agent on Linux enables a local user to access sensitive configuration data and credentials. The Prisma Access Agent on macOS, Windows, iOS, Android and Chrome OS is not affected.
CVE-2026-16941	4.3	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, and 7.4 could allow a remote authenticated attacker to modify certain system messages due to improper authorization.
CVE-2026-52730	4.3	MEDI		0.002		Xibo is an open source digital signage platform with a web content management system and Windows display player software. Prior to 4.4.3, missing Authorization in Module::settingsForm allows to view (not change) super admin-restricted module settings and leak the full module entity. Exploitation of the vulnerability is possible on behalf of an authorized user who has access to the Module View feature, which are no...
CVE-2026-53487	4.3	MEDI		0.002		Kite is a Kubernetes dashboard. Prior to version 0.12.3, authenticated Kite users with any role can request `api/v1/overview` for a cluster that their roles do not permit by selecting that cluster with `x-cluster-name`. The overview route is registered before `middleware.RBACMiddleware()` and `GetOverview` only checks `len(user.Roles) > 0`, so it returns aggregate Kubernetes inventory and capacity data from unaut...
CVE-2026-53541	4.3	MEDI		0.003		OliveTin gives access to predefined shell commands from a web interface. The `filterToDefinedArgumentsOnly` function in the executor is intended to discard any arguments not explicitly defined in the action's configuration. However, prior to commit ebffd9f040f791208aee1db2e5a8aecd1e3e603d, a special case allows any argument whose name starts with `ot_` to bypass this filter. While two system arguments (`ot_executi...
CVE-2026-54492	4.3	MEDI		0.003		Koel is a free, open-source music streaming solution. Prior to 9.7.0, the Subsonic-compatible createPodcastChannel.view route accepts an authenticated user's private URL because app/Http/Requests/Subsonic/CreatePodcastChannelRequest.php does not apply the SafeUrl validation used by the regular podcast API. app/Http/Controllers/Subsonic/CreatePodcastChannelController.php passes the URL to app/Services/Podcast/Podca...
CVE-2026-55547	4.3	MEDI		0.003		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs omits SystemPrivilege.ControlAccess checks from lamApi.listRoles, lamApi.getRole, and lamApi.listPrivileges in yamcs-core/src/main/java/org/yamcs/http/api/lamApi.java. Any authenticated account can call GET /api/roles, GET /api/roles/{name}, and GET /api/privileges to enumerate available system privileges and configured role mappings. The disc...
CVE-2026-55566	4.3	MEDI		0.003		Yamcs is a mission control framework. Prior to 5.12.8 and 5.13.2, Yamcs processes attacker-controlled data from the /ext URL route in yamcs-web/src/main/webapp/projects/webapp/src/app/core/routes/extension.matcher.ts, extension.component.ts, and app.component.ts without checking registered plugin IDs before DOM rendering through innerHTML. A crafted URL can execute JavaScript when opened by a user. The script can ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55696	4.3	MEDI		0.002		PrivateBin is an online pastebin where the server has zero knowledge of pasted data. Prior to 2.0.5, AttachmentViewer.setAttachment in js/privatebin.js uses getAttachmentMimeType to accept attacker-controlled MIME types and uses getBlobUrl to create a same-origin blob before setting attachmentLink's href for the Download attachment link. The SVG-only sanitization branch updates only the preview blob, so text/html,...
CVE-2026-55834	4.3	MEDI		0.003		Pocket ID is an OIDC provider that allows users to authenticate with their passkeys to services. From 2.6.0 until 2.9.0, frontend/src/routes/authorize/+page.ts reads the redirect_uri query parameter and frontend/src/routes/authorize/+page.svelte uses the raw callbackURL in redirectWithError when prompt=none cannot complete silent authorization. The client-side path only blocks javascript and data schemes and does ...
CVE-2026-61911	4.3	MEDI		0.002		An issue was discovered in Cyrus IMAP before 3.12.4. There is a Sieve mailbox existence oracle. An authenticated user could install a Sieve script that probed whether another user's private mailbox existed, or read the value of shared mailbox annotations, by observing which fileinto branch fired during LMTP delivery.
CVE-2026-62986	4.3	MEDI		0.002		OpenEXR is the reference implementation and specification for the EXR image file format, widely used in the motion picture industry. In versions 3.3.0 through 3.3.12 and 3.4.0 through 3.4.13, the PyOpenEXR Python bindings return stale heap data when reading a crafted deep scanline EXR that uses layer-prefixed RGB channels. With the default channel coalescing (separate_channels=False), the wrapper groups channels s...
CVE-2026-66761	4.3	MEDI		0.002	sap:approuter	SAP Approuter does not enforce sufficient flow control in certain functionality. An attacker with low privileges could send high volumes of data without consuming responses, causing unbounded memory growth. This results in a low impact on availability. There is no impact on confidentiality and integrity.
CVE-2026-66775	4.3	MEDI		0.001	sap:approuter	SAP Approuter does not enforce cross-site request forgery protection on the authentication flow by default. An unauthenticated attacker could craft a malicious link and trick a victim into following it. Successful exploitation could allow the attacker to bind the victim's session to an attacker-controlled identity, resulting in a low impact on integrity. There is no impact on confidentiality and availability.
CVE-2026-70427	4.3	MEDI		0.003	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier does not safely handle symbolic links with effectively empty names during the extraction of `.tar` and `.tar.gz` archives, allowing attackers able to control agent processes to provide crafted archives to the controller to write files to arbitrary locations on the file system, restricted only by file system access permissions of the user running Jenkins.
CVE-2026-70428	4.3	MEDI		0.003	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier improperly identifies file paths attempting path traversal in file parameter names, allowing attackers with Item/Configure and Item/Build permission to write files to arbitrary locations on the controller file system.
CVE-2026-70596	4.3	MEDI		0.002		Ghost is a Node.js content management system. From 4.9.0 until 6.54.1, an input validation issue allowed any staff user to create a post with content in feature_image_caption that could be used to hijack another staff user's Ghost Admin session, resulting in privilege escalation. This issue is fixed in 6.54.1.
CVE-2026-71322	4.3	MEDI		0.002		Lemur manages TLS certificate creation. Prior to 1.9.3, CertificateExport placed its CertificatePermission ownership check inside the plugin.requires_key branch for POST /api/1/certificates/export. A plugin declaring requires_key false bypassed that check, and the handler still passed cert.private_key as an argument and recorded a key_view audit event. The bundled JavaTruststoreExportPlugin ignored the key, so th...
CVE-2026-73019	4.3	MEDI		0.007		Improper resolution of path equivalence in Windows URL Moniker allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-76962	4.3	MEDI		0.002		SAP S/4HANA (Manage Bank Chains app) does not perform sufficient authorization checks within certain affected functionality. An attacker with low privileges could send specially crafted requests to delete specific entries that should not be accessible to them. This results in a low impact on availability. There is no impact on confidentiality and integrity.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-76963	4.3	MEDI		0.002		Due to a missing authorization check in Application Server ABAP of SAP NetWeaver and ABAP Platform, an authenticated attacker could gain unauthorized access to sensitive system configuration information. Successful exploitation could result in exposure of security relevant settings and internal system details, resulting in low impact on confidentiality while integrity and availability remain unaffected.
CVE-2026-76977	4.3	MEDI		0.002		SAP UI5 does not sufficiently validate the parent frame's origin against the configured allowlist. An unauthenticated attacker could host a malicious page to bypass framing restrictions. If an authenticated victim visits the attacker's page and interacts with it, the attacker could trick the victim into performing unintended actions, resulting in a low impact on integrity. There is no impact on confidentiality and...
CVE-2026-78516	4.3	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows Storage allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78593	4.3	MEDI		0.002		An insufficiently validated configuration field in Kibana's Cribl integration allows an authenticated user holding Kibana Fleet management privileges to inject attacker-controlled expressions into a server-side script template, resulting in an Elasticsearch ingest pipeline being written beyond the caller's authorized Elasticsearch permissions.
CVE-2026-86087	4.3	MEDI				IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an authenticated user to send a specially crafted request to write arbitrary files on the system.
CVE-2026-9736	4.3	MEDI		0.002	ibm:netezza_performance_server	IBM Netezza Software 11.3.0.3 through Interim Fix 002 could allow an unauthorized user to inject data into log messages due to improper neutralization of special elements when written to log files.
CVE-2026-0295	4.1	MEDI		0.001	paloaltonetworks:globalprotect	A race condition in the Palo Alto Networks GlobalProtect™ client on macOS enables a locally authenticated low-privileged attacker to escalate their privileges to root. The GlobalProtect app on Linux, Windows, iOS, Android, and Chrome OS is not affected.
CVE-2026-63466	4.1	MEDI		0.002		Unleash is an open-source feature management platform. Prior to 8.0.3, FeatureEventFormatterMd.format in src/lib/addons/feature-event-formatter-md.ts assigns Mustache.escape to an identity function before rendering action and path templates. Because Mustache.escape is process-wide, the assignment disables escaping for subsequent Mustache.render calls in email-service.ts, webhook.ts, datadog.ts, and new-relic.ts. A...
CVE-2026-70591	4.1	MEDI		0.002		Ghost is a Node.js content management system. From 0.10.0 until 6.54.1, a Server-Side Request Forgery in Ghost Admin image fetching allowed any staff-level user to perform a blind HTTP GET request against internal hosts. No output was returned, but this could have been used to probe open ports on internal hosts. This issue is fixed in version 6.54.1.
CVE-2026-0309	4.0	MEDI		0.004		A command injection vulnerability in Palo Alto Networks PAN-OS® software enables an authenticated administrator to bypass system restrictions and run arbitrary commands as a root user. To be able to exploit this issue, the user must have access to the PAN-OS CLI and the device must be configured with a Luna Hardware Security Module (HSM). The security risk posed by this issue is significantly minimized when CLI ...
CVE-2026-28581	4.0	MEDI		0.001	google:android	In fixInitiatingUserIfNecessary of CallIntentProcessor.java, there is a possible way to make an emergency call due to a logic error in the code. This could lead to local escalation with User execution privileges needed. User interaction is needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70595	4.0	MEDI		0.002		Ghost is a Node.js content management system. From 6.26.0 until 6.54.1, a validation issue allowed some functionality, such as Webmentions, to be abused by an unauthenticated user to make limited HTTP requests to hosts in the Ghost server's internal network. A successful attack would not result in any response data being returned. This vulnerability is fixed in 6.54.1.
CVE-2026-80159	4.0	MEDI		0.001	adobe:acrobat, adobe:acrobat_dc, adobe:acrobat_reader_dc, apple:macos, microsoft:windows	Acrobat Reader is affected by an Untrusted Search Path vulnerability that could result in privilege escalation. An attacker with high privileges could leverage this vulnerability to gain elevated access. Exploit depends on conditions beyond the attacker's control. Exploitation of this issue requires user interaction in that a victim must open a malicious file.
CVE-2026-88059	4.0	MEDI				Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.1, Angular's @angular/common HttpTransferCache can cache an authenticated response when Server-Side Rendering (SSR) and hydration use a hierarchical HttpClient configured with withRequestsMadeViaParent. The child TransferCache evaluates an initially...
CVE-2026-70598	3.9	LOW		0.001		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.10, 40.9.0, 41.2.1, and 42.0.0-beta.3, offscreen rendering frame data received from the GPU process was not fully validated by the main process. A compromised GPU process could cause the main process to read out-of-bounds memory while producing paint event images, disclosing memory or crashing the ...
CVE-2026-70467	3.8	LOW		0.002	fortinet:fortisiem	A server-side request forgery (ssrf) vulnerability in Fortinet FortiSIEM 7.5.0, FortiSIEM 7.4.0 through 7.4.2, FortiSIEM 7.3.0 through 7.3.5, FortiSIEM 7.2 all versions, FortiSIEM 7.1 all versions, FortiSIEM 7.0 all versions, FortiSIEM 6.7 all versions, FortiSIEM 6.6 all versions, FortiSIEM 6.5 all versions may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2026-55785	3.7	LOW		0.003		free5GC is an open-source implementation of the 5G core network. Prior to 1.4.5, the AUSF component performs cryptographic authentication comparisons in internal/sbi/processor/ue_authentication.go with ordinary equality helpers. Auth5gAkaComfirmRequestProcedure compares RES* and XRES* with strings.EqualFold and logs the expected XRES* value at INFO level before comparison. EapAuthComfirmRequestProcedure compares A...
CVE-2026-58239	3.7	LOW		0.002	sap:approuter	SAP Approuter does not sufficiently validate tenant context in inbound requests. An unauthenticated attacker could send specially crafted requests to spoof the tenant context under conditions not fully within their control. Successful exploitation could allow limited access to another tenant's information, resulting in a low impact on confidentiality. There is no impact on integrity and availability.
CVE-2026-66774	3.7	LOW		0.002	sap:approuter	SAP Approuter does not consistently handle certain error conditions. An attacker with low privileges could exploit this under a non-default configuration. Successful exploitation is highly complex, as it depends on conditions outside the attacker's control. This could result in a low impact on availability. There is no impact on confidentiality and integrity.
CVE-2026-71849	3.7	LOW		0.002		Hono is a Web application framework that provides support for any JavaScript runtime. From 4.7.0 to 4.12.33, the Proxy Helper proxy() function in hono/proxy does not remove response headers named by the origin's Connection header. Per RFC 9110 Section 7.6.1, an intermediary must remove the header fields listed in a message's Connection header field before forwarding the message, in addition to the well known hop b...
CVE-2026-73425	3.7	LOW		0.002		Astro is a web framework for content-driven websites. Prior to 8.1.2, the Astro Netlify adapter converts each image.remotePatterns entry into a regular expression written to .netlify/v1/config.json under images.remote_images for Netlify's Image CDN allowlist. In packages/integrations/netlify/src/index.ts, remotePatternToRegex() escapes dots in hostname values but interpolates literal pathname values without escapi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78124	3.7	LOW				strongSwan 5.0.2 through 6.0.7 allows PKCS#7 certificate enumeration in the openssl plugin that leads to a lack of release of memory after its effective lifetime.
CVE-2026-84367	3.7	LOW		0.003		joi is a schema description language and data validator for JavaScript. From 16.0.0 until 17.13.5 and 18.2.4, joi's lib/types/keys.js internals.rename() implementation used by object().rename() permits a schema that renames keys with a regular-expression source and a Joi.expression() or Joi.x() target that interpolates the pattern's own match data, combined with { multiple: true }, to derive a target from an attac...
CVE-2026-84368	3.7	LOW		0.003		joi is a schema description language and data validator for JavaScript. From 16.0.0 until 17.13.6 and 18.2.5, the @hapi/joi package through 17.1.1 and the successor joi package contain prototype pollution in lib/messages.js, where exports.compile() and exports.merge() reuse inherited objects for attacker-controlled language keys supplied through messages(), message(), prefs({ messages }), Joi.extend({ messages }),...
CVE-2025-15695	3.5	LOW				The Translate WordPress with GTranslate WordPress plugin before 3.0.10 does not validate one of its settings before the bundled front-end scripts build markup from it, allowing users with a role as high as administrator to store JavaScript that runs in the session of any visitor to the site.
CVE-2026-69904	3.5	LOW		0.006	microsoft:sharepoint_server	Server-side request forgery (ssrf) in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-76960	3.5	LOW		0.001		SAP S/4HANA Finance (Advanced Payment Management) does not perform sufficient Cross-Site Request Forgery protection on certain requests, due to this an attacker with low privileges could craft a malicious link or page. If an authenticated victim interacts with it, unintended actions could be triggered on the web server on their behalf. This results in a low impact on confidentiality and integrity. There is no impa...
CVE-2026-76961	3.5	LOW		0.001		SAP S/4HANA Finance (Advanced Payment Management) does not perform sufficient Cross-Site Request Forgery protection on certain requests, due to this an attacker with low privileges could craft a malicious link or page. If an authenticated victim interacts with it, unintended actions could be triggered on the web server on their behalf. This results in a low impact on confidentiality and integrity. There is no impa...
CVE-2026-17483	3.3	LOW		0.002	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 IBM i could allow a local attacker to delete historical flight-recorder archives due to improper access control in an SQL procedure.
CVE-2026-28582	3.3	LOW		0.001		In onCreate of ConfirmDeviceCredentialActivity.java, there is a possible unauthorized access to and modification of device credentials due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28622	3.3	LOW		0.001		In getQueryBuilderInternal of MediaProvider.java, there is a possible way to retrieve location metadata due to a permissions bypass. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28623	3.3	LOW		0.001		In writeToParcel of BleRssiRangingCapabilities.java, there is a possible way to obtain the Bluetooth MAC address due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28638	3.3	LOW		0.001		In multiple functions of XmpDataParser.java, there is a possible improper data sanitization due to a logic error in the code. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-28671	3.3	LOW		0.001		In updateInternal of MediaProvider.java, there is a possible expose contents of files due to a race condition. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45521	3.3	LOW		0.001		In openFile of AppFuseBridge.java, there is a possible information disclosure due to a missing permission check. This could lead to local information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-59326	3.3	LOW		0.001	broadcom:spring_tools	The Spring Boot language server logs the raw value of the https_proxy/HTTPS_PROXY/http_proxy/HTTP_PROXY environment variable at INFO level whenever it creates an outbound HTTP client and no explicit http.proxy workspace setting is configured. Corporate proxy URLs frequently embed Basic-auth credentials in the form http://user:pass@proxy:8080, and the language server writes this value to its log file without any re...
CVE-2026-86503	3.3	LOW		0.001		In JetBrains IntelliJ IDEA before 2026.2.2 opening an untrusted project could trigger SSRF via Kubernetes spec-source URL fetching
CVE-2026-28652	3.1	LOW		0.001		In multiple functions of RangingServiceImpl.java, there is a possible MITM due to a missing permission check. This could lead to remote information disclosure with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-70600	3.1	LOW		0.002		Electron is a framework for writing cross-platform desktop applications using JavaScript, HTML and CSS. Prior to 39.8.8, 40.9.0, 41.2.1, and 42.0.0-beta.3, the native autofill popup could be positioned by a cross-origin iframe outside that iframe's bounds, over the embedding page's UI, enabling clickjacking or spoofing of trusted UI. Apps are only affected if they embed untrusted content in iframes within windows ...
CVE-2026-84389	3.1	LOW		0.001		A url redirection to untrusted site ('open redirect') vulnerability in Fortinet FortiSIEM 7.5.0 through 7.5.1, FortiSIEM 7.4.1 through 7.4.2 may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2025-69873	2.9	LOW		0.005		ajv (Another JSON Schema Validator) before 8.18.0 is vulnerable to Regular Expression Denial of Service (ReDoS) when the \$data option is enabled. The pattern keyword accepts runtime data via JSON Pointer syntax (\$data reference), which is passed directly to the JavaScript RegExp() constructor without validation. An attacker can inject a malicious regex pattern (e.g., "^(a a)*\$") combined with crafted input to caus...
CVE-2026-86231	2.9	LOW		0.003		A security flaw has been discovered in mwiede jsch up to 2.28.5. Affected is the function getRevokedKeys of the file src/main/java/com/jcraft/jsch/KnownHosts.java. Performing a manipulation of the argument known_hosts results in improper check for certificate revocation. The attack is possible to be carried out remotely. The attack is considered to have high complexity. The exploitability is told to be difficult. ...
CVE-2026-70430	2.7	LOW		0.002	jenkins:jenkins	Jenkins 2.575 and earlier, LTS 2.568.1 and earlier does not restrict the types of objects that can be instantiated as part of the project naming strategy configuration, allowing attackers with Overall/Manage permission to instantiate arbitrary types related to configuration, including those intended for configuration only by administrators.
CVE-2026-84392	2.7	LOW		0.003		A NULL Pointer Dereference vulnerability [CWE-476] vulnerability in Fortinet FortiOS 7.4 all versions, FortiOS 7.2 all versions, FortiPAM 1.9.0, FortiPAM 1.8 all versions, FortiPAM 1.7 all versions, FortiPAM 1.6 all versions, FortiPAM 1.5 all versions, FortiPAM 1.4 all versions, FortiPAM 1.3 all versions, FortiPAM 1.2 all versions, FortiPAM 1.1 all versions, FortiPAM 1.0 all versions, FortiProxy 7.6.0 through 7.6....
CVE-2026-87525	2.7	LOW		0.001	google:chrome, microsoft:windows	Out of bounds read in Chromoting in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to read memory outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-0303	2.4	LOW		0.001		A code execution vulnerability in Palo Alto Networks Checkov by Prisma® Cloud can allow arbitrary code execution when Checkov scans a directory that contains an attacker-controlled configuration file.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-15418	2.4	LOW				In the silabser.sys driver for CP210x devices v11.5.0 and earlier, a local unprivileged user with a malicious device can use malformed packets to leak up to 145 bytes of uninitialized kernel pool memory. This vulnerability affects Windows 10 and earlier.
CVE-2026-71438	2.4	LOW		0.002		Mermaid is a JavaScript tool that uses Markdown-inspired text to create and modify diagrams and charts. Prior to 10.9.8 and 11.16.1, Mermaid's configuration setters (mermaid.initialize, mermaidAPI.setConfig, and mermaidAPI.updateSiteConfig) merge caller-supplied configuration into Mermaid's internal config using the assignWithDepth deep-merge helper, which is vulnerable to prototype pollution. This is only exploit...
CVE-2026-73087	2.3	LOW		0.003		Dozzle is a realtime log viewer for docker containers. From 10.5.2 until 10.6.15, the isBlockedIP SSRF guard in internal/notification/dispatcher/webhook.go, used by safeDialContext for webhook notification URLs, does not inspect IPv4 addresses embedded in 6to4, NAT64, Teredo, or IPv4-compatible IPv6 addresses, allowing an authenticated user to reach loopback or link-local targets that the guard intends to block. T...
CVE-2026-73491	2.3	LOW		0.002		Loofah is a general library for manipulating and transforming HTML/XML documents and fragments, built on top of Nokogiri. From 2.25.0 until 2.25.2, Loofah::HTML5::Scrub.allowed_uri? does not reject javascript: URIs whose scheme is split or prefixed with the HTML5 named whitespace character references 	 or
. CGI.unescapeHTML leaves those references intact, so allowed_uri? reports the URL safe even thou...
CVE-2026-73492	2.3	LOW		0.002		Loofah is a general library for manipulating and transforming HTML/XML documents and fragments, built on top of Nokogiri. From 2.25.0 until 2.25.2, Loofah::HTML5::Scrub.allowed_uri? does not reject javascript: or vbscript: URIs whose scheme is split by semicolon-less numeric character references such as :, 	,
, or . CGI.unescapeHTML leaves these references encoded, so allowed_uri? reports the URL safe...
CVE-2026-81738	2.3	LOW		0.003		OpenVPN 2.5.0 through 2.7.6 on Windows using the tap-windows6 driver allows attackers to trigger an out-of-bounds write via crafted DOMAIN-SEARCH entries
CVE-2026-82060	2.3	LOW		0.002		In MongoDB, insufficient validation of shard key values during document insertion allowed authenticated users to store documents with specially crafted, operator-shaped objects as shard key values in sharded collections. When change stream events for such documents were processed with the updateLookup full document mode, the crafted values were embedded into internal post-image lookup queries without proper saniti...
CVE-2026-86441	2.3	LOW		0.002	misp-project:misp	Affected versions of MISP contain inconsistent authorization checks across dashboard widgets that display organisation information. Several organisation-related widgets did not honor Security.hide_organisation_index_from_users. As a result, authenticated users without the perm_sharing_group permission could enumerate organisations even though the normal organisation index was intentionally hidden from them. Th...
CVE-2026-58234	2.2	LOW		0.002		SAP Process Integration (SOAP Adapter) allows a privileged user to send specially crafted requests containing deeply nested entity definitions, which under certain conditions could temporarily increase processor load and degrade system responsiveness. Successful exploitation results in low impact on availability with no impact on confidentiality and integrity.
CVE-2026-0292	2.1	LOW		0.001	microsoft:windows, paloaltonetworks:prisma_access_agent	An authentication bypass vulnerability in the network driver of Palo Alto Networks Prisma® Access Agent on Windows enables a local administrator to bypass security inspection, subsequently allowing them to inject and intercept arbitrary network traffic. The Prisma Access Agent on Linux, macOS, iOS, Android, and Chrome OS is not affected.
CVE-2026-15310	2.1	LOW		0.003		When decompressing crafted zip files using the bzip/LZMA/Zstandard compressions, Python could use an attacker-controlled size to pre-allocate memory, possibly resulting in memory exhaustion.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73427	2.1	LOW		0.003		Trix is a what-you-see-is-what-you-get rich text editor for everyday writing. Prior to 2.1.18, Trix is vulnerable to cross-site scripting when a crafted application/x-trix-document JSON payload is dropped into an editor using the fallback Level0InputController, such as an embedded WebView without Input Events Level 2 support. The StringPiece.fromJSON method trusts href attributes from the JSON payload without sani...
CVE-2026-82865	2.1	LOW		0.001		pdfme schemas before 5.5.10 contains a cross-site scripting vulnerability in the multiVariableText property panel that assigns unsanitized i18n label values to innerHTML. Attackers who control label overrides through options.labels can inject arbitrary JavaScript that executes when users open the Designer and select a multiVariableText field without variable placeholders.
CVE-2026-86228	2.1	LOW		0.002		A security vulnerability has been detected in JeecgBoot up to 3.9.3. This vulnerability affects the function exportXls of the file jeecg-boot/jeecg-boot-module/jeecg-boot-module-airag/src/main/java/org/jeecg/modules/airag/llm/controller/AiragModelController.java. Such manipulation of the argument credential leads to improper access controls. It is possible to launch the attack remotely. The exploit has been disclo...
CVE-2026-86264	2.1	LOW		0.003		A flaw has been found in sfturing ssm_pro up to 627f426331da8086ce8fff2017d65b1ddef384f8. Affected is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/OrderController.java of the component Order Endpoint. This manipulation of the argument hospitalName/officesName/doctorName causes cross site scripting. It is possible to initiate the attack remotely. The exploit has been published and may be us...
CVE-2026-86512	2.1	LOW		0.002		A vulnerability was identified in java-json-tools json-patch up to 1.13. This affects the function CopyOperation.apply/MoveOperation.apply of the file src/main/java/com/github/fge/jsonpatch/CopyOperation.java of the component Copy Move Operations. The manipulation leads to improper access controls. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The project was i...
CVE-2026-86517	2.1	LOW		0.002		A flaw has been found in itsourcecode Sales and Inventory System 1.0. The impacted element is the function mysqli_query of the file /pages/us_searchfrm.php. Executing a manipulation of the argument ID can lead to sql injection. It is possible to launch the attack remotely. The exploit has been published and may be used.
CVE-2026-86674	2.1	LOW		0.002		A vulnerability was found in ningzichun Student Management System up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this vulnerability is the function session_start of the file login.php. The manipulation results in session fixation. The attack can be launched remotely. The exploit has been made public and could be used. This product does not use versioning. This is why information about affected and un...
CVE-2026-48791	2.0	LOW		0.001		sigstore-java is a sigstore java client for interacting with sigstore infrastructure. Version 2.0.0 erroneously removed verification of the integrated (Rekor entry) time) against the Fulcio certificate. Version 2.1.0 re-added this verification with enhancements that adhere to the Sigstore verification spec. The old sigstore-conformance test for this check was built incorrectly. This vulnerability impacts only user...
CVE-2026-53759	2.0	LOW		0.003		linuxfabrik-lib provides Python modules for database access, caching, shell execution, and API integrations. Prior to version 4.2.0, db_sqlite.py created SQLite databases at predictable paths in the shared /tmp directory and followed attacker-created symbolic links at those paths. An attacker who controls a local monitoring account can create a symlink such as /tmp/linuxfabrik-monitoring-plugins-docker-stats.db an...
CVE-2026-85643	2.0	LOW		0.002		A flaw has been found in code-projects Online Shopping System 1.0. Impacted is the function mysqli_query of the file admin/adduser.php. Executing a manipulation of the argument mobile can lead to sql injection. The attack may be performed from remote. The exploit has been published and may be used.
CVE-2026-82312	1.8	LOW		0.001		OpenVPN 2.0.0 through 2.6.22 and 2.7_alpha1 through 2.7.6 on Windows allows local authenticated users to cause a denial of service via a NULL DACL on named IPC objects

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-0291	1.1	LOW		0.001	linux:linux_kernel, paloaltonetworks:prisma_access_agent	An improper link resolution before file access vulnerability exists in the Palo Alto Networks Prisma® Access Agent on Linux platforms that enables a local low privileged user to delete system files in a limited scope and disable Prisma Access Agent. The Prisma Access Agent on macOS, Windows, iOS, Android, and Chrome OS is not affected.
CVE-2026-0302	1.1	LOW		0.008		An OS command injection vulnerability in Palo Alto Networks Checkov by Prisma® Cloud enables a local user to execute arbitrary commands in the processes running Checkov.
CVE-2026-0308	1.1	LOW		0.003		A stored cross-site scripting (XSS) vulnerability in Palo Alto Networks PAN-OS® software enables a malicious authenticated administrator to store or execute a JavaScript payload using the web interface. This issue is applicable to PAN-OS software on PA-Series and VM-Series firewalls and on Panorama (virtual and M-Series). Cloud NGFW and Prisma® Access are not affected by this vulnerability.
CVE-2026-86422	1.0	LOW		0.001	imagemagick:imagemagick	ImageMagick before 7.1.2-30 contains a time-of-check-time-of-use vulnerability in path policy enforcement on Windows that allows attackers to bypass read or write restrictions by exploiting symlink race conditions. Attackers can swap symlinks between policy validation and file access to read or write policy-denied files.
CVE-2026-0289	0.5	LOW		0.002	paloaltonetworks:prisma_browser	A security bypass vulnerability in the Account Protection feature of Palo Alto Networks Prisma® Browser enables a user to bypass intended security controls.
CVE-2026-0290	0.5	LOW		0.001	paloaltonetworks:prisma_browser	An information disclosure vulnerability in the Account Protection feature of Palo Alto Networks Prisma® Browser enables a local attacker to view sensitive data.
CVE-2022-26962						Italtel NFV 11.1.2-20210318 allows Multiple Stored XSS under NP_BCCAS-RMCTRL-01/IMCSCIWebGui/configuration.jsp?opration=list&object=announcementAS via the name, username, or mrfAnnouncementNameparameter. A malicious user leveraging this vulnerability could inject arbitrary JavaScript. The malicious payload will then be triggered every time an authenticated user browses the page containing it.
CVE-2026-36392						FairSketch Rise CRM Version 3.9.6 is vulnerable to Cross Site Scripting (XSS). An authenticated administrator can inject arbitrary JavaScript into an item's title, which is stored server-side and executed in the browser of any client user who visits the store page, enabling session hijacking, account takeover, and phishing.
CVE-2026-4765	0.0	NONE		0.004		Self Cross-Site Scripting (Self-XSS) vulnerability in the RD Station Conversas chat feature. The vulnerability lies in the 'name' parameter of the initialisation process due to incorrect sanitisation of user-supplied input. Exploitation allows specially crafted JavaScript code to be injected, which is executed within the context of the user's own session who provides the payload. The demonstrated impact is limited...
CVE-2026-61634	0.0	NONE		0.003		The RabbitMQ Java client library allows Java and JVM-based applications to connect to and interact with RabbitMQ nodes. Prior to 5.33.0, the AMQP connection tuning path records the negotiated AMQP frame_max value, but src/main/java/com/rabbitmq/client/impl/SocketFrameHandler.java and NettyFrameHandlerFactory continue to validate broker-controlled frame payload lengths against maxInboundMessageBodySize because the ...
CVE-2026-71802				0.001		A stored Cross-Site Scripting (XSS) vulnerability exists in the announcement preview component of REBUILD 4.4.3. Although the announcement content undergoes HTML escaping on the server side, the client-side preview code reverses the escaped entities using jQuery's `html().text()` method and subsequently injects the result into the DOM. An administrator or attacker capable of controlling the announcement content ca...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72885	0.0	NONE		0.007		Dokploy is a free, self-hostable Platform as a Service (PaaS). Prior to 0.29.13, dockerContextPath accepted by apps/dokploy/components/dashboard/application/build/show.tsx flows through getDockerContextPath in packages/server/src/utls/filesystem/directory.ts into the unquoted cd command in packages/server/src/utls/builders/docker-file.ts before execution by execAsync, allowing an authenticated application editor...
CVE-2026-80841				0.002		In the Linux kernel, the following vulnerability has been resolved: net/packet: defer vmalloc TX_RING free until skbs finish AF_PACKET TX_RING skbs keep a raw pointer to their ring frame. The skb page references preserve page-backed ring blocks after pg_vec is freed, but they do not preserve a vmalloc mapping. tpacket_destruct_skb() currently drops the pending reference before writing the timestamp and TP_STATU...
CVE-2026-80847				0.002		In the Linux kernel, the following vulnerability has been resolved: tcp: clamp route advmss to TCP_MIN_MSS tcp_select_initial_window() assumes that callers never pass an MSS smaller than 1, but route-derived advmss values can violate that assumption. A too-small explicit RTAX_ADVMS is one way to get there, but it is not the only one. The same divide-by-zero can also be reached through the "default advmss" path...
CVE-2026-80858				0.001		In the Linux kernel, the following vulnerability has been resolved: fuse: publish io-uring queues with release semantics fuse_uring_create_queue() initializes a fuse_ring_queue and then publishes the pointer into ring->queues[qid] with WRITE_ONCE() under the fch->lock. There are several readers that may concurrently be fetching that pointer locklessly and then deferencing it. WRITE_ONCE() doesn't ensure orderin...
CVE-2026-80859				0.001		In the Linux kernel, the following vulnerability has been resolved: fuse: fix missing barrier when checking io-uring readiness fuse_block_alloc() reads fch->initialized and then fch->io_uring. fch->io_uring is set before fch->initialized, ordered by the smp_wmb() in fuse_chan_set_intialized(), but fuse_block_alloc() has no matching read barrier between the two loads. This may lead a CPU to observe fch->initiali...
CVE-2026-80860				0.001		In the Linux kernel, the following vulnerability has been resolved: fuse: fix race between interrupt and resend After commit f8fce75fedf7 ("fuse: clear intr_entry in fuse_resend and fuse_remove_pending_req") the WARN_ON(!list_empty(&req->intr_entry)) in fuse_request_free() still triggers due to the following race: In request_wait_answer() if (test_bit(FR_SENT, &req->flags)) -> returns true In fuse_chan_resen...
CVE-2026-80861				0.002		In the Linux kernel, the following vulnerability has been resolved: usb: xhci: bail out of setup if the controller is inaccessible xhci_gen_setup() locates the operational registers using the capability length read from the very first register: xhci->op_regs = hcd->regs + HC_LENGTH(readl(&xhci->cap_regs->hc_capbase)); If the controller is dead or has dropped off the bus, that read returns ~0, HC_LENGTH() tr...
CVE-2026-80878				0.001		In the Linux kernel, the following vulnerability has been resolved: afs: Fix leak of ungot volume Fix afs_lookup_volume_rcu() so that it doesn't leak a dying volume if afs_try_get_volume() fails.
CVE-2026-80915				0.002		In the Linux kernel, the following vulnerability has been resolved: drm/xe: Fix DPT allocation paths. Remove the fallback for VRAM to system memory, I tested it and that doesn't work at all, only a black screen with pipe fault errors were observed. On systems with media GT, extra latency is added when accessing stolen memory when the GT is in MC6. Since we additionally aren't counting how much memory is used fo...
CVE-2026-80916				0.002		In the Linux kernel, the following vulnerability has been resolved: kcov: fix data corruption and race conditions on PREEMPT_RT syzbot is reporting KCOV state corruption on PREEMPT_RT kernels, for the temporary storage used for saving/restoring remote KCOV state is currently allocated as the per-CPU area. On PREEMPT_RT kernels, softirq handlers run as preemptible task threads (e.g., ksoftirqd). If a softirq con...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80917				0.002		In the Linux kernel, the following vulnerability has been resolved: PCI: host-generic: Fix NULL pointer dereference on 32-bit CAM systems On 32-bit systems the config space is too large to ioremap in one go, so pci_ecam_create() maps each bus segment separately and relies on the ->add_bus callback (pci_ecam_add_bus) to populate the per-bus mapping in cfg->winp[]. pci_ecam_map_bus() then uses that mapping as the ...
CVE-2026-80918				0.002		In the Linux kernel, the following vulnerability has been resolved: HID: core: fix number/pointer type confusion on long items When fetch_item() is called by hid_scan_report() on an item with HID_ITEM_TAG_LONG, it stores a pointer to the item data in item->data.longdata instead of storing a value directly in item->data.{u8/u16/u32}. When item_udata() or item_sdata() encounters such an item, it incorrectly assum...
CVE-2026-80919				0.001		In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: fix recursive ww_mutex acquire in amdgpu_devcoredump_format When dumping IB contents from a hung job, amdgpu_devcoredump_format() acquired the VM root PD's reservation via amdgpu_vm_lock_by_pasid() and then, for each IB, called amdgpu_bo_reserve() on the BO backing the IB. Both reservations are reservation_ww_class_mutex objects and ...
CVE-2026-80920				0.002		In the Linux kernel, the following vulnerability has been resolved: io_uring: defer eventfd signaling when queued from a wakeup handler io_req_local_work_add() signals the CQ ring eventfd inline when it is the one to push the first entry onto ->work_list. For DEFER_TASKRUN rings that add is frequently done from a waitqueue wakeup handler, where an arbitrary waitqueue lock is held. eventfd_signal_mask() only ref...
CVE-2026-80922				0.002		In the Linux kernel, the following vulnerability has been resolved: crypto: qcom-rng - Allow zero as a random number Zero is a valid random number and needs to be allowed. Otherwise the output is distinguishable from random.
CVE-2026-80923				0.002		In the Linux kernel, the following vulnerability has been resolved: xhci: dbgtty: Fix unregister on tty_register_driver() failure If tty_register_driver() fails, it drops the reference, but fails to set the global dbc_tty_driver to NULL, causing the unregister to be called again when module exits. On module unload dbc_tty_exit() only gates its cleanup on the driver pointer being non-NULL, so it operates on the ...
CVE-2026-80925				0.001		In the Linux kernel, the following vulnerability has been resolved: vlan: fix skb_under_panic and races when toggling HW VLAN offload Toggling hardware VLAN TX offload (NETIF_F_HW_VLAN_CTAG_TX or NETIF_F_HW_VLAN_STAG_TX) on a lower device invokes vlan_transfer_features(), which dynamically changed vlandev->hard_header_len. This causes two issues: 1. Lockless TX paths (e.g. packet_snd in af_packet.c, ip6_finish_...

P3/P4 items (5409) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.